

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG

HOÀNG XUÂN DẬU

GIÁO TRÌNH
CƠ SỞ AN TOÀN THÔNG TIN

HÀ NỘI 2018

MỤC LỤC

MỤC LỤC	1
DANH MỤC CÁC HÌNH	5
DANH MỤC CÁC THUẬT NGỮ TIẾNG ANH VÀ VIẾT TẮT	9
MỞ ĐẦU	11
CHƯƠNG 1. TỔNG QUAN VỀ AN TOÀN THÔNG TIN	13
1.1. KHÁI QUÁT VỀ AN TOÀN THÔNG TIN	13
1.1.1. Một số khái niệm trong an toàn thông tin.....	13
1.1.2. Sự cần thiết của an toàn thông tin.....	15
1.2. CÁC YÊU CẦU ĐẢM BẢO ATTT VÀ HTTT	17
1.2.1. Bí mật	17
1.2.2. Toàn vẹn	18
1.2.3. Sẵn dùng	18
1.3. CÁC THÀNH PHẦN CỦA AN TOÀN THÔNG TIN	19
1.3.2. An toàn máy tính và dữ liệu	20
1.3.3. An ninh mạng	20
1.3.4. Quản lý an toàn thông tin	20
1.3.5. Chính sách an toàn thông tin	21
1.4. CÁC MỐI ĐE DỌA VÀ NGUY CƠ TRONG CÁC VÙNG HẠ TẦNG CNTT	22
1.4.1. Bảy vùng trong cơ sở hạ tầng CNTT.....	22
1.4.2. Các mối đe dọa và nguy cơ trong các vùng hạ tầng CNTT.....	23
1.5. MÔ HÌNH TỔNG QUÁT ĐẢM BẢO ATTT VÀ HỆ THỐNG THÔNG TIN.....	24
1.5.1. Nguyên tắc đảm bảo an toàn thông tin, hệ thống và mạng.....	24
1.5.2. Mô hình tổng quát đảm bảo an toàn thông tin và hệ thống thông tin.....	24
1.6. CÂU HỎI ÔN TẬP	26
CHƯƠNG 2. LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG	27
2.1. TỔNG QUAN VỀ LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG	27
2.1.1. Khái quát về điểm yếu hệ thống và lỗ hổng bảo mật	27
2.1.2. Một số thống kê về lỗ hổng bảo mật	29
2.2. CÁC DẠNG LỖ HỔNG TRONG HỆ ĐIỀU HÀNH VÀ PHẦN MỀM ỨNG DỤNG	31
2.2.1. Lỗi tràn bộ đệm	32
2.2.2. Lỗi không kiểm tra đầu vào.....	37

2.2.3. Các vấn đề với điều khiển truy nhập	39
2.2.4. Các điểm yếu trong xác thực, trao quyền	40
2.2.5. Các điểm yếu trong các hệ mật mã.....	40
2.2.6. Các lỗ hổng bảo mật khác.....	41
2.3. QUẢN LÝ, KHẮC PHỤC CÁC LỖ HỔNG BẢO MẬT VÀ TĂNG CƯỜNG KHẢ NẲNG ĐỀ KHÁNG CHO HỆ THỐNG	41
2.3.1. Nguyên tắc chung	41
2.3.2. Các biện pháp cụ thể.....	42
2.4. GIỚI THIỆU MỘT SỐ CÔNG CỤ RÀ QUÉT ĐIỂM YẾU VÀ LỖ HỔNG BẢO MẬT	43
2.4.1. Công cụ rà quét lỗ hổng bảo mật hệ thống.....	43
2.4.2. Công cụ rà quét lỗ hổng ứng dụng web.....	44
2.5. CÂU HỎI ÔN TẬP	45
CHƯƠNG 3. CÁC DẠNG TẤN CÔNG VÀ CÁC PHẦN MỀM ĐỘC HẠI	46
3.1. KHÁI QUÁT VỀ MỐI ĐE DỌA VÀ TẤN CÔNG.....	46
3.1.1. Mối đe dọa.....	46
3.1.2. Tấn công	46
3.2. CÁC CÔNG CỤ HỖ TRỢ TẤN CÔNG.....	47
3.2.1. Công cụ quét cổng dịch vụ	47
3.2.2. Công cụ nghe lén	48
3.2.3. Công cụ ghi phím gõ	49
3.3. CÁC DẠNG TẤN CÔNG THƯỜNG GẶP.....	50
3.3.1. Tấn công vào mật khẩu.....	50
3.3.2. Tấn công bằng mã độc.....	51
3.3.3. Tấn công từ chối dịch vụ và tấn công từ chối dịch vụ phân tán.....	56
3.3.4. Tấn công giả mạo địa chỉ.....	62
3.3.5. Tấn công nghe lén.....	62
3.3.6. Tấn công kiểu người đứng giữa.....	63
3.3.7. Tấn công bằng bom thư và thư rác	64
3.3.8. Tấn công sử dụng các kỹ thuật xã hội	65
3.3.9. Tấn công pharming.....	67
3.4. CÁC DẠNG PHẦN MỀM ĐỘC HẠI	68
3.4.1. Giới thiệu	68
3.4.2. Bom lô gic	69
3.4.3. Trojan Horses	70

3.4.4. Cửa hậu.....	70
3.4.5. Vi rút.....	71
3.4.6. Sâu	73
3.4.7. Zombies	74
3.4.8. Rootkits.....	75
3.4.9. Adware và Spyware.....	75
3.4.10. Phòng chống phần mềm độc hại.....	76
3.5. CÂU HỎI ÔN TẬP	78
CHƯƠNG 4. ĐẢM BẢO AN TOÀN THÔNG TIN DỰA TRÊN MÃ HÓA.....	79
4.1. KHÁI QUÁT VỀ MÃ HÓA THÔNG TIN VÀ ỨNG DỤNG.....	79
4.1.1. Các khái niệm cơ bản	79
4.1.2. Các thành phần của một hệ mã hóa	82
4.1.3. Mã hóa dòng và mã hóa khối	82
4.1.4. Sơ lược lịch sử mật mã	83
4.1.5. Ứng dụng của mã hóa.....	84
4.2. CÁC PHƯƠNG PHÁP MÃ HÓA.....	84
4.2.1. Phương pháp thay thế	84
4.2.2. Phương pháp hoán vị	85
4.2.3. Phương pháp XOR	86
4.2.4. Phương pháp Vernam	86
4.2.5. Phương pháp sách hoặc khóa chạy.....	87
4.2.6. Phương pháp hàm băm	87
4.3. CÁC GIẢI THUẬT MÃ HÓA.....	87
4.3.1. Các giải thuật mã hóa khóa đối xứng	87
4.3.2. Các giải thuật mã hóa khóa bất đối xứng	96
4.4. Các hàm băm	99
4.4.1. Khái quát về hàm băm	99
4.4.2. Một số hàm băm thông dụng	102
4.5. CÂU HỎI ÔN TẬP	104
CHƯƠNG 5. CÁC KỸ THUẬT VÀ CÔNG NGHỆ ĐẢM BẢO AN TOÀN THÔNG TIN	105
5.1. ĐIỀU KHIỂN TRUY NHẬP	105
5.1.1. Khái niệm điều khiển truy nhập	105
5.1.2. Các biện pháp điều khiển truy nhập	105

5.1.3. Một số công nghệ điều khiển truy nhập	110
5.2. TƯỜNG LỬA.....	115
5.2.1. Giới thiệu.....	115
5.2.2. Các loại tường lửa	117
5.2.3. Các kỹ thuật kiểm soát truy nhập	119
5.2.4. Các hạn chế của tường lửa.....	119
5.3. CÁC HỆ THỐNG PHÁT HIỆN VÀ NGĂN CHẶN XÂM NHẬP.....	120
5.3.1. Giới thiệu.....	120
5.3.2. Phân loại	121
5.3.3. Các kỹ thuật phát hiện xâm nhập	122
5.4. CÂU HỎI ÔN TẬP	124
CHƯƠNG 6. QUẢN LÝ, CHÍNH SÁCH VÀ PHÁP LUẬT AN TOÀN THÔNG TIN	125
6.1 QUẢN LÝ AN TOÀN THÔNG TIN.....	125
6.1.1. Khái quát về quản lý an toàn thông tin.....	125
6.1.2. Đánh giá rủi ro an toàn thông tin.....	126
6.1.3. Phân tích chi tiết rủi ro an toàn thông tin	128
6.1.4. Thực thi quản lý an toàn thông tin.....	131
6.2. CÁC CHUẨN QUẢN LÝ AN TOÀN THÔNG TIN	133
6.2.1. Giới thiệu.....	133
6.2.2. Chu trình Plan-Do-Check-Act	134
6.3. PHÁP LUẬT VÀ CHÍNH SÁCH AN TOÀN THÔNG TIN.....	135
6.3.1. Giới thiệu về pháp luật và chính sách an toàn thông tin.....	135
6.3.2. Luật quốc tế về an toàn thông tin	136
6.3.3. Luật Việt Nam về an toàn thông tin	138
6.4. VẤN ĐỀ ĐẠO ĐỨC AN TOÀN THÔNG TIN	138
6.4.1. Sự cần thiết của đạo đức an toàn thông tin.....	138
6.4.2. Một số bộ quy tắc ứng xử trong CNTT và ATTT	139
6.4.3. Một số vấn đề khác.....	139
6.5. CÂU HỎI ÔN TẬP	140
TÀI LIỆU THAM KHẢO	142

DANH MỤC CÁC HÌNH

Hình 1.1. Các thuộc tính cần bảo vệ của tài sản thông tin: Bí mật (Confidentiality), Toàn vẹn (Integrity) và Sẵn dùng (Availability) [1]	13
Hình 1.2. Mô hình hệ thống thông tin của cơ quan, tổ chức	14
Hình 1.3. Các thành phần của hệ thống thông tin và an toàn hệ thống thông tin.....	15
Hình 1.4. Số lượng các thiết bị kết nối vào Internet đến 2015 và dự báo đến 2021 [3].....	16
Hình 1.5. Số lượng các sự cố toàn hệ thống thông tin được thông báo đến Cơ quan ứng cứu khẩn cấp máy tính (US-CERT) trong giai đoạn 2006 – 2014 [4]	16
Hình 1.6. Một văn bản được đóng dấu Confidential (Mật).....	17
Hình 1.7. Đảm bảo tính bí mật bằng đường hầm VPN, hoặc mã hóa	18
Hình 1.8. Minh họa tính sẵn dùng: (a) không đảm bảo và (b) đảm bảo tính sẵn dùng	19
Hình 1.9. Các thành phần chính của An toàn thông tin [1]	19
Hình 1.10. Đảm bảo an toàn máy tính và dữ liệu.....	20
Hình 1.11. Đảm bảo an toàn cho thông tin và hệ thống mạng sử dụng tường lửa	21
Hình 1.12. Chu trình quản lý an toàn thông tin	21
Hình 1.13. Chính sách an toàn thông tin và các thành phần của nó.....	22
Hình 1.14. Bảy vùng trong hạ tầng CNTT theo mức kết nối mạng [2].....	22
Hình 1.15. Các lớp bảo vệ cần cân bằng giữa Tính hữu dụng (Usability), Chi phí (Cost) và An toàn (Security)	24
Hình 1.16. Mô hình đảm bảo an toàn thông tin với bảy lớp.....	25
Hình 1.17. Mô hình đảm bảo an toàn thông tin với ba lớp chính.....	25
Hình 2.1. Mô hình hệ điều hành Unix/Linux, các dịch vụ và ứng dụng	27
Hình 2.2. Phân bố lỗ hổng bảo mật trong các thành phần của hệ thống [6].....	29
Hình 2.3. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng năm 2012 [6]	29
Hình 2.4. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng giai đoạn 2005-2018 [6]	30
Hình 2.5. Lỗ hổng bảo mật phát hiện trong các năm 2011 và 2012 trên các hệ điều hành.....	30
Hình 2.6. Lỗ hổng bảo mật phát hiện trong các năm 2011 và 2012 trên một số ứng dụng.....	31
Hình 2.7. Các vùng bộ nhớ cấp cho chương trình.....	32
Hình 2.8. Một chương trình minh họa cấp phát bộ nhớ trong ngăn xếp	33
Hình 2.9. Các thành phần được lưu trong vùng bộ nhớ trong ngăn xếp	33
Hình 2.10. Cấp phát bộ nhớ cho các biến nhớ trong vùng bộ nhớ trong ngăn xếp	33
Hình 2.11. Một chương trình minh họa gây tràn bộ nhớ đệm trong ngăn xếp.....	34
Hình 2.12. Minh họa hiện tượng tràn bộ nhớ đệm trong ngăn xếp	34
Hình 2.13. Một shellcode viết bằng hợp ngữ và chuyển thành chuỗi tấn công.....	35
Hình 2.14. Chèn và thực hiện shellcode khai thác lỗi tràn bộ đệm	35
Hình 2.15. Chèn shellcode với phần đệm bằng lệnh NOP (N).....	36
Hình 2.16. Bản đồ lây nhiễm sâu Slammer (màu xanh) theo trang www.caida.org vào ngày 25/1/2003 lúc 6h00 (giờ UTC) với 74.855 máy chủ bị nhiễm	36
Hình 2.17. Cung cấp dữ liệu quá lớn để gây lỗi cho ứng dụng	38
Hình 2.18. Cân bằng giữa An toàn (Secure), Hữu dụng (Usable) và Rẻ tiền (Cheap).....	41
Hình 2.19. Báo cáo kết quả quét của Microsoft Baseline Security Analyzer.....	43
Hình 2.20. Màn hình tổng hợp kết quả quét lỗ hổng của Nessus Vulnerability Scanner.....	44
Hình 2.21. Kết quả quét website sử dụng Acunetix Web Vulnerability Scanner	45

Hình 3.1. Giao diện của công cụ quét cổng Zenmap.....	48
Hình 3.2. Sử dụng Wireshark để bắt gói tin có chứa thông tin nhạy cảm.....	49
Hình 3.3. Mô đun Keylogger phần cứng và cài đặt trên máy tính để bàn.....	49
Hình 3.4. Form đăng nhập (log in) và đoạn mã xử lý xác thực người dùng.....	52
Hình 3.5. Form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm.....	53
Hình 3.6. (a) Thủ tục bắt tay 3 bước của giao thức TCP và (b) Tấn công SYN Flood.....	57
Hình 3.7. Mô hình tấn công Smurf.....	58
Hình 3.8. Kiến trúc tấn công DDoS trực tiếp.....	60
Hình 3.9. Kiến trúc tấn công DDoS gián tiếp hay phản xạ.....	61
Hình 3.10. Minh họa quá trình tấn công giả mạo địa chỉ IP.....	62
Hình 3.11. Một mô hình tấn công nghe lén.....	63
Hình 3.12. Mô hình chung của tấn công kiểu người đứng giữa.....	63
Hình 3.13. Một kịch bản tấn công kiểu người đứng giữa.....	64
Hình 3.14. Một phishing email gửi cho khách hàng của mạng đấu giá eBay.....	66
Hình 3.15. Một phishing email gửi cho khách hàng của ngân hàng Royal Bank.....	66
Hình 3.16. Tấn công pharming "cướp" trình duyệt.....	67
Hình 3.17. Tấn công pharming thông qua tấn công vào máy chủ DNS.....	68
Hình 3.18. Các dạng phần mềm độc hại.....	69
Hình 3.19. Minh họa bom lô gic.....	69
Hình 3.20. Minh họa trojan horse.....	70
Hình 3.21. Minh họa cửa hậu trên điện thoại Apple iPhone cho phép truy nhập trái phép.....	70
Hình 3.22. Minh họa vi rút máy tính.....	71
Hình 3.23. Chèn và gọi thực hiện mã vi rút.....	71
Hình 3.24. Macro vi rút chỉ lây nhiễm vào các tài liệu của bộ ứng dụng Microsoft Office.....	72
Hình 3.25. Một email vi rút gửi đến người dùng.....	73
Hình 3.26. Minh họa sâu máy tính.....	73
Hình 3.27. Bản đồ lây nhiễm sâu Code Red trên toàn thế giới.....	74
Hình 3.28. Mô hình kẻ tấn công sử dụng các máy tính Zombie để tấn công DDoS.....	75
Hình 3.29. Mô hình kẻ tấn công sử dụng các máy tính Zombie để gửi thư rác.....	75
Hình 3.30. Màn hình chính của Microsoft Windows Defender.....	77
Hình 4.1. Các khâu Mã hóa (Encryption) và Giải mã (Decryption) của một hệ mã hóa.....	79
Hình 4.2. Mã hóa khóa đối xứng sử dụng 1 khóa bí mật chia sẻ để mã hoá và giải mã.....	80
Hình 4.3. Mã hóa khóa bất đối xứng sử dụng một cặp khóa để mã hoá và giải mã.....	81
Hình 4.4. Minh họa đầu vào (Input) và đầu ra (Digest) của hàm băm.....	81
Hình 4.5. Các thành phần của một hệ mã hóa đơn giản.....	82
Hình 4.6. Mã hóa dòng (Stream cipher).....	82
Hình 4.7. Mã hóa khối (Block cipher).....	83
Hình 4.8. Mã hóa bằng hệ mã hóa Caesar cipher.....	84
Hình 4.9. Phương pháp thay thế với 4 bộ chữ mã.....	85
Hình 4.10. Phương pháp hoán vị thực hiện đổi chỗ các bit.....	85
Hình 4.11. Phương pháp hoán vị thực hiện đổi chỗ các ký tự.....	85
Hình 4.12. Mã hóa bằng phương pháp XOR.....	86
Hình 4.13. Mã hóa bằng phương pháp Vernam.....	86
Hình 4.14. Quá trình mã hóa khóa đối xứng (Symmetric key encryption).....	88
Hình 4.15. Mô hình các khâu mã hóa và giải mã của DES.....	88

Hình 4.16. Thủ tục sinh các khóa phụ từ khóa chính của DES	89
Hình 4.17. Các bước xử lý chuyển khối rõ 64 bit thành khối mã 64 bit của DES	90
Hình 4.18. Các bước xử lý của hàm Feistel (F).....	91
Hình 4.19. Mã hóa và giải mã với giải thuật 3-DES	91
Hình 4.20. Các bước xử lý mã hóa dữ liệu của AES.....	93
Hình 4.21. Thủ tục sinh khóa Rijndael.....	94
Hình 4.22. Hàm SubBytes sử dụng Rijndael S-box	94
Hình 4.23. Hàm ShiftRows	94
Hình 4.24. Hàm MixColumns	95
Hình 4.25. Hàm AddRoundKey	95
Hình 4.26. Quá trình mã hóa và giải mã trong AES.....	96
Hình 4.27. Mã hóa và giải mã trong hệ mã hóa bất đối xứng	96
Hình 4.28. Mô hình nén thông tin của hàm băm	99
Hình 4.29. Phân loại các hàm băm theo khóa sử dụng.....	100
Hình 4.30. Mô hình tổng quát xử lý dữ liệu của hàm băm.....	101
Hình 4.31. Mô hình chi tiết xử lý dữ liệu của hàm băm.....	101
Hình 4.32. Lưu đồ xử lý một thao tác của MD5.....	103
Hình 4.33. Lưu đồ một vòng xử lý của SHA1	104
Hình 5.1. Mô hình ma trận điều khiển truy nhập	106
Hình 5.2. Mô hình danh sách điều khiển truy nhập.....	107
Hình 5.3. Mô hình điều khiển truy nhập Bell-LaPadula	109
Hình 5.4. Một mô hình RBAC đơn giản	110
Hình 5.5. Giao diện kiểm tra thông tin của một chứng chỉ số khóa công khai	112
Hình 5.6. Thẻ thông minh tiếp xúc (a) và thẻ không tiếp xúc (b)	112
Hình 5.7. Một số thẻ bài (Token) của hãng RSA Security.....	113
Hình 5.8. Ví điện tử (một dạng thẻ bài) của cổng thanh toán trực tuyến Paypal	113
Hình 5.9. Hệ thống ApplePay tích hợp vào điện thoại di động.....	114
Hình 5.10. (a) Khóa vân tay, (b) Khe xác thực vân tay trên laptop và (c) Xác thực vân tay trên điện thoại thông minh Samsung	115
Hình 5.11. Quét võng mạc nhận dạng tròng mắt.....	115
Hình 5.12. Một tường lửa phần cứng chuyên dụng của hãng Cisco	116
Hình 5.13. Tường lửa bảo vệ mạng gia đình hoặc văn phòng nhỏ.....	116
Hình 5.14. Tường lửa bảo vệ các máy chủ dịch vụ	116
Hình 5.15. Hệ thống tường lửa bảo vệ các máy chủ dịch vụ và máy trạm.....	117
Hình 5.16. Mô hình tường lửa lọc gói (a), Cổng ứng dụng (b) và Cổng chuyển mạch (c) ...	118
Hình 5.17. Tường lửa có trạng thái chặn gói tin không thuộc kết nối đang hoạt động.....	119
Hình 5.18. Vị trí các hệ thống IDS và IPS trong sơ đồ mạng	120
Hình 5.19. Các NIDS được bố trí để giám sát phát hiện xâm nhập tại cổng vào và cho từng phân đoạn mạng.....	121
Hình 5.20. Sử dụng kết hợp NIDS và HIDS để giám sát lưu lượng mạng và các host.....	122
Hình 5.21. Lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký	122
Hình 5.22. Giá trị entropy của IP nguồn của các gói tin từ lưu lượng hợp pháp (phần giá trị cao, đều) và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS (phần giá trị thấp).....	123
Hình 6.1. Mô hình hệ thống quản lý an toàn thông tin theo chuẩn ISO 27001.....	126

Hình 6.2. Mô hình đánh giá rủi ro an toàn thông tin	126
Hình 6.3. Chu trình Plan-Do-Check-Act của ISO/IEC 27001:2005	134
Hình 6.4. Vấn đề tuân thủ (Compliance) pháp luật, chính sách và các nội quy, quy định.....	136

ATTN.PTIT

DANH MỤC CÁC THUẬT NGỮ TIẾNG ANH VÀ VIỆT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
AES	Advanced Encryption Standard	Chuẩn mã hóa tiên tiến
ATTT	Information Security	An toàn thông tin
CNTT	Information Technology	Công nghệ thông tin
CRC	Cyclic redundancy checks	Kiểm tra dư thừa vòng
CSDL	Database	Cơ sở dữ liệu
CSRF	Cross-Site Request Forgery	Tấn công giả mạo yêu cầu liên miền
DAC	Discretionary Access Control	Điều khiển truy nhập tùy chọn
DES	Data Encryption Standard	Chuẩn mã hóa dữ liệu
DNS	Domain Name System	Hệ thống tên miền
DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
DoS	Denial of Service	Tấn công từ chối dịch vụ
FTP	File Transfer Protocol	Giao thức truyền file
HTTP	HyperText Transfer Protocol	Giao thức truyền siêu văn bản
HTTT	Information System	Hệ thống thông tin
IDEA	International Data Encryption Algorithm	Giải thuật mã hóa dữ liệu quốc tế
ICMP	Internet Control Message Protocol	Giao thức điều khiển truyền thông điệp
IP	Internet Protocol	Giao thức Internet
IPSec	Internet Protocol Security	An toàn giao thức Internet
IRC	Internet Relay Chat	Giao thức IRC
LAN	Local Area Network	Mạng cục bộ
MAC	Mandatory Access Control	Điều khiển truy nhập bắt buộc
MAC	Message Authentication Code	Mã xác thực thông điệp (sử dụng hàm băm có khóa)
MD	Message Digest	Chuỗi đại diện thông điệp
MDC	Modification Detection Code	Mã phát hiện sửa đổi (sử dụng hàm băm không khóa)
NSA	National Security Agency	Cơ quan mật vụ liên bang Hoa Kỳ
PGP	Pretty Good Privacy	Chuẩn bảo mật PGP
PKI	Public Key Infrastructure	Hạ tầng khóa công khai
RBAC	Role-Based Access Control	Điều khiển truy nhập dựa trên vai trò
RSA	RSA Public Key Cryptosystem	Hệ mật khóa công khai RSA
SET	Secure Electronic Transactions	Các giao dịch điện tử an toàn
SHA	Secure Hash Algorithm	Giải thuật băm an toàn

SMTP	Simple Mail Transfer Protocol	Giao thức truyền thư điện tử đơn giản
SQL	Structured Query Language	Ngôn ngữ truy vấn có cấu trúc
SSH	Secure Shell	Vô an toàn
SSL/TLS	Secure Socket Layer/Transport Layer Security	Bộ giao thức bảo mật SSL / TLS
SSO	Single Sign On	Đăng nhập một lần
TCP	Transmission Control Protocol	Giao thức điều khiển truyền
UDP	User Datagram Protocol	Giao thức gói dữ liệu người dùng
XSS	Cross-Site Scripting	Tấn công script liên miền
WAN	Wide Area Network	Mạng diện rộng
WLAN	Wireless Local Area Network	Mạng cục bộ không dây

MỞ ĐẦU

An toàn thông tin (Information security) là một lĩnh vực tương đối mới và được quan tâm trong vài thập kỷ gần đây và phát triển mạnh trong khoảng hơn một thập kỷ qua nhờ sự phát triển mạnh mẽ của mạng Internet và các dịch vụ mạng trên nền Internet. Tuy nhiên, do Internet ngày càng mở rộng và gần như không còn khái niệm biên giới quốc gia trong không gian mạng, các sự cố mất an toàn thông tin liên tục xảy ra. Đặc biệt, các dạng tấn công, xâm nhập vào các hệ thống máy tính và mạng xuất hiện ngày càng phổ biến với mức độ phá hoại ngày càng nghiêm trọng. Vấn đề đảm bảo an toàn cho thông tin, các hệ thống và mạng trở nên cấp thiết và là mối quan tâm của mỗi quốc gia, cơ quan, tổ chức và mỗi người dùng.

An toàn thông tin được định nghĩa là việc bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, hoặc phá hủy thông tin một cách trái phép. Dưới một góc nhìn khác, An toàn thông tin là việc bảo vệ các thuộc tính, bao gồm tính bí mật, tính toàn vẹn và tính sẵn dùng của các tài sản thông tin trong quá trình chúng được lưu trữ, xử lý, hoặc truyền tải. An toàn thông tin có thể được chia thành ba thành phần chính: An toàn máy tính và dữ liệu, An ninh mạng và Quản lý an toàn thông tin.

Môn học Cơ sở an toàn thông tin là môn học cơ sở chuyên ngành trong chương trình đào tạo đại học các ngành An toàn thông tin và ngành Công nghệ thông tin (chuyên ngành An toàn thông tin) của Học viện Công nghệ Bưu chính Viễn thông. Mục tiêu của môn học cung cấp cho sinh viên các khái niệm và nguyên tắc cơ bản về đảm bảo an toàn thông tin, an toàn máy tính, an toàn hệ thống thông tin và mạng; các nguy cơ và các lỗ hổng gây mất an toàn; các dạng tấn công, xâm nhập thường gặp; các dạng phần mềm độc hại; các kỹ thuật, giải pháp và công cụ phòng chống, đảm bảo an toàn thông tin, hệ thống và mạng; vấn đề quản lý an toàn thông tin, chính sách, pháp luật và đạo đức an toàn thông tin.

Với phạm vi là một trong môn học cơ sở nhất về an toàn thông tin, tác giả cố gắng trình bày những vấn đề cơ sở nhất phục vụ mục tiêu môn học. Nội dung của giáo trình này được biên soạn thành 6 chương với tóm tắt nội dung như sau:

Chương 1- Tổng quan về an toàn thông tin giới thiệu các khái niệm về an toàn thông tin, an toàn hệ thống thông tin và các yêu cầu đảm bảo an toàn thông tin, an toàn hệ thống thông tin. Chương 1 cũng đề cập các nguy cơ, rủi ro trong các vùng của hạ tầng công nghệ thông tin theo mức kết nối mạng. Phần cuối của chương giới thiệu mô hình tổng quát đảm bảo an toàn thông tin và an toàn hệ thống thông tin.

Chương 2- Các lỗ hổng bảo mật và các điểm yếu hệ thống giới thiệu các khái niệm về các điểm yếu và lỗ hổng bảo mật tồn tại trong hệ thống, các dạng lỗ hổng bảo mật trong hệ điều hành và các phần mềm ứng dụng. Chương này đi sâu phân tích cơ chế xuất hiện và khai thác các lỗ hổng tràn bộ đệm và lỗ hổng không kiểm tra đầu vào. Phần cuối của chương đề cập vấn đề quản lý, khắc phục các lỗ hổng bảo mật, tăng cường khả năng đề kháng cho hệ thống và giới thiệu một số công cụ rà quét lỗ hổng bảo mật.

Chương 3- Các dạng tấn công và các phần mềm độc hại giới thiệu về các dạng tấn công điển hình vào các hệ thống máy tính và mạng, bao gồm tấn công vào mật khẩu, tấn công nghe lén, người đứng giữa, tấn công DoS, DDoS, tấn công sử dụng các kỹ thuật xã hội,... Nửa cuối của chương 3 đề cập đến các dạng phần mềm độc hại, gồm cơ chế lây nhiễm và tác hại của chúng. Kèm theo phần mô tả mỗi tấn công, hoặc phần mềm độc hại, chương đề cập các biện pháp, kỹ thuật phòng chống.

Chương 4 – Đảm bảo an toàn thông tin dựa trên mã hóa giới thiệu các khái niệm cơ bản về mật mã, hệ mã hóa, các phương pháp mã hóa. Phần tiếp theo của chương 4 trình bày một số giải thuật cơ bản của mã hóa khóa đối xứng (DES, 3-DES và AES), mã hóa khóa bất đối xứng (RSA) và các hàm băm (MD5 và SHA1).

Chương 5- Các kỹ thuật và công nghệ đảm bảo an toàn thông tin giới thiệu khái quát về điều khiển truy nhập, các cơ chế (mô hình) điều khiển truy nhập và một số công nghệ điều khiển truy nhập được sử dụng trên thực tế. Phần tiếp theo của chương 5 giới thiệu về tường lửa – một trong các kỹ thuật được sử dụng rất phổ biến trong đảm bảo an toàn cho hệ thống máy tính và mạng. Phần cuối của chương giới thiệu về các hệ thống phát hiện, ngăn chặn xâm nhập.

Chương 6 – Quản lý, chính sách và pháp luật an toàn thông tin giới thiệu một số khái niệm cơ bản trong quản lý an toàn thông tin, vấn đề đánh giá rủi ro an toàn thông tin và thực thi quản lý an toàn thông tin. Nội dung tiếp theo được đề cập là các chuẩn quản lý an toàn thông tin, trong đó giới thiệu một số chuẩn của bộ chuẩn ISO/IEC 27000. Phần cuối của chương giới thiệu khái quát về các vấn đề chính sách, pháp luật và đạo đức an toàn thông tin.

Tài liệu được biên soạn dựa trên kinh nghiệm giảng dạy các môn học Cơ sở an toàn thông tin trong nhiều năm của tác giả tại Học viện Công nghệ Bưu chính Viễn thông, kết hợp tiếp thu các đóng góp của đồng nghiệp và phản hồi từ sinh viên. Tài liệu có thể được sử dụng làm tài liệu học tập cho sinh viên hệ đại học các ngành An toàn thông tin và ngành Công nghệ thông tin (chuyên ngành An toàn thông tin). Trong quá trình biên soạn, mặc dù tác giả đã rất cố gắng song không thể tránh khỏi có những thiếu sót. Tác giả rất mong muốn nhận được ý kiến phản hồi và các góp ý cho các thiếu sót, cũng như ý kiến về việc cập nhật, hoàn thiện nội dung của tài liệu.

Hà Nội, Tháng 12 năm 2018

Tác giả

TS. Hoàng Xuân Dậu

CHƯƠNG 1. TỔNG QUAN VỀ AN TOÀN THÔNG TIN

Chương 1 giới thiệu các khái niệm về an toàn thông tin, an toàn hệ thống thông tin và các yêu cầu đảm bảo an toàn thông tin, an toàn hệ thống thông tin. Chương này cũng đề cập các nguy cơ, rủi ro trong các vùng của hạ tầng công nghệ thông tin theo mức kết nối mạng. Phần cuối của chương 1 giới thiệu mô hình tổng quát đảm bảo an toàn thông tin và an toàn hệ thống thông tin.

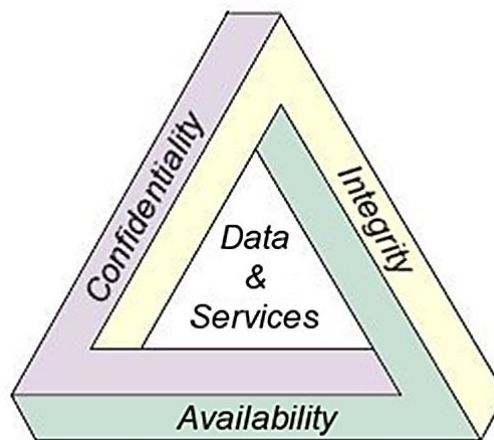
1.1. KHÁI QUÁT VỀ AN TOÀN THÔNG TIN

1.1.1. Một số khái niệm trong an toàn thông tin

1.1.1.1. An toàn thông tin

An toàn thông tin (Information security) là việc bảo vệ chống truy nhập, sử dụng, tiết lộ, sửa đổi, hoặc phá hủy thông tin một cách trái phép, theo trang Wikipedia¹.

Theo cuốn sách “Principles of Information Security” [1], An toàn thông tin là việc bảo vệ các thuộc tính bí mật (confidentiality), toàn vẹn (integrity) và sẵn dùng (availability) của các tài sản thông tin trong quá trình chúng được lưu trữ, xử lý, hoặc truyền tải. Hình 1.1 minh họa ba thuộc tính cần bảo vệ nói trên của các tài sản thông tin, bao gồm dữ liệu (Data) và dịch vụ (Services).



Hình 1.1. Các thuộc tính cần bảo vệ của tài sản thông tin: Bí mật (Confidentiality), Toàn vẹn (Integrity) và Sẵn dùng (Availability) [1]

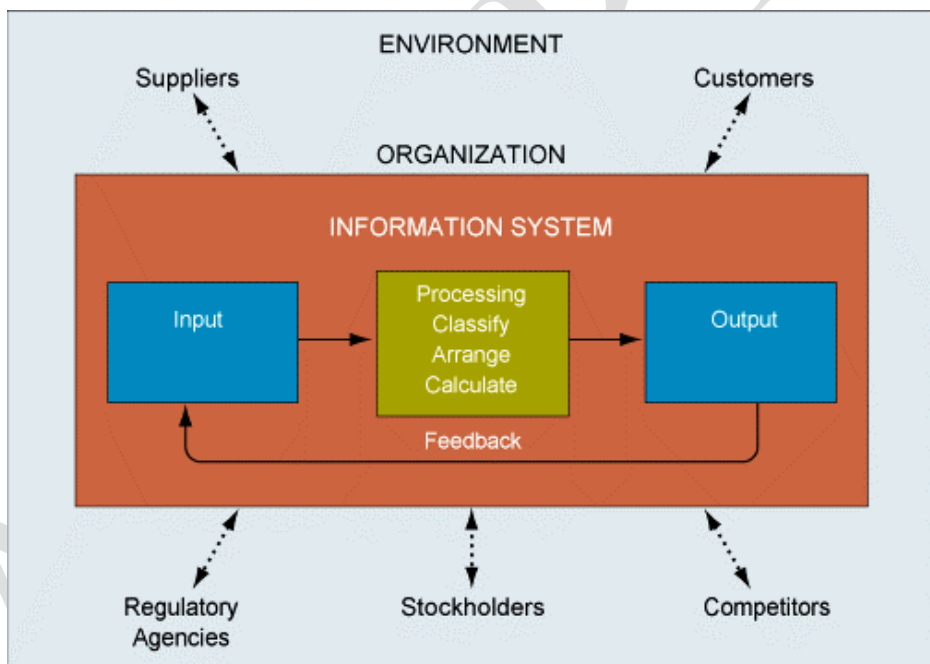
An toàn thông tin gồm hai lĩnh vực chính là An toàn công nghệ thông tin (Information technology security, hay IT security) và Đảm bảo thông tin (Information assurance). An toàn công nghệ thông tin, hay còn gọi là An toàn máy tính (Computer security) là việc đảm bảo an toàn cho các hệ thống công nghệ thông tin, bao gồm các hệ thống máy tính và mạng, chống lại các cuộc tấn công phá hoại. Đảm bảo thông tin là việc đảm bảo thông tin không bị mất khi xảy ra các sự cố, như thiên tai, hỏng hóc, trộm cắp, phá hoại,... Đảm bảo thông tin thường

¹ https://en.wikipedia.org/wiki/Information_security

được thực hiện sử dụng các kỹ thuật *sao lưu ngoại vi* (offsite backup), trong đó dữ liệu thông tin từ hệ thống gốc được sao lưu ra các thiết bị lưu trữ vật lý đặt ở một vị trí khác.

1.1.1.2. Hệ thống thông tin và an toàn hệ thống thông tin

Hệ thống thông tin (Information system), theo cuốn sách “Fundamentals of Information Systems Security” [2] là một hệ thống tích hợp các thành phần nhằm phục vụ việc thu thập, lưu trữ, xử lý thông tin, và chuyển giao thông tin, tri thức và các sản phẩm số. Trong nền kinh tế số, hệ thống thông tin đóng vai trò rất quan trọng trong hoạt động của các tổ chức, cơ quan và doanh nghiệp (gọi chung là tổ chức). Có thể nói, hầu hết các tổ chức đều sử dụng các hệ thống thông tin với các quy mô khác nhau để quản lý các hoạt động của mình. Hình 1.2 minh họa mô hình một hệ thống thông tin điển hình. Trong mô hình này, mỗi hệ thống thông tin gồm ba thành phần chính: (i) thành phần thu thập thông tin (Input), (ii) thành phần xử lý thông tin (Processing) và (iii) thành phần kết xuất thông tin (Output). Hệ thống thông tin được sử dụng để tương tác với khách hàng (Customers), với nhà cung cấp (Suppliers), với cơ quan chính quyền (Regulatory Agencies), với cổ đông (Stockholders) và với đối thủ cạnh tranh (Competitors). Có thể nêu là một số hệ thống thông tin điển hình như các hệ lập kế hoạch nguồn lực doanh nghiệp (Enterprise resource planning), các máy tìm kiếm (Search engine) và các hệ thống thông tin địa lý (Geographical information system).

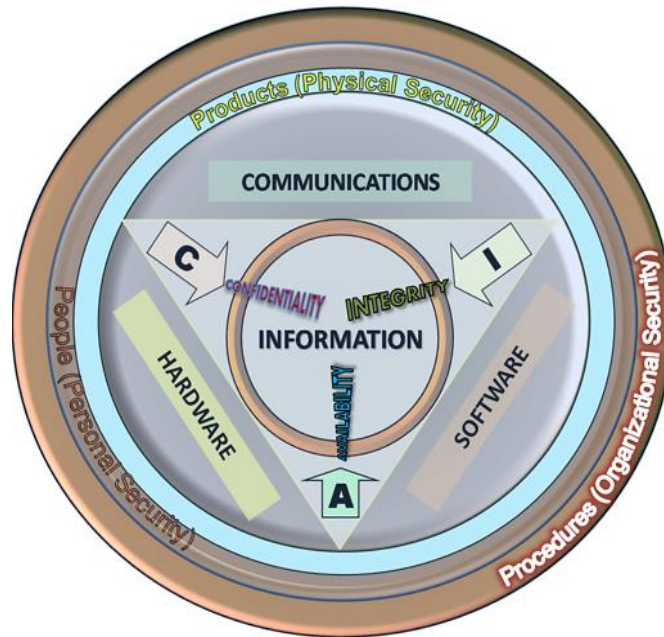


Hình 1.2. Mô hình hệ thống thông tin của cơ quan, tổ chức

Trong lớp các hệ thống thông tin, hệ thống thông tin dựa trên máy tính (Computer-based information system), hay sử dụng công nghệ máy tính để thực thi các nhiệm vụ là lớp hệ thống thông tin được sử dụng rộng rãi nhất. Hệ thống thông tin dựa trên máy tính thường gồm các thành phần chính: phần cứng (Hardware) để thu thập, lưu trữ, xử lý và biểu diễn dữ liệu; phần mềm (Software) chạy trên phần cứng để xử lý dữ liệu; và mạng/truyền thông (Network/Communication) là hệ thống truyền dẫn thông tin/dữ liệu. Ngoài ra, hệ thống thông tin dựa trên máy tính còn có thể gồm: cơ sở dữ liệu (Database) để lưu trữ dữ liệu và các thủ

tục (Procedure) là tập hợp các lệnh kết hợp các bộ phận nêu trên để xử lý dữ liệu, đưa ra kết quả mong muốn.

An toàn hệ thống thông tin (Information systems security) là việc đảm bảo các thuộc tính an ninh, an toàn của hệ thống thông tin, bao gồm tính *bí mật* (confidentiality), tính *toàn vẹn* (integrity) và tính *sẵn dùng* (availability). Hình 1.3 minh họa các thành phần cơ bản của Hệ thống thông tin dựa trên máy tính và An toàn hệ thống thông tin.



Hình 1.3. Các thành phần của hệ thống thông tin và an toàn hệ thống thông tin

1.1.1.3. Một số khái niệm khác

Truy nhập (Access) là việc một chủ thể, người dùng hoặc một đối tượng có khả năng sử dụng, xử lý, sửa đổi, hoặc gây ảnh hưởng đến một chủ thể, người dùng hoặc một đối tượng khác. Trong khi người dùng hợp pháp có quyền truy nhập hợp pháp đến một hệ thống thì kẻ tấn công truy nhập bất hợp pháp đến hệ thống.

Tài sản (Asset) là tài nguyên của các tổ chức, cá nhân được bảo vệ. Tài sản có thể là tài sản vô hình, như một trang web, thông tin, hoặc dữ liệu. Tài sản cũng có thể là tài sản vật lý, như hệ thống máy tính, thiết bị mạng, hoặc các tài sản khác.

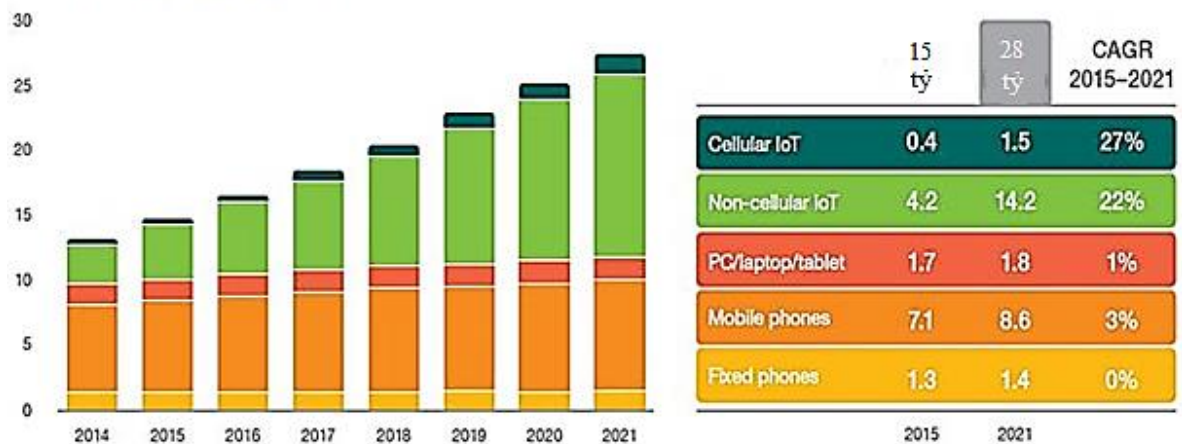
Tấn công (Attack) là hành động có chủ ý hoặc không có chủ ý có khả năng gây hại, hoặc làm thỏa hiệp các thông tin, hệ thống và các tài sản được bảo vệ. Tấn công có thể chủ động hoặc thụ động, trực tiếp hoặc gián tiếp.

1.1.2. Sự cần thiết của an toàn thông tin

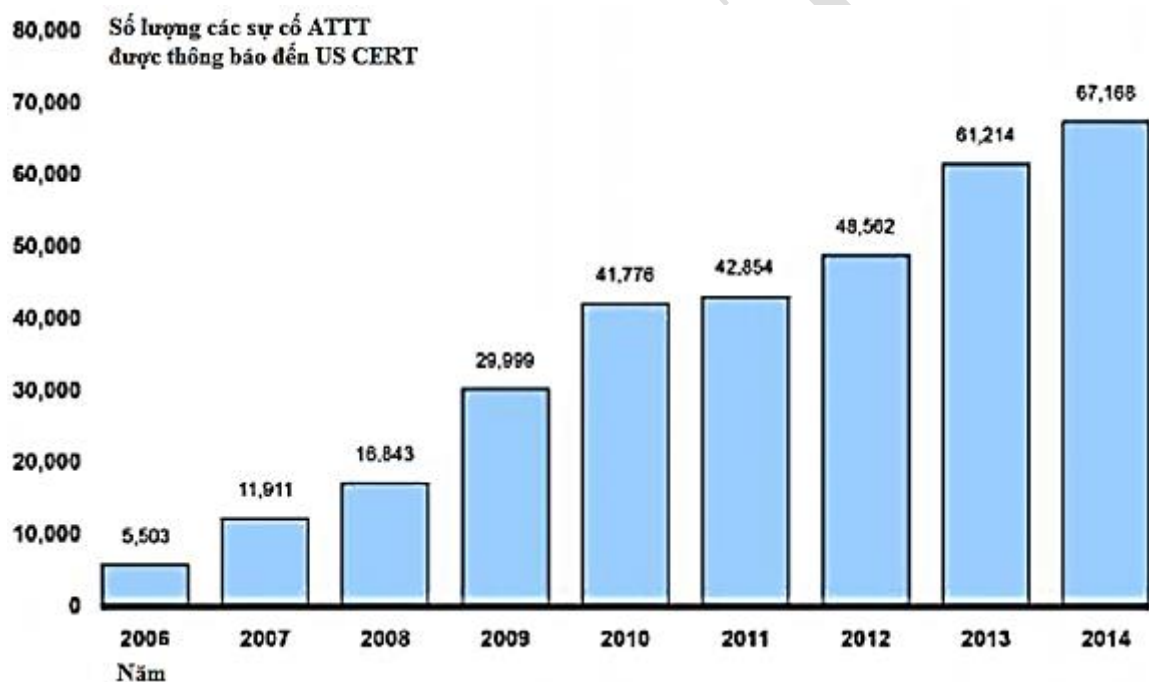
Trong những năm gần đây, cùng với sự phát triển mạnh mẽ của các thiết bị di động, và đặc biệt là các thiết bị IoT (Internet of Things), số lượng người dùng mạng Internet và số lượng thiết bị kết nối vào mạng Internet tăng trưởng nhanh chóng. Theo thống kê và dự báo của Forbes [3] cho trên Hình 1.4, số lượng các thiết bị có kết nối Internet là khoảng 15 tỷ trong năm 2015, tăng lên khoảng 20 tỷ vào năm 2018 và dự báo sẽ tăng mạnh lên khoảng 28 tỷ vào năm 2021. Các thiết bị IoT kết nối thông minh là nền tảng cho phát triển nhiều ứng

dụng quan trọng trong các lĩnh vực của đời sống xã hội, như thành phố thông minh, cộng đồng thông minh, ngôi nhà thông minh, các ứng dụng giám sát và chăm sóc sức khỏe,...

Thiết bị kết nối (đơn vị: tỷ cái)



Hình 1.4. Số lượng các thiết bị kết nối vào Internet đến 2015 và dự báo đến 2021 [3]



Hình 1.5. Số lượng các sự cố toàn hệ thống thông tin được thông báo đến Cơ quan ứng cứu khẩn cấp máy tính (US-CERT) trong giai đoạn 2006 – 2014 [4]

Cùng với những lợi ích to lớn mà các thiết bị kết nối Internet mạng lại, các sự cố mất an toàn thông tin đối với các hệ thống máy tính, điện thoại di động thông minh, các thiết bị IoT và người dùng cũng tăng vọt. Theo số liệu ghi nhận của Cơ quan Thống kê quốc gia Hoa Kỳ cho trên Hình 1.5, số lượng các sự cố mất an toàn hệ thống thông tin được thông báo đến Cơ quan ứng cứu khẩn cấp máy tính (US-CERT) trong giai đoạn 2006 – 2014 tăng rất mạnh, từ 5.503 vụ vào năm 2006 lên đến 67.168 vụ vào năm 2014. Ở Việt Nam, trong báo cáo “*Tổng kết an ninh mạng năm 2017 và dự báo xu hướng 2018*” [5], Tập đoàn công nghệ Bkav cho biết 12.300 tỷ đồng (tương đương khoảng 540 triệu USD) là tổng thiệt hại ước tính do vi rút

máy tính gây ra đối với người dùng Việt Nam trong năm 2017, vượt xa mốc 10.400 tỷ đồng thiệt hại do vi rút máy tính trong năm 2016. Dự báo trong năm 2018 và các năm tiếp theo, số lượng sự cố và thiệt hại do mất an toàn thông tin gây ra còn có thể lớn hơn nữa, do số lượng thiết bị kết nối tăng trưởng nhanh chóng và nguy cơ từ sự bùng phát mạnh của các phần mềm độc hại (các loại mã độc mã hóa tổng tiền (ransomware), mã độc đào tiền ảo...) và các kỹ thuật tấn công, phá hoại tinh vi (như các cuộc tấn công có chủ đích - APT).

Từ các số liệu nêu trên có thể khẳng định, việc đảm bảo an toàn cho thông tin, máy tính, hệ thống mạng và các thiết bị kết nối khác là rất cần thiết bởi 2 lý do: (1) số lượng các thiết bị có kết nối Internet tăng nhanh chóng, đặc biệt là các thiết bị thông minh, IoT và (2) sự bùng phát của các dạng mã độc, các dạng tấn công mạng trên diện rộng và các nguy cơ gây mất an toàn thông tin. Việc đảm bảo an toàn thông tin không chỉ cần thiết đối với các cá nhân, tổ chức, cơ quan, doanh nghiệp mà còn là vấn đề cấp thiết đối với an ninh quốc gia. Hơn nữa, việc xây dựng các giải pháp an toàn thông tin chỉ thực sự hiệu quả khi được thực hiện bài bản, đồng bộ, đảm bảo cân bằng giữa tính an toàn, tính hữu dụng của hệ thống và chi phí đầu tư cho các biện pháp đảm bảo an toàn.

1.2. CÁC YÊU CẦU ĐẢM BẢO ATTT VÀ HTTT

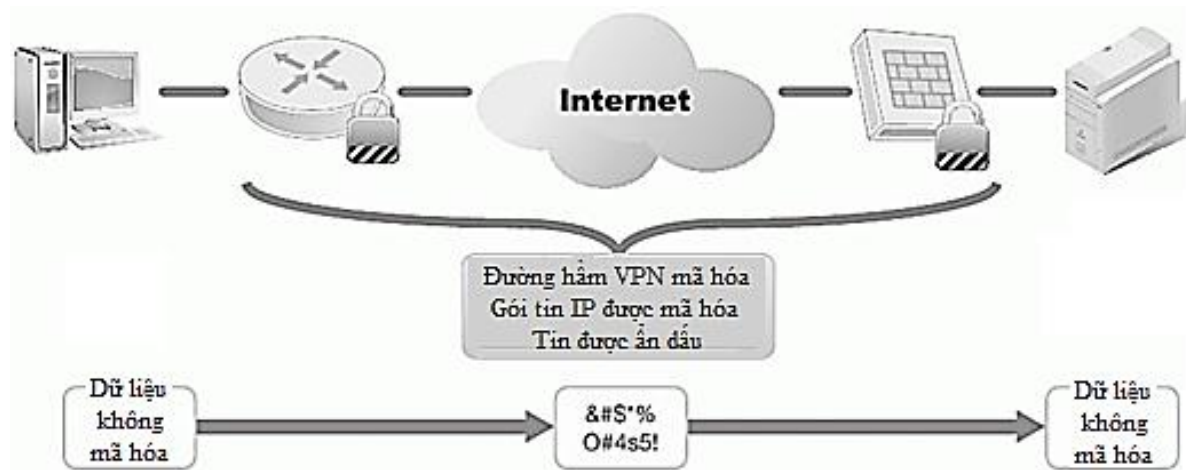
Như đã trình bày trong Mục 1.1, việc đảm bảo an toàn thông tin, hoặc hệ thống thông tin là việc đảm bảo ba thuộc tính của thông tin, hoặc hệ thống, bao gồm tính *Bí mật* (Confidentiality), tính *Toàn vẹn* (Integrity) và tính *Sẵn dùng* (Availability). Đây cũng là ba yêu cầu cơ bản trong đảm bảo an toàn thông tin và hệ thống thông tin.

1.2.1. Bí mật

Tính bí mật đảm bảo rằng chỉ người dùng có thẩm quyền mới được truy nhập thông tin, hệ thống. Các thông tin bí mật có thể bao gồm: (i) dữ liệu riêng của cá nhân, (ii) các thông tin thuộc quyền sở hữu trí tuệ của các doanh nghiệp hay các cơ quan, tổ chức và (iii) các thông tin có liên quan đến an ninh của các quốc gia và các chính phủ. Hình 1.6 minh họa một văn bản được đóng dấu *Confidential* (Mật), theo đó chỉ những người có thẩm quyền (có thể không gồm người soạn thảo văn bản) mới được đọc và phổ biến văn bản.



Hình 1.6. Một văn bản được đóng dấu Confidential (Mật)



Hình 1.7. Đảm bảo tính bí mật bằng đường hầm VPN, hoặc mã hóa

Thông tin bí mật lưu trữ hoặc trong quá trình truyền tải cần được bảo vệ bằng các biện pháp phù hợp, tránh bị lộ lọt hoặc bị đánh cắp. Các biện pháp có thể sử dụng để đảm bảo tính bí mật của thông tin như bảo vệ vật lý, hoặc sử dụng mật mã (cryptography). Hình 1.7 minh họa việc đảm bảo tính bí mật bằng cách sử dụng đường hầm VPN (Virtual private network), hoặc mã hóa để truyền tải thông tin.

1.2.2. Toàn vẹn

Tính toàn vẹn đảm bảo rằng thông tin và dữ liệu chỉ có thể được sửa đổi bởi những người dùng có thẩm quyền. Tính toàn vẹn liên quan đến tính hợp lệ (validity) và chính xác (accuracy) của dữ liệu. Trong nhiều tổ chức, thông tin và dữ liệu có giá trị rất lớn, như bản quyền phần mềm, bản quyền âm nhạc, bản quyền phát minh, sáng chế. Mọi thay đổi không có thẩm quyền có thể ảnh hưởng rất nhiều đến giá trị của thông tin. Thông tin hoặc dữ liệu là toàn vẹn nếu nó thỏa mãn ba điều kiện:

- Không bị thay đổi;
- Hợp lệ, và
- Chính xác.

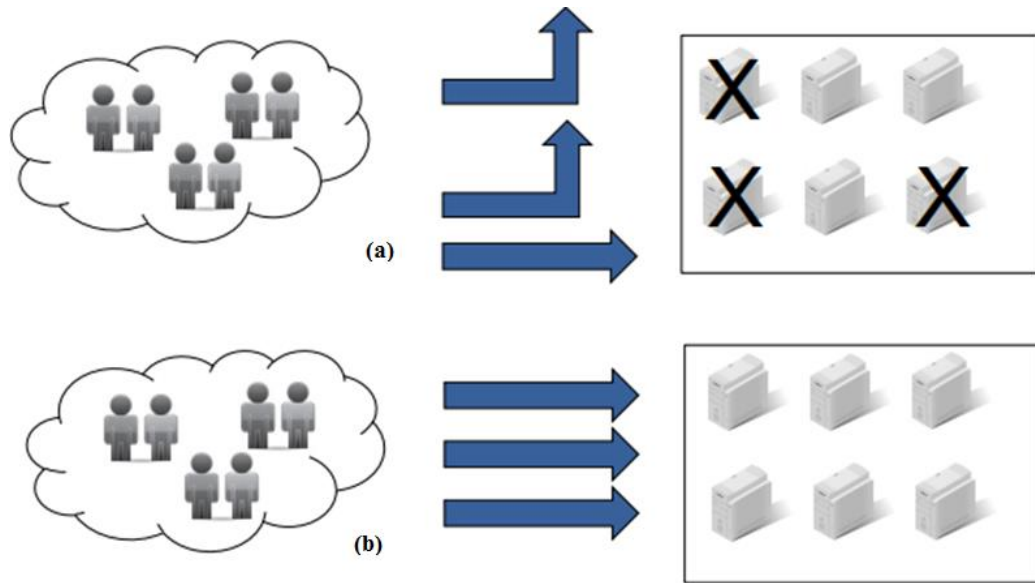
1.2.3. Sẵn dùng

Tính sẵn dùng, hoặc khả dụng đảm bảo rằng thông tin, hoặc hệ thống có thể truy nhập bởi người dùng hợp pháp bất cứ khi nào họ có yêu cầu. Tính sẵn dùng có thể được đo thông qua các yếu tố:

- Thời gian cung cấp dịch vụ (Uptime);
- Thời gian ngừng cung cấp dịch vụ (Downtime);
- Tỷ lệ phục vụ: $A = \text{Uptime} / (\text{Uptime} + \text{Downtime})$;
- Thời gian trung bình giữa các sự cố;
- Thời gian trung bình ngừng để sửa chữa;
- Thời gian khôi phục sau sự cố.

Hình 1.8 minh họa tính sẵn dùng của một hệ thống trong 2 trường hợp: trường hợp (a) hệ thống không đảm bảo tính sẵn dùng khi có một số thành phần gặp sự cố khi không có khả

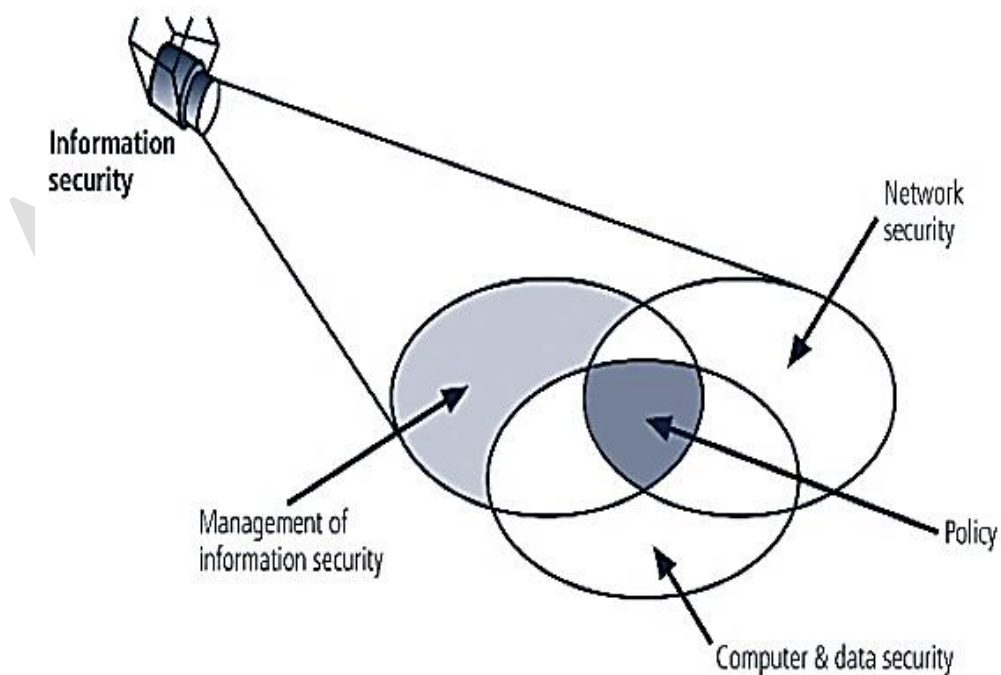
năng phục vụ tất cả các yêu cầu của người dùng và (b) hệ thống đảm bảo tính sẵn dùng khi các thành phần của nó hoạt động bình thường.



Hình 1.8. Minh họa tính sẵn dùng: (a) không đảm bảo và (b) đảm bảo tính sẵn dùng

1.3. CÁC THÀNH PHẦN CỦA AN TOÀN THÔNG TIN

An toàn thông tin có thể được chia thành ba thành phần chính: *An toàn máy tính và dữ liệu* (Computer & data security), *An ninh mạng* (Network security) và *Quản lý an toàn thông tin* (Management of information security) [1]. Ba thành phần trên của an toàn thông tin có quan hệ mật thiết và giao thoa với nhau, trong đó phần chung của cả ba thành phần trên là *Chính sách an toàn thông tin* (Policy) như minh họa trên Hình 1.9.



Hình 1.9. Các thành phần chính của An toàn thông tin [1]

1.3.2. An toàn máy tính và dữ liệu

An toàn máy tính và dữ liệu là việc đảm bảo an toàn cho hệ thống phần cứng, phần mềm và dữ liệu trên máy tính; đảm bảo cho máy tính có thể vận hành an toàn, đáp ứng các yêu cầu của người sử dụng. An toàn máy tính và dữ liệu bao gồm các nội dung:

- Đảm bảo an toàn hệ điều hành, ứng dụng, dịch vụ;
- Vấn đề điều khiển truy nhập;
- Vấn đề mã hóa và bảo mật dữ liệu;
- Vấn đề phòng chống phần mềm độc hại;
- Việc sao lưu tạo dự phòng dữ liệu, đảm bảo dữ liệu lưu trong máy tính không bị mất mát khi xảy ra sự cố.



Hình 1.10. Đảm bảo an toàn máy tính và dữ liệu

1.3.3. An ninh mạng

An ninh mạng là việc đảm bảo an toàn cho hệ thống mạng và các thông tin truyền tải trên mạng, chống lại các dạng tấn công, xâm nhập trái phép. Các kỹ thuật và công cụ thường được sử dụng trong an ninh mạng bao gồm:

- Các tường lửa, proxy cho lọc gói tin và điều khiển truy nhập;
- Mạng riêng ảo và các kỹ thuật bảo mật thông tin truyền như SSL/TLS, PGP;
- Các kỹ thuật và hệ thống phát hiện, ngăn chặn tấn công, xâm nhập;
- Vấn đề giám sát mạng.

1.3.4. Quản lý an toàn thông tin

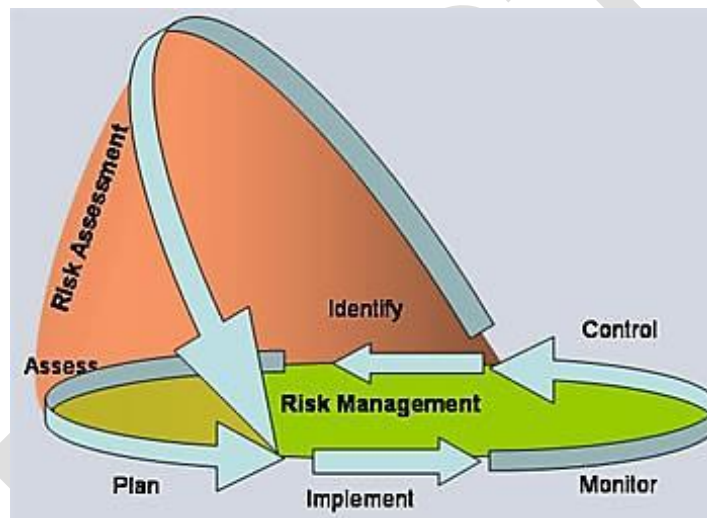
Quản lý an toàn thông tin là việc quản lý và giám sát việc thực thi các biện pháp đảm bảo an toàn thông tin, giúp nâng cao hiệu quả của chúng. Một trong các nội dung cốt lõi của quản lý an toàn thông tin là việc quản lý các rủi ro (risk management), trong đó việc nhận dạng và đánh giá rủi ro (risk assessment) đóng vai trò then chốt. Các nội dung khác của quản lý an toàn thông tin, bao gồm các chuẩn quản lý an toàn thông tin, chính sách an toàn thông tin và vấn đề đào tạo, nâng cao ý thức an toàn thông tin của người dùng.

Việc thực thi quản lý an toàn thông tin cần được thực hiện theo chu trình lặp lại, từ khâu lập kế hoạch (Plan), thực thi kế hoạch (Implement), giám sát kết quả thực hiện (Monitor) và

thực thi các kiểm soát (Control) như minh họa trên Hình 1.12, do các điều kiện bên trong và bên ngoài hệ thống luôn thay đổi theo thời gian.



Hình 1.11. Đảm bảo an toàn cho thông tin và hệ thống mạng sử dụng tường lửa



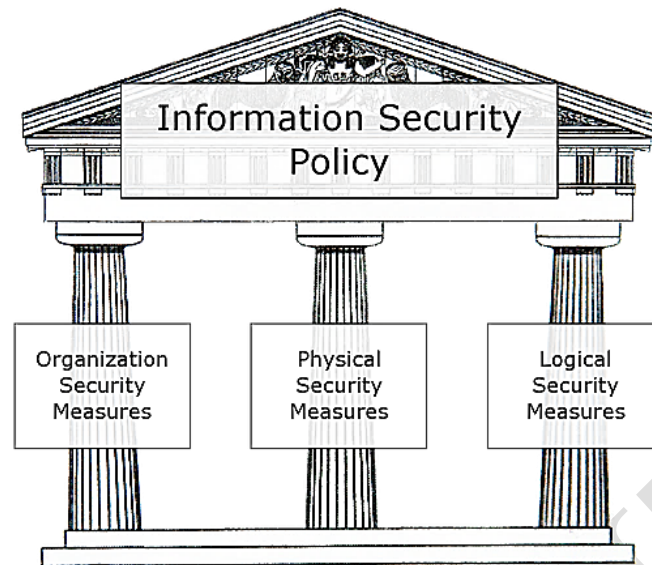
Hình 1.12. Chu trình quản lý an toàn thông tin

1.3.5. Chính sách an toàn thông tin

Chính sách an toàn thông tin (Information security policy) là các nội quy, quy định của cơ quan, tổ chức, nhằm đảm bảo các biện pháp đảm bảo an toàn thông tin được thực thi và tuân thủ. Chính sách an toàn thông tin, như minh họa trên Hình 1.13 gồm 3 thành phần:

- Chính sách an toàn ở mức vật lý (Physical security policy);
- Chính sách an toàn ở mức tổ chức (Organizational security policy);
- Chính sách an toàn ở mức logic (Logical security policy).

Một ví dụ về chính sách an toàn thông tin: để tăng cường an toàn cho hệ thống công nghệ thông tin, một tổ chức có thể áp dụng chính sách xác thực ‘mạnh’ sử dụng các đặc điểm sinh trắc (Biometrics), như xác thực sử dụng vân tay thay cho mật khẩu truyền thống cho hệ thống cửa ra vào trung tâm dữ liệu, hoặc đăng nhập vào hệ thống máy tính.



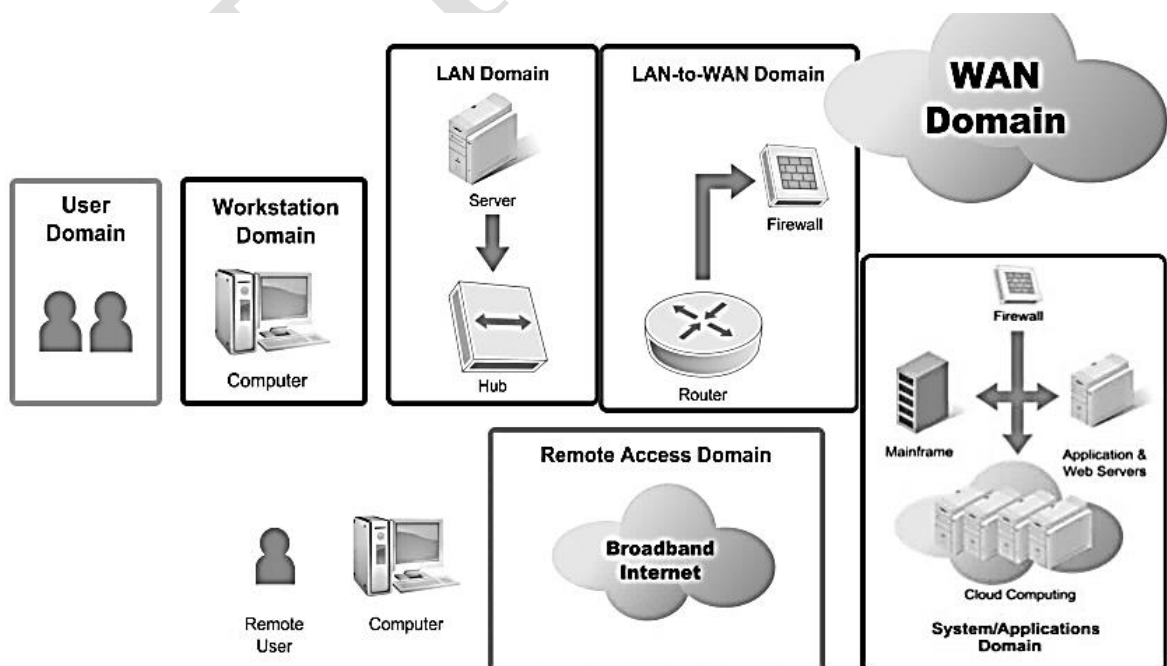
Hình 1.13. Chính sách an toàn thông tin và các thành phần của nó

1.4. CÁC MỐI ĐE DỌA VÀ NGUY CƠ TRONG CÁC VÙNG HẠ TẦNG CNTT

1.4.1. Bảy vùng trong cơ sở hạ tầng CNTT

Hạ tầng công nghệ thông tin (IT infrastructure) của các tổ chức, cơ quan, doanh nghiệp có thể có quy mô lớn hay nhỏ khác nhau, nhưng thường gồm bảy vùng theo mức kết nối mạng như minh họa trên Hình 1.14 [2].

Các vùng cụ thể gồm: vùng người dùng (User domain), vùng máy trạm (Workstation domain), vùng mạng LAN (LAN domain), vùng LAN-to-WAN (LAN-to-WAN domain), vùng mạng WAN (WAN domain), vùng truy nhập từ xa (Remote Access domain) và vùng hệ thống/ứng dụng (Systems/Applications domain). Do mỗi vùng kể trên có đặc điểm khác nhau nên chúng có các mối đe dọa và nguy cơ mất an toàn thông tin khác nhau.



Hình 1.14. Bảy vùng trong hạ tầng CNTT theo mức kết nối mạng [2]

1.4.2. Các mối đe dọa và nguy cơ trong các vùng hạ tầng CNTT

Vùng người dùng

Có thể nói vùng người dùng là vùng có nhiều mối đe dọa và nguy cơ nhất do người dùng có bản chất khó đoán định và khó kiểm soát hành vi. Các vấn đề thường gặp như thiếu ý thức, coi nhẹ vấn đề an ninh an toàn, vi phạm các chính sách an ninh an toàn; đưa CD/DVD/USB với các file cá nhân vào hệ thống; tải ảnh, âm nhạc, video trái phép; phá hoại dữ liệu, ứng dụng và hệ thống; ngoài ra, các nhân viên bất mãn có thể tấn công hệ thống từ bên trong, hoặc nhân viên có thể tống tiền hoặc chiếm đoạt thông tin nhạy cảm, thông tin quan trọng.

Vùng máy trạm

Vùng máy trạm cũng có nhiều mối đe dọa và nguy cơ do vùng máy trạm tiếp xúc trực tiếp với vùng người dùng. Các nguy cơ thường gặp gồm: truy nhập trái phép vào máy trạm, hệ thống, ứng dụng và dữ liệu; các lỗ hổng an ninh trong hệ điều hành, trong các phần mềm ứng dụng máy trạm; các hiểm họa từ vi rút, mã độc và các phần mềm độc hại. Ngoài ra, vùng máy trạm cũng chịu các nguy cơ do hành vi bị cấm từ người dùng, như đưa CD/DVD/USB với các file cá nhân vào hệ thống; tải ảnh, âm nhạc, video trái phép.

Vùng mạng LAN

Các nguy cơ có thể có đối với vùng mạng LAN bao gồm: truy nhập trái phép vào mạng LAN vật lý, truy nhập trái phép vào hệ thống, ứng dụng và dữ liệu; các lỗ hổng an ninh trong hệ điều hành và các phần mềm ứng dụng máy chủ; nguy cơ từ người dùng giả mạo trong mạng WLAN; tính bí mật dữ liệu trong mạng WLAN có thể bị đe dọa do sóng mang thông tin của WLAN truyền trong không gian có thể bị nghe trộm. Ngoài ra, các hướng dẫn và cấu hình chuẩn cho máy chủ trong mạng LAN nếu không được tuân thủ nghiêm ngặt sẽ dẫn đến những lỗ hổng an ninh mà kẻ tấn công có thể khai thác.

Vùng mạng LAN-to-WAN

Vùng mạng LAN-to-WAN là vùng chuyển tiếp từ mạng nội bộ ra mạng diện rộng, nên nguy cơ lớn nhất là kẻ tấn công từ mạng WAN có thể thăm dò và rà quét trái phép các cổng dịch vụ, nguy cơ truy nhập trái phép. Ngoài ra, một nguy cơ khác cần phải xem xét là lỗ hổng an ninh trong các bộ định tuyến, tường lửa và các thiết bị mạng khác.

Vùng mạng WAN

Vùng mạng WAN, hay mạng Internet là vùng mạng mở, trong đó hầu hết dữ liệu được truyền dưới dạng rõ, nên các nguy cơ lớn nhất là dễ bị nghe trộm và dễ bị tấn công phá hoại, tấn công từ chối dịch vụ (DoS) và từ chối dịch vụ phân tán (DDoS). Kẻ tấn công có thể tự do, dễ dàng gửi email có đính kèm vi rút, sâu và các phần mềm độc hại.

Vùng truy nhập từ xa

Trong vùng truy nhập từ xa, các nguy cơ điển hình bao gồm: tấn công kiểu vét cạn vào tên người dùng và mật khẩu, tấn công vào hệ thống đăng nhập và điều khiển truy nhập; truy nhập trái phép vào hệ thống CNTT, ứng dụng và dữ liệu; các thông tin bí mật có thể bị đánh cắp từ xa; và vấn đề rò rỉ dữ liệu do vi phạm các tiêu chuẩn phân loại dữ liệu.

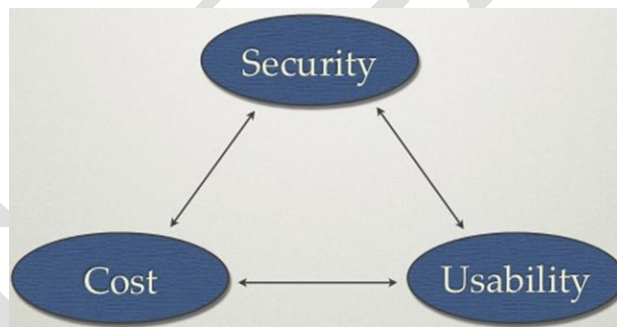
Vùng hệ thống và ứng dụng

Trong vùng hệ thống và ứng dụng, các nguy cơ có thể bao gồm: truy nhập trái phép đến trung tâm dữ liệu, phòng máy hoặc tủ cáp; các khó khăn trong quản lý các máy chủ với yêu cầu tính sẵn dùng cao; các lỗ hổng trong quản lý các phần mềm ứng dụng của hệ điều hành máy chủ; các vấn đề an ninh trong các môi trường ảo của điện toán đám mây; và vấn đề hỏng hóc hoặc mất dữ liệu.

1.5. MÔ HÌNH TỔNG QUÁT ĐẢM BẢO ATTT VÀ HỆ THỐNG THÔNG TIN

1.5.1. Nguyên tắc đảm bảo an toàn thông tin, hệ thống và mạng

Nguyên tắc chủ đạo xuyên suốt trong đảm bảo an toàn thông tin, hệ thống và mạng là *Phòng vệ nhiều lớp có chiều sâu* (Defence in depth). Theo nguyên tắc này, ta cần tạo ra nhiều lớp bảo vệ, kết hợp tính năng, tác dụng của mỗi lớp để đảm bảo an toàn tối đa cho thông tin, hệ thống và mạng. Một lớp, một công cụ phòng vệ riêng rẽ dù có hiện đại, nhưng vẫn không thể đảm bảo an toàn. Do vậy, việc tạo ra nhiều lớp bảo vệ có khả năng bổ sung cho nhau là cách làm hiệu quả. Một điểm quan trọng khác cần lưu ý khi thiết kế và triển khai hệ thống đảm bảo an toàn thông tin là cần cân bằng giữa *tính hữu dụng* (Usability), *chi phí* (Cost) và *an toàn* (Security), như minh họa trên Hình 1.15. Hệ thống đảm bảo an toàn thông tin chỉ thực sự phù hợp và hiệu quả khi hệ thống được bảo vệ đạt mức an toàn phù hợp mà vẫn có khả năng cung cấp các tính năng hữu dụng cho người dùng với chi phí cho đảm bảo an toàn phù hợp với giá trị của tài sản được bảo vệ.



Hình 1.15. Các lớp bảo vệ cần cân bằng giữa Tính hữu dụng (Usability), Chi phí (Cost) và An toàn (Security)

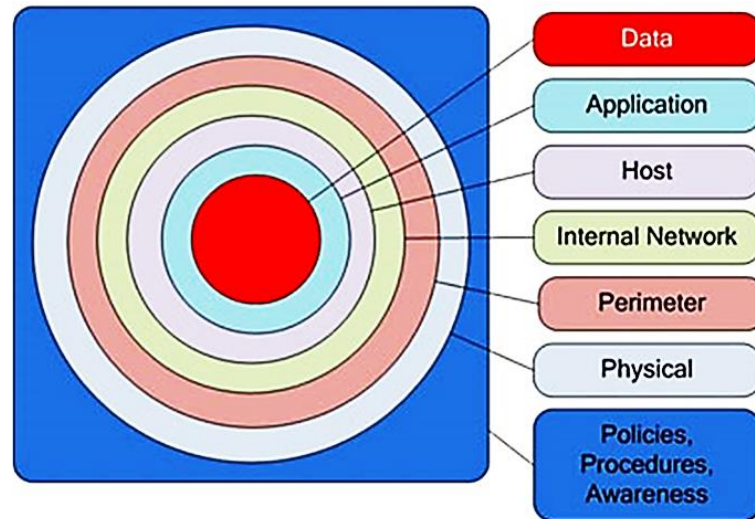
1.5.2. Mô hình tổng quát đảm bảo an toàn thông tin và hệ thống thông tin

Hình 1.16 minh họa mô hình đảm bảo an toàn thông tin với bảy lớp bảo vệ, bao gồm lớp chính sách, thủ tục, ý thức (Policies, procedures, awareness); lớp vật lý (Physical); lớp ngoại vi (Perimeter); lớp mạng nội bộ (Internal network); lớp host (Host); lớp ứng dụng (Application) và lớp dữ liệu (Data). Trong mô hình này, để truy nhập được đến đối tượng đích là dữ liệu, kẻ tấn công cần phải vượt qua cả 7 lớp bảo vệ.

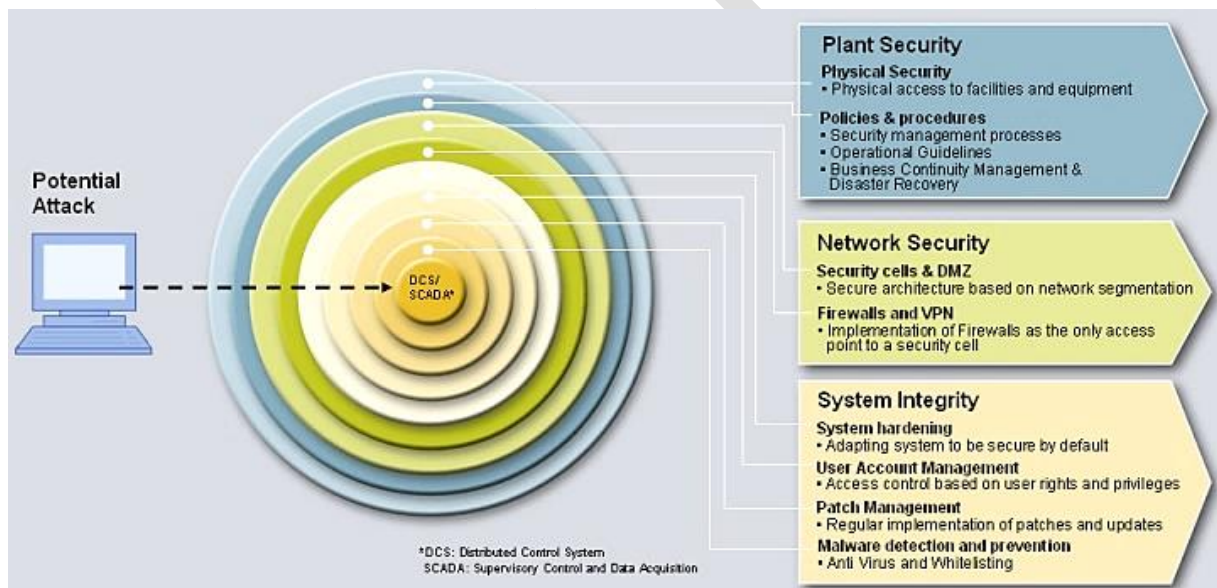
Tương tự, Hình 1.17 minh họa mô hình phòng vệ gồm 3 lớp chính: lớp an ninh cơ quan/tổ chức (Plant Security), lớp an ninh mạng (Network Security) và lớp an ninh hệ thống (System Integrity). Mỗi lớp chính lại gồm một số lớp con như sau:

- Lớp an ninh cơ quan/tổ chức gồm 2 lớp con:

- + Lớp bảo vệ vật lý (Physical Security) có nhiệm vụ kiểm soát các truy nhập vật lý đến các trang thiết bị hệ thống và mạng.
- + Lớp chính sách & thủ tục (Policies & procedures) bao gồm các quy trình quản lý an toàn thông tin, các hướng dẫn vận hành, quản lý hoạt động liên tục và phục hồi sau sự cố.



Hình 1.16. Mô hình đảm bảo an toàn thông tin với bảy lớp



Hình 1.17. Mô hình đảm bảo an toàn thông tin với ba lớp chính

- Lớp an ninh mạng gồm 2 lớp con:
 - + Lớp bảo vệ vùng hạn chế truy nhập (Security cells and DMZ) cung cấp các biện pháp bảo vệ cho từng phân đoạn mạng.
 - + Lớp các tường lửa, mạng riêng ảo (Firewalls and VPN) được triển khai như điểm truy nhập duy nhất đến một phân đoạn mạng.

- Lớp an ninh hệ thống gồm 4 lớp con:
 - + Lớp tăng cường an ninh hệ thống (System hardening) đảm bảo việc cài đặt và cấu hình các thành phần trong hệ thống đảm bảo các yêu cầu an toàn.
 - + Lớp quản trị tài khoản người dùng (User Account Management) thực hiện kiểm soát truy nhập dựa trên quyền truy nhập và các đặc quyền của người dùng.
 - + Lớp quản lý các bản vá (Patch Management) có nhiệm vụ định kỳ cài đặt các bản vá an ninh và các bản cập nhật cho hệ thống.
 - + Lớp phát hiện và ngăn chặn phần mềm độc hại (Malware detection and prevention) có nhiệm vụ bảo vệ hệ thống, chống vi rút và các phần mềm độc hại khác.

1.6. CÂU HỎI ÔN TẬP

- 1) An toàn thông tin (Information Security) là gì?
- 2) Tại sao cần phải đảm bảo an toàn cho thông tin?
- 3) Đảm bảo thông tin thường được thực hiện bằng cách nào?
- 4) An toàn hệ thống thông tin là gì?
- 5) Nêu các yêu cầu đảm bảo an toàn thông tin và hệ thống thông tin.
- 6) An toàn thông tin gồm những thành phần cơ bản nào? Mô tả vắn tắt chức năng của mỗi thành phần.
- 7) Nêu các rủi ro trong vùng người dùng và vùng máy trạm trong hạ tầng CNTT. Tại sao nói vùng người dùng là vùng có nhiều nguy cơ và rủi ro nhất?
- 8) Nêu các rủi ro trong vùng mạng LAN, LAN-to-WAN và vùng mạng WAN trong hạ tầng CNTT. Tại sao vùng mạng WAN có nguy cơ bị tấn công phá hoại cao?
- 9) Nguyên tắc cơ bản cho đảm bảo an toàn thông tin, hệ thống và mạng là gì?
- 10) Mô tả một mô hình nhiều lớp cho đảm bảo an toàn thông tin và hệ thống thông tin.

CHƯƠNG 2. LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG

Chương 2 giới thiệu các khái niệm về lỗ hổng bảo mật và điểm yếu tồn tại trong hệ thống, các dạng lỗ hổng bảo mật trong hệ điều hành và các phần mềm ứng dụng. Chương đi sâu phân tích cơ chế xuất hiện và khai thác các lỗ hổng tràn bộ đệm và lỗ hổng không kiểm tra đầu vào. Phần cuối của chương đề cập vấn đề quản lý, khắc phục các lỗ hổng bảo mật, tăng cường khả năng đề kháng cho hệ thống và giới thiệu một số công cụ rà quét lỗ hổng bảo mật.

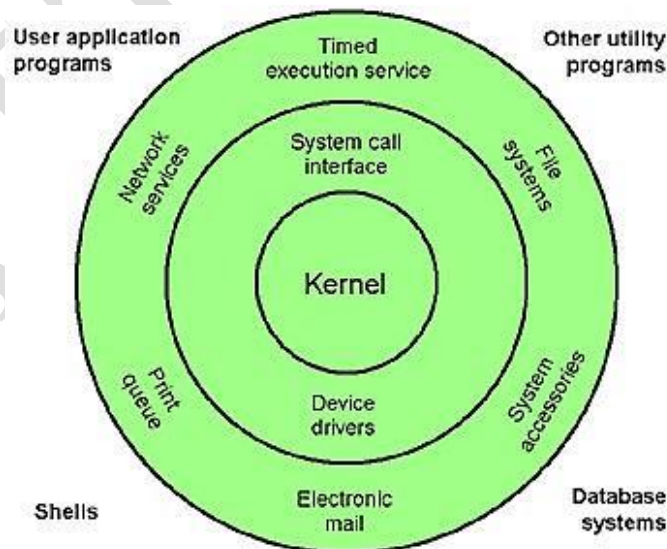
2.1. TỔNG QUAN VỀ LỖ HỔNG BẢO MẬT VÀ ĐIỂM YẾU HỆ THỐNG

2.1.1. Khái quát về điểm yếu hệ thống và lỗ hổng bảo mật

2.1.1.1. Các thành phần của hệ thống

Một hệ thống máy tính gồm 2 thành phần cơ bản là hệ thống phần cứng và hệ thống phần mềm. Hệ thống phần cứng bao gồm các mô đun phần cứng tạo nên máy tính vật lý, bao gồm CPU, ROM, RAM, Bus,...; các giao diện ghép nối và các thiết bị ngoại vi, như bàn phím, màn hình, ổ đĩa,... và các giao diện ghép nối mạng LAN, WLAN,...

Hệ thống phần mềm bao gồm hệ điều hành và các phần mềm ứng dụng. Hệ điều hành cung cấp môi trường làm việc cho các ứng dụng và giao diện người dùng. Hệ điều hành được cấu thành từ nhân hệ điều hành, các trình điều khiển thiết bị, trình quản lý tiến trình, trình quản lý file, các trình cung cấp dịch vụ, tiện ích,... Các phần mềm ứng dụng là các chương trình cung cấp các tính năng hữu ích cho người dùng, bao gồm các dịch vụ (máy chủ web, cơ sở dữ liệu, DNS,...), các trình duyệt web, các ứng dụng giao tiếp, các bộ ứng dụng văn phòng, các công cụ lập trình, phát triển phần mềm... Hình 2.1 minh họa mô hình hệ điều hành Unix/Linux, các dịch vụ và ứng dụng.



Hình 2.1. Mô hình hệ điều hành Unix/Linux, các dịch vụ và ứng dụng

2.1.1.2. Điểm yếu hệ thống và lỗ hổng bảo mật

Trên thực tế, gần như không có hệ thống nào là hoàn hảo, không có điểm yếu, hoặc khiếm khuyết. Các hệ thống máy tính, hoặc hệ thống thông tin là các hệ thống rất phức tạp, được cấu

thành từ nhiều thành phần phần cứng, phần mềm, do vậy trong chúng luôn tồn tại các lỗi, các khiếm khuyết, hay các điểm yếu. Các điểm yếu có thể tồn tại trong các mô đun phần cứng cũng như trong các mô đun phần mềm. Nhìn chung, các hệ thống càng phức tạp, nhiều thành phần và nhiều tính năng thì khả năng xuất hiện các lỗi và điểm yếu càng tăng.

Các điểm yếu hệ thống (System weakness) là các lỗi hay các khiếm khuyết tồn tại trong hệ thống. Nguyên nhân của sự tồn tại các điểm yếu có thể do lỗi thiết kế, lỗi cài đặt, lỗi lập trình, hoặc lỗi quản trị, lỗi cấu hình hoạt động. Các điểm yếu có thể tồn tại trong cả các mô đun phần cứng và các mô đun phần mềm. Một số điểm yếu được phát hiện và đã được khắc phục. Tuy nhiên, cũng có những điểm yếu được phát hiện nhưng chưa được khắc phục, hoặc các điểm yếu chưa được phát hiện, hoặc chỉ tồn tại trong một điều kiện đặc biệt nào đó.

Lỗ hổng bảo mật (Security vulnerability) là một điểm yếu tồn tại trong một hệ thống cho phép kẻ tấn công khai thác gây tổn hại đến các thuộc tính an toàn, an ninh của hệ thống đó, bao gồm tính bí mật, tính toàn vẹn và tính sẵn dùng. Phụ thuộc vào khả năng bị khai thác, các lỗ hổng bảo mật có mức độ nghiêm trọng (severity) khác nhau. Theo Microsoft, có 4 mức độ nghiêm trọng của các lỗ hổng bảo mật: *nguy hiểm* (Critical), *quan trọng* (Important), *trung bình* (Moderate) và *thấp* (Low). Tuy nhiên, một số tổ chức khác chỉ phân loại các lỗ hổng bảo mật theo 3 mức độ nghiêm trọng: *cao* (High), *trung bình* (Medium) và *thấp* (Low).

Lỗ hổng bảo mật thuộc *cấp độ nguy hiểm* là lỗ hổng cho phép kẻ tấn công thực hiện mã khai thác mà không cần tương tác người dùng. Các thông tin khai thác lỗ hổng, như mã mẫu khai thác tồn tại phổ biến trên mạng Internet. Ngoài ra, việc khai thác lỗ hổng có thể được thực hiện dễ dàng mà không yêu cầu có tài khoản trong hệ thống hoặc các điều kiện phức tạp. Ví dụ như một số lỗ hổng tràn bộ đệm thuộc cấp độ nguy hiểm do có thể bị khai thác bởi sâu mạng hoặc email chứa vi rút, mã độc. Các lỗ hổng loại nguy hiểm cần được khắc phục ngay hoặc càng sớm càng tốt.

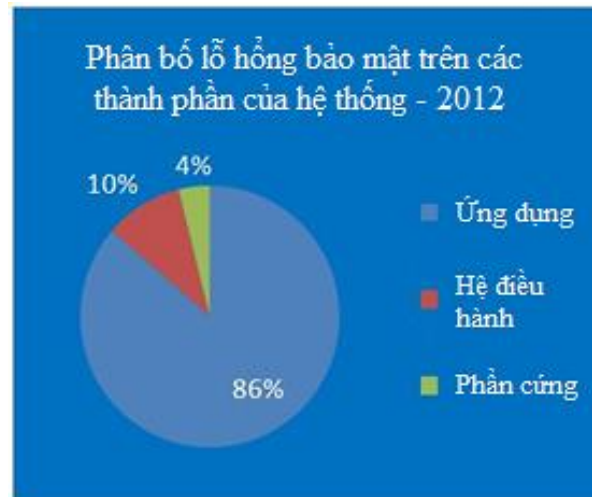
Lỗ hổng bảo mật thuộc *cấp độ quan trọng* là lỗ hổng khi bị khai thác có thể dẫn đến vi phạm các yêu cầu an toàn thông tin như bí mật, toàn vẹn và sẵn dùng của dữ liệu, tài nguyên tính toán, hoặc cả hệ thống. Khác với lỗ hổng loại nguy hiểm, lỗ hổng loại quan trọng cho phép kẻ tấn công thực hiện mã khai thác, nhưng cần có tương tác người dùng. Ví dụ vi rút hoặc các phần mềm độc hại cần tương tác người dùng để lây lan, như sao chép các file qua thẻ nhớ USB, mở email đính kèm, thực thi mã độc,... Các lỗ hổng loại quan trọng cũng cần được khắc phục càng sớm càng tốt.

Lỗ hổng bảo mật thuộc *cấp độ trung bình* là các lỗ hổng mà khi khai thác, kẻ tấn công phải ở trong cùng mạng cục bộ với hệ thống nạn nhân. Một ngữ cảnh khai thác lỗ hổng loại này là kẻ tấn công thực hiện việc bẫy nạn nhân sử dụng các kỹ thuật xã hội, như khai thác sự cả tin, tò mò và lòng tham của người dùng. Ngoài ra, việc khai thác lỗ hổng loại trung bình cũng chỉ cho phép kẻ tấn công có quyền truy nhập rất hạn chế vào hệ thống. Với lỗ hổng loại trung bình, cần xem xét khắc phục sớm nhất hoặc định kỳ để hạn chế ảnh hưởng.

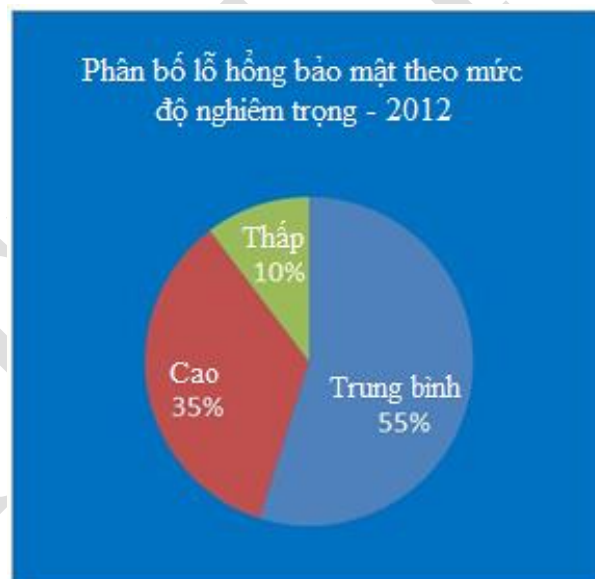
Loại cuối cùng là các lỗ hổng bảo mật thuộc *cấp độ thấp*. Các lỗ hổng loại này ít có ảnh hưởng đến hoạt động của tổ chức và chúng chỉ có thể bị khai thác khi kẻ tấn công có truy nhập cục bộ hoặc truy nhập vật lý trực tiếp vào hệ thống. Mặc dù có mức rủi ro thấp, các lỗ hổng loại này vẫn cần được xem xét khắc phục định kỳ để hạn chế ảnh hưởng.

2.1.2. Một số thống kê về lỗ hổng bảo mật

Theo số liệu thống kê từ Cơ sở dữ liệu lỗ hổng quốc gia Hoa Kỳ [6], trong năm 2012, phân bố lỗ hổng bảo mật được phát hiện trên các thành phần của hệ thống lần lượt là phần cứng – 4%, hệ điều hành – 10% và phần mềm ứng dụng – 86%, như minh họa trên Hình 2.2. Như vậy, có thể thấy các lỗ hổng bảo mật chủ yếu xuất hiện trong hệ thống phần mềm và phần lớn tồn tại trong các phần mềm ứng dụng.

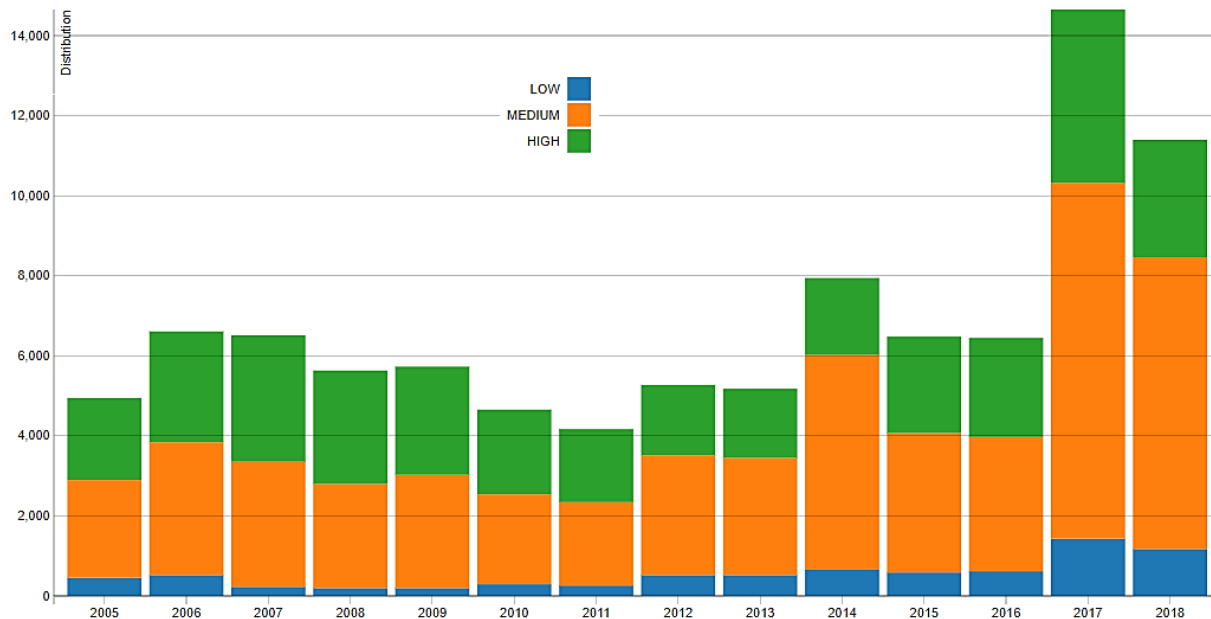


Hình 2.2. Phân bố lỗ hổng bảo mật trong các thành phần của hệ thống [6]



Hình 2.3. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng năm 2012 [6]

Theo mức độ nghiêm trọng của các lỗ hổng bảo mật hệ thống minh họa trên Hình 2.3, trong năm 2012 các lỗ hổng có mức độ nghiêm trọng cao (High) chiếm 35%, các lỗ hổng có mức độ nghiêm trọng trung bình (Medium) chiếm 55% và các lỗ hổng có mức độ nghiêm trọng thấp (Low) chỉ chiếm 10%. Theo thống kê rộng hơn trong giai đoạn 2005-2018 cho trên Hình 2.4 [6], các lỗ hổng có mức độ nghiêm trọng cao và mức độ nghiêm trọng trung bình luôn chiếm đa số. Như vậy, ta có thể thấy, đa số các lỗ hổng bảo mật có mức độ nghiêm trọng từ trung bình trở lên và cần được xem xét khắc phục càng sớm càng tốt.



Hình 2.4. Phân bố lỗ hổng bảo mật theo mức độ nghiêm trọng giai đoạn 2005-2018 [6]

Operating system	# of vulnerabilities		# of HIGH vulnerabilities		# of MEDIUM vulnerabilities		# of LOW vulnerabilities	
	2012	2011	2012	2011	2012	2011	2012	2011
Apple iOS	↑ 86	35	↑ 46	9	↑ 28	19	↑ 12	7
Microsoft Windows Server 2003	↓ 45	105	↓ 40	98	↓ 5	7	● 0	0
Microsoft XP	↓ 42	96	↓ 37	91	↑ 5	4	↓ 0	1
Microsoft Windows Server 2008	↓ 48	101	↓ 35	89	↑ 12	11	● 1	1
Microsoft Windows Vista	↓ 41	91	↓ 34	86	↑ 6	4	↑ 1	0
Microsoft Windows 7	↓ 42	98	↓ 33	88	↓ 8	9	● 1	1
Cisco IOS	↑ 36	31	↓ 23	26	↑ 10	5	↑ 3	0
Linux Kernel	↓ 45	56	↑ 12	10	↓ 28	34	↓ 5	12
Oracle Solaris	↑ 47	39	↑ 7	6	↑ 29	19	↓ 11	14
VMware ESXi	↑ 12	7	↑ 11	2	● 1	1	↓ 0	4
VMware ESX	↑ 11	7	↑ 9	2	↑ 2	1	↓ 0	4
Cisco IOS XE	↓ 9	13	↓ 9	12	↓ 0	1	● 0	0
Citrix Xen	↑ 33	3	↑ 2	1	↑ 21	1	↑ 10	1
Apple Mac OS X	↓ 21	69	↓ 3	9	↓ 16	50	↓ 2	10
Apple Mac OS X Server	↓ 17	66	↓ 3	7	↓ 12	50	↑ 2	9

Hình 2.5. Lỗ hổng bảo mật phát hiện trong các năm 2011 và 2012 trên các hệ điều hành

Hình 2.5 cung cấp số liệu thống kê về các loại lỗ hổng bảo mật trên các hệ điều hành phổ biến trong hai năm 2011 và 2012. Theo đó, hệ điều hành iOS cho điện thoại di động iPhone và máy tính bảng iPad có số lỗ hổng được phát hiện cao nhất và tăng cao trong những năm gần đây do sự phổ biến của iPhone và iPad. Xếp sau iOS về số lượng lỗ hổng được phát hiện là các hệ điều hành họ Microsoft Windows, bao gồm Windows 2003, 2008 servers, Windows XP, Windows 7 và Windows 8.

Application	# of vulnerabilities		# of HIGH vulnerabilities		# of MEDIUM vulnerabilities		# of LOW vulnerabilities	
	2012	2011	2012	2011	2012	2011	2012	2011
Mozilla Firefox	↑ 159	97	↑ 99	66	↑ 55	30	↑ 5	2
Mozilla Thunderbird	↑ 144	63	↑ 95	46	↑ 47	15	● 2	2
Mozilla SeaMonkey	↑ 143	63	↑ 94	45	↑ 46	17	↑ 3	1
Mozilla Firefox ESR	115	-	75	-	39	-	1	-
Mozilla Thunderbird ESR	109	-	74	-	34	-	1	-
Google Chrome	↓ 125	275	↓ 68	162	↓ 55	113	↑ 2	0
Apple Safari	↑ 85	45	↑ 65	28	↑ 20	16	↓ 0	1
Adobe Flash Player	↑ 66	63	↑ 61	57	↓ 5	6	● 0	0
Apple iTunes	↑ 102	78	↓ 51	78	↑ 51	0	● 0	0
Adobe Air	↑ 54	27	↑ 51	26	↑ 3	1	● 0	0
Adobe Flash Player for Android	53	-	49	-	4	-	0	-
Oracle Java	↑ 58	37	↑ 32	23	↑ 20	10	↑ 6	4
Microsoft Internet Explorer	↓ 41	45	↑ 34	31	↓ 7	14	● 0	0
FFmpeg	↑ 42	10	↑ 28	3	↑ 13	7	↑ 1	0
Adobe Shockwave Player	↓ 27	38	↓ 27	38	● 0	0	● 0	0
Adobe Reader	↓ 25	65	↓ 25	54	↓ 0	11	● 0	0

Hình 2.6. Lỗ hổng bảo mật phát hiện trong các năm 2011 và 2012 trên một số ứng dụng

Hình 2.6 cung cấp số liệu thống kê về các loại lỗ hổng bảo mật trên một số ứng dụng phổ biến trong hai năm 2011 và 2012. Theo đó, số lượng lỗ hổng được phát hiện nhiều nhất thuộc về các ứng dụng trình duyệt và email của Mozilla, trình duyệt Google Chrome, Apple Safari,... Có thể thấy các trình duyệt web tồn tại nhiều lỗ hổng bảo mật và bị tấn công khai thác nhiều nhất là do chúng là các ứng dụng được sử dụng thường xuyên nhất trên mạng Internet. Kẻ tấn công thường khai thác các lỗ hổng trên các trang web và trình duyệt để đánh cắp các dữ liệu cá nhân của người dùng.

2.2. CÁC DẠNG LỖ HỔNG TRONG HỆ ĐIỀU HÀNH VÀ PHẦN MỀM ỨNG DỤNG

Như đã đề cập trong Mục 2.1, trên thực tế các lỗ hổng bảo mật trong hệ điều hành và các phần mềm ứng dụng chiếm hơn 95% số lượng lỗ hổng bảo mật được phát hiện cho thấy mức độ phổ biến của các lỗ hổng bảo mật trong hệ thống phần mềm. Các dạng lỗ hổng bảo mật thường gặp trong hệ điều hành và các phần mềm ứng dụng bao gồm:

- Lỗi tràn bộ đệm (Buffer overflows);
- Lỗi không kiểm tra đầu vào (Unvalidated input);
- Các vấn đề với điều khiển truy nhập (Access-control problems);
- Các điểm yếu trong xác thực, trao quyền hoặc các hệ mật mã (Weaknesses in authentication, authorization, or cryptographic practices); và
- Các lỗ hổng bảo mật khác.

2.2.1. Lỗi tràn bộ đệm

2.2.1.1. Giới thiệu và nguyên nhân

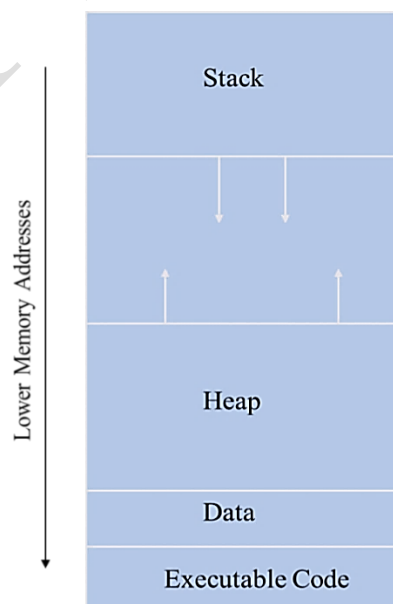
Lỗi tràn bộ đệm (Buffer overflow) là một trong các lỗi thường gặp trong hệ điều hành và đặc biệt nhiều ở các phần mềm ứng dụng, như đã nêu ở mục 2.1 [6]. Lỗi tràn bộ đệm xảy ra khi một ứng dụng cố gắng ghi dữ liệu vượt khỏi phạm vi của bộ nhớ đệm, là giới hạn cuối hoặc cả giới hạn đầu của bộ nhớ đệm. Lỗi tràn bộ đệm có thể khiến ứng dụng ngừng hoạt động, gây mất dữ liệu hoặc thậm chí cho phép kẻ tấn công chen, thực hiện mã độc để kiểm soát hệ thống. Lỗi tràn bộ đệm chiếm một tỷ lệ lớn trong số các lỗi sinh lỗi hỏng bảo mật [6]. Tuy nhiên, trên thực tế không phải tất cả các lỗi tràn bộ đệm đều có thể bị khai thác.

Lỗi tràn bộ đệm xuất hiện trong khâu lập trình phần mềm (coding) trong quá trình phát triển phần mềm. Nguyên nhân của lỗi tràn bộ đệm là người lập trình không kiểm tra, hoặc kiểm tra không đầy đủ các dữ liệu đầu vào được nạp vào bộ nhớ đệm. Khi dữ liệu có kích thước quá lớn hoặc có định dạng sai được ghi vào bộ nhớ đệm, nó sẽ gây tràn và có thể ghi đè lên các tham số thực hiện chương trình, có thể khiến chương trình bị lỗi và ngừng hoạt động. Một nguyên nhân bổ sung khác là việc sử dụng các ngôn ngữ lập trình với các thư viện không an toàn, như hợp ngữ, C và C++.

2.2.1.2. Cơ chế gây tràn và khai thác

a. Cơ chế gây tràn

Trên hầu hết các nền tảng, khi một chương trình ứng dụng được nạp vào bộ nhớ, hệ điều hành cấp phát các vùng nhớ để tải mã và lưu dữ liệu của chương trình. Hình 2.7 minh họa các vùng bộ nhớ cấp cho chương trình, bao gồm vùng lưu mã thực hiện (Executable code), vùng lưu dữ liệu toàn cục (Data), vùng bộ nhớ cấp phát động (Heap) và vùng bộ nhớ ngăn xếp (Stack). Vùng bộ nhớ ngăn xếp là vùng nhớ lưu các tham số gọi hàm, thủ tục, phương thức (gọi chung là hàm hay chương trình con) và dữ liệu cục bộ của chúng. Vùng nhớ cấp phát động là vùng nhớ chung lưu dữ liệu cho chương trình, được cấp phát hay giải phóng trong quá trình hoạt động của chương trình.



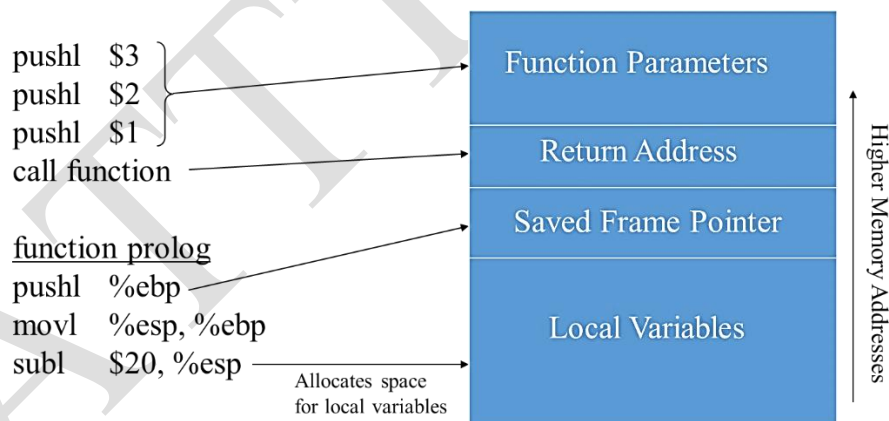
Hình 2.7. Các vùng bộ nhớ cấp cho chương trình

Chúng ta sử dụng vùng bộ nhớ ngăn xếp để giải thích cơ chế gây tràn và khai thác lỗi tràn bộ đệm. Bộ nhớ ngăn xếp được cấp phát cho chương trình dùng để lưu các biến cục bộ của hàm, trong đó có các biến nhớ được gọi là bộ đệm, các tham số hình thức của hàm, các tham số quản lý ngăn xếp, và địa chỉ trở về (Return address). Địa chỉ trở về là địa chỉ của lệnh nằm kế tiếp lời gọi hàm ở chương trình gọi được tự động lưu vào ngăn xếp khi hàm được gọi thực hiện. Khi việc thực hiện hàm kết thúc, hệ thống nạp địa chỉ trở về đã lưu trong ngăn xếp vào thanh ghi con trỏ lệnh (còn gọi là bộ đếm chương trình), kích hoạt việc quay trở lại thực hiện lệnh kế tiếp lời gọi hàm ở chương trình gọi.

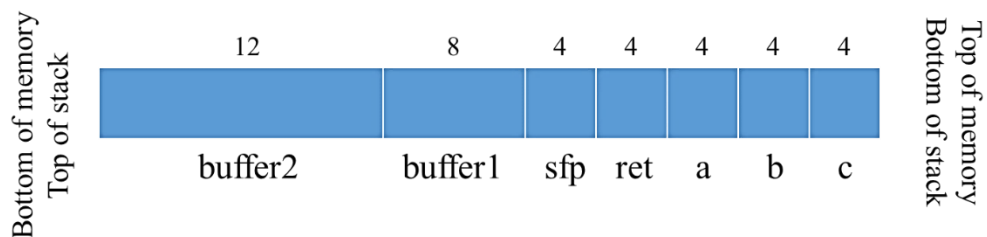
```
// định nghĩa một hàm
void function(int a, int b, int c){
    char buffer1[8];
    char buffer2[12];
}
// chương trình chính
int main(){
    function(1,2,3); // gọi hàm
}
```

Hình 2.8. Một chương trình minh họa cấp phát bộ nhớ trong ngăn xếp

Hình 2.8 là một đoạn chương trình gồm một hàm con (*function()*) và một hàm chính (*main()*) minh họa cho việc gọi làm và cấp phát bộ nhớ trong vùng nhớ ngăn xếp. Hàm *function()* có 3 tham số hình thức kiểu nguyên và kê khai 2 biến cục bộ *buffer1* và *buffer2* kiểu xâu ký tự. Hàm chính *main()* chỉ chứa lời gọi đến hàm *function()* với 3 tham số thực.



Hình 2.9. Các thành phần được lưu trong vùng bộ nhớ trong ngăn xếp



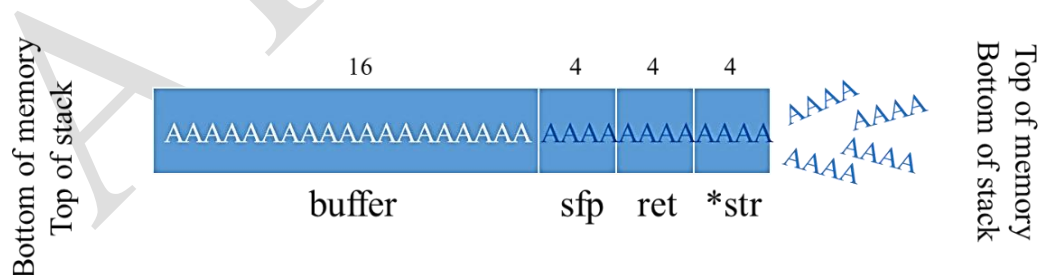
Hình 2.10. Cấp phát bộ nhớ cho các biến nhớ trong vùng bộ nhớ trong ngăn xếp

Hình 2.9 biểu diễn việc cấp phát bộ nhớ cho các thành phần trong ngăn xếp: các tham số gọi hàm được lưu vào Function Parameters, địa chỉ trở về được lưu vào ô Return Address, giá trị con trỏ khung ngăn xếp được lưu vào ô Save Frame Pointer và các biến cục bộ trong hàm được lưu vào Local Variables. Hình 2.10 minh họa chi tiết việc cấp phát bộ nhớ cho các biến trong ngăn xếp: ngoài ô địa chỉ trở về (ret) và con trỏ khung (sfp) được cấp cố định ở giữa, các tham số gọi hàm được cấp các ô nhớ bên phải (phía đáy ngăn xếp – bottom of stack) và các biến cục bộ được cấp các ô nhớ bên trái (phía đỉnh ngăn xếp – top of stack).

```
// định nghĩa một hàm
void function(char *str){
    char buffer[16];
    strcpy(buffer, str);
}
// chương trình chính
int main(){
    char large_string[256];
    int i;
    for (i = 0; i < 255; i++){
        large_string[i] = 'A';
    }
    function(large_string);
}
```

Hình 2.11. Một chương trình minh họa gây tràn bộ nhớ đệm trong ngăn xếp

Hình 2.11 là một đoạn chương trình minh họa gây tràn bộ nhớ đệm trong ngăn xếp. Đoạn chương trình này gồm hàm con *function()* và hàm chính *main()*, trong đó hàm *function()* nhận một con trỏ chuỗi ký tự *str* làm đầu vào. Hàm này khai báo 1 biến *buffer* kiểu chuỗi ký tự với độ dài 16 byte. Hàm này sử dụng hàm thư viện *strcpy()* để sao chép chuỗi ký tự từ con trỏ *str* sang biến cục bộ *buffer*. Hàm chính *main()* kê khai một chuỗi ký tự *large_string* với độ dài 256 byte và sử dụng một vòng lặp để điền đầy chuỗi *large_string* bằng ký tự 'A'. Sau đó *main()* gọi hàm *function()* với tham số đầu vào là *large_string*.



Hình 2.12. Minh họa hiện tượng tràn bộ nhớ đệm trong ngăn xếp

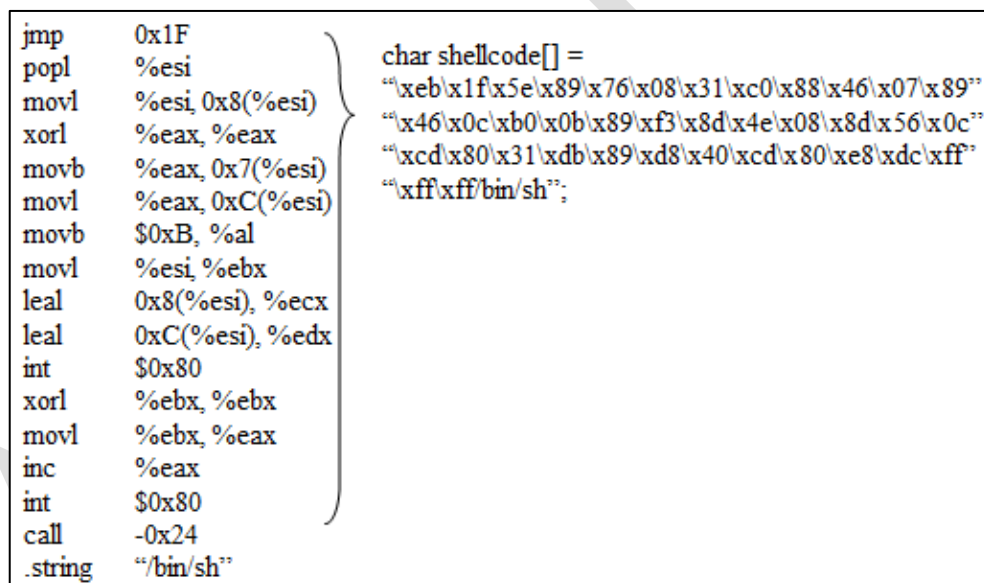
Có thể thấy đoạn chương trình biểu diễn trên Hình 2.11 khi được thực hiện sẽ gây tràn trong biến nhớ *buffer* của hàm *function()* do tham số truyền vào *large_string* có kích thước 256 byte lớn hơn nhiều so với *buffer* có kích thước 16 byte và hàm *strcpy()* không hề thực hiện việc kiểm tra kích thước dữ liệu vào khi sao chép vào biến *buffer*. Như minh họa trên Hình 2.12, chỉ 16 byte đầu tiên của *large_string* được lưu vào *buffer*, phần còn lại được ghi đè

lên các ô nhớ khác trong ngăn xếp, bao gồm *sfp*, *ret* và cả con trỏ đầu vào vào *str*. Ô nhớ chứa địa chỉ trỏ về *ret* bị ghi đè và giá trị địa chỉ trỏ về mới là 'AAAA' (0x41414141). Khi kết thúc thực hiện hàm con *function()*, chương trình tiếp tục thực hiện lệnh tại địa chỉ 0x41414141. Đây không phải là địa chỉ của lệnh chương trình phải thực hiện theo logic đã định ra từ trước.

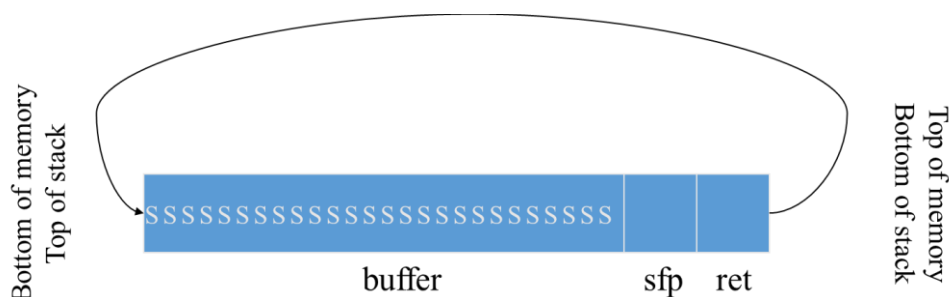
Như vậy, lỗi tràn bộ đệm xảy ra khi dữ liệu nạp vào biến nhớ (gọi chung là bộ đệm) có kích thước lớn hơn so với khả năng lưu trữ của bộ đệm và chương trình thiếu các bước kiểm tra kích thước và định dạng dữ liệu nạp vào. Phần dữ liệu tràn sẽ được ghi đè lên các ô nhớ liền kề trong ngăn xếp, như các biến cục bộ khác, con trỏ khung, địa chỉ trỏ về, các biến tham số đầu vào,....

b. Khai thác lỗi tràn bộ đệm

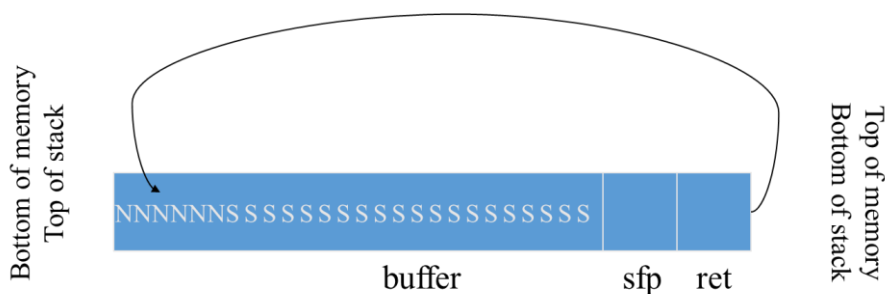
Khi một ứng dụng chứa lỗi hỏng tràn bộ đệm, kẻ tấn công có thể khai thác bằng cách gửi mã độc dưới dạng dữ liệu đến chương trình ứng dụng nhằm ghi đè, thay thế địa chỉ trỏ về với mục đích tái định hướng chương trình đến thực hiện đoạn mã độc mà kẻ tấn công gửi đến. Đoạn mã độc kẻ tấn công xây dựng là mã máy có thể thực hiện được và thường được gọi là *shellcode*. Như vậy, để có thể khai thác lỗi tràn bộ đệm, kẻ tấn công thường phải thực hiện việc gỡ rối (debug) chương trình (hoặc có thông tin từ nguồn khác) và nắm chắc cơ chế gây lỗi và phương pháp quản lý, cấp phát vùng nhớ ngăn xếp của ứng dụng.



Hình 2.13. Một shellcode viết bằng hợp ngữ và chuyển thành chuỗi tấn công



Hình 2.14. Chèn và thực hiện shellcode khai thác lỗi tràn bộ đệm

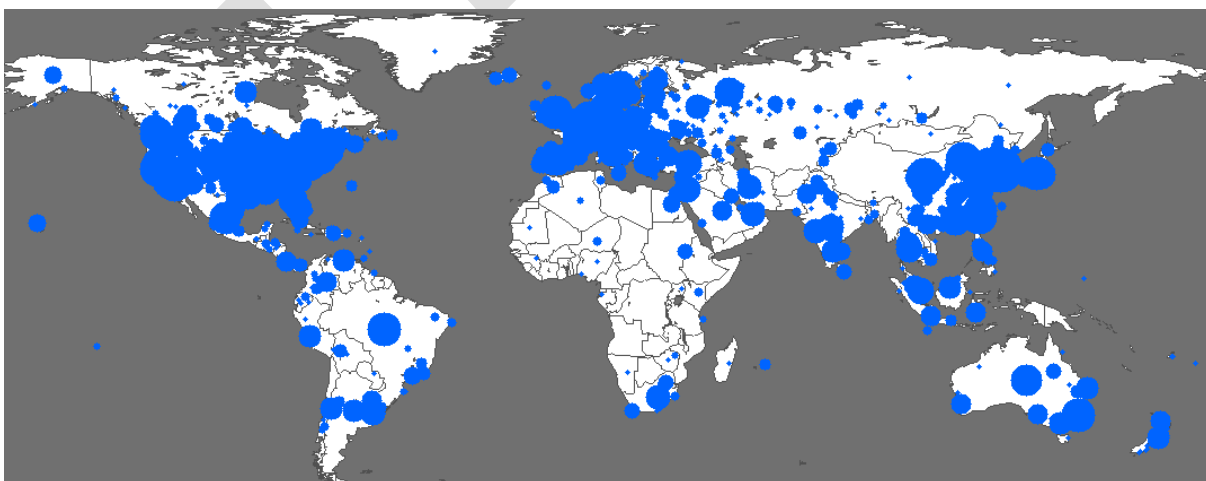


Hình 2.15. Chèn shellcode với phân đệm bằng lệnh NOP (N)

Mã *shellcode* có thể được viết bằng hợp ngữ, C, hoặc các ngôn ngữ lập trình khác, sau đó được dịch thành mã máy, rồi chuyển định dạng thành một chuỗi dữ liệu và cuối cùng được gửi đến chương trình ứng dụng. Hình 2.13 minh họa một đoạn mã *shellcode* viết bằng hợp ngữ và được chuyển đổi thành một chuỗi dưới dạng hexa làm dữ liệu đầu vào gây tràn bộ đệm và gọi thực hiện *shell sh* trong các hệ thống Linux hoặc Unix thông qua lệnh `/bin/sh`. Hình 2.14 minh họa việc chèn *shellcode*, ghi đè lên ô nhớ chứa địa chỉ trở về *ret*, tái định hướng việc trở về từ chương trình con và chuyển đến thực hiện mã *shellcode* được chèn vào. Trên thực tế, để tăng khả năng đoạn mã *shellcode* được thực hiện, người ta thường chèn một số lệnh NOP (N) vào phần đầu *shellcode* để phòng khả năng địa chỉ *ret* mới không trỏ chính xác đến địa chỉ bắt đầu *shellcode*, như minh họa trên Hình 2.15. Lệnh NOP (No OPeration) là lệnh không thực hiện tác vụ nào cả, chỉ tiêu tốn một số chu kỳ của bộ vi xử lý.

c. Ví dụ về khai thác lỗi tràn bộ đệm

Sâu SQL Slammer (một số tài liệu gọi là sâu Sapphire) được phát hiện ngày 25/1/2003 lúc 5h30 (UTC) là sâu có tốc độ lây lan nhanh nhất lúc bấy giờ: nó lây nhiễm đến khoảng 75.000 máy chủ chỉ trong khoảng 30 phút, như minh họa trên Hình 2.16. Sâu Slammer khai thác lỗi tràn bộ đệm trong thành phần Microsoft SQL Server Resolution Service của hệ quản trị cơ sở dữ liệu Microsoft SQL Server 2000.



Hình 2.16. Bản đồ lây nhiễm sâu Slammer (màu xanh) theo trang www.caida.org vào ngày 25/1/2003 lúc 6h00 (giờ UTC) với 74.855 máy chủ bị nhiễm

Sâu sử dụng giao thức UDP với kích thước gói tin 376 byte và vòng lặp chính của sâu chỉ gồm 22 lệnh hợp ngữ. Chu trình hoạt động của sâu SQL Slammer gồm:

- Sinh tự động địa chỉ IP;
- Quét tìm các máy có lỗi với IP tự sinh trên cổng dịch vụ 1434;
- Nếu tìm được, gửi một bản sao của sâu đến máy có lỗi;
- Mã của sâu gây tràn bộ đệm, thực thi mã của sâu và quá trình lặp lại.

SQL Slammer là sâu “lạnh tính” vì nó không can thiệp vào hệ thống file, không thực hiện việc phá hoại hay đánh cắp thông tin trên hệ thống bị lây nhiễm. Tuy nhiên, sâu tạo ra lưu lượng mạng khổng lồ trong quá trình lây nhiễm, gây tê liệt đường truyền mạng Internet trên nhiều vùng của thế giới. Do mã của SQL Slammer chỉ được lưu trong bộ nhớ nó gây tràn mà không được lưu vào hệ thống file, nên chỉ cần khởi động lại máy là có thể tạm thời xóa được sâu khỏi hệ thống. Tuy nhiên, hệ thống chứa lỗ hổng có thể bị lây nhiễm lại nếu nó ở gần một máy khác bị nhiễm sâu. Các biện pháp phòng chống triệt để khác là cập nhật bản vá cho bộ phần mềm Microsoft SQL Server 2000. Thông tin chi tiết về sâu SQL Slammer có thể tìm ở các trang: <https://technet.microsoft.com/library/security/ms02-039>, hoặc <https://www.caida.org/publications/papers/2003/sapphire/sapphire.html>.

2.2.1.3. Phòng chống

Để phòng chống lỗi tràn bộ đệm một cách hiệu quả, cần kết hợp nhiều biện pháp. Các biện pháp có thể thực hiện bao gồm:

- Kiểm tra thủ công mã nguồn hay sử dụng các công cụ phân tích mã tự động để tìm và khắc phục các điểm có khả năng xảy ra lỗi tràn bộ đệm, đặc biệt lưu ý đến các hàm xử lý xâu ký tự.
- Sử dụng cơ chế không cho phép thực hiện mã trong dữ liệu DEP (Data execution prevention). Cơ chế DEP được hỗ trợ bởi hầu hết các hệ điều hành (từ Windows XP và các hệ điều hành họ Linux, Unix,...) không cho phép thực hiện mã chương trình chứa trong vùng nhớ dành cho dữ liệu. Như vậy, nếu kẻ tấn công khai thác lỗi tràn bộ đệm, chèn được mã độc vào bộ đệm trong ngăn xếp, mã độc cũng không thể thực hiện.
- Ngẫu nhiên hóa sơ đồ địa chỉ cấp phát các ô nhớ trong ngăn xếp khi thực hiện chương trình, nhằm gây khó khăn cho việc gỡ rối và phát hiện vị trí các ô nhớ quan trọng như ô nhớ chứa địa chỉ trở về.
- Sử dụng các cơ chế bảo vệ ngăn xếp, theo đó thêm một số ngẫu nhiên (canary) phía trước địa chỉ trở về và kiểm tra số ngẫu nhiên này trước khi trở về chương trình gọi để xác định khả năng bị thay đổi địa chỉ trở về.
- Sử dụng các ngôn ngữ, thư viện và công cụ lập trình an toàn. Trong các trường hợp có thể, sử dụng các ngôn ngữ không gây tràn, như Java, các ngôn ngữ lập trình trên nền Microsoft .Net. Với các ngôn ngữ có thể gây tràn như C, C++, nên sử dụng các thư viện an toàn (Safe C/C++ Libraries) để thay thế các thư viện chuẩn có thể gây tràn.

2.2.2. Lỗi không kiểm tra đầu vào

2.2.2.1. Giới thiệu

Lỗi không kiểm tra đầu vào (Unvalidated input) là một trong các dạng lỗ hổng bảo mật phổ biến, trong đó ứng dụng không kiểm tra, hoặc kiểm tra không đầy đủ các dữ liệu đầu vào, nhờ đó kẻ tấn công có thể khai thác lỗi để tấn công ứng dụng và hệ thống. Dữ liệu đầu vào

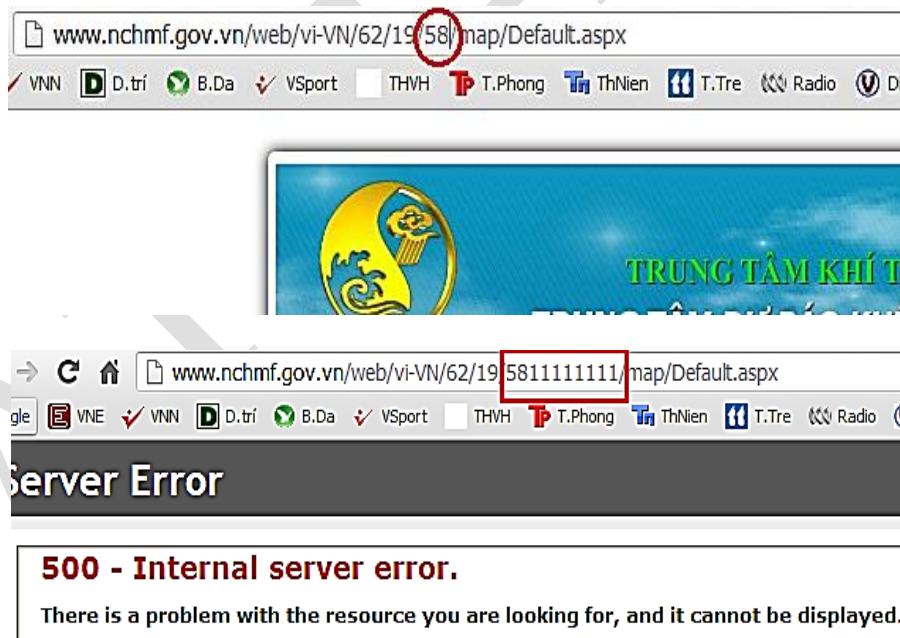
(Input data) cho ứng dụng rất đa dạng, có thể đến từ nhiều nguồn với nhiều định dạng khác nhau. Các dạng dữ liệu đầu vào điển hình cho ứng dụng có thể bao gồm:

- Các trường dữ liệu văn bản (text);
- Các lệnh được truyền qua địa chỉ URL để kích hoạt chương trình;
- Các file âm thanh, hình ảnh, hoặc đồ họa do người dùng, hoặc các tiến trình khác cung cấp;
- Các đối số đầu vào trong dòng lệnh;
- Các dữ liệu từ mạng hoặc từ các nguồn không tin cậy.

Trên thực tế, kẻ tấn công có thể sử dụng phương pháp thủ công, hoặc tự động để kiểm tra các dữ liệu đầu vào và thử tất cả các khả năng có thể để khai thác lỗi không kiểm tra đầu vào. Theo thống kê của trang web OWASP², một trang web chuyên về thống kê các lỗi bảo mật ứng dụng web, lỗi không kiểm tra đầu vào luôn có mặt ở nhóm dẫn đầu trong các lỗi bảo mật web trong khoảng 5 năm trở lại đây.

2.2.2.2. Tấn công khai thác

Có hai dạng chính tấn công khai thác lỗi không kiểm tra đầu vào: (1) cung cấp dữ liệu quá lớn hoặc sai định dạng để gây lỗi cho ứng dụng, và (2) chèn mã khai thác vào dữ liệu đầu vào để thực hiện trên hệ thống của nạn nhân, nhằm đánh cắp dữ liệu nhạy cảm hoặc thực hiện các hành vi phá hoại. Hình 2.17 minh họa tấn công khai thác lỗi không kiểm tra đầu vào dạng (1) thông qua việc nhập dữ liệu quá lớn, gây lỗi thực hiện cho trang web.



Hình 2.17. Cung cấp dữ liệu quá lớn để gây lỗi cho ứng dụng

Chúng ta minh họa tấn công khai thác lỗi không kiểm tra đầu vào dạng (2) bằng việc chèn mã tấn công SQL vào dữ liệu đầu vào, tiếp theo mã tấn công SQL được thực hiện trên hệ

² <http://www.owasp.org>

quản trị cơ sở dữ liệu đích nhằm đánh cắp, hoặc phá hủy dữ liệu trong cơ sở dữ liệu. Giả thiết một trang web tìm kiếm sản phẩm sử dụng câu lệnh SQL sau để tìm kiếm các sản phẩm:

```
"SELECT * FROM tbl_products WHERE product_name like "%" + keyword + "%"
```

trong đó *tbl_products* là bảng lưu thông tin các sản phẩm, *product_name* là trường tên sản phẩm và *keyword* là từ khóa cung cấp bởi người dùng thông qua form tìm kiếm. Nếu người dùng nhập từ khóa là "iPhone 7", khi đó câu lệnh SQL trở thành:

```
"SELECT * FROM tbl_products WHERE product_name like "%iPhone 7%"
```

Nếu trong bảng có sản phẩm thỏa mãn điều kiện tìm kiếm, câu lệnh SQL sẽ trả về tập bản ghi. Nếu không có sản phẩm nào thỏa mãn điều kiện tìm kiếm, câu lệnh SQL sẽ trả về tập bản ghi rỗng. Nếu người dùng nhập từ khóa "iPhone 7";*DELETE FROM tbl_products;--*", khi đó câu lệnh SQL trở thành:

```
"SELECT * FROM tbl_products WHERE product_name like "%iPhone 7";DELETE FROM tbl_products;--%"
```

Như vậy, câu lệnh SQL được thực hiện trên cơ sở dữ liệu gồm 2 câu lệnh: câu lệnh chọn SELECT ban đầu và câu lệnh xóa DELETE do kẻ tấn công chèn thêm. Câu lệnh "*DELETE FROM tbl_products*" sẽ xóa tất cả các bản ghi trong bảng *tbl_products*. Sở dĩ kẻ tấn công có thể thực hiện điều này là do hầu hết các hệ quản trị cơ sở dữ liệu cho phép thực hiện nhiều câu lệnh SQL theo *mé* (batch) trong một chuỗi lệnh, trong đó các câu lệnh được ngăn cách bởi dấu (;). Ngoài ra, dấu "--" ở cuối dữ liệu nhập để loại bỏ hiệu lực của phần lệnh còn lại do "--" là ký hiệu bắt đầu phần chú thích của dòng lệnh SQL. Ngoài DELETE, kẻ tấn công có thể chèn thêm các lệnh SQL khác, như INSERT, hoặc UPDATE để thực hiện việc chèn thêm bản ghi, hoặc sửa đổi dữ liệu theo ý đồ tấn công của mình.

2.2.2.3. Phòng chống

Biện pháp chủ yếu phòng chống tấn công khai thác lỗi không kiểm tra đầu vào là lọc dữ liệu đầu vào. Tất cả các dữ liệu đầu vào, đặc biệt dữ liệu nhập từ người dùng và từ các nguồn không tin cậy cần được kiểm tra kỹ lưỡng. Các biện pháp cụ thể bao gồm:

- Kiểm tra kích thước và định dạng dữ liệu đầu vào;
- Kiểm tra sự hợp lý của nội dung dữ liệu;
- Tạo các bộ lọc để lọc bỏ các ký tự đặc biệt và các từ khóa của các ngôn ngữ trong các trường hợp cần thiết mà kẻ tấn công có thể sử dụng:
 - + Các ký tự đặc biệt: *, ', =, --
 - + Các từ khóa ngôn ngữ: SELECT, INSERT, UPDATE, DELETE, DROP,.... (với dạng tấn công chèn mã SQL).

2.2.3. Các vấn đề với điều khiển truy nhập

Điều khiển truy nhập (Access control) là một lớp bảo vệ đặc biệt quan trọng trong hệ thống các lớp bảo vệ hệ thống và dữ liệu. Điều khiển truy nhập liên quan đến việc điều khiển *ai* (chủ thể) được truy cập đến *cái gì* (đối tượng). Điều khiển truy nhập có thể được thực hiện bởi hệ điều hành, hoặc từng ứng dụng. Điều khiển truy nhập thường gồm 2 khâu: xác thực (Authentication) và trao quyền (Authorization). Xác thực là việc xác minh tính chân thực của

thông tin nhận dạng của chủ thể, còn trao quyền là việc cấp quyền truy nhập cho chủ thể sau khi thông tin nhận dạng đã được xác thực. Các chủ thể được cấp quyền truy nhập vào hệ thống theo các cấp độ khác nhau dựa trên chính sách an ninh của tổ chức.

Các vấn đề thường gặp với điều khiển truy nhập là hệ thống xác thực, hoặc trao quyền yếu hoặc có lỗi. Nếu điều khiển truy nhập có lỗi, một người dùng bình thường có thể chiếm đoạt quyền của người quản trị và toàn quyền truy nhập vào hệ thống. Hoặc, kẻ tấn công có thể lợi dụng lỗ hổng bảo mật của hệ thống điều khiển truy nhập để truy nhập trái phép vào các file trong hệ thống. Một dạng khai thác hệ thống điều khiển truy cập điển hình là một ứng dụng chạy trên người dùng quản trị có toàn quyền truy nhập vào hệ thống, và nếu một kẻ tấn công chiếm được quyền điều khiển ứng dụng đó, hắn sẽ có toàn quyền truy nhập vào hệ thống.

Để đảm bảo an toàn cho hệ thống điều khiển truy nhập, các biện pháp sau cần được xem xét áp dụng:

- Không sử dụng tài khoản quản trị (root hoặc administrator) để chạy các chương trình ứng dụng.
- Luôn chạy các chương trình ứng dụng với quyền tối thiểu, vừa đủ để chúng thực thi các tác vụ.
- Kiểm soát chặt chẽ người dùng, xóa bỏ hoặc cấm truy nhập với những người dùng ngầm định, kiểu *everyone*.
- Thực thi chính sách mật khẩu an toàn.
- Chỉ cấp quyền vừa đủ cho người dùng thực thi nhiệm vụ.

2.2.4. Các điểm yếu trong xác thực, trao quyền

Do các khâu xác thực và trao quyền là hai thành phần cốt lõi của một hệ thống điều khiển truy nhập, nên các điểm yếu trong xác thực và trao quyền ảnh hưởng trực tiếp đến độ an toàn của hệ thống điều khiển truy nhập. Một điểm yếu điển hình trong khâu xác thực là mật khẩu được sử dụng dưới dạng rõ (plaintext), dẫn đến nguy cơ bị lộ mật khẩu rất cao trong quá truyền thông tin xác thực. Ngoài ra, việc sử dụng mật khẩu đơn giản, dễ đoán, hoặc dùng mật khẩu trong thời gian dài cũng là điểm yếu dễ bị khai thác. Việc sử dụng cơ chế xác thực không đủ mạnh, như các cơ chế xác thực đơn giản cung cấp bởi giao thức HTTP cũng tiềm ẩn các nguy cơ bị tấn công khai thác.

Khâu trao quyền cũng tồn tại một số điểm yếu, như sử dụng cơ chế trao quyền không đủ mạnh, dễ bị vượt qua. Chẳng hạn, một trang web chỉ ẩn các liên kết (link) đến các trang web mà người dùng không được quyền truy nhập mà không thực sự kiểm tra quyền truy nhập trên từng trang, nếu người dùng tự gõ URL của trang thì vẫn có thể truy nhập.

2.2.5. Các điểm yếu trong các hệ mật mã

Các vấn đề với các hệ mật mã bao gồm việc sử dụng các giải thuật mã hóa, giải mã, hàm băm yếu, lạc hậu, hoặc có lỗ hổng đã biết không thể khắc phục (như các giải thuật DES, MD4, MD5,...), hoặc sử dụng khóa (key) mã hóa, giải mã yếu, như các khóa có chiều dài ngắn, hoặc dễ đoán. Các hệ mã hóa khóa bí mật có độ an toàn cao, tốc độ cao, nhưng gặp phải khó khăn trong vấn đề trao đổi, chia sẻ các khóa bí mật. Các khóa bí mật trao đổi trong môi trường không an toàn như mạng Internet có thể bị lộ, bị đánh cắp. Một số vấn đề khác có thể

gặp phải với các hệ mã hóa, gồm vấn đề xác thực người gửi, người nhận, vấn đề sử dụng các khóa, các chứng chỉ hết hạn hoặc bị thu hồi, hoặc chi phí tính toán quá lớn, đặc biệt đối với các hệ mã hóa khóa công khai.

2.2.6. Các lỗ hổng bảo mật khác

Các thao tác không an toàn với các file cũng có thể là một lỗ hổng bảo mật nghiêm trọng. Chẳng hạn, một người dùng thực hiện đọc/ghi một file được lưu ở những nơi mà những người dùng khác cũng có thể ghi file đó. Các lỗi bảo mật điển hình khác có thể gồm:

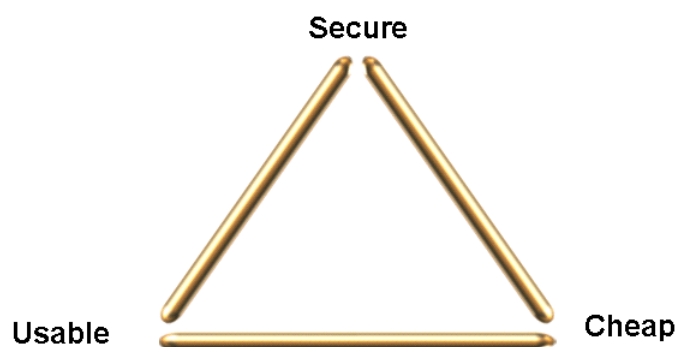
- Không kiểm tra chính xác loại file, định danh thiết bị, các liên kết hoặc các thuộc tính khác của file trước khi sử dụng;
- Cho phép tải file tài liệu, hình ảnh lên máy chủ nhưng không kiểm tra định dạng file và không cấm quyền thực hiện, và do vậy kẻ tấn công có thể tải lên và thực hiện các file chứa mã độc;
- Không kiểm tra mã trả về sau mỗi thao tác với file;
- Giả thiết một file có đường dẫn cục bộ là file cục bộ và bỏ qua các thủ tục kiểm tra. Kẻ tấn công có thể khai thác lỗi này bằng cách ánh xạ file ở xa vào hệ thống file cục bộ, tức là có đường dẫn cục bộ và có thể được thực thi trên hệ thống cục bộ.

Một dạng điểm yếu bảo mật khác xảy ra khi xuất hiện các điều kiện đua tranh (Race conditions). Một điều kiện đua tranh tồn tại khi có sự thay đổi trật tự của 2 hay một số sự kiện gây ra sự thay đổi hành vi của hệ thống. Đây là một dạng lỗi nếu chương trình chỉ có thể thực hiện đúng chức năng nếu các sự kiện phải xảy ra theo đúng trật tự. Kẻ tấn công có thể lợi dụng khoảng thời gian giữa 2 sự kiện để chen mã độc, đổi tên file hoặc can thiệp vào quá trình hoạt động bình thường của hệ thống.

2.3. QUẢN LÝ, KHẮC PHỤC CÁC LỖ HỔNG BẢO MẬT VÀ TĂNG CƯỜNG KHẢ NĂNG ĐỀ KHÁNG CHO HỆ THỐNG

2.3.1. Nguyên tắc chung

Việc quản lý, khắc phục các lỗ hổng bảo mật và tăng cường khả năng đề kháng cho hệ thống cần được thực hiện theo nguyên tắc chung là cân bằng giữa *an toàn* (Secure), *hữu dụng* (Usable) và *rẻ tiền* (Cheap), như minh họa trên Hình 2.18. Ý nghĩa cụ thể của nguyên tắc này là đảm bảo an toàn cho hệ thống ở mức phù hợp với chi phí hợp lý và hệ thống vẫn phải hữu dụng, hay có khả năng cung cấp đầy đủ các tính năng hữu ích cho người dùng.



Hình 2.18. Cân bằng giữa An toàn (Secure), Hữu dụng (Usable) và Rẻ tiền (Cheap)

2.3.2. Các biện pháp cụ thể

Trên cơ sở nguyên tắc chung của việc quản lý, khắc phục các lỗ hổng bảo mật và tăng cường khả năng đề kháng cho hệ thống, các biện pháp cụ thể cần được xem xét áp dụng với từng trường hợp cụ thể, đảm bảo hiệu quả cao. Biện pháp thiết yếu đầu tiên cần được thực hiện thường xuyên cho mọi trường hợp là thường xuyên cập nhật thông tin về các điểm yếu, lỗ hổng bảo mật từ các trang web chính thức:

- CVE - Common Vulnerabilities and Exposures: <http://cve.mitre.org>
- CVE Details: <http://www.cvedetails.com>
- US National Vulnerability Database: <http://web.nvd.nist.gov>
- OWASP: <https://www.owasp.org/index.php/Category:Vulnerability>

Biện pháp hiệu quả tiếp theo là định kỳ cập nhật các bản vá, nâng cấp hệ điều hành và các phần mềm ứng dụng, nhằm khắc phục các lỗ hổng đã biết, cũng như tăng cường khả năng đề kháng cho hệ thống bằng các phiên bản mới an toàn hơn. Để thực hiện công việc này có thể sử dụng các hệ thống quản lý các bản vá và tự động cập nhật định kỳ, như Microsoft Windows Updates, các tiện ích cập nhật tự động trên Linux/Unix, và tính năng tự động cập nhật của các ứng dụng, như Google Update Service. Căn cứ vào mức độ nghiêm trọng của các lỗ hổng bảo mật, tần suất cập nhật các bản vá cần được tuân thủ. Với các lỗ hổng nghiêm trọng, cần cập nhật tức thời các bản vá, còn với các lỗ hổng ít nghiêm trọng hơn, cần có kế hoạch cập nhật, hoặc khắc phục định kỳ.

Một biện pháp hiệu quả khác là sử dụng các phần mềm, hoặc công cụ rà quét các điểm yếu, lỗ hổng bảo mật trong hệ điều hành và các phần mềm ứng dụng, để chủ động tìm và khắc phục các điểm yếu và lỗ hổng bảo mật của hệ thống. Nhờ vậy có thể giảm thiểu nguy cơ bị lợi dụng, khai thác các lỗ hổng bảo mật đã biết.

Một biện pháp bổ sung là cần có chính sách quản trị người dùng, mật khẩu và quyền truy nhập chặt chẽ ở cả mức hệ điều hành và mức ứng dụng, trong đó người dùng chỉ được cấp quyền truy nhập vừa đủ để thực hiện công việc được giao. Nếu người dùng được cấp nhiều quyền truy nhập hơn mức cần thiết, họ có khuynh hướng lạm dụng quyền để truy nhập vào các dữ liệu nhạy cảm, hoặc có thể bị kẻ tấn công khai thác.

Việc sử dụng các biện pháp phòng vệ ở lớp ngoài như tường lửa, proxy cũng đem lại hiệu quả do chúng giúp làm giảm bề mặt tiếp xúc với hệ thống, qua đó giảm thiểu khả năng bị tấn công. Tường lửa và proxy có thể chặn các dịch vụ, hoặc cổng không sử dụng, hoặc không thực sự cần thiết, đồng thời ghi log các hoạt động truy nhập mạng phục vụ cho việc phân tích, điều tra khi cần thiết.

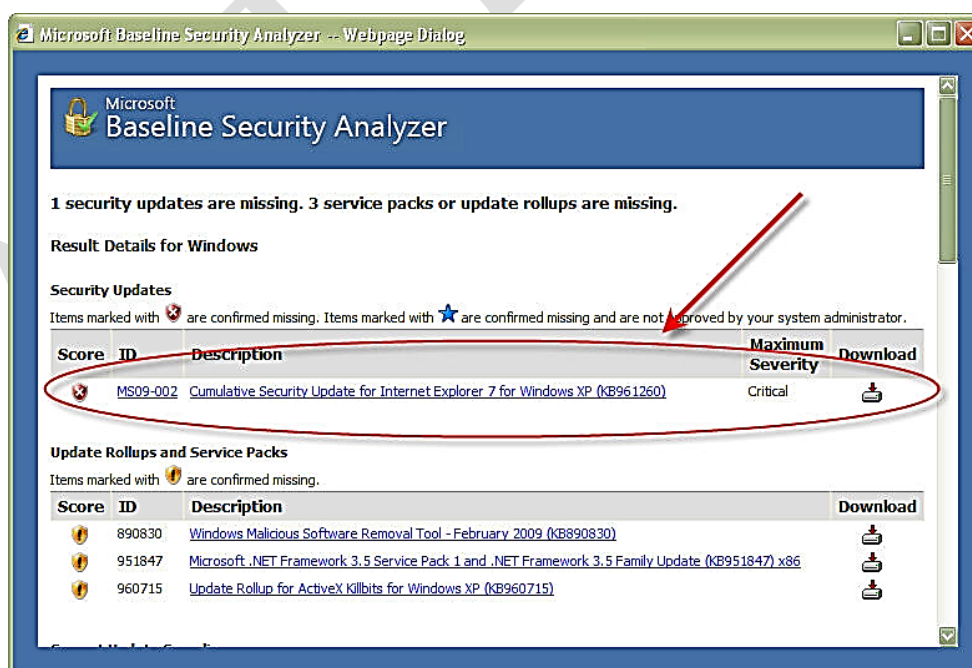
Với các nhà phát triển phần mềm thì phát triển phần mềm an toàn là một trong các biện pháp cho phép giải quyết tận gốc vấn đề lỗ hổng bảo mật. Cần bổ sung các yêu cầu đảm bảo an ninh, an toàn vào quy trình phát triển phần mềm. Ngoài ra, cần kiểm tra, kiểm thử tất cả các khâu, như thiết kế, cài đặt để tìm các điểm yếu, lỗ hổng bảo mật, và có biện pháp khắc phục phù hợp với các điểm yếu, lỗ hổng được phát hiện.

2.4. GIỚI THIỆU MỘT SỐ CÔNG CỤ RÀ QUÉT ĐIỂM YẾU VÀ LỖ HỔNG BẢO MẬT

Các công cụ rà quét các điểm yếu và lỗ hổng bảo mật có thể được người quản trị sử dụng để chủ động rà quét các hệ thống, nhằm tìm ra các điểm yếu và lỗ hổng bảo mật tồn tại trong hệ thống. Trên cơ sở kết quả rà quét, người quản trị có thể phân tích và đề xuất áp dụng các biện pháp khắc phục phù hợp. Các công cụ bao gồm: công cụ rà quét cổng dịch vụ, các công cụ rà quét lỗ hổng bảo mật hệ thống, và các công cụ rà quét lỗ hổng ứng dụng web, hay các trang web.

2.4.1. Công cụ rà quét lỗ hổng bảo mật hệ thống

Các công cụ rà quét lỗ hổng bảo mật hệ thống cho phép rà quét hệ thống, tìm các điểm yếu và lỗ hổng bảo mật. Đồng thời, chúng cũng phân tích chi tiết từng điểm yếu, lỗ hổng, kèm theo là hướng dẫn khắc phục, sửa chữa. Các công cụ được sử dụng rộng rãi là Microsoft Baseline Security Analyzer³ cho rà quét các hệ thống chạy hệ điều hành Microsoft Windows và Nessus Vulnerability Scanner⁴ cho rà quét các hệ thống chạy nhiều loại hệ điều hành khác nhau. Microsoft Baseline Security Analyzer cho phép quét các thành phần của hệ điều hành Microsoft Windows (vấn đề cài đặt, cấu hình hệ thống, quản trị người dùng), các dịch vụ, tiện ích chạy trên hệ điều hành Windows (máy chủ web IIS, máy chủ cơ sở dữ liệu SQL server, trình cập nhật Windows Updates,...) và các chương trình ứng dụng (Microsoft Office, trình duyệt Internet Explorer,...) trên một máy hoặc một nhóm các máy tính. Hình 2.19 là màn hình báo cáo kết quả rà quét điểm yếu và lỗ hổng bảo mật của Microsoft Baseline Security Analyzer. Ưu điểm của Microsoft Baseline Security Analyzer là tốc độ rà quét nhanh, miễn phí và dễ sử dụng. Hạn chế của công cụ này là chỉ có khả năng rà quét hệ điều hành Microsoft Windows và các ứng dụng do Microsoft phát triển.

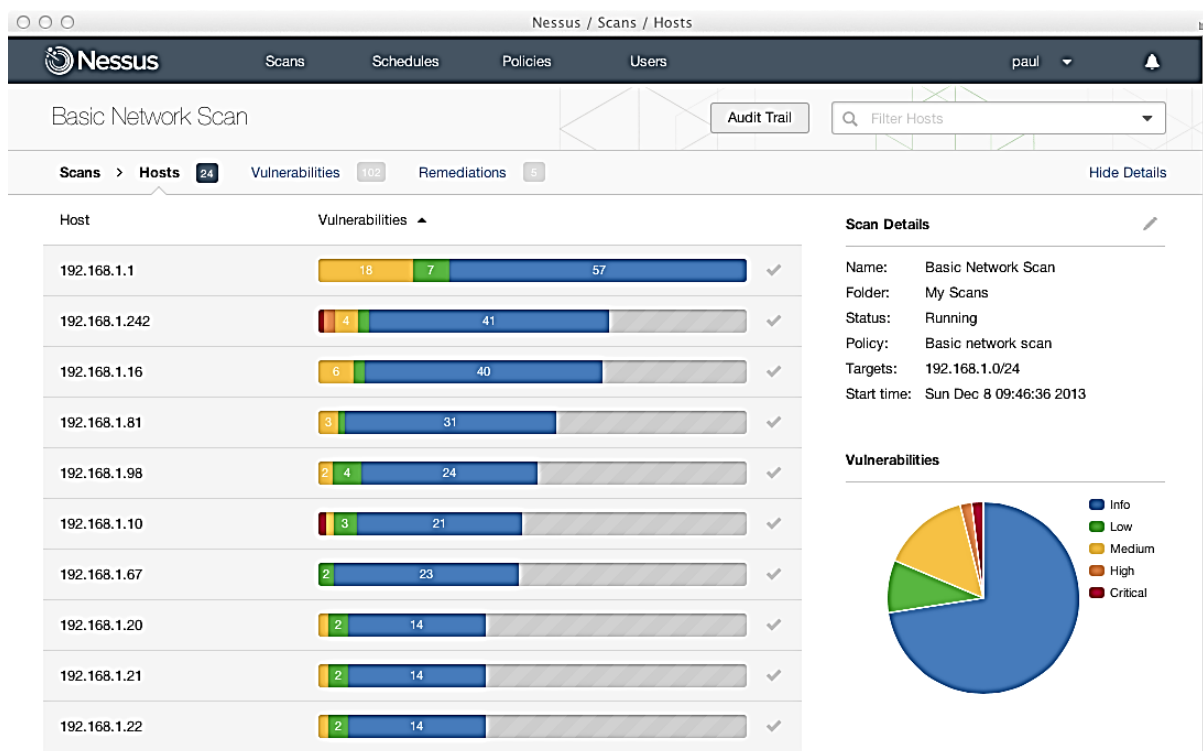


Hình 2.19. Báo cáo kết quả quét của Microsoft Baseline Security Analyzer

³ Tham khảo tại: <https://www.microsoft.com/en-us/download/details.aspx?id=15623>

⁴ Tham khảo tại: <https://www.tenable.com/products/nessus/nessus-professional>

Ngược lại, Nessus Vulnerability Scanner có khả năng rà quét hầu hết các hệ điều hành và các ứng dụng khác nhau. Tương tự Microsoft Baseline Security Analyzer, công cụ này cũng hỗ trợ quét từng máy (host) cụ thể, hoặc quét mạng (network) theo địa chỉ IP. Hình 2.20 là màn hình tổng hợp kết quả quét lỗ hổng cho một tập các host của Nessus Vulnerability Scanner. Ưu điểm của bộ công cụ này là có khả năng rà quét tìm điểm yếu, lỗ hổng trên nhiều hệ điều hành và ứng dụng. Tuy nhiên, hạn chế của nó là vấn đề phí bản quyền và tương đối chậm do hệ thống hoạt động dưới dạng một máy chủ web.



Hình 2.20. Màn hình tổng hợp kết quả quét lỗ hổng của Nessus Vulnerability Scanner

2.4.2. Công cụ rà quét lỗ hổng ứng dụng web

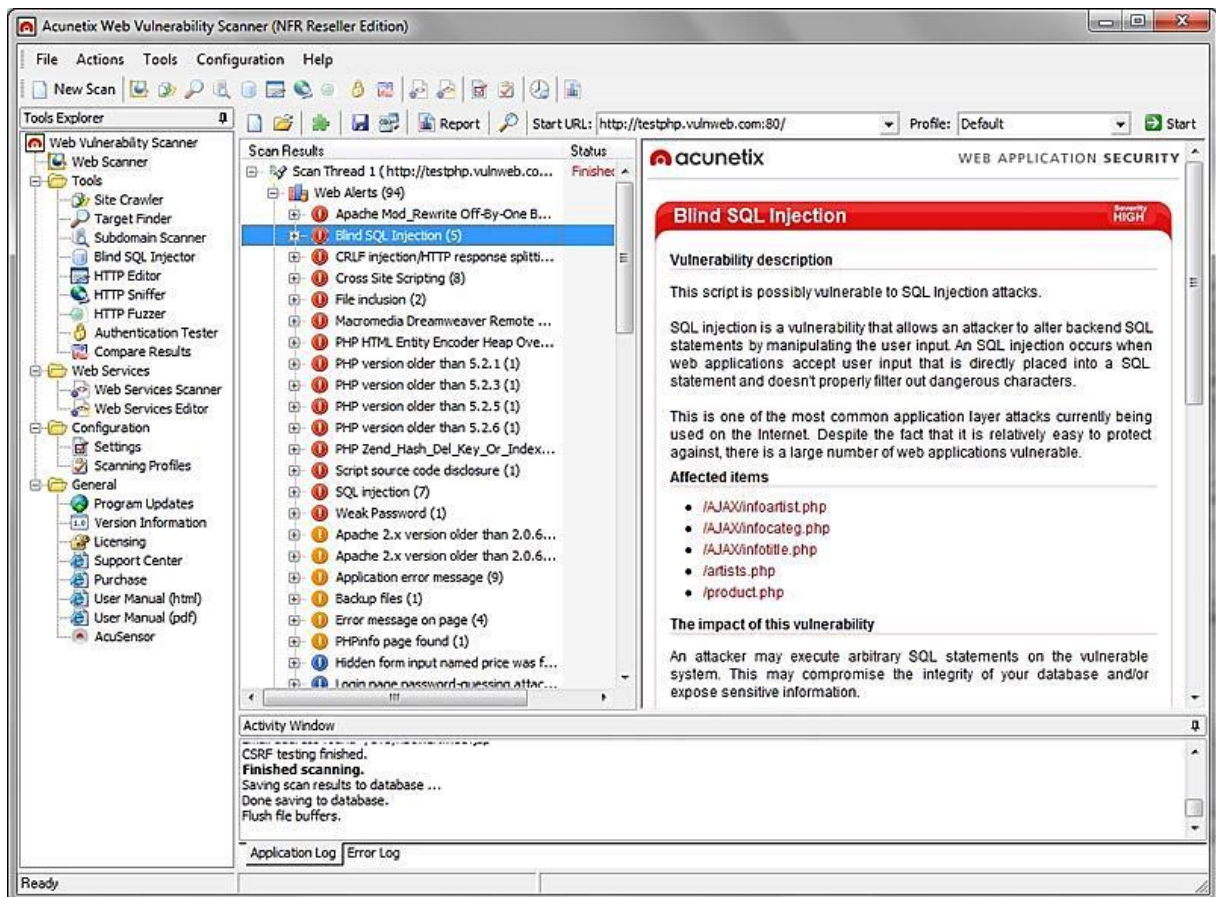
Các công cụ rà quét lỗ hổng ứng dụng web cho phép rà quét, phân tích các trang web, tìm các lỗi và lỗ hổng bảo mật. Chúng cũng hỗ trợ phân tích tình trạng các lỗi tìm được, như các lỗi XSS, lỗi chèn mã SQL, lỗi CSRF, lỗi bảo mật phiên,... Các công cụ được sử dụng phổ biến bao gồm Acunetix Web Vulnerability Scanner⁵, IBM AppScan⁶, Beyond Security AVDS⁷ và SQLmap⁸. Hình 2.21. Acunetix Web Vulnerability Scanner là bộ công cụ quét các điểm yếu, lỗ hổng cho các website, ứng dụng web được sử dụng phổ biến. Acunetix Web Vulnerability Scanner có khả năng tải toàn bộ website để phân tích, đánh giá kiểu kiểm thử hộp trắng, hoặc kiểm thử kết hợp giữa kiểm thử hộp trắng và kiểm thử hộp đen sử dụng một cơ sở dữ liệu gồm hàng ngàn các mẫu tấn công website được xây dựng sẵn. Acunetix Web Vulnerability Scanner cung cấp mô tả chi tiết cho từng lỗ hổng tìm được và kèm theo là hướng dẫn khắc phục, sửa chữa. Ưu điểm của bộ công cụ là tốc độ quét nhanh và dễ sử dụng. Hạn chế duy nhất của nó là vấn đề phí bản quyền.

⁵ Tham khảo tại: <https://www.acunetix.com/vulnerability-scanner>

⁶ Tham khảo tại: <https://www.ibm.com/security/application-security/appscan>

⁷ Tham khảo tại: <https://www.beyondsecurity.com/avds.html>

⁸ Tham khảo tại: <http://sqlmap.org>



Hình 2.21. Kết quả quét website sử dụng Acunetix Web Vulnerability Scanner

2.5. CÂU HỎI ÔN TẬP

- 1) Điểm yếu hệ thống là gì? Nêu các nguyên nhân của sự tồn tại các điểm yếu trong hệ thống.
- 2) Lỗ hổng bảo mật là gì? Các lỗ hổng bảo mật thường tồn tại nhiều nhất trong thành phần nào của hệ thống?
- 3) Nêu các dạng lỗ hổng bảo mật thường gặp trong hệ điều hành và các phần mềm ứng dụng.
- 4) Lỗi tràn bộ đệm là lỗi trong khâu nào của quá trình phát triển phần mềm?
- 5) Các vùng bộ nhớ nào thường bị gây tràn trong tấn công khai thác lỗi tràn bộ đệm?
- 6) Mô tả một trường hợp tấn công khai thác lỗi tràn bộ đệm đã xảy ra trên thực tế.
- 7) Nêu các biện pháp phòng chống tấn công khai thác lỗi tràn bộ đệm.
- 8) Mô tả cơ chế tấn công khai thác lỗi không kiểm tra đầu vào.
- 9) Nêu các biện pháp phòng chống tấn công khai thác lỗi không kiểm tra đầu vào.
- 10) Mô tả các vấn đề với hệ thống điều khiển truy nhập và khả năng bị khai thác.
- 11) Mô tả các điểm yếu trong xác thực, trao quyền hoặc các hệ mật mã và khả năng bị khai thác.
- 12) Việc quản lý, khắc phục các lỗ hổng bảo mật và tăng cường khả năng đề kháng cho hệ thống cần được thực hiện theo nguyên tắc chung nào?

CHƯƠNG 3. CÁC DẠNG TẤN CÔNG VÀ CÁC PHẦN MỀM ĐỘC HẠI

Chương 3 giới thiệu về các dạng tấn công điển hình vào các hệ thống máy tính và mạng, bao gồm tấn công vào mật khẩu, tấn công nghe lén, người đứng giữa, tấn công DoS, DDoS, tấn công sử dụng các kỹ thuật xã hội, ... Nửa cuối của chương đề cập đến các dạng phần mềm độc hại, gồm cơ chế lây nhiễm và tác hại của chúng. Kèm theo phần mô tả mỗi tấn công, hoặc phần mềm độc hại, chương đề cập các biện pháp, kỹ thuật phòng chống tương ứng.

3.1. KHÁI QUÁT VỀ MỐI ĐE DỌA VÀ TẤN CÔNG

3.1.1. Mối đe dọa

Mối đe dọa (Threat) là bất kỳ một hành động nào có thể gây hư hại đến các tài nguyên hệ thống. Các tài nguyên hệ thống bao gồm phần cứng, phần mềm, cơ sở dữ liệu, các file, dữ liệu, hoặc hạ tầng mạng vật lý, ... Mối đe dọa và lỗ hổng bảo mật luôn có quan hệ hữu cơ với nhau: Các mối đe dọa thường khai thác một hoặc một số lỗ hổng bảo mật đã biết để thực hiện các cuộc tấn công phá hoại. Điều này có nghĩa là nếu tồn tại một lỗ hổng trong hệ thống, sẽ có khả năng một mối đe dọa trở thành hiện thực. Nói chung, không thể triệt tiêu được hết các mối đe dọa do đó là yếu tố khách quan, nhưng có thể giảm thiểu các lỗ hổng bảo mật, qua đó giảm thiểu khả năng bị khai thác để thực hiện tấn công.

Trên thực tế, không phải tất cả các mối đe dọa đều là ác tính hay độc hại (malicious). Một số mối đe dọa là chủ động, cố ý, nhưng một số khác chỉ là ngẫu nhiên, hoặc vô tình. Các mối đe dọa thường gặp đối với thông tin, hệ thống và mạng có thể gồm:

- Phần mềm độc hại, hoặc các dạng mã độc
- Kẻ tấn công ở bên trong
- Kẻ tấn công ở bên ngoài
- Hư hỏng phần cứng hoặc phần mềm
- Mất trộm các thiết bị
- Tai họa thiên nhiên
- Gián điệp công nghiệp
- Khủng bố phá hoại.

3.1.2. Tấn công

3.1.2.1. Giới thiệu

Tấn công (Attack) là một, hoặc một chuỗi các hành động vi phạm các chính sách an ninh, an toàn của tổ chức, cơ quan, gây tổn hại đến các thuộc tính bí mật, toàn vẹn và sẵn dùng của thông tin, hệ thống và mạng. Một cuộc tấn công vào hệ thống máy tính hoặc các tài nguyên mạng thường được thực hiện bằng cách khai thác các lỗ hổng bảo mật tồn tại trong hệ thống. Như vậy, tấn công chỉ có thể trở thành hiện thực nếu có sự tồn tại đồng thời của mối đe dọa và lỗ hổng bảo mật, hay có thể nói:

$$\text{Tấn công} = \text{Mối đe dọa} + \text{Lỗ hổng bảo mật}$$

3.1.2.2. Phân loại

Có thể chia các dạng tấn công theo mục đích thực hiện thành 4 loại chính như sau:

- Giả mạo (Fabrication): Tấn công giả mạo thông tin thường được sử dụng để đánh lừa người dùng thông thường;
- Chặn bắt (Interception): Tấn công chặn bắt thường liên quan đến việc nghe lén trên đường truyền và chuyển hướng thông tin để sử dụng trái phép;
- Gây ngắt quãng (Interruption): Tấn công gây ngắt quãng làm ngắt, hoặc chậm kênh truyền thông, hoặc làm quá tải hệ thống, ngăn cản việc truy nhập dịch vụ của người dùng hợp pháp;
- Sửa đổi (Modification): Tấn công sửa đổi liên quan đến việc sửa đổi thông tin trên đường truyền hoặc sửa đổi dữ liệu file.

Theo hình thức thực hiện, có thể chia các dạng tấn công thành 2 kiểu chính như sau:

- Tấn công chủ động (Active attack): Tấn công chủ động là một đột nhập, xâm nhập (intrusion) về mặt vật lý vào hệ thống, hoặc mạng. Các tấn công chủ động thực hiện sửa đổi dữ liệu trên đường truyền, sửa đổi dữ liệu trong file, hoặc giành quyền truy nhập trái phép vào máy tính hoặc hệ thống mạng.
- Tấn công thụ động (Passive attack): Tấn công thụ động thường không gây ra thay đổi trên hệ thống. Các tấn công thụ động điển hình là nghe lén và giám sát lưu lượng trên đường truyền.

Trên thực tế, tấn công thụ động thường là giai đoạn đầu của một cuộc tấn công chủ động, trong đó kẻ tấn công sử dụng các kỹ thuật tấn công thụ động để thu thập các thông tin về hệ thống, mạng, và trên cơ sở các thông tin có được sẽ lựa chọn kỹ thuật tấn công chủ động có xác suất thành công cao nhất.

3.2. CÁC CÔNG CỤ HỖ TRỢ TẤN CÔNG

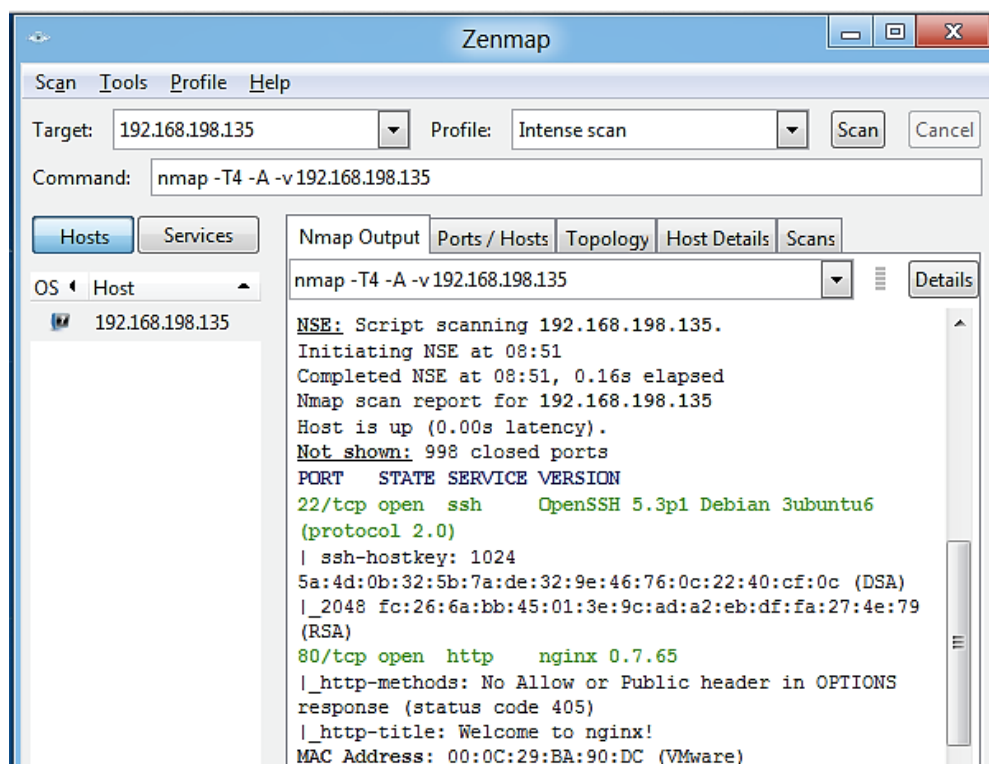
Các công cụ hỗ trợ tấn công (Attacking assistant tool) là các công cụ phần cứng, phần mềm, hoặc các kỹ thuật hỗ trợ kẻ tấn công (attacker) thu thập các thông tin về hệ thống máy tính, hoặc mạng. Trên cơ sở các thông tin thu được, kẻ tấn công sẽ lựa chọn công cụ, kỹ thuật tấn công có khả năng thành công cao nhất. Các công cụ hỗ trợ tấn công bao gồm 4 nhóm chính: (i) công cụ quét điểm yếu, lỗ hổng bảo mật, (ii) công cụ quét cổng dịch vụ, (iii) công cụ nghe lén và (iv) công cụ ghi phím gõ. Các công cụ quét điểm yếu, lỗ hổng bảo mật đã được trình bày ở Mục 2.4. Mục này giới thiệu 3 nhóm công cụ còn lại.

3.2.1. Công cụ quét cổng dịch vụ

Các công cụ quét cổng dịch vụ (Port scanner) cho phép quét các cổng, tìm các cổng đang mở, đang hoạt động, đồng thời tìm các thông tin về ứng dụng, dịch vụ và hệ điều hành đang hoạt động trên hệ thống. Dựa trên thông tin quét cổng dịch vụ, có thể xác định được dịch vụ, ứng dụng nào đang chạy trên hệ thống:

- Cổng 80/443 mở có nghĩa là dịch vụ/máy chủ web đang hoạt động;
- Cổng 25 mở có nghĩa là dịch vụ gửi/nhận email SMTP đang hoạt động;
- Cổng 1433 mở có nghĩa là máy chủ Microsoft SQL Server đang hoạt động;

- Cổng 53 mở có nghĩa là dịch vụ tên miền DNS đang hoạt động,...



Hình 3.1. Giao diện của công cụ quét cổng Zenmap

Các công cụ quét cổng dịch vụ được sử dụng phổ biến bao gồm: Nmap, Zenmap⁹, Portswep, Advanced Port Scanner, Angry IP Scanner, SuperScan và NetScanTools. Hình 3.1 là giao diện của công cụ quét cổng dịch vụ Nmap/ Zenmap – một trong các công cụ quét cổng dịch vụ được sử dụng rộng rãi. Nmap cung cấp tập lệnh rà quét rất mạnh. Tuy nhiên, Nmap tương đối khó sử dụng do chỉ hỗ trợ giao diện dòng lệnh với rất nhiều tham số khác nhau.

3.2.2. Công cụ nghe lén

Công cụ nghe lén (Sniffer) cho phép bắt các gói tin khi chúng được truyền trên mạng. Công cụ nghe lén có thể là mô đun phần cứng, phần mềm hoặc kết hợp. Các thông tin nhạy cảm như thông tin tài khoản, thẻ tín dụng, hoặc mật khẩu nếu không được mã hóa thì có thể bị kẻ tấn công nghe lén khi được truyền từ máy trạm đến máy chủ và bị lạm dụng. Một số công cụ phần mềm cho phép bắt gói tin truyền trên mạng được sử dụng phổ biến bao gồm:

- Tcpdump¹⁰
- Wireshark¹¹ (minh họa trên Hình 3.2)
- Pcap¹² / Wincap¹³ / Libcap¹⁴ (Packet capture – các thư viện hỗ trợ bắt gói tin)
- Network-Tools/IP Tools¹⁵.

⁹ Thao khảo tại: <https://nmap.org/zenmap>

¹⁰ Thao khảo tại: <http://www.tcpdump.org>

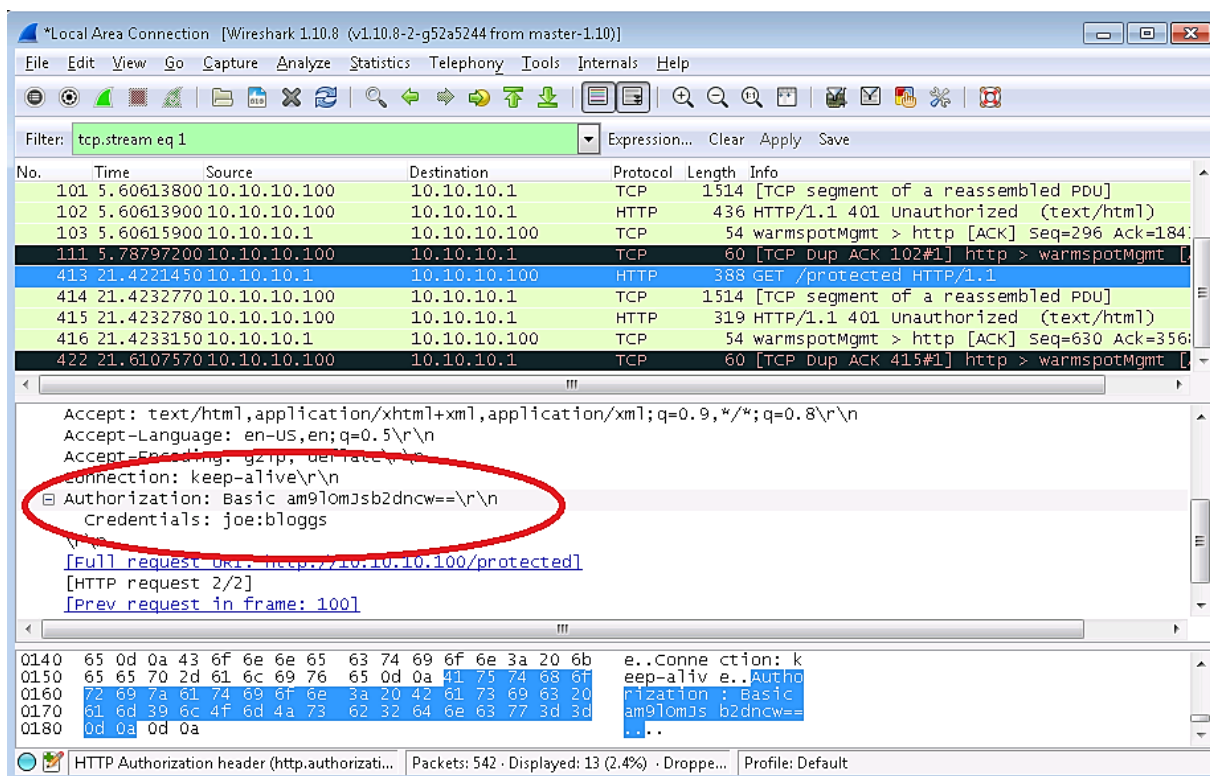
¹¹ Thao khảo tại: <https://www.wireshark.org>

¹² Thao khảo tại: <http://www.tcpdump.org>

¹³ Thao khảo tại: <https://www.wincap.org>

¹⁴ Thao khảo tại: <http://www.tcpdump.org>

¹⁵ Thao khảo tại: <https://www.softpedia.com/get/Network-Tools/IP-Tools>



Hình 3.2. Sử dụng Wireshark để bắt gói tin có chứa thông tin nhạy cảm

3.2.3. Công cụ ghi phím gõ

Công cụ ghi phím gõ (Keylogger) là một dạng công cụ giám sát bằng phần cứng hoặc phần mềm có khả năng ghi lại mọi phím người dùng gõ và lưu vào một file. File đã ghi sau đó có thể được gửi cho kẻ tấn công theo địa chỉ email chỉ định trước, hoặc kẻ tấn công có thể sao chép trực tiếp. Ngoài kẻ tấn công, người quản lý cũng có thể cài đặt keylogger vào máy tính của nhân viên để theo dõi hoạt động của họ. Việc cài đặt keylogger có thể được thực hiện tương đối đơn giản: Hình 3.3 minh họa một keylogger dưới dạng một khớp nối phần cứng (dongle) kết nối cổng bàn phím với đầu nối bàn phím, hỗ trợ cả giao diện cổng bàn phím PS/2 và USB. Với keylogger phần mềm, kẻ tấn công có thể tích hợp keylogger vào một phần mềm thông thường và lừa người dùng cài đặt vào máy tính của mình.



Hình 3.3. Mô đun Keylogger phần cứng và cài đặt trên máy tính để bàn

3.3. CÁC DẠNG TẤN CÔNG THƯỜNG GẶP

Các dạng tấn công thường gặp là các dạng tấn công điển hình, xảy ra thường xuyên nhằm vào thông tin, hệ thống máy tính, hệ thống mạng và người dùng. Các dạng tấn công thường gặp bao gồm:

- Tấn công vào mật khẩu
- Tấn công bằng mã độc
- Tấn công từ chối dịch vụ
- Tấn công giả mạo địa chỉ
- Tấn công nghe lén
- Tấn công kiểu người đứng giữa
- Tấn công bằng bom thư và thư rác
- Tấn công sử dụng các kỹ thuật xã hội
- Tấn công pharming.

Phần tiếp theo của mục này trình bày chi tiết về các dạng tấn công thường gặp kể trên và các biện pháp phòng chống tương ứng.

3.3.1. Tấn công vào mật khẩu

3.3.1.1. Giới thiệu

Tấn công vào mật khẩu (Password attack) là dạng tấn công nhằm đánh cắp mật khẩu và thông tin tài khoản của người dùng để lạm dụng. Tên người dùng và mật khẩu không được mã hóa có thể bị đánh cắp trên đường truyền từ máy khách chuyển đến máy chủ. Các thông tin này cũng có thể bị đánh cắp thông qua các dạng tấn công XSS, hoặc lừa đảo, bẫy người dùng cung cấp thông tin. Đây là một trong các dạng tấn công phổ biến nhất do hầu hết các ứng dụng sử dụng cơ chế xác thực người dùng dựa trên tên người dùng, hoặc email và mật khẩu. Nếu kẻ tấn công có tên người dùng và mật khẩu thì hắn có thể đăng nhập vào tài khoản và thực hiện các thao tác như người dùng hợp pháp.

3.3.1.2. Mô tả

Có thể chia tấn công vào mật khẩu thành 2 dạng:

- Tấn công dựa trên từ điển (Dictionary attack): Dạng tấn công này khai thác vấn đề, theo đó người dùng có xu hướng chọn mật khẩu là các từ đơn giản cho dễ nhớ. Kẻ tấn công thử các từ có tần suất sử dụng cao làm mật khẩu, nhờ vậy có thể giảm số lần thử và tăng khả năng thành công. Danh sách các từ có tần suất sử dụng cao làm mật khẩu thường được biên soạn sẵn gọi là từ điển trong dạng tấn công này.
- Tấn công vét cạn (Brute force attack): Tấn công vét cạn sử dụng tổ hợp các ký tự, số và thử tự động. Phương pháp này thường được sử dụng với các mật khẩu đã được mã hóa. Kẻ tấn công sinh tổ hợp ký tự, sau đó mã hóa với cùng thuật toán mà hệ thống sử dụng, tiếp theo so sánh chuỗi mã hóa từ tổ hợp ký tự với chuỗi mật khẩu mã hóa thu thập được. Nếu hai bản mã trùng nhau thì tổ hợp ký tự là mật khẩu.

3.3.1.3. Phòng chống

Để đảm bảo an toàn cho mật khẩu, cần thực hiện kết hợp các biện pháp sau:

- Chọn mật khẩu đủ mạnh: Mật khẩu mạnh cho người dùng thông thường cần có độ dài lớn hơn hoặc bằng 8 ký tự, gồm tổ hợp của 4 loại ký tự: chữ cái hoa, chữ cái thường, chữ số và ký tự đặc biệt (?#\$....). Mật khẩu cho người quản trị hệ thống cần có độ dài lớn hơn hoặc bằng 10 ký tự cũng với các loại ký tự như mật khẩu cho người dùng thông thường.
- Định kỳ thay đổi mật khẩu: Thời hạn đổi mật khẩu tùy thuộc vào chính sách an ninh của tổ chức, cơ quan, có thể là 3 tháng, hoặc 6 tháng. Với yêu cầu này, hệ thống cần hỗ trợ cơ chế nhắc đổi mật khẩu khi đến hạn cho người dùng.
- Mật khẩu không nên lưu ở dạng rõ (plaintext): Nên lưu mật khẩu ở dạng đã mã hóa sử dụng hàm băm một chiều.
- Hạn chế trao đổi tên người dùng và mật khẩu trên kênh truyền không được mã hóa.

3.3.2. Tấn công bằng mã độc

3.3.2.1. Giới thiệu

Tấn công bằng mã độc (Malicious code attack) là dạng tấn công sử dụng các mã độc (Malicious code) làm công cụ để tấn công hệ thống nạn nhân. Tấn công bằng mã độc có thể chia thành 2 loại:

- Khai thác các lỗ hổng về lập trình, lỗ hổng cấu hình hệ thống để chèn và thực hiện mã độc trên hệ thống nạn nhân. Loại tấn công này lại gồm 2 dạng:
 - + Tấn công khai thác lỗi tràn bộ đệm (Buffer Overflow)
 - + Tấn công khai thác lỗi không kiểm tra đầu vào, gồm tấn công chèn mã SQL (SQL Injection) và tấn công sử dụng mã script, kiểu XSS, CSRF.
- Lừa người sử dụng tải, cài đặt và thực hiện các phần mềm độc hại, như:
 - + Các phần mềm quảng cáo (Adware), gián điệp (Spyware)
 - + Vi rút
 - + Zombie/Bot
 - + Trojan.

Tấn công khai thác lỗi tràn bộ đệm đã được đề cập ở Mục 2.2.1. Các dạng tấn công sử dụng mã script, kiểu XSS, CSRF đặc thù với các ứng dụng web sẽ được đề cập trong môn học *An toàn ứng dụng web và cơ sở dữ liệu* của chương trình đào tạo đại học ngành An toàn thông tin. Dạng tấn công lừa người sử dụng tải, cài đặt và thực hiện các phần mềm độc hại sẽ được đề cập ở Mục 3.4. Phần tiếp theo của mục này chủ yếu đề cập về tấn công chèn mã SQL.

3.3.2.2. Tấn công chèn mã SQL

a. Khái quát

Tấn công chèn mã SQL (SQL injection hay SQLi) là một kỹ thuật cho phép kẻ tấn công chèn mã SQL vào dữ liệu gửi đến máy chủ và cuối cùng được thực hiện trên máy chủ cơ sở dữ liệu của hệ thống nạn nhân. Tùy vào mức độ tinh vi, tấn công chèn mã SQL có thể cho phép kẻ tấn công (1) vượt qua các khâu xác thực người dùng, (2) chèn, xóa hoặc sửa đổi dữ

liệu, (3) đánh cắp các thông tin trong cơ sở dữ liệu và (4) chiếm quyền điều khiển hệ thống máy chủ cơ sở dữ liệu. Tấn công chèn mã SQL là dạng tấn công rất phổ biến ở các ứng dụng web, các trang web có kết nối đến cơ sở dữ liệu.

Hai nguyên nhân chính của lỗ hổng bảo mật trong ứng dụng cho phép thực hiện tấn công chèn mã SQL là:

- Dữ liệu đầu vào từ người dùng hoặc từ các nguồn khác không được kiểm tra, hoặc kiểm tra không đầy đủ;
- Sử dụng các câu lệnh SQL động trong ứng dụng, trong đó có thao tác nối dữ liệu đầu vào từ người dùng với mã lệnh SQL gốc.

b. Vượt qua các khâu xác thực người dùng

Xem xét một form đăng nhập (Log in) và đoạn mã xử lý xác thực người dùng lưu trong bảng cơ sở dữ liệu tbl_accounts(username, password) cho như trên Hình 3.4.

```
<!-- Form đăng nhập -->
<form method="post" action="/log_in.asp">
    Tên đăng nhập: <input type="text" name="username"><br \>
    Mật khẩu: <input type="password" name="password"><br \>
    <input type="submit" name="login" value="Log In">
</form>

<%
' Mã ASP xử lý đăng nhập trong file log_in.asp:
' giả thiết đã kết nối với CSDL SQL servê qua đối tượng
' conn và bảng tbl_accounts lưu thông tin người dùng
Dim username, password, sqlString, rsLogin
' lấy dữ liệu từ form
username = Request.Form("username")
password = Request.Form("password")
' tạo và thực hiện câu truy vấn sql
sqlString = "SELECT * FROM tbl_accounts WHERE username='" &
username & "' AND password = '" & password & "'"
set rsLogin = conn.execute(sqlString)
if (NOT rsLogin.eof()) then
    ' cho phép đăng nhập, bắt đầu phiên làm việc
else
    ' từ chối đăng nhập, báo lỗi
end if
%>
```

Hình 3.4. Form đăng nhập (log in) và đoạn mã xử lý xác thực người dùng

Nếu người dùng nhập 'admin' vào trường *username* và 'abc123' vào trường *password* của form, mã xử lý hoạt động đúng: Nếu tồn tại người dùng với *username* và *password* kể trên, hệ thống sẽ cho phép đăng nhập với thông báo đăng nhập thành công; Ngược lại, nếu không tồn tại người dùng với *username* và *password* đã cung cấp, hệ thống sẽ từ chối đăng nhập và trả lại thông báo lỗi. Tuy nhiên, nếu người dùng nhập *aaaa' OR 1=1--* vào trường *username* và

một chuỗi bất kỳ, chẳng hạn 'aaaa' vào trường *password* của form, mã xử lý hoạt động sai và chuỗi chứa câu truy vấn SQL trở thành:

```
SELECT * FROM tbl_accounts WHERE username='aaaa' OR 1=1--' AND password='aaaa'
```

Câu truy vấn sẽ trả về mọi bản ghi trong bảng do thành phần OR 1=1 làm cho điều kiện trong mệnh đề WHERE trở lên luôn đúng và phần kiểm tra mật khẩu đã bị loại bỏ bởi ký hiệu (--). Phần lệnh SQL sau ký hiệu (--) được coi là chú thích (comment) và không được thực hiện. Nếu trong bảng *tbl_accounts* có chứa ít nhất một bản ghi, kẻ tấn công sẽ luôn đăng nhập thành công vào hệ thống.

c. Chèn, sửa đổi, hoặc xóa dữ liệu

Xem xét một form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm lưu trong bảng cơ sở dữ liệu *tbl_products*(*product_id*, *product_name*, *product_desc*, *product_cost*) cho như trên Hình 3.5.

```
<!-- Form tìm kiếm sản phẩm -->
<form method="post" action="/search.asp">
  Nhập tên sản phẩm: <input type="text" name="keyword">
  <input type="submit" name="search" value="Search">
</form>

<%
' Mã ASP xử lý tìm sản phẩm trong file search.asp:
' giả thiết đã kết nối với CSDL SQL server qua đối tượng
' conn và bảng tbl_products lưu thông tin sản phẩm
Dim keyword, sqlString, rsSearch
' lấy dữ liệu từ form
keyword = Request.Form(" keyword")
' tạo và thực hiện câu truy vấn SQL
sqlString = "SELECT * FROM tbl_products WHERE product_name
like '%" & keyword & "%'"
set rsSearch = conn.execute(sqlString)
if (NOT rsSearch.eof()) then
  ' hiển thị danh sách các sản phẩm
else
  ' thông báo không tìm thấy sản phẩm
end if
%>
```

Hình 3.5. Form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm

Nếu người dùng nhập chuỗi "Samsung Galaxy S9" vào trường *keyword* của form, mã xử lý hoạt động đúng: Nếu tìm thấy các sản phẩm có tên chứa từ khóa, hệ thống sẽ hiển thị danh sách các sản phẩm tìm thấy; Ngược lại, nếu không tìm thấy sản phẩm nào có tên chứa từ khóa, hệ thống thông báo không tìm thấy sản phẩm. Tuy nhiên, nếu người dùng nhập chuỗi "Samsung Galaxy S9';DELETE FROM tbl_products;--" vào trường *keyword* của form, mã xử lý sẽ hoạt động sai và chuỗi chứa câu truy vấn SQL trở thành:

```
SELECT * FROM tbl_products WHERE keyword like '%Samsung Galaxy S9';DELETE
FROM tbl_products;--'
```

Chuỗi lệnh SQL mới gồm 2 câu lệnh SQL: câu lệnh SELECT tìm kiếm các sản phẩm có tên chứa từ khóa "Samsung Galaxy S9" trong bảng tbl_products và câu lệnh DELETE xóa tất cả các sản phẩm lưu trong bảng tbl_products. Sở dĩ điều này có thể thực hiện được là do hệ quản trị cơ sở dữ liệu MS-SQL server nói riêng và hầu hết các hệ quản trị cơ sở dữ liệu quan hệ nói chung cho phép thực hiện nhiều lệnh SQL theo lô và dùng dấu ; để ngăn cách các lệnh trong chuỗi lệnh. Ký hiệu "--" dùng để hủy tác dụng của phần lệnh còn lại nếu có.

Bằng thủ thuật tương tự, kẻ tấn công có thể thay lệnh DELETE bằng lệnh UPDATE hoặc INSERT để chỉnh sửa, hoặc chèn thêm các bản ghi trong bảng cơ sở dữ liệu. Chẳng hạn, kẻ tấn công chèn thêm lệnh UPDATE để cập nhật mật khẩu của người quản trị bằng cách nhập chuỗi sau làm từ khóa tìm kiếm (giả thiết bảng tbl_administrators chứa thông tin tài khoản người quản trị):

```
Galaxy S9';UPDATE tbl_administrators SET password='abc123'
WHERE username = 'admin';--
```

Hoặc kẻ tấn công có thể chèn thêm bản ghi vào bảng tbl_administrators bằng cách nhập chuỗi sau làm từ khóa tìm kiếm:

```
Galaxy S9';INSERT INTO tbl_administrators (username, password)
VALUES ('attacker', 'abc12345');--
```

d. Đánh cắp các thông tin trong cơ sở dữ liệu

Lỗ hổng chèn mã SQL cho phép kẻ tấn công có thể đánh cắp dữ liệu trong cơ sở dữ liệu thông qua một số bước như sau:

- (1) Tìm lỗ hổng chèn mã SQL và thăm dò các thông tin về hệ quản trị cơ sở dữ liệu:
 - + Nhập một số dữ liệu mẫu vào các trường nhập liệu hoặc URL để kiểm tra một trang web có chứa lỗ hổng chèn mã SQL, như các dấu nháy đơn, dấu --,...
 - + Tìm phiên bản máy chủ cơ sở dữ liệu: nhập các câu lệnh lỗi và kiểm tra thông báo lỗi, hoặc sử dụng biến @@version (với MS-SQL Server), hoặc hàm version() (với MySQL) trong câu lệnh ghép với UNION SELECT.
- (2) Tìm thông tin về số lượng và kiểu dữ liệu các trường của câu truy vấn hiện tại của trang web.
 - + Sử dụng mệnh đề ORDER BY <số thứ tự của trường>
 - + Sử dụng UNION SELECT 1, 2, 3, ...
- (3) Trích xuất thông tin về các bảng, các trường của cơ sở dữ liệu thông qua các bảng hệ thống (metadata). Chẳng hạn, với hệ quản trị cơ sở dữ liệu MS-SQL Server, các bảng sys.objects, sys.tables và sys.columns được sử dụng tương ứng để lưu thông tin về các đối tượng, các bảng dữ liệu người dùng và các trường của các bảng.
- (4) Sử dụng UNION SELECT để ghép các thông tin định trích xuất vào câu truy vấn hiện tại của ứng dụng.

e. Chiếm quyền điều khiển hệ thống máy chủ cơ sở dữ liệu

Khả năng máy chủ cơ sở dữ liệu bị chiếm quyền điều khiển xảy ra khi trang web tồn tại đồng thời 2 lỗ hổng bảo mật: (1) lỗ hổng cho phép tấn công chèn mã SQL và (2) lỗ hổng thiết lập quyền truy nhập cơ sở dữ liệu. Lỗ hổng (2) liên quan đến việc sử dụng người dùng có quyền quản trị để truy nhập và thao tác dữ liệu của trang web. Khai thác 2 lỗ hổng này, kẻ tấn công có thể gọi thực hiện các lệnh hệ thống của máy chủ cơ sở dữ liệu cho phép can thiệp sâu vào cơ sở dữ liệu, hệ quản trị cơ sở dữ liệu và cả hệ điều hành nền. Chẳng hạn, hệ quản trị cơ sở dữ liệu MS-SQL Server cung cấp thủ tục `sp_send_dbmail` cho phép gửi email từ máy chủ cơ sở dữ liệu và thủ tục `xp_cmdshell` cho phép chạy các lệnh và chương trình cài đặt trên hệ điều hành Microsoft Windows. Sau đây là một số ví dụ chạy các lệnh Microsoft Windows thông qua thủ tục `xp_cmdshell`:

EXEC xp_cmdshell 'dir *.exe' : liệt kê nội dung thư mục hiện thời

EXEC xp_cmdshell 'shutdown /s /t 00' : tắt máy chủ nền chạy hệ quản trị CSDL

EXEC xp_cmdshell 'net stop W3SVC' : dừng hoạt động máy chủ web trên cùng hệ thống

EXEC xp_cmdshell 'net stop MSSQLSERVER' : dừng hoạt động máy chủ CSDL

Ngoài ra, kẻ tấn công có thể thực hiện các thao tác nguy hiểm đến cơ sở dữ liệu nếu có quyền của người quản trị cơ sở dữ liệu, hoặc quản trị hệ thống, như:

Xóa cả bảng (gồm cả cấu trúc): DROP TABLE <tên bảng>

Xóa cả cơ sở dữ liệu: DROP DATABASE <tên CSDL>

Tạo 1 tài khoản mới truy nhập CSDL: sp_addlogin <username> <password>

Đổi mật khẩu tài khoản truy nhập CSDL: sp_password <password>

f. Phòng chống

Do tính chất nguy hiểm của tấn công chèn mã SQL, nhiều giải pháp đã được đề xuất nhằm hạn chế tác hại và ngăn chặn triệt để dạng tấn công này. Nhìn chung, cần áp dụng kết hợp các biện pháp phòng chống tấn công chèn mã SQL để đảm bảo an toàn cho hệ thống. Các biện pháp, kỹ thuật cụ thể có thể áp dụng gồm:

(1) Kiểm tra và lọc dữ liệu đầu vào:

- + Kiểm tra tất cả các dữ liệu đầu vào, đặc biệt dữ liệu nhập từ người dùng và từ các nguồn không tin cậy;
- + Kiểm tra kích thước và định dạng dữ liệu đầu vào;
- + Tạo các bộ lọc để lọc bỏ các ký tự đặc biệt (như *, ', =, --) và các từ khóa của ngôn ngữ SQL (SELECT, INSERT, UPDATE, DELETE, DROP,...) mà kẻ tấn công có thể sử dụng.

(2) Sử dụng thủ tục cơ sở dữ liệu (stored procedure) và cơ chế tham số hóa dữ liệu:

- + Đưa tất cả các câu truy vấn (SELECT) và cập nhật, sửa, xóa dữ liệu (INSERT, UPDATE, DELETE) vào các thủ tục. Dữ liệu truyền vào thủ tục thông qua các tham số, giúp tách dữ liệu khỏi mã lệnh SQL, nhờ đó ngăn chặn hiệu quả tấn công chèn mã SQL;

- + Hạn chế thực hiện các câu lệnh SQL động trong thủ tục;
- + Sử dụng cơ chế tham số hóa dữ liệu được hỗ trợ bởi nhiều ngôn ngữ lập trình web như ASP.NET, PHP và JSP.

(3) Thiết lập quyền truy nhập phù hợp cho người dùng cơ sở dữ liệu:

- + Không sử dụng người dùng có quyền quản trị hệ thống hoặc quản trị cơ sở dữ liệu làm người dùng truy cập dữ liệu. Ví dụ: không dùng người dùng *sa* (Microsoft SQL) hoặc *root* (MySQL) làm người dùng truy cập dữ liệu. Chỉ dùng các người dùng này cho mục đích quản trị cơ sở dữ liệu.
- + Chia nhóm người dùng, chỉ cấp quyền vừa đủ để truy cập các bảng biểu, thực hiện câu truy vấn và chạy các thủ tục.
- + Trường hợp tốt nhất, không cấp quyền thực hiện các câu truy vấn, cập nhật, sửa, xóa trực tiếp trên các bảng dữ liệu. Thủ tục hóa tất cả các câu lệnh SQL và chỉ cấp quyền thực hiện thủ tục.
- + Cấm hoặc vô hiệu hóa (disable) việc thực hiện các thủ tục hệ thống (các thủ tục hỗ trợ sẵn trong hệ quản trị cơ sở dữ liệu) cho phép can thiệp vào hệ quản trị cơ sở dữ liệu và hệ điều hành nền.

(4) Sử dụng các công cụ rà quét lỗ hổng chèn mã SQL, như SQLMap, hoặc Acunetix Vulnerability Scanner để chủ động rà quét, tìm các lỗ hổng chèn mã SQL và có biện pháp khắc phục phù hợp.

3.3.3. Tấn công từ chối dịch vụ và tấn công từ chối dịch vụ phân tán

3.3.3.1. Tấn công từ chối dịch vụ

a. Giới thiệu

Tấn công từ chối dịch vụ (Denial of Service - DoS) là dạng tấn công nhằm ngăn chặn người dùng hợp pháp truy nhập các tài nguyên mạng. Tấn công DoS có thể được chia thành 2 loại: (1) tấn công logic (Logic attack) và (2) tấn công gây ngập lụt (Flooding attack). Tấn công logic là dạng tấn công khai thác các lỗi phần mềm làm dịch vụ ngừng hoạt động, hoặc làm giảm hiệu năng hệ thống. Tấn công DoS sử dụng sâu SQL Slammer đề cập ở Mục 2.2.1.2.c là dạng tấn công khai thác lỗi tràn bộ đệm trong phần mềm. Ngược lại, trong tấn công gây ngập lụt, kẻ tấn công gửi một lượng lớn yêu cầu gây cạn kiệt tài nguyên hệ thống hoặc băng thông đường truyền mạng.

Có nhiều kỹ thuật tấn công DoS đã được phát hiện trên thực tế. Các kỹ thuật tấn công DoS thường gặp bao gồm: SYN Flood, Smurf, Teardrop, Ping of Death, Land Attack, ICMP Flood, HTTP Flood, UDP Flood,... Trong phạm vi của môn học này, chúng ta chỉ đề cập đến 2 kỹ thuật phổ biến nhất là SYN Flood và Smurf.

b. Tấn công SYN flood

* Giới thiệu

Tấn công SYN Flood là kỹ thuật tấn công DoS khai thác điểm yếu trong thủ tục bắt tay 3 bước (3-way handshake) khi hai bên tham gia truyền thông thiết lập kết nối TCP để bắt đầu phiên trao đổi dữ liệu. SYN là bit cờ điều khiển của giao thức TCP dùng để đồng bộ số trình

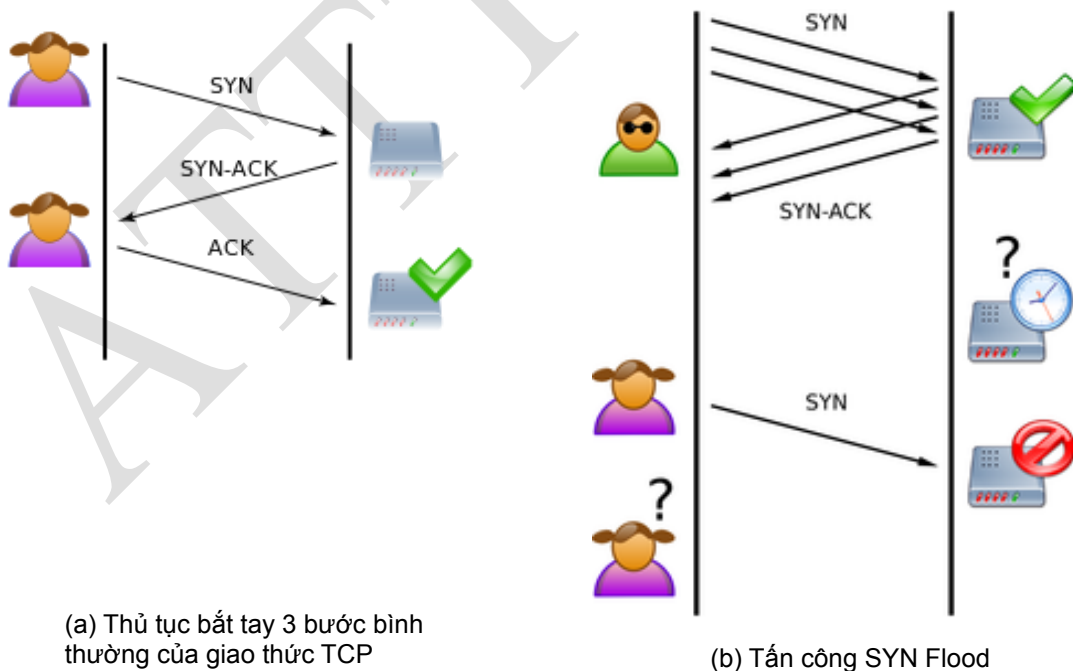
tự gói tin. Thủ tục bắt tay khi một người dùng hợp pháp thiết lập một kết nối TCP đến máy chủ, như minh họa trên hình Hình 3.6 (a) gồm 3 bước như sau:

- (1) Người dùng thông qua máy khách gửi yêu cầu mở kết nối (SYN hay SYN-REQ) đến máy chủ;
- (2) Máy chủ nhận được yêu cầu kết nối, lưu vào Bảng kết nối (Backlog) và gửi lại xác nhận kết nối SYN-ACK cho máy khách;
- (3) Khi nhận được SYN-ACK từ máy chủ, máy khách gửi lại xác nhận kết nối ACK đến máy chủ. Khi máy chủ nhận được xác nhận kết nối ACK từ máy khách, nó xác nhận kết nối mở thành công, máy chủ và máy khách bắt đầu phiên truyền thông TCP. Bản ghi mở kết nối được xóa khỏi Bảng kết nối.

** Kịch bản tấn công*

Kịch bản tấn công SYN Flood, như minh họa trên Hình 3.6 (b) gồm các bước sau:

- (1) Kẻ tấn công gửi một lượng lớn yêu cầu mở kết nối (SYN-REQ) đến máy nạn nhân;
- (2) Nhận được yêu cầu mở kết nối, máy nạn nhân lưu yêu cầu kết nối vào Bảng kết nối trong bộ nhớ;
- (3) Máy nạn nhân sau đó gửi xác nhận kết nối (SYN-ACK) đến kẻ tấn công;
- (4) Do kẻ tấn công không gửi lại xác nhận kết nối ACK, nên máy nạn nhân vẫn phải lưu tất cả các yêu cầu kết nối chưa được xác nhận trong Bảng kết nối. Khi Bảng kết nối bị điền đầy thì các yêu cầu mở kết nối của người dùng hợp pháp sẽ bị từ chối;
- (5) Máy nạn nhân chỉ có thể xóa một yêu cầu kết nối đang mở khi nó hết hạn (timed-out).



Hình 3.6. (a) Thủ tục bắt tay 3 bước của giao thức TCP và (b) Tấn công SYN Flood

Do kẻ tấn công thường sử dụng địa chỉ IP giả mạo, hoặc địa chỉ không có thực làm địa chỉ nguồn (Source IP) trong gói tin IP của yêu cầu mở kết nối, nên xác nhận kết nối SYN-ACK

gửi từ máy nạn nhân không thể đến đích. Đồng thời, kẻ tấn công cố tình tạo một lượng rất lớn yêu cầu mở kết nối dở dang để chúng điền đầy Bảng kết nối. Hậu quả là máy nạn nhân không thể chấp nhận yêu cầu mở kết nối của những người dùng khác. Tấn công SYN Flood làm cạn kiệt tài nguyên bộ nhớ (cụ thể là bộ nhớ Bảng kết nối) của máy nạn nhân, có thể làm máy nạn nhân ngừng hoạt động và gây nghẽn đường truyền mạng.

* Phòng chống

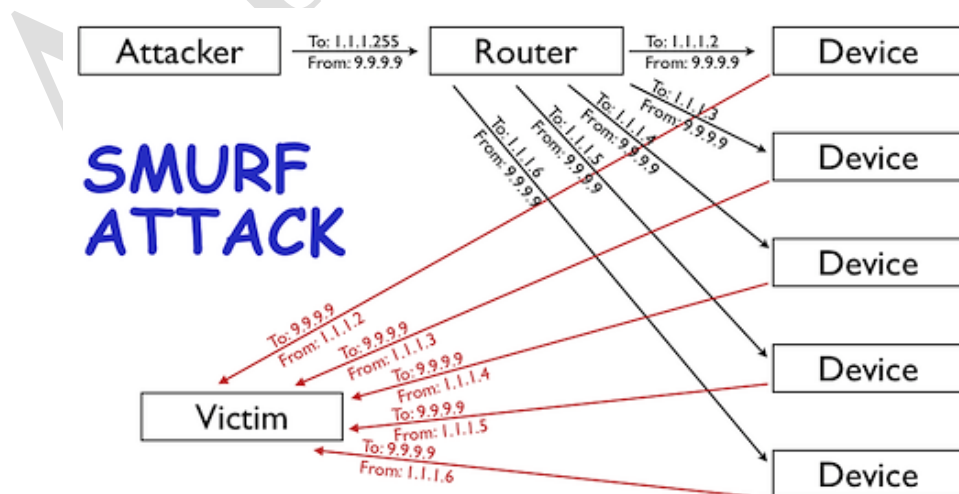
Nhiều biện pháp phòng chống tấn công SYN Flood được đề xuất, nhưng chưa có giải pháp nào có khả năng ngăn chặn triệt để dạng tấn công này. Do vậy, để phòng chống tấn công SYN Flood hiệu quả, cần kết hợp các biện pháp sau:

- Sử dụng kỹ thuật lọc địa chỉ giả mạo (Spoofed IP Filtering): Kỹ thuật này đòi hỏi chỉnh sửa giao thức TCP/IP nhằm không cho phép kẻ tấn công giả mạo địa chỉ;
- Tăng kích thước Bảng kết nối: Tăng kích thước Bảng kết nối cho phép tăng khả năng chấp nhận các yêu cầu mở kết nối;
- Giảm thời gian chờ (SYN-RECEIVED Timer): Các yêu cầu mở kết nối chưa được xác nhận sẽ bị xóa sớm hơn khi thời gian chờ ngắn hơn;
- SYN cache: Một yêu cầu mở kết nối chỉ được cấp phát không gian nhớ đầy đủ khi nó được xác nhận;
- Sử dụng tường lửa (Firewall) và Proxy: Tường lửa và proxy có khả năng nhận dạng các địa chỉ IP nguồn là địa chỉ không có thực, đồng thời chúng có khả năng tiếp nhận yêu cầu mở kết nối, chờ đến khi có xác nhận mới chuyển cho máy chủ đích.

c. Tấn công Smurf

* Giới thiệu

Tấn công Smurf là dạng tấn công DoS sử dụng giao thức điều khiển truyền ICMP và kiểu phát quảng bá có định hướng để gây ngập lụt đường truyền mạng của máy nạn nhân. Trên mỗi phân vùng mạng IP thường có 1 địa chỉ quảng bá, theo đó khi có một gói tin gửi tới địa chỉ này, nó sẽ được router của mạng chuyển đến tất cả các máy trong mạng đó.



Hình 3.7. Mô hình tấn công Smurf

*** Kịch bản tấn công**

Hình 3.7 minh họa mô hình tấn công Smurf. Theo đó, kịch bản tấn công Smurf gồm các bước:

- (1) Kẻ tấn công gửi một lượng lớn gói tin chứa yêu cầu ICMP (Ping) với địa chỉ IP nguồn là địa chỉ của máy nạn nhân đến một địa chỉ quảng bá (IP Broadcast address) của một mạng;
- (2) Router của mạng nhận được yêu cầu ICMP gửi đến địa chỉ quảng bá sẽ tự động chuyển yêu cầu này đến tất cả các máy trong mạng;
- (3) Các máy trong mạng nhận được yêu cầu ICMP sẽ gửi trả lời (reply) đến máy có địa chỉ IP là địa nguồn trong yêu cầu ICMP (là máy nạn nhân). Nếu số lượng máy trong mạng rất lớn thì máy nạn nhân sẽ bị ngập lụt đường truyền, hoặc ngừng hoạt động.

*** Phòng chống**

Có thể sử dụng các biện pháp sau để phòng chống tấn công Smurf:

- Cấu hình các máy trong mạng và router không trả lời các yêu cầu ICMP, hoặc các yêu cầu phát quảng bá;
- Cấu hình các router không chuyển tiếp yêu cầu ICMP gửi đến các địa chỉ quảng bá;
- Sử dụng tường lửa để lọc các gói tin với địa chỉ giả mạo địa chỉ trong mạng.

Việc cấu hình các router không chuyển tiếp yêu cầu ICMP, hoặc các máy trong mạng không trả lời các yêu cầu ICMP có thể gây khó khăn cho các ứng dụng dựa trên phát quảng bá và giao thức ICMP, như ứng dụng giám sát trạng thái hoạt động của các máy trong mạng dựa trên ICMP/Ping.

3.3.3.2. Tấn công từ chối dịch vụ phân tán**a. Giới thiệu**

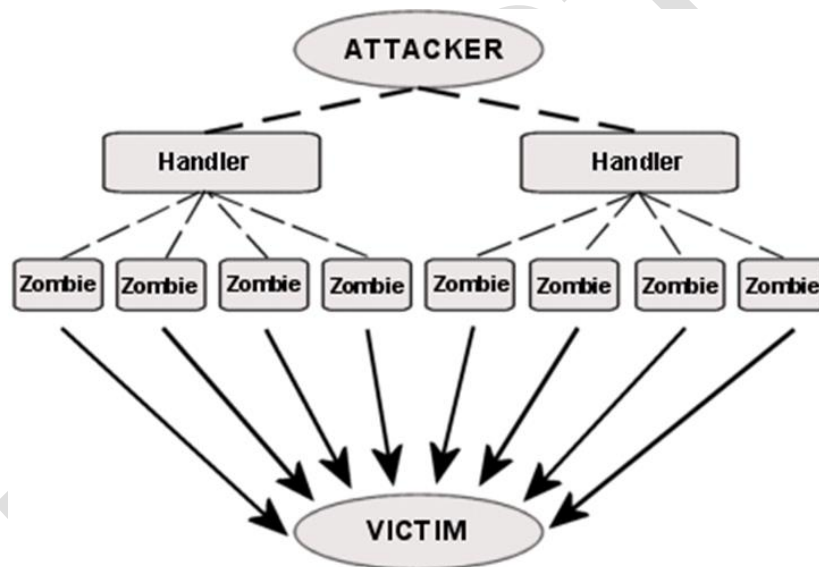
Tấn công từ chối dịch vụ phân tán (Distributed Denial of Service - DDoS) là một loại tấn công DoS đặc biệt, liên quan đến việc gây ngập lụt các máy nạn nhân với một lượng rất lớn các yêu cầu kết nối giả mạo. Điểm khác biệt chính giữa DDoS và DoS là phạm vi (scope) tấn công: trong khi số lượng máy tham gia tấn công DoS thường tương đối nhỏ, chỉ gồm một số ít máy tại một, hoặc một số ít địa điểm, thì số lượng máy tham gia tấn công DDoS thường rất lớn, có thể lên đến hàng ngàn, hoặc hàng trăm ngàn máy. Đồng thời, các máy tham gia tấn công DDoS có thể đến từ rất nhiều vị trí địa lý khác nhau trên toàn cầu. Do vậy, việc phòng chống tấn công DDoS gặp nhiều khó khăn hơn so với việc phòng chống tấn công DoS.

Có thể chia tấn công DDoS thành 2 dạng chính theo mô hình kiến trúc: tấn công DDoS trực tiếp (Direct DDoS) và tấn công DDoS gián tiếp, hay phản xạ (Indirect/Reflective DDoS). Trong tấn công DDoS trực tiếp, các yêu cầu tấn công được các máy tấn công gửi trực tiếp đến máy nạn nhân. Ngược lại, trong tấn công DDoS gián tiếp, các yêu cầu tấn công được gửi đến các máy phản xạ (Reflector) và sau đó gián tiếp chuyển đến máy nạn nhân.

b. Tấn công DDoS trực tiếp

Hình 3.8 minh họa kiến trúc điển hình của dạng tấn công DDoS trực tiếp. Tấn công DDoS trực tiếp được thực hiện theo nhiều giai đoạn theo kịch bản như sau:

- (1) Kẻ tấn công (Attacker) chiếm quyền điều khiển hàng ngàn, thậm chí hàng chục ngàn máy tính trên mạng Internet, sau đó bí mật cài đặt các agent tự động (Automated agent) lên các máy này. Các agent tự động cho phép kẻ tấn công điều khiển máy tính từ xa. Các máy tính được cài đặt agent tự động và bị điều khiển từ xa được gọi là các Bot hoặc Zombie (Máy tính ma);
- (2) Các máy bị điều khiển từ xa hình thành mạng máy tính ma, gọi là botnet hay zombie network. Các botnet, hay zombie network không bị giới hạn bởi chủng loại thiết bị và tổ pô mạng vật lý;
- (3) Kẻ tấn công có thể giao tiếp với các máy bot, zombie thông qua một mạng lưới các máy trung gian (Handler) gồm nhiều tầng. Phương thức giao tiếp có thể là IRC (Internet Relay Chat), P2P (Peer to Peer), HTTP,...
- (4) Tiếp theo, kẻ tấn công ra lệnh cho các bot đồng loạt tạo các yêu cầu giả mạo gửi đến các máy nạn nhân tạo thành cuộc tấn công DDoS;
- (5) Lượng yêu cầu giả mạo có thể rất lớn, đến từ rất nhiều nguồn với vị trí địa lý khác nhau nên rất khó đối phó và lần vết để tìm ra kẻ tấn công thực sự.



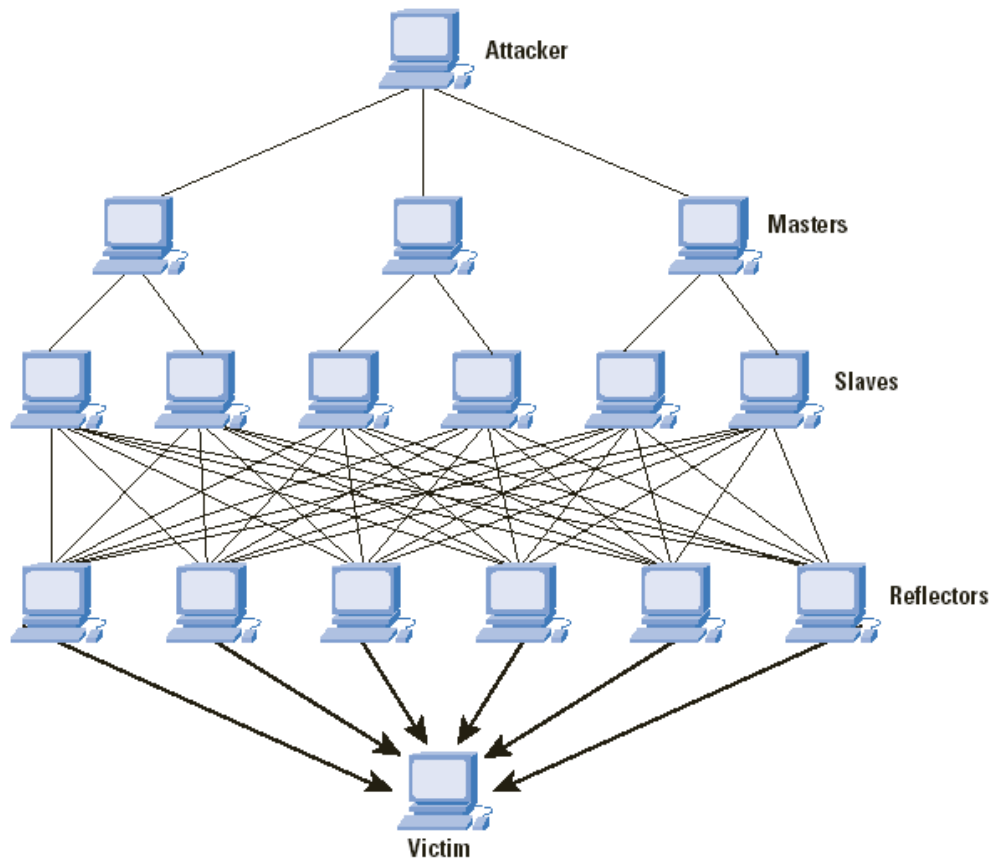
Hình 3.8. Kiến trúc tấn công DDoS trực tiếp

c. Tấn công DDoS gián tiếp

Hình 3.9 minh họa kiến trúc tấn công DDoS gián tiếp, hay phản xạ. Tấn công DDoS gián tiếp cũng được thực hiện theo nhiều giai đoạn theo kịch bản như sau:

- (1) Kẻ tấn công chiếm quyền điều khiển của một lượng lớn máy tính trên mạng Internet, sau đó cài đặt agent tự động và biến chúng thành các bot, hay zombie (còn gọi là slave). Các bot hình thành nên mạng botnet;
- (2) Theo lệnh của kẻ tấn công, các Slave/Zombie trong botnet gửi một lượng lớn yêu cầu giả mạo với địa chỉ nguồn là địa chỉ máy nạn nhân đến một số lớn các máy khác (Reflector – máy phản xạ) trên mạng Internet;
- (3) Các Reflector gửi các phản hồi (Reply) đến máy nạn nhân do địa chỉ của máy nạn nhân được đặt vào địa chỉ nguồn của yêu cầu giả mạo;

- (4) Khi các yêu cầu giả mạo gửi đến các Reflector có số lượng rất lớn, số lượng phản hồi cũng sẽ rất lớn gây ngập lụt đường truyền mạng, hoặc làm cạn kiệt tài nguyên của máy nạn nhân, dẫn đến ngắt quãng hoặc ngừng dịch vụ cung cấp cho người dùng. Các Reflector bị lợi dụng để tham gia tấn công thường là các hệ thống máy chủ có công suất lớn trên mạng Internet và không chịu sự điều khiển của kẻ tấn công.



Hình 3.9. Kiến trúc tấn công DDoS gián tiếp hay phản xạ

d. Phòng chống tấn công DDoS

Nhìn chung, để phòng chống tấn công DDoS hiệu quả, cần kết hợp nhiều biện pháp và sự phối hợp của nhiều bên do tấn công DDoS có tính phân tán cao và hệ thống mạng máy tính ma (botnet) được hình thành và điều khiển theo nhiều tầng, lớp. Sau đây là một số biện pháp có thể xem xét áp dụng:

- Sử dụng các phần mềm rà quét vi rút và các phần mềm độc hại khác nhằm loại bỏ các loại bot, zombie, slave khỏi các hệ thống máy tính;
- Sử dụng các hệ thống lọc đặt trên các router, tường lửa của các nhà cung cấp dịch vụ Internet (ISP) để lọc các yêu cầu điều khiển (C&C – Command and Control) gửi từ kẻ tấn công đến các bot;
- Sử dụng các hệ thống giám sát, phát hiện bất thường, nhằm phát hiện sớm các dấu hiệu của tấn công DDoS.
- Sử dụng tường lửa để chặn (block) tạm thời các cổng dịch vụ bị tấn công.

3.3.4. Tấn công giả mạo địa chỉ

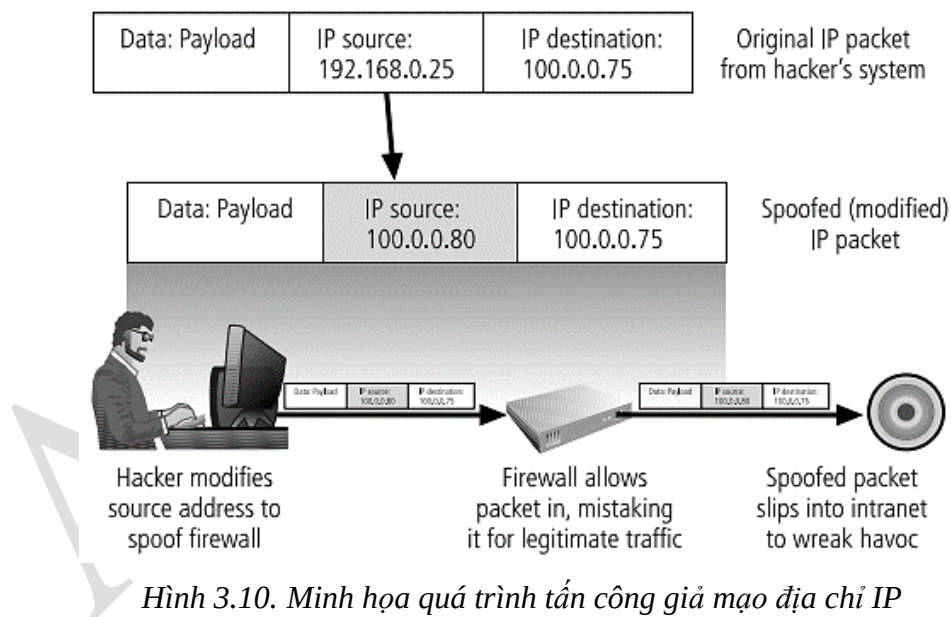
3.3.4.1. Giới thiệu

Dạng tấn công giả mạo địa chỉ thường gặp nhất là tấn công giả mạo địa chỉ IP, trong đó kẻ tấn công sử dụng địa chỉ IP giả làm địa chỉ nguồn (Source IP) của các gói tin IP, thường để đánh lừa máy nạn nhân vượt qua hàng rào kiểm soát an ninh thông thường. Chẳng hạn, nếu kẻ tấn công giả địa chỉ IP là địa chỉ cục bộ của mạng LAN, hẳn có thể có nhiều cơ hội xâm nhập vào các máy khác trong mạng LAN đó do chính sách kiểm soát an ninh với các máy trong cùng mạng LAN thường được giảm nhẹ.

3.3.4.2. Kịch bản

Hình 3.10 minh họa một cuộc tấn công giả mạo địa chỉ IP vào một máy nạn nhân trong mạng cục bộ. Các bước thực hiện như sau:

- (1) Giả sử máy tính của kẻ tấn công có địa chỉ IP là 192.168.0.25 (IP source) và hắn muốn gửi gói tin tấn công đến máy nạn nhân có địa chỉ IP là 100.0.0.75 (IP destination);
- (2) Kẻ tấn công tạo và gửi yêu cầu giả mạo với địa chỉ IP nguồn của các gói tin IP của yêu cầu là 100.0.0.80 đến máy nạn nhân. Địa chỉ 100.0.0.80 là địa chỉ cùng mạng LAN với máy nạn nhân 100.0.0.75;
- (3) Nếu tường lửa của mạng LAN không lọc được các gói tin với địa chỉ nguồn giả mạo, yêu cầu giả mạo của kẻ tấn công có thể đến được và gây tác hại cho máy nạn nhân.



Hình 3.10. Minh họa quá trình tấn công giả mạo địa chỉ IP

3.3.4.3. Phòng chống

Biện pháp phòng chống tấn công giả mạo địa chỉ IP hiệu quả nhất là sử dụng kỹ thuật lọc trên tường lửa, hoặc các router với nguyên tắc lọc: các gói tin từ mạng ngoài đi vào mạng LAN mà có địa chỉ nguồn (Source IP) là địa chỉ nội bộ của mạng LAN đó thì chúng là các gói tin giả mạo và phải bị chặn.

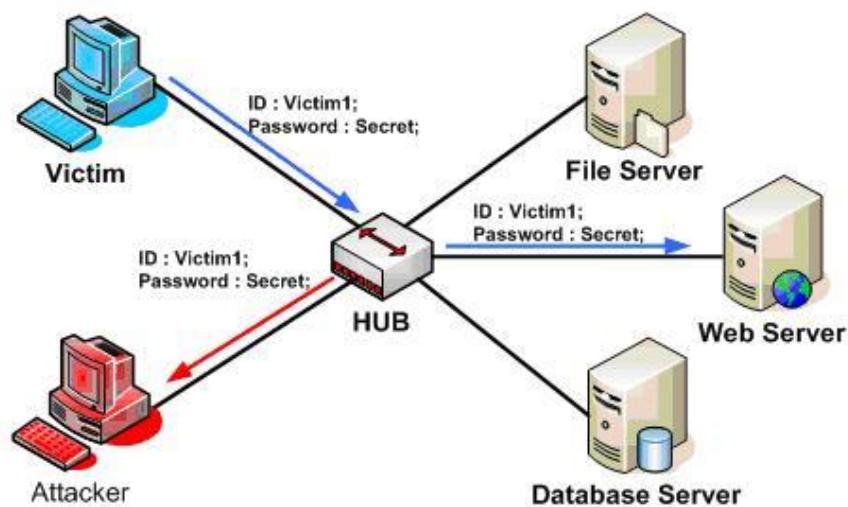
3.3.5. Tấn công nghe lén

Tấn công nghe lén (Sniffing/Eavesdropping), như minh họa trên 0 là dạng tấn công sử dụng thiết bị phần cứng hoặc phần mềm, lắng nghe trên card mạng, hub, switch, router, hoặc

môi trường truyền dẫn để bắt các gói tin dùng cho phân tích, hoặc lạm dụng về sau. Đây là kiểu tấn công thụ động nhằm thu thập các thông tin nhạy cảm, hoặc giám sát lưu lượng mạng. Các thông tin nhạy cảm như tên người dùng, mật khẩu, thông tin thanh toán nếu không được mã hóa có thể bị nghe lén và lạm dụng. Các thông tin truyền trong mạng WiFi, hoặc các mạng không dây cũng có thể bị nghe lén dễ dàng do môi trường truyền dẫn vô tuyến và nếu không sử dụng các cơ chế bảo mật đủ mạnh.

Để phòng chống tấn công nghe lén, có thể áp dụng các biện pháp sau:

- Có cơ chế bảo vệ các thiết bị mạng và hệ thống truyền dẫn ở mức vật lý;
- Sử dụng các biện pháp, cơ chế xác thực người dùng đủ mạnh;
- Sử dụng các biện pháp bảo mật thông tin truyền dựa trên các kỹ thuật mã hóa.



Hình 3.11. Một mô hình tấn công nghe lén

3.3.6. Tấn công kiểu người đứng giữa

3.3.6.1. Giới thiệu

Tấn công kiểu người đứng giữa (Man in the middle) là dạng tấn công khai thác quá trình chuyển gói tin đi qua nhiều trạm (hop) thuộc các mạng khác nhau, trong đó kẻ tấn công chặn bắt các thông điệp giữa 2 bên tham gia truyền thông và chuyển thông điệp lại cho bên kia. Mục đích chính của dạng tấn công này là đánh cắp thông tin. Hình 3.12 minh họa mô hình chung của tấn công kiểu người đứng giữa trong một phiên truyền file ở dạng rõ (plaintext) sử dụng giao thức FTP giữa máy khách (Client) và máy chủ (Server).

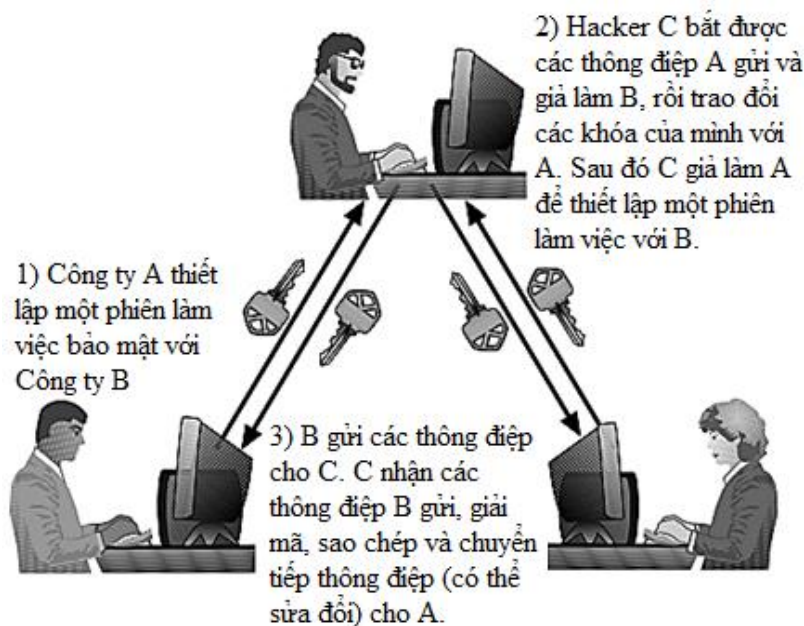


Hình 3.12. Mô hình chung của tấn công kiểu người đứng giữa

3.3.6.2. Kịch bản

Hình 3.13 biểu diễn một kịch bản tấn công kiểu người đứng giữa, trong đó hai bên A và B (Công ty A và Công ty B) trao đổi các thông điệp bí mật và kẻ tấn công C (Hacker) chặn bắt và có thể sửa đổi, lạm dụng các thông điệp trao đổi giữa A và B. Các bước tấn công cụ thể như sau:

- (1) A gửi các thông điệp để thiết lập một phiên làm việc bảo mật với B;
- (2) C bắt được các thông điệp A gửi và giả làm B, rồi trao đổi các khóa của mình với A. Sau đó C giả làm A để thiết lập một phiên làm việc với B (có trao đổi khóa với B);
- (3) B gửi các thông điệp cho C mà vẫn tưởng như đang liên lạc với A. C nhận các thông điệp B gửi, giải mã bằng khóa của mình (và có thể sửa đổi), sau đó chuyển tiếp thông điệp cho A. A nhận các thông điệp mà không biết là chúng đã bị C lạm dụng.



Hình 3.13. Một kịch bản tấn công kiểu người đứng giữa

3.3.6.3. Phòng chống

Một trong các biện pháp hiệu quả để phòng chống tấn công kiểu người đứng giữa là hai bên tham gia truyền thông phải có cơ chế xác thực thông tin nhận dạng của nhau và xác thực tính toàn vẹn của các thông điệp trao đổi. Chẳng hạn, các bên có thể sử dụng chứng chỉ số khóa công khai (Public key certificate) để xác thực thông tin nhận dạng của nhau và sử dụng chữ ký số để đảm bảo tính toàn vẹn của các thông điệp trao đổi.

3.3.7. Tấn công bằng bom thư và thư rác

Tấn công bằng bom thư (Mail bombing) là một dạng tấn công DoS khi kẻ tấn công gửi một lượng rất lớn email đến hộp thư của nạn nhân. Khi đó hộp thư và cả máy chủ nạn nhân có thể bị tê liệt và không thể hoạt động bình thường. Tấn công bằng bom thư có thể được thực hiện bằng một số thủ thuật như sau:

- Gửi bom thư bằng cách sử dụng kỹ thuật xã hội, đánh lừa người dùng phát tán email;
- Khai thác lỗi trong hệ thống gửi nhận email SMTP;

- Lợi dụng các máy chủ email không được cấu hình tốt để gửi email cho chúng.

Tấn công bằng thư rác (Email spamming) là dạng tấn công gửi các thư không mong muốn, như thư quảng cáo, thư chứa các phần mềm độc hại. Theo một số thống kê, khoảng 70-80% lượng email gửi trên mạng Internet là thư rác. Kẻ tấn công thường sử dụng các máy tính bị điều khiển (bot/zombie) để gửi email cho chúng. Spam email gây lãng phí tài nguyên tính toán và thời gian của người dùng.

3.3.8. Tấn công sử dụng các kỹ thuật xã hội

3.3.8.1. Giới thiệu

Tấn công sử dụng các kỹ thuật xã hội (Social engineering) là dạng tấn công phi kỹ thuật nhằm vào người dùng. Dạng tấn công này khai thác các điểm yếu cố hữu của người dùng, như tính cả tin, ngây thơ, tò mò và lòng tham. Dạng thường gặp của kiểu tấn công này là thuyết phục người dùng tiết lộ thông tin truy nhập hoặc các thông tin có giá trị cho kẻ tấn công. Một số kỹ thuật mà kẻ tấn công thường áp dụng gồm:

- Kẻ tấn công có thể giả danh làm người có vị trí cao hơn so với nạn nhân để có được sự tin tưởng, từ đó thuyết phục hoặc đánh lừa nạn nhân cung cấp thông tin;
- Kẻ tấn công có thể mạo nhận là người được ủy quyền của người có thẩm quyền để yêu cầu các nhân viên tiết lộ thông tin về cá nhân, hoặc tổ chức;
- Kẻ tấn công có thể lập trang web giả để đánh lừa người dùng cung cấp các thông tin cá nhân, thông tin tài khoản, thẻ tín dụng,...

3.3.8.2. Trò lừa đảo Nigeria 4-1-9

Trò lừa đảo Nigeria 4-1-9 là một trong các dạng tấn công sử dụng các kỹ thuật xã hội nổi tiếng nhất, trong đó đã có hàng chục nghìn người ở Hoa Kỳ, Canada và Châu Âu đã sập bẫy của kẻ lừa đảo. Kẻ lừa đảo lợi dụng sự ngây thơ và lòng tham của một số người với kịch bản tóm tắt như sau:

- (1) Kẻ lừa đảo gửi thư tay, hoặc email đến nhiều người nhận, mô tả về việc có 1 khoản tiền lớn (từ thừa kế, hoặc lợi tức,..) cần chuyển ra nước ngoài, nhờ người nhận giúp đỡ để hoàn thành giao dịch. Khoản tiền có thể lên đến hàng chục, hoặc trăm triệu USD. Kẻ lừa đảo hứa sẽ trả cho người tham gia một phần số tiền, có thể lên đến 20-30% khoản tiền;
- (2) Nếu người nhận có phản hồi và đồng ý tham gia, kẻ lừa đảo sẽ gửi tiếp thư, hoặc email khác, yêu cầu chuyển trước cho hắn 1 khoản phí giao dịch chuyển tiền (từ vài ngàn đến hàng chục ngàn USD) với lý do hắn không có đủ tiền và khoản tiền trên không thể rút ra ở trong nước;
- (3) Nếu người nhận gửi tiền phí giao dịch theo yêu cầu thì người đó sẽ mất tiền, do giao dịch mà kẻ lừa đảo hứa hẹn là giả mạo.

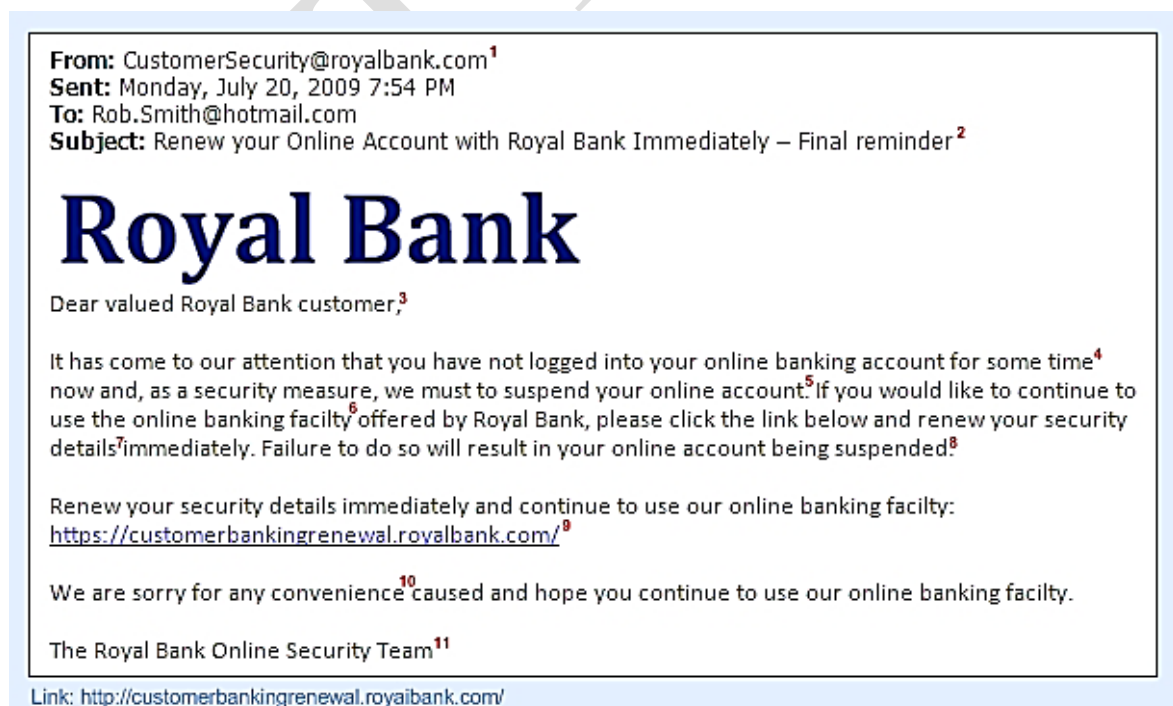
Nhiều biến thể của trò lừa đảo Nigeria 4-1-9 đã xuất hiện trong những năm gần đây trên thế giới cũng như ở Việt Nam, chẳng hạn như thông báo lừa trúng thưởng các tài sản có giá trị lớn (như điện thoại, xe máy,...) để chiếm đoạt khoản "phí trả thưởng" (sử dụng thẻ cào điện thoại, thẻ game,..), lừa đầu tư vào tài khoản vàng ảo, lừa mua gian hàng ảo với hứa hẹn lợi suất cao,...

3.3.8.3. Phishing

Phishing là một dạng đặc biệt phát triển rất mạnh của tấn công sử dụng các kỹ thuật xã hội, trong đó kẻ tấn công bẫy người dùng để đánh cắp thông tin cá nhân, thông tin tài khoản, thông tin thẻ tín dụng,... Kẻ tấn công có thể giả mạo trang web của các tổ chức tài chính, ngân hàng, sau đó chúng gửi email cho người dùng (sử dụng địa chỉ email thu thập trên mạng), yêu cầu xác thực thông tin. Hình 3.14 và Hình 3.15 minh họa 2 phishing email gửi cho khách hàng của mạng đấu giá trực tuyến eBay và ngân hàng Royal Bank yêu cầu người dùng cập nhật thông tin thanh toán đã hết hạn, hoặc xác nhận thông tin tài khoản không sử dụng. Nếu người dùng làm theo hướng dẫn thì sẽ vô tình cung cấp các thông tin cá nhân, thông tin tài khoản, thẻ tín dụng cho kẻ tấn công.



Hình 3.14. Một phishing email gửi cho khách hàng của mạng đấu giá eBay



Hình 3.15. Một phishing email gửi cho khách hàng của ngân hàng Royal Bank

3.3.8.4. Phòng chống

Do tấn công sử dụng các kỹ thuật xã hội nhắm đến người dùng nên biện pháp phòng chống hiệu quả là giáo dục, đào tạo nâng cao ý thức cảnh giác cho người dùng. Một số khuyến nghị giúp người dùng phòng tránh dạng tấn công này:

- Cảnh giác với các lời mời, hoặc thông báo trúng thưởng bằng email, tin nhắn điện thoại, hoặc quảng cáo trên các trang web, diễn đàn mà không có lý do, nguồn gốc trúng thưởng rõ ràng;
- Cảnh giác với các yêu cầu cung cấp thông tin, xác nhận tài khoản, thông tin thanh toán, thông tin thẻ tín dụng,..;
- Kiểm tra kỹ địa chỉ (URL) các trang web, đảm bảo truy nhập đúng trang web của cơ quan, tổ chức.

3.3.9. Tấn công pharming

Pharming là kiểu tấn công vào trình duyệt của người dùng, trong đó người dùng gõ địa chỉ 1 website, trình duyệt lại yêu cầu 1 website khác, thường là website độc hại. Có 2 dạng tấn công pharming:

- (1) Kẻ tấn công thường sử dụng sâu, vi rút hoặc các phần mềm độc hại cài đặt vào hệ thống nạn nhân để điều khiển trình duyệt của người dùng; và
- (2) Kẻ tấn công cũng có thể tấn công vào hệ thống tên miền (DNS) để thay đổi kết quả truy vấn: thay địa chỉ IP của website hợp pháp thành IP của website độc hại.

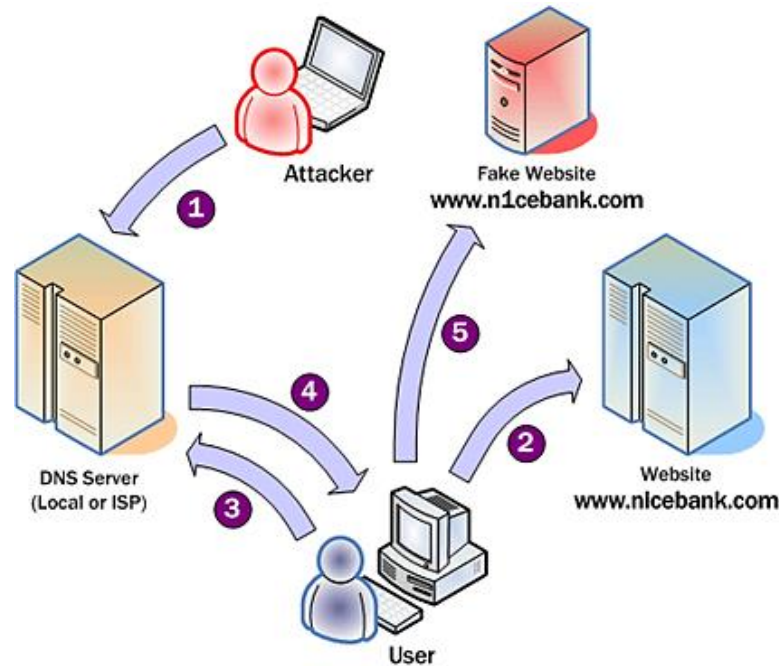


Hình 3.16. Tấn công pharming "cướp" trình duyệt

Hình 3.16 minh họa cửa sổ trình duyệt của người dùng bị tấn công pharming ở dạng (1), hay còn gọi là *tấn công cướp trình duyệt* (Browser hijacking), trong đó người dùng nhập địa chỉ trang google.com thì trình duyệt lại nạp trang adventureinsecurity.com. Trong trường hợp

này, trình duyệt của nạn nhân đã bị cài đặt trình cắm (plug-in, hoặc add-on) độc hại có khả năng điều khiển trình duyệt.

Hình 3.17 minh họa các bước của tấn công pharming dạng (2), trong đó kẻ tấn công xâm nhập vào máy chủ DNS chỉnh sửa địa chỉ IP của website hợp pháp thành địa chỉ IP của máy chủ của chúng. Kết quả là trình duyệt người dùng bị chuyển hướng yêu cầu nạp website của kẻ tấn công.



Hình 3.17. Tấn công pharming thông qua tấn công vào máy chủ DNS

3.4. CÁC DẠNG PHẦN MỀM ĐỘC HẠI

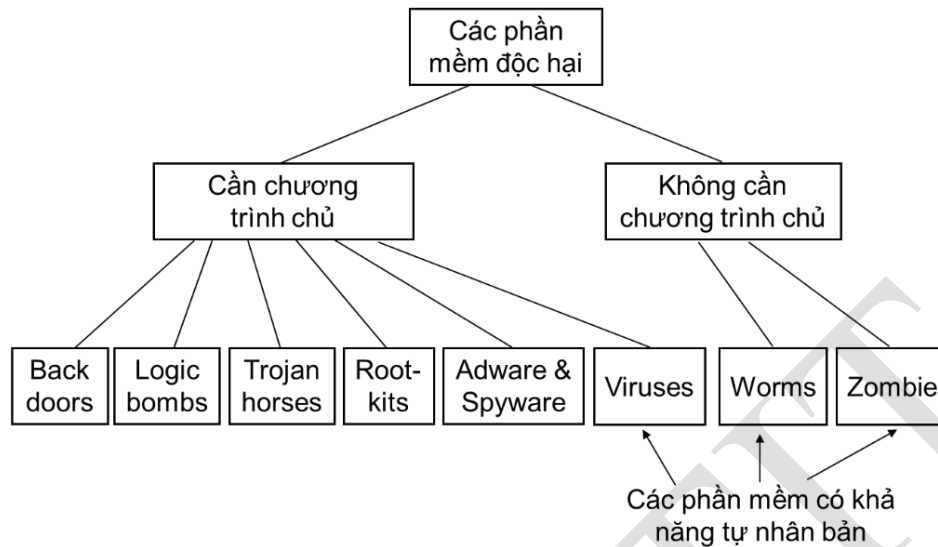
3.4.1. Giới thiệu

Các phần mềm độc hại, còn gọi là phần mềm mã độc (Malware hay Malicious software) là các chương trình, phần mềm được viết ra nhằm các mục đích xấu, như đánh cắp thông tin nhạy cảm, hoặc phá hoại các hệ thống. Có nhiều phương pháp phân loại các phần mềm độc hại, trong đó một phương pháp được thừa nhận rộng rãi là chia các phần mềm độc hại thành 2 nhóm chính như biểu diễn trên Hình 3.18:

- (1) Các phần mềm độc hại cần chương trình chủ, vật chủ (host) để ký sinh và lây nhiễm. Các phần mềm độc hại thuộc nhóm này gồm Logic bombs (Bom lô gic), Back doors (Cửa hậu), Trojan horses (Con ngựa thành Troia), Viruses (Vi rút), Rootkits, Adware (Phần mềm quảng cáo) và Spyware (Phần mềm gián điệp);
- (2) Các phần mềm độc hại không cần chương trình chủ, vật chủ để lây nhiễm. Các phần mềm độc hại thuộc nhóm này gồm Worms (Sâu) và Zombies hay Bots (Phần mềm máy tính ma).

Trong số các phần mềm độc hại, các phần mềm độc hại có khả năng tự lây nhiễm (self-infection), hay tự nhân bản (self-replicate) gồm Vi rút, Sâu và Phần mềm máy tính ma. Các dạng còn lại không có khả năng tự lây nhiễm. Việc phân loại các phần mềm độc hại kể trên

mang tính chất tương đối do hiện nay, có một số phần mềm độc hại có các đặc tính của cả Vi rút, Sâu và Phần mềm gián điệp.

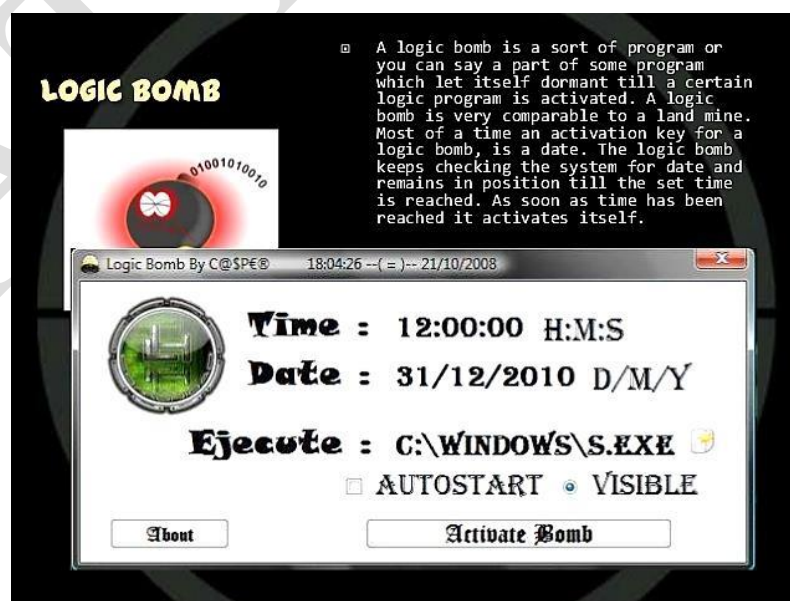


Hình 3.18. Các dạng phần mềm độc hại

3.4.2. Bom lô gic

Bom lô gic là các đoạn mã độc thường được “nhúng” vào các chương trình bình thường và thường hẹn giờ để “phát nổ” trong một số điều kiện cụ thể. Điều kiện để bom “phát nổ” có thể là sự xuất hiện hoặc biến mất của các file cụ thể, một thời điểm cụ thể, hoặc một ngày trong tuần. Khi “phát nổ” bom lô gic có thể xóa dữ liệu, file, tất cả hệ thống...

Thực tế đã ghi nhận quả bom lô gic do Tim Lloyd cài lại đã “phát nổ” tại công ty Omega Engineering vào ngày 30/7/1996, 20 ngày sau khi Tim Lloyd bị sa thải. Bom lô gic này đã xóa sạch các bản thiết kế và các chương trình, gây thiệt hại 10 triệu USD cho công ty. Bản thân Tim Lloyd toà án tuyên phạt 2 triệu USD và 41 tháng tù.



Hình 3.19. Minh họa bom lô gic

3.4.3. Trojan Horses

Trojan horses, hay thường gọi tắt là trojan lấy tên theo tích “Con ngựa thành Tơ roa”, là chương trình chứa mã độc, thường giả danh những chương trình có ích, nhằm lừa người dùng kích hoạt chúng. Trojan thường được sử dụng để thực thi gián tiếp các tác vụ, trong đó tác giả của chúng không thể thực hiện trực tiếp do không có quyền truy nhập. Chẳng hạn, trong một hệ thống nhiều người dùng, một người dùng ác tính có thể tạo ra một trojan đội lốt một chương trình hữu ích đặt ở thư mục chung. Khi trojan này được thực thi bởi một người dùng khác, nó sẽ thay đổi quyền truy nhập các file của người dùng đó, cho phép tất cả người dùng (trong đó có người dùng ác tính) truy nhập vào các file của người dùng đó.



Hình 3.20. Minh họa trojan horse

3.4.4. Cửa hậu



Hình 3.21. Minh họa cửa hậu trên điện thoại Apple iPhone cho phép truy nhập trái phép

Cửa hậu thường được các lập trình viên tạo ra, dùng để gỡ rối và kiểm thử chương trình trong quá trình phát triển. Cửa hậu thường cho phép truy nhập trực tiếp vào hệ thống mà không qua các thủ tục kiểm tra an ninh thông thường. Khi cửa hậu được lập trình viên tạo ra để truy nhập bất hợp pháp vào hệ thống, nó trở thành một mối đe dọa đến an ninh hệ thống.

Cửa hậu thường được thiết kế và cài đặt khéo léo và chỉ được kích hoạt trong một ngữ cảnh nào đó, do vậy nó rất khó bị phát hiện.

3.4.5. Vi rút

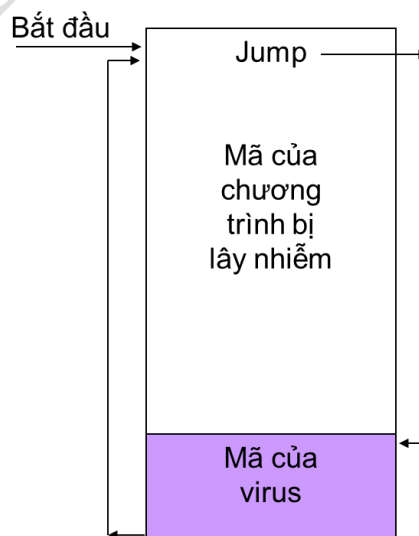
3.4.5.1. Giới thiệu

Vi rút là một chương trình có thể “nhiễm” vào các chương trình khác, bằng cách sửa đổi các chương trình này. Nếu các chương trình đã bị sửa đổi chứa vi rút được kích hoạt thì vi rút sẽ tiếp tục “lây nhiễm” sang các chương trình khác. Tương tự như vi rút sinh học, vi rút máy tính cũng có khả năng tự nhân bản, tự lây nhiễm sang các chương trình khác mà nó tiếp xúc. Có nhiều con đường lây nhiễm vi rút, như sao chép file, gọi các ứng dụng và dịch vụ qua mạng, email...

Vi rút có thể thực hiện được mọi việc mà một chương trình thông thường có thể thực hiện. Khi đã lây nhiễm vào một chương trình, vi rút tự động được thực hiện khi chương trình này chạy. Hình 3.23 minh họa việc chèn mã vi rút vào cuối một chương trình và chỉnh sửa chương trình để khi chương trình được kích hoạt, mã vi rút luôn được thực hiện trước, sau đó mới thực hiện mã chương trình.



Hình 3.22. Minh họa vi rút máy tính



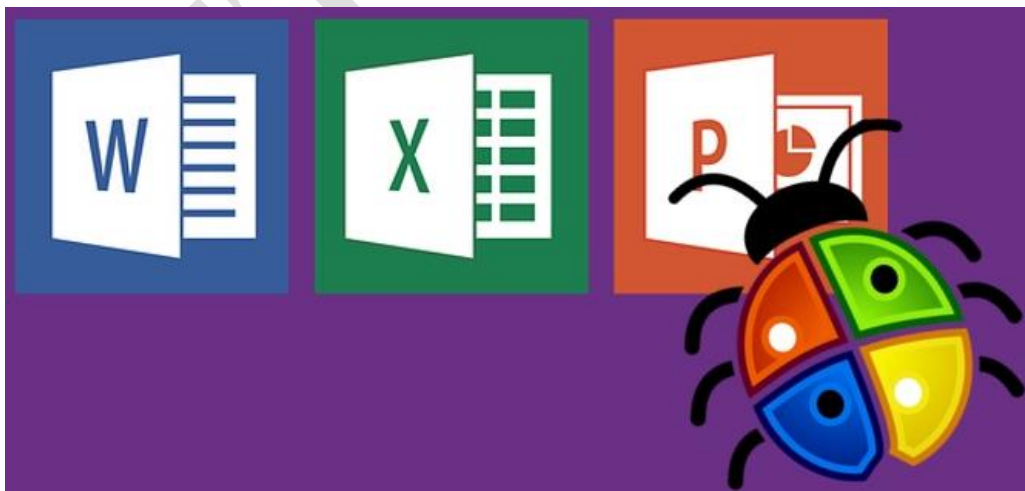
Hình 3.23. Chèn và gọi thực hiện mã vi rút

3.4.5.2. Các loại vi rút

Các loại vi rút thường gặp bao gồm file vi rút, boot vi rút, macro vi rút và email vi rút. Boot vi rút là dạng vi rút lây nhiễm vào cung khởi động (boot sector) của đĩa hoặc phần hệ thống của đĩa như cung khởi động chủ của đĩa cứng (master boot record). Do boot vi rút lây nhiễm vào cung khởi động nên nó luôn được nạp vào bộ nhớ mỗi khi hệ thống máy khởi động. Boot vi rút có thể gây hỏng phần khởi động của đĩa, thậm chí có thể làm cho đĩa không thể truy nhập được.

File vi rút là dạng vi rút phổ biến nhất, đối tượng lây nhiễm của chúng là các file chương trình và các file dữ liệu. Mỗi khi chương trình được kích hoạt hoặc file dữ liệu được nạp vào bộ nhớ, vi rút được kích hoạt. Mọi chương trình tiếp theo được kích hoạt đều bị lây nhiễm vi rút này. File vi rút có thể làm hỏng chương trình, hỏng hoặc phá hủy các file dữ liệu, đánh cắp các dữ liệu nhạy cảm,...

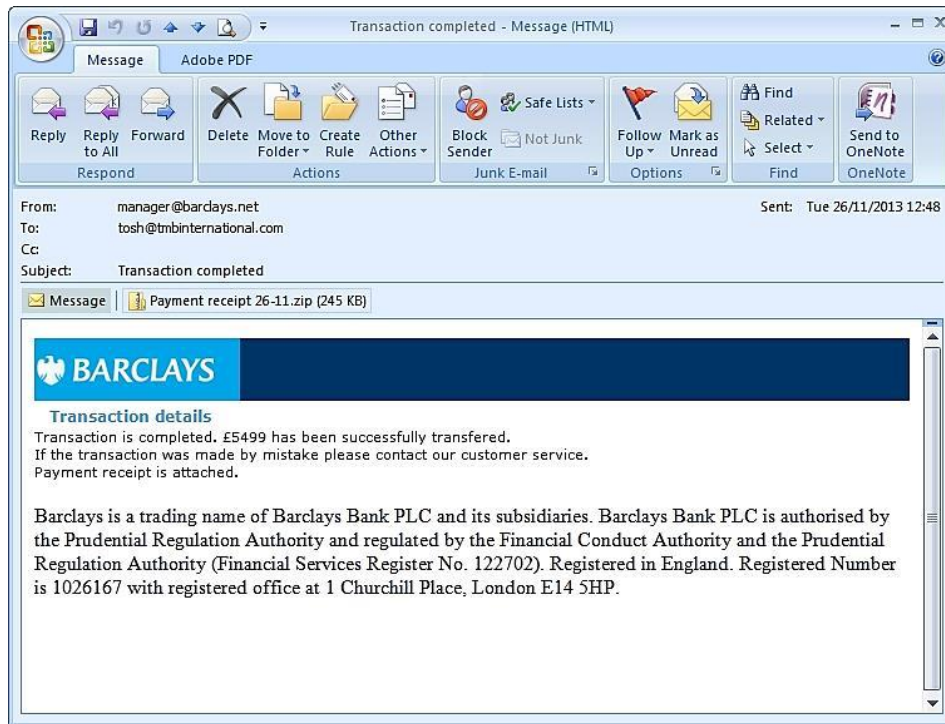
Macro vi rút là một loại file vi rút đặc biệt do chúng chỉ lây nhiễm vào các tài liệu của bộ phần mềm Microsoft Office. Macro vi rút hoạt động được nhờ tính năng cho phép tạo và thực hiện các đoạn mã macro trong các tài liệu của bộ ứng dụng Microsoft Office, gồm ứng dụng soạn thảo Word, bảng tính Excel, trình email Outlook,.... Các đoạn mã macro thường được dùng để tự động hóa 1 số việc và được viết bằng ngôn ngữ Visual Basic for Applications (VBA). Macro vi rút thường lây nhiễm vào các file định dạng chuẩn (các template như normal.dot và normal.dotx) và từ đó lây nhiễm vào tất cả các file tài liệu được mở. Macro vi rút cũng có thể được tự động kích hoạt nhờ các auto-executed macros, như AutoExecute, Automacro và Command macro. Theo thống kê, macro vi rút chiếm khoảng 2/3 tổng lượng vi rút đã được phát hiện. Tuy nhiên, lượng tài liệu bị lây nhiễm macro vi rút đã giảm đáng kể từ khi Microsoft Office 2010 có thiết lập ngầm định không cho phép chạy các macro.



Hình 3.24. Macro vi rút chỉ lây nhiễm vào các tài liệu của bộ ứng dụng Microsoft Office

Email vi rút là loại vi rút sử dụng email là phương tiện lan lan. Email vi rút lây nhiễm bằng cách tự động gửi một bản copy của nó như 1 file đính kèm đến tất cả các địa chỉ email trong sổ địa chỉ của người dùng trên máy bị lây nhiễm. Nếu người dùng mở email hoặc file đính kèm, vi rút được kích hoạt. Email vi rút có thể lây nhiễm rất nhanh chóng, lan tràn trên

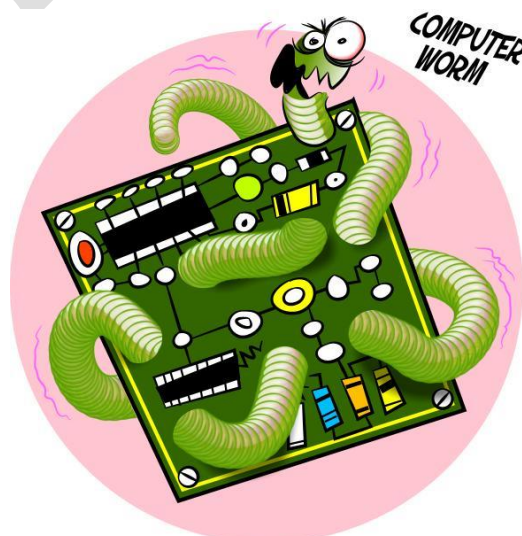
khấp thể giới trong một thời gian ngắn. Hình 3.25 là một email do vi rút gửi đến người dùng, email có đính kèm một file giả dạng một giấy biên nhận chứa mã vi rút lừa người dùng mở và kích hoạt.



Hình 3.25. Một email vi rút gửi đến người dùng

3.4.6. Sâu

Sâu là một loại phần mềm độc hại có khả năng tự lây nhiễm từ máy này sang máy khác mà không cần chương trình chủ, vật chủ, hoặc sự trợ giúp của người dùng. Khi sâu lây nhiễm vào một máy, nó sử dụng máy này làm “bàn đạp” để tiếp tục rà quét, tấn công các máy khác. Một trong các dạng sâu phổ biến là *sâu mạng* (network worm) sử dụng kết nối mạng để lây lan từ máy này sang máy khác. Mặc dù sử dụng phương thức lây lan khác vi rút, khi sâu hoạt động, nó tương tự vi rút.

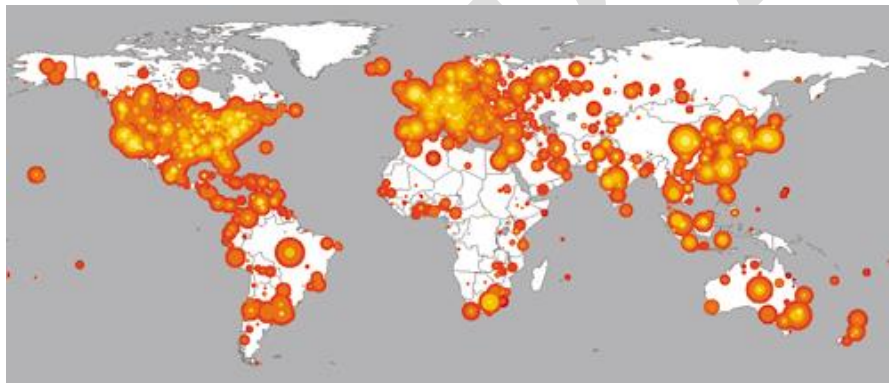


Hình 3.26. Minh họa sâu máy tính

Sâu có thể lây lan sử dụng nhiều phương pháp khác nhau. Một số sâu chỉ sử dụng một phương pháp lây lan, nhưng một số sâu khác có khả năng lây lan theo nhiều phương pháp. Các phương pháp lây lan chính của sâu gồm:

- Lây lan qua thư điện tử: Sâu sử dụng email để gửi bản sao của mình đến các máy khác. Dạng sâu này tương tự email vì rút, nhưng có khả năng tự kích hoạt mà không cần người dùng mở email hay thực hiện file đính kèm.
- Lây lan thông qua khả năng thực thi từ xa: Sâu gửi và thực thi một bản sao của nó trên một máy khác thông qua việc khai thác các lỗ hổng an ninh của hệ điều hành, các dịch vụ, hoặc phần mềm ứng dụng.
- Lây lan thông qua khả năng log-in (đăng nhập) từ xa: Sâu đăng nhập vào hệ thống ở xa như một người dùng và sử dụng lệnh để sao chép bản thân nó từ máy này sang máy khác.

Sâu Code Red được phát hiện vào tháng 7/2001 lây nhiễm thông qua việc khai thác lỗi tràn bộ đệm khi xử lý các file .ida trong máy chủ web Microsoft IIS (Internet Information Service). Code Red quét các địa chỉ IP ngẫu nhiên để tìm các hệ thống có lỗi và lây nhiễm vào 360.000 máy chủ trong vòng 14 giờ.



Hình 3.27. Bản đồ lây nhiễm sâu Code Red trên toàn thế giới

Sau sâu Code Red, sâu Nimda được phát hiện vào tháng 9/2001 là sâu có khả năng lây lan theo nhiều con đường:

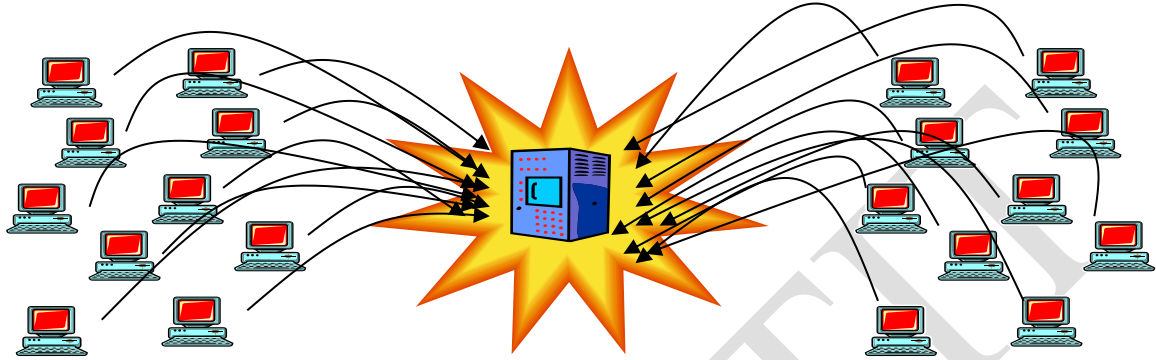
- Qua email từ máy client sang client.
- Qua các thư mục chia sẻ trên mạng.
- Từ máy chủ web sang trình duyệt.
- Từ máy khách đến máy chủ nhờ khai thác các lỗi máy chủ.

Nhờ khả năng hỗ trợ nhiều phương pháp lây lan, chỉ 22 phút sau khi ra đời, Nimda trở thành sâu có tốc độ lan truyền nhanh nhất trên Internet vào thời điểm đó.

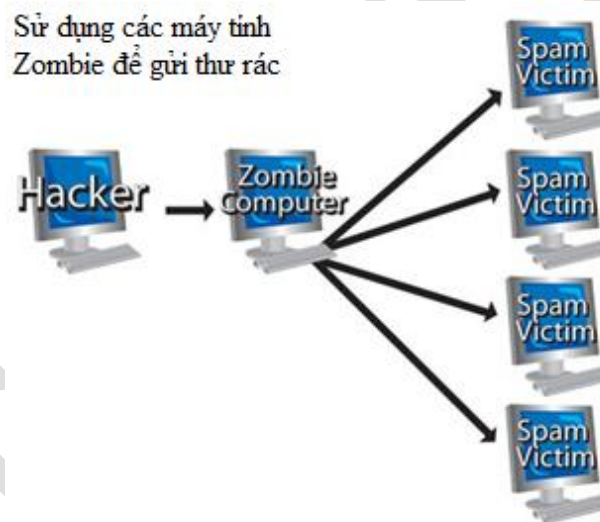
3.4.7. Zombies

Zombie (còn gọi là *Bot* hoặc *Automated agent*) là một chương trình được thiết kế để giành quyền kiểm soát một máy tính có kết nối Internet, và sử dụng máy tính bị kiểm soát để tấn công các hệ thống khác, hoặc gửi spam email. Tương tự như sâu, zombie có khả năng tự lây nhiễm sang các hệ thống khác mà không cần chương trình chủ, hoặc các hỗ trợ từ người dùng.

Một tập hợp các máy tính zombie/bot dưới sự kiểm soát của một, hoặc một nhóm kẻ tấn công được gọi là mạng máy tính ma, hay zombie network, hay botnet. Các zombie thường được điều phối và sử dụng để thực hiện các cuộc tấn công DDoS các máy chủ, các website của các công ty, hoặc các tổ chức chính phủ, như minh họa trên Hình 3.28. Các máy tính zombie cũng có thể được sử dụng để gửi thư rác tạo ra khoản tiền không nhỏ cho các nhóm kẻ tấn công, như minh họa trên Hình 3.29.



Hình 3.28. Mô hình kẻ tấn công sử dụng các máy tính Zombie để tấn công DDoS



Hình 3.29. Mô hình kẻ tấn công sử dụng các máy tính Zombie để gửi thư rác

3.4.8. Rootkits

Rootkit là một dạng phần mềm độc hại gồm một tập các công cụ có mục đích giành quyền truy nhập vào hệ thống máy tính mà người dùng không có thẩm quyền không thể truy nhập. Rootkit thường che giấu mình bằng cách đội lốt một phần mềm khác. Rootkit có thể được cài đặt tự động, hoặc kẻ tấn công cài đặt rootkit khi chiếm được quyền quản trị hệ thống. Do rootkit có quyền truy nhập hệ thống ở mức quản trị nên nó có toàn quyền truy nhập vào các thành phần trong hệ thống và rất khó bị phát hiện.

3.4.9. Adware và Spyware

Adware (tên đầy đủ là advertising-supported software) là các phần mềm tự động hiển thị các bảng quảng cáo trong thời gian người dùng tải hoặc sử dụng các phần mềm. Adware thường được đóng gói chung với các phần mềm khác có thể dưới dạng như một phần của một

phần mềm hoặc một dịch vụ miễn phí. Adware cũng thường được cài đặt như một trình cắm chạy trong trình duyệt web của người dùng nhằm hiển thị các pop-up quảng cáo. Adware trong một số trường hợp có thể được coi là một phần mềm độc hại nếu chúng được tự động cài đặt và kích hoạt mà không được sự đồng ý của người dùng.

Spyware là một dạng phần mềm độc hại được cài đặt tự động nhằm giám sát, thu thập và đánh cắp các thông tin nhạy cảm trên hệ thống nạn nhân. Có 4 loại spyware thường gặp, gồm system monitor (giám sát hệ thống), trojan, adware, and tracking cookie (các cookie theo dõi người dùng). Spyware có thể được cài đặt vào hệ thống nạn nhân thông qua nhiều phương pháp, như tích hợp, đóng gói vào các phần mềm khác, bẫy nạn nhân tự tải và cài đặt, hoặc kẻ tấn công có thể sử dụng vi rút, sâu để tải và cài đặt. Spyware thường được trang bị khả năng ẩn mình nên rất khó có thể phát hiện bằng các phương pháp thông thường.

3.4.10. Phòng chống phần mềm độc hại

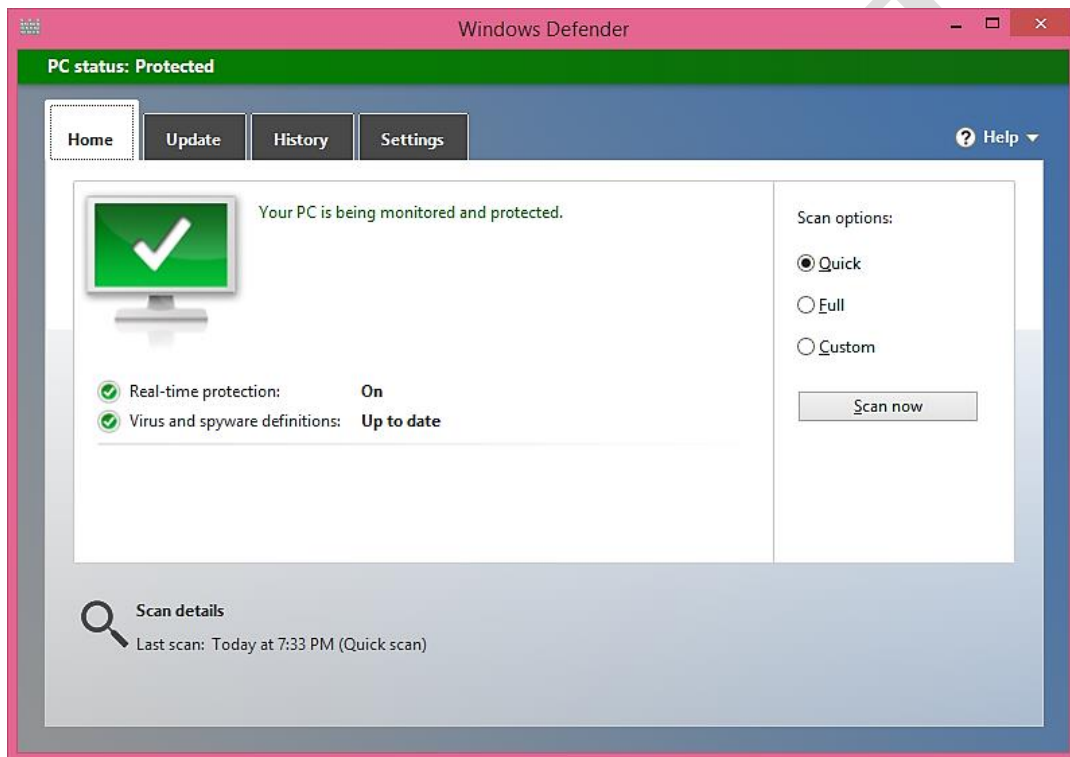
3.4.10.1. Nguyên tắc chung

Có thể thấy các phần mềm độc hại là một trong các nguy cơ gây mất lớn nhất đối với thông tin, hệ thống và người dùng do sự bùng nổ về số lượng, mức độ tinh vi ngày càng cao và khả năng phá hoại của chúng. Nguyên tắc chung trong phòng chống phần mềm độc hại vẫn là *phòng vệ theo chiều sâu*, trong đó nhiều nhóm biện pháp đảm bảo an toàn cần được áp dụng để phòng ngừa và ngăn chặn việc lây nhiễm các phần mềm độc hại vào hệ thống. Có thể liệt kê các biện pháp phòng chống các phần mềm độc hại theo thứ tự ưu tiên từ cao đến thấp như sau:

- (1) Sử dụng các biện pháp điều khiển truy nhập cung cấp bởi hệ điều hành và tường lửa để hạn chế giao diện tiếp xúc của hệ thống với mạng ngoài. Chẳng hạn, tường lửa có thể chặn các kết nối trái phép từ Internet đến hệ thống máy tính để khai thác các lỗ hổng, hoặc tải các phần mềm độc hại;
- (2) Sử dụng công cụ rà quét phần mềm độc hại. Với mỗi hệ thống máy tính (nhất là các máy trạm và máy tính cá nhân), cần cài đặt **một** bộ công cụ rà quét phần mềm độc hại có khả năng bảo vệ hệ thống theo thời gian thực. Bộ công cụ này cần được cập nhật thường xuyên để đảm bảo khả năng phát hiện và diệt trừ các phần mềm độc hại mới nhất;
- (3) Đào tạo và nâng cao ý thức của người dùng. Việc nâng cao ý thức người dùng đóng vai trò quan trọng trong việc phòng ngừa việc lây lan của các dạng phần mềm độc hại;
- (4) Sử dụng các phần mềm có bản quyền. Sử dụng các phần mềm có bản quyền là cách hiệu quả để hạn chế các loại mã độc, như trojan, adware và spyware được tích hợp vào các công cụ phá khoá (cracker) hệ điều hành và các phần mềm ứng dụng;
- (5) Thường xuyên cập nhật hệ điều hành và các phần mềm ứng dụng. Việc cập nhật thường xuyên, nhất là các bản vá an ninh nhằm giảm thiểu các lỗ hổng bảo mật đã biết trên hệ thống và nhờ vậy giảm thiểu khả năng bị khai thác bởi các dạng mã độc;
- (6) Phân quyền người dùng phù hợp giúp hạn chế khả năng tự động cài đặt các dạng mã độc lên hệ thống. Không sử dụng người dùng có quyền quản trị (root, hoặc administrator) để chạy các ứng dụng. Người dùng thông thường chỉ nên được cấp quyền truy nhập vừa đủ để thực thi nhiệm vụ.

3.4.10.2. Các công cụ rà quét vi rút và các phần mềm độc hại

Các công cụ rà quét vi rút và các phần mềm độc hại (Antivirus software) là các phần mềm có khả năng rà quét, bảo vệ hệ thống khỏi vi rút và các phần mềm độc hại khác theo thời gian thực. Hầu hết các công cụ này đều cho phép thực hiện 2 chế độ quét: quét định kỳ từng phần, hoặc toàn bộ hệ thống các file và bảo vệ hệ thống theo thời gian thực (Realtime protection). Chúng cho phép giám sát tất cả các thao tác đọc/ghi hệ thống file để phát hiện các phần mềm độc hại. Đa số công cụ rà quét vi rút và các phần mềm độc hại hoạt động dựa trên một cơ sở dữ liệu các mẫu, hoặc chữ ký của các phần mềm độc hại đã biết. Do vậy, để đảm bảo an toàn cơ sở dữ liệu này phải được cập nhật thường xuyên. Một số bộ công cụ cho phép quét theo hành vi hoặc heuristics.



Hình 3.30. Màn hình chính của Microsoft Windows Defender

Có thể liệt kê một số công cụ rà quét vi rút và các phần mềm độc hại thông dụng, như:

- Microsoft Security Essentials (Windows 7 trở lên)
- Microsoft Windows Defender (Windows 8 trở lên) – minh họa trên Hình 3.30
- Semantec Norton Antivirus
- Kaspersky Antivirus
- BitDefender Antivirus
- AVG Antivirus
- McAfee VirusScan
- Trend Micro Antivirus
- F-secure Antivirus và
- BKAU Antivirus.

3.5. CÂU HỎI ÔN TẬP

- 1) Mối đe dọa (threat) là gì? Nêu quan hệ giữa lỗ hổng và mối đe dọa.
- 2) Mô tả 4 loại tấn công chính và 2 kiểu tấn công chủ động và thụ động.
- 3) Nêu mục đích và các dạng tấn công vào mật khẩu.
- 4) Tấn công chèn mã SQL là gì? Nêu các nguyên nhân của lỗ hổng chèn mã SQL. Tấn công chèn mã SQL có khả năng cho phép kẻ tấn công thực hiện hành động gì trên hệ thống nạn nhân?
- 5) Mô tả cơ chế tấn công chèn mã SQL trong từng trường hợp khai thác sau: vượt qua xác thực người dùng; chèn, sửa xóa dữ liệu; và đánh cắp dữ liệu.
- 6) Nêu các biện pháp phòng chống tấn công chèn mã SQL.
- 7) Vẽ sơ đồ, mô tả cơ chế tấn công SYN Flood và các biện pháp phòng chống.
- 8) Vẽ sơ đồ, mô tả cơ chế tấn công Smurf và các biện pháp phòng chống.
- 9) Vẽ sơ đồ và mô tả kịch bản tấn công DDoS trực tiếp và tấn công DDoS gián tiếp.
- 10) Mô tả cơ chế và các biện pháp phòng chống tấn công người đứng giữa.
- 11) Đối tượng của tấn công sử dụng các kỹ thuật xã hội là gì? Mô tả kịch bản của Trò lừa đảo Nigeria 4-1-9.
- 12) Tấn công pharming là gì? Mô tả các dạng tấn công pharming.
- 13) Phần mềm độc hại là gì? Phân loại các phần mềm độc hại.
- 14) Vi rút là gì? Nêu các phương pháp lây nhiễm và các loại vi rút.
- 15) Trojan là gì? Mô tả cơ chế hoạt động của trojan.
- 16) Sâu máy tính là gì? Nêu điểm khác biệt cơ bản của sâu và vi rút. Nêu các phương pháp lây lan của sâu.
- 17) Zombie, hay bot là gì? Nêu 2 trường hợp điển hình kẻ tấn công sử dụng Zombie, hay bot để lạm dụng, hoặc tấn công các hệ thống.
- 18) Nêu nguyên tắc chung cho phòng chống các phần mềm độc hại.
- 19) Giải thích tại sao trong một hệ thống máy tính chỉ nên sử dụng một bộ công cụ rà quét các phần mềm độc hại hoạt động ở chế độ “bảo vệ theo thời gian thực”?
- 20) Tìm hiểu một phiên bản của bộ công cụ rà quét các phần mềm độc hại Kaspersky Antivirus và Bkav Antivirus. So sánh các tính năng của 2 bộ công cụ này.

CHƯƠNG 4. ĐẢM BẢO AN TOÀN THÔNG TIN DƯỚI TRÊN MÃ HÓA

Chương 4 giới thiệu các khái niệm cơ bản về mật mã, hệ mã hóa, các phương pháp mã hóa. Phần tiếp theo của chương trình bày một số giải thuật cơ bản của mã hóa khóa đối xứng (DES, 3-DES và AES), mã hóa khóa bất đối xứng (RSA) và các hàm băm (MD5 và SHA1).

4.1. KHÁI QUÁT VỀ MÃ HÓA THÔNG TIN VÀ ỨNG DỤNG

4.1.1. Các khái niệm cơ bản

Mật mã

Theo từ điển Webster's Revised Unabridged Dictionary¹⁶: “cryptography is the act or art of writing secret characters”, hay mật mã (cryptography) là một hành động hoặc nghệ thuật viết các ký tự bí mật. Còn theo từ điển Free Online Dictionary of Computing¹⁷: “cryptography is encoding data so that it can only be decoded by specific individuals”, có nghĩa là mật mã là việc mã hóa dữ liệu mà nó chỉ có thể được giải mã bởi một số người chỉ định.

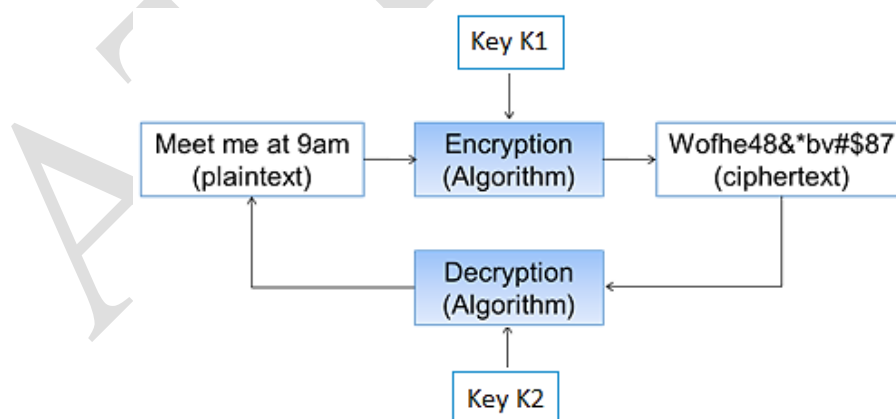
Bản rõ, Bản mã, Mã hóa và Giải mã

Bản rõ (Plaintext), hay thông tin chưa mã hóa (Unencrypted information) là thông tin ở dạng có thể hiểu được.

Bản mã (Ciphertext), hay thông tin đã được mã hóa (Encrypted information) là thông tin ở dạng đã bị xáo trộn.

Mã hóa (Encryption) là hành động xáo trộn (scrambling) bản rõ để chuyển thành bản mã.

Giải mã (Decryption) là hành động giải xáo trộn (unscrambling) bản mã để chuyển thành bản rõ.



Hình 4.1. Các khâu Mã hóa (Encryption) và Giải mã (Decryption) của một hệ mã hóa

Hình 4.1 minh họa các khâu của một hệ mã hóa, trong đó khâu mã hóa thực hiện ở phía người gửi: chuyển bản rõ (plaintext) thành bản mã (ciphertext) sử dụng khoá mã hoá K1 và

¹⁶ Tham khảo tại: <http://www.dict.org/bin/Dict?Form=Dict3&Database=web1913>

¹⁷ Tham khảo tại: <http://foldoc.org/cryptography>

khâu giải mã được thực hiện ở phía người nhận: chuyển bản mã thành bản rõ sử dụng khoá giải mã K2. Khoá mã hoá K1 và khoá giải mã K2 có quan hệ về mặt toán học với nhau.

Giải thuật mã hóa & giải mã, Bộ mã hóa, Khóa/Chìa, Không gian khóa

Giải thuật mã hóa (Encryption algorithm) là giải thuật dùng để mã hóa thông tin và giải thuật giải mã (Decryption algorithm) dùng để giải mã thông tin.

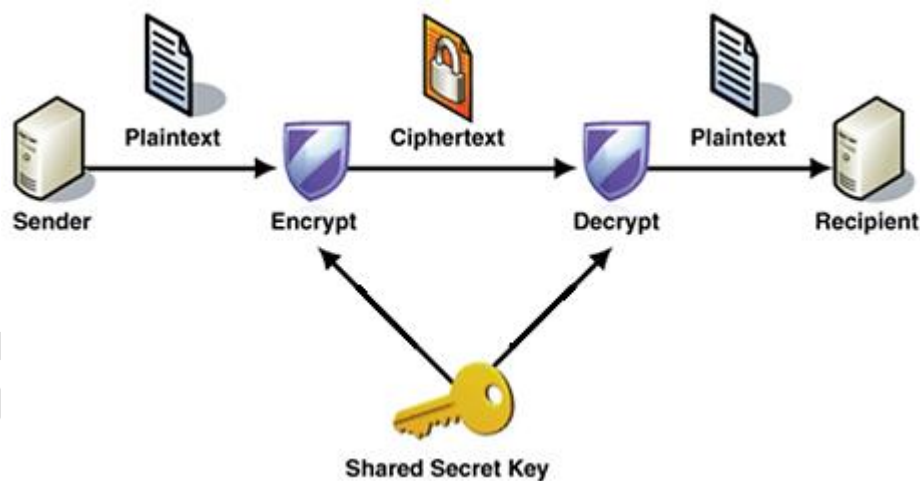
Một bộ mã hóa (Cipher) gồm một giải thuật để mã hóa và một giải thuật để giải mã thông tin.

Khóa, hay Chìa (Key) là một chuỗi dữ liệu được sử dụng trong giải thuật mã hóa và giải mã.

Không gian khóa (Keyspace) là tổng số khóa có thể có của một hệ mã hóa. Ví dụ, nếu sử dụng khóa kích thước 64 bit thì không gian khóa là 2^{64} .

Mã hóa khóa đối xứng, Mã hóa khóa bất đối xứng, Hàm băm, Thâm mã

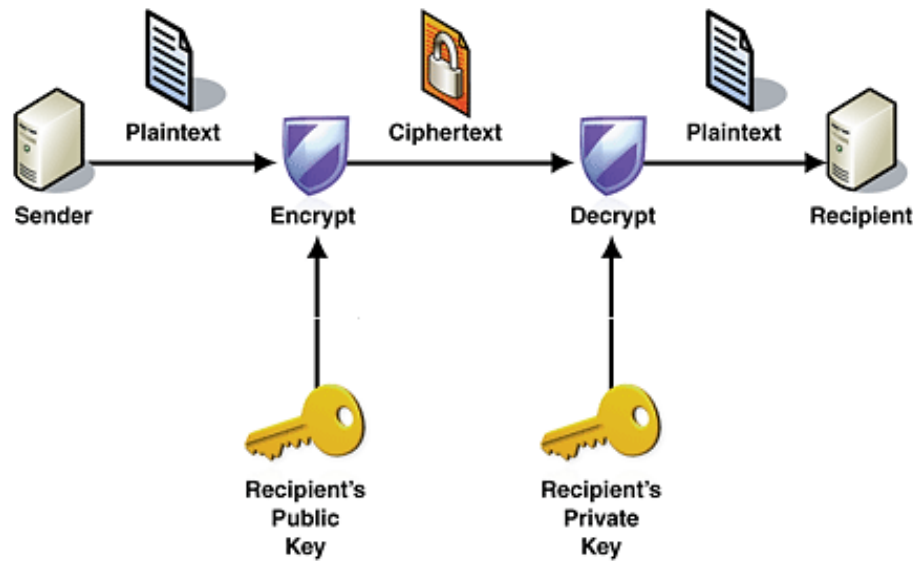
Mã hóa khóa đối xứng (Symmetric key cryptography) là dạng mã hóa trong đó một khóa được sử dụng cho cả giải thuật mã hóa và giải mã. Do khóa sử dụng chung cần phải được giữ bí mật nên mã hóa khóa đối xứng còn được gọi là mã hóa khóa bí mật (Secret key cryptography). Hình 4.2 minh họa hoạt động của một hệ mã hóa khóa đối xứng, trong đó một khóa bí mật duy nhất, hay khoá chia sẻ (Shared Secret Key) được sử dụng cho cả hai khâu mã hóa (Encrypt) ở bên người gửi (Sender) và giải mã (Decrypt) một thông điệp ở bên người nhận (Recipient/ Receiver).



Hình 4.2. Mã hóa khóa đối xứng sử dụng 1 khóa bí mật chia sẻ để mã hoá và giải mã

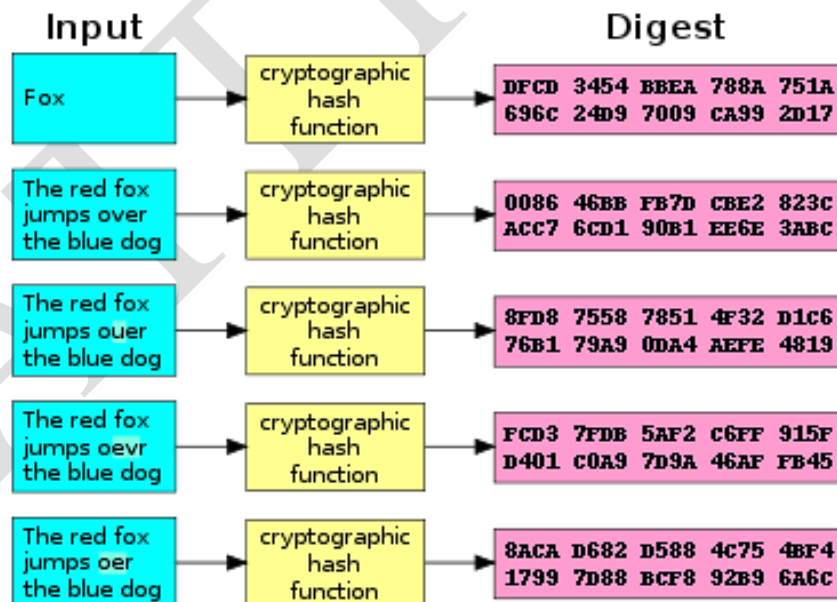
Mã hóa khóa bất đối xứng (Asymmetric key cryptography) là dạng mã hóa trong đó một cặp khóa được sử dụng: khóa công khai (public key) dùng để mã hóa, khóa riêng (private key) dùng để giải mã. Chỉ có khóa riêng cần phải giữ bí mật, còn khóa công khai có thể phổ biến rộng rãi. Do khóa để mã hóa có thể công khai nên đôi khi mã hóa khóa bất đối xứng còn được gọi là mã hóa khóa công khai (Public key cryptography). Hình 4.3 minh họa hoạt động của một hệ mã hóa khóa bất đối xứng, trong đó người gửi (Sender) sử dụng khóa công khai của

người nhận (Recipient's public key) để mã hóa (Encrypt) thông điệp và người nhận (Recipient) sử dụng khóa riêng của mình (Recipient's private key) để giải mã thông điệp.



Hình 4.3. Mã hóa khóa bất đối xứng sử dụng một cặp khóa để mã hoá và giải mã

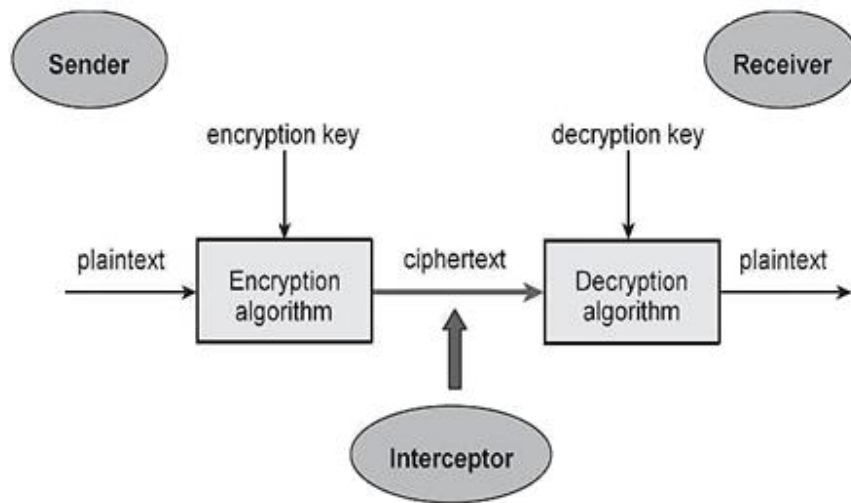
Hàm băm (Hash function) là một ánh xạ chuyển các dữ liệu có kích thước thay đổi về dữ liệu có kích thước cố định. Hình 4.4 minh họa đầu vào (Input) và đầu ra (Digest) của hàm băm. Trong các loại hàm băm, hàm băm 1 chiều (One-way hash function) là hàm băm, trong đó việc thực hiện mã hóa tương đối đơn giản, còn việc giải mã thường có độ phức tạp rất lớn, hoặc không khả thi về mặt tính toán.



Hình 4.4. Minh họa đầu vào (Input) và đầu ra (Digest) của hàm băm

Thăm mã hay phá mã (Cryptanalysis) là quá trình giải mã thông điệp đã bị mã hóa mà không cần có trước thông tin về giải thuật mã hóa và khóa mã.

4.1.2. Các thành phần của một hệ mã hóa

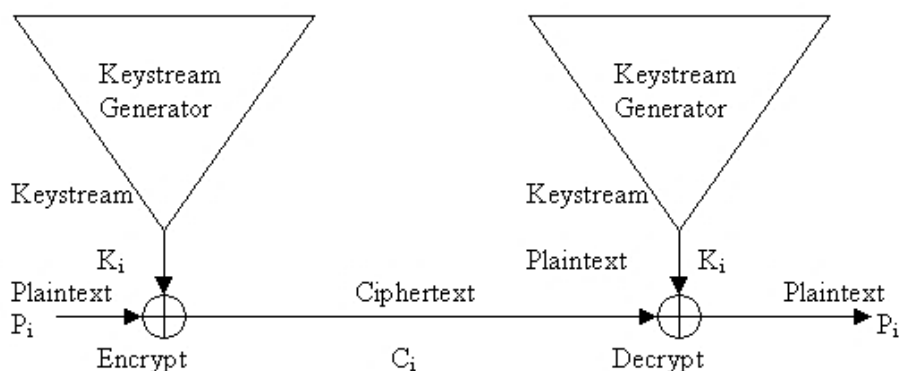


Hình 4.5. Các thành phần của một hệ mã hóa đơn giản

Một hệ mã hóa hay hệ mật mã (Cryptosystem) là một bản cài đặt của các kỹ thuật mật mã và các thành phần có liên quan để cung cấp dịch vụ bảo mật thông tin. Hình 4.5 mô tả các thành phần của một hệ mã hóa đơn giản dùng để đảm bảo tính bí mật của thông tin từ người gửi (Sender) truyền đến người nhận (Receiver) mà không bị một bên thứ ba (Interceptor) nghe lén. Các thành phần của một hệ mã hóa đơn giản gồm bản rõ (plaintext), giải thuật mã hóa (Encryption Algorithm), bản mã (ciphertext), giải thuật giải mã (Decryption Algorithm), khóa mã hóa (encryption key) và khóa giải mã (decryption key). Một thành phần quan trọng khác của một hệ mã hóa là không gian khóa (Keyspace). Không gian khóa là tập hợp tất cả các khóa có thể có. Ví dụ, nếu chọn kích thước khóa là 64 bit thì không gian khóa sẽ là 2^{64} . Nhìn chung, hệ mã hóa có độ an toàn càng cao nếu không gian khóa lựa chọn càng lớn.

4.1.3. Mã hóa dòng và mã hóa khối

4.1.3.1. Mã hóa dòng

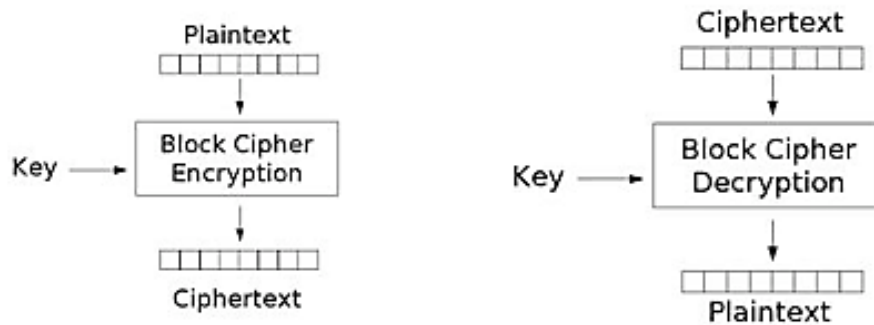


Hình 4.6. Mã hóa dòng (Stream cipher)

Mã hóa dòng (Stream cipher) là kiểu mã hóa mà từng bit, hoặc ký tự của bản rõ được kết hợp với từng bit, hoặc ký tự tương ứng của khóa để tạo thành bản mã. Hình 4.6 biểu diễn quá trình mã hóa (Encrypt) và giải mã (Decrypt) trong mã hóa dòng. Theo đó, ở bên gửi các bit P_i

của bản rõ (plaintext) được liên tục đưa vào kết hợp với bit tương ứng K_i của khóa để tạo thành bit mã C_i ; Ở bên nhận, bit mã C_i được kết hợp với bit khóa C_i để khôi phục bit rõ P_i . Một bộ sinh dòng khóa (Keystream Generator) được sử dụng để liên tục sinh các bit khóa K_i từ khóa gốc K . Các giải thuật mã hóa dòng tiêu biểu như A5, hoặc RC4 được sử dụng rộng rãi trong viễn thông.

4.1.3.2. Mã hóa khối



Hình 4.7. Mã hóa khối (Block cipher)

Mã hóa khối (Block cipher) là kiểu mã hóa mà dữ liệu được chia ra thành từng khối có kích thước cố định để mã hóa và giải mã. Hình 4.7 biểu diễn quá trình mã hóa và giải mã trong mã hóa khối. Theo đó, ở bên gửi bản rõ (Plaintext) được chia thành các khối (block) có kích thước cố định, sau đó từng khối được mã hóa để chuyển thành khối mã. Các khối mã được ghép lại thành bản mã (Ciphertext). Ở bên nhận, bản mã lại được chia thành các khối và từng lại được giải mã để chuyển thành khối rõ. Cuối cùng ghép các khối rõ để có bản rõ hoàn chỉnh. Các giải thuật mã hóa khối tiêu biểu như DES, 3-DES, IDEA, AES được sử dụng rất rộng rãi trong mã hóa dữ liệu với kích thước khối 64, hoặc 128 bit.

4.1.4. Sơ lược lịch sử mật mã

Có thể nói mật mã là con đẻ của toán học nên sự phát triển của mật mã đi liền với sự phát triển của toán học. Tuy nhiên, do nhiều giải thuật mật mã đòi hỏi khối lượng tính toán lớn nên mật mã chỉ thực sự phát triển mạnh cùng với sự ra đời và phát triển của máy tính điện tử. Sau đây là một số mốc trong sự phát triển của mật mã và ứng dụng mật mã:

- Các kỹ thuật mã hoá thô sơ đã được người cổ Ai cập sử dụng cách đây 4000 năm.
- Người cổ Hy Lạp, Ấn độ cũng đã sử dụng mã hoá cách đây hàng ngàn năm.
- Các kỹ thuật mã hoá chỉ thực sự phát triển mạnh từ thế kỷ 1800 nhờ công cụ toán học, và phát triển vượt bậc trong thế kỷ 20 nhờ sự phát triển của máy tính và ngành công nghệ thông tin.
- Trong chiến tranh thế giới thứ I và II, các kỹ thuật mã hóa được sử dụng rộng rãi trong liên lạc quân sự sử dụng sóng vô tuyến. Quân đội các nước đã sử dụng các công cụ phá mã, thám mã để giải mã các thông điệp của quân địch.
- Năm 1976 chuẩn mã hóa DES (Data Encryption Standard) được Cơ quan mật vụ Hoa Kỳ (NSA – National Security Agency) thừa nhận và sử dụng rộng rãi.

- Năm 1976, hai nhà khoa học Whitman Diffie và Martin Hellman đã đưa ra khái niệm mã hóa khóa bất đối xứng (Asymmetric key cryptography), hay mã hóa khóa công khai (Public key cryptography). Điều này đã đem đến những thay đổi lớn trong kỹ thuật mật mã. Theo đó, các hệ mã hóa khóa công khai bắt đầu được sử dụng rộng rãi nhờ khả năng hỗ trợ trao đổi khóa dễ dàng hơn trong khi các hệ mã hóa khóa bí mật gặp khó khăn trong quản lý và trao đổi khóa, đặc biệt khi số lượng người dùng lớn.
- Năm 1977, ba nhà khoa học Ronald Rivest, Adi Shamir, và Leonard Adleman giới thiệu giải thuật mã hóa khóa công khai RSA. Từ đó, RSA trở thành giải thuật mã hóa khóa công khai được sử dụng rộng rãi nhất do RSA có thể vừa được sử dụng để mã hóa thông tin và sử dụng trong chữ ký số.
- Năm 1991, phiên bản đầu tiên của chuẩn PGP (Pretty Good Privacy) ra đời.
- Năm 2001, chuẩn mã hóa AES (Advanced Encryption Standard) được thừa nhận và ứng dụng rộng rãi.

4.1.5. Ứng dụng của mã hóa

Mã hoá thông tin có thể được sử dụng để đảm bảo an toàn thông tin với các thuộc tính: bí mật (confidentiality), toàn vẹn (integrity), xác thực (authentication), không thể chối bỏ (non-repudiation). Cụ thể, các kỹ thuật mã hóa được ứng dụng rộng rãi trong các hệ thống, công cụ và dịch vụ bảo mật như:

- Dịch vụ xác thực (Kerberos, SSO, RADIUS,...)
- Điều khiển truy nhập
- Các công cụ cho đảm bảo an toàn cho truyền thông không dây
- Các nền tảng bảo mật như PKI, PGP
- Các giao thức bảo mật như SSL/TLS, SSH, SET, IPSec
- Các hệ thống bảo mật kênh truyền, như VPN.

4.2. CÁC PHƯƠNG PHÁP MÃ HÓA

4.2.1. Phương pháp thay thế

Phương pháp thay thế (Substitution) là phương pháp thay thế một giá trị này bằng một giá trị khác, như thay một ký tự bằng một ký tự khác, hoặc thay một bit bằng một bit khác. Hình 4.8 biểu diễn bộ chữ gốc, bộ chữ mã và ví dụ mã hóa sử dụng hệ mã hóa nổi tiếng thời La Mã là Caesar cipher. Nguyên tắc của Caesar cipher là dịch 3 chữ trong bộ ký tự tiếng Anh sang bên phải ($A \rightarrow D, B \rightarrow E, C \rightarrow F, \dots$). Bản rõ “LOVE” được mã hóa thành “ORYH”.

Bộ chữ gốc	ABCDEFGHIJKLMNOPQRSTUVWXYZ
Bộ chữ mã	DEFGHIJKLMNOPQRSTUVWXYZABC
LOVE $\rightarrow$ ORYH	

Hình 4.8. Mã hóa bằng hệ mã hóa Caesar cipher

Plaintext =	ABCDEFGHIJKLMNOPQRSTUVWXYZ
Substitution cipher 1 =	DEFGHIJKLMNOPQRSTUVWXYZABC
Substitution cipher 2 =	GHIJKLMNOPQRSTUVWXYZABCDEF
Substitution cipher 3 =	JKLMNOPQRSTUVWXYZABCDEFGHI
Substitution cipher 4 =	MNOPQRSTUVWXYZABCDEFGHIJKL

Ký tự số 1 dùng bộ mã 1, ký tự 2 dùng bộ mã 2,...
TEXT → WKGF

Hình 4.9. Phương pháp thay thế với 4 bộ chữ mã

Để tăng độ an toàn của phương pháp thay thế với một bộ chữ mã, người ta có thể sử dụng nhiều bộ chữ mã, như minh họa trên Hình 4.9 với 4 bộ chữ mã (Substitution cipher), với nguyên tắc thay thế: ký tự số 1 ở bản rõ thay thế sử dụng bộ chữ mã số 1, ký tự số 2 sử dụng bộ chữ mã số 2,..., ký tự số 5 sử dụng bộ chữ mã số 1, ký tự số 6 sử dụng bộ chữ mã số 2,... Nếu các bộ chữ mã được sắp đặt ngẫu nhiên thì cùng một ký tự xuất hiện ở các vị trí khác nhau trong bản rõ sẽ được chuyển đổi thành các ký tự khác nhau trong bản mã. Điều này giúp tăng độ an toàn do làm tăng độ khó trong việc phân tích đoán bản rõ từ bản mã.

4.2.2. Phương pháp hoán vị

Key	1→4, 2→8, 3→1, 4→5, 5→7, 6→2, 7→6, 8→3
Bit locations:	87654321 87654321 87654321 87654321
Plaintext 8-bit blocks:	00100101 01101011 10010101 01010100
Ciphertext:	00001011 10111010 01001101 01100001

Hình 4.10. Phương pháp hoán vị thực hiện đổi chỗ các bit

Letter locations:	87654321 87654321 87654321 87654321
Plaintext:	SACKGAUL SPARENOO NE
Key:	1→4, 2→8, 3→1, 4→5, 5→7, 6→2, 7→6, 8→3
Ciphertext:	UKAGLSCA ORPEOSAN E N

Hình 4.11. Phương pháp hoán vị thực hiện đổi chỗ các ký tự

Phương pháp hoán vị, hoặc đổi chỗ (Permutation) thực hiện sắp xếp lại các giá trị trong một khối bản rõ để tạo bản mã. Thao tác hoán vị có thể thực hiện với từng bit hoặc từng byte (ký tự). Hình 4.10 minh họa ví dụ mã hóa bằng phương pháp hoán vị thực hiện đổi chỗ các bit, trong đó việc đổi chỗ được thực hiện theo khóa (Key) trong khối 8 bit, tính từ bên phải. Hình 4.11 minh họa ví dụ mã hóa bằng phương pháp hoán vị thực hiện đổi chỗ các ký tự,

trong đó việc đổi chỗ được thực hiện theo khóa trong khối 8 ký tự, tính từ bên phải. Với bản rõ “SACKGAULSPARENOONE” ta có 3 khối, 2 khối đầu đủ 8 ký tự, còn khối cuối chỉ có 2 ký tự “NE” nên phải chèn thêm dấu trắng cho đủ khối 8 ký tự.

4.2.3. Phương pháp XOR

Phương pháp mã hóa XOR sử dụng phép toán logic XOR (eXclusive OR – hoặc loại trừ) để tạo bản mã, trong đó từng bit của bản rõ được XOR với bit tương ứng của khóa. Để giải mã, ta thực hiện XOR từng bit của bản mã với bit tương ứng của khóa. Hình 4.12 minh họa quá trình mã hóa bản rõ “CAT” với khóa “VVV”. Theo đó, các ký tự của bản rõ và khóa trước hết được chuyển thành mã ASCII và biểu diễn dưới dạng nhị phân. Sau đó, thực hiện phép toán XOR trên các bit tương ứng của bản rõ và khóa để tạo bản mã (Cipher).

Text Value	Binary Value
CAT as bits	0 1 0 0 0 0 1 1 0 1 0 0 0 0 0 1 0 1 0 1 0 1 0 0
VVV as key	0 1 0 1 0 1 1 0 0 1 0 1 0 1 1 0 0 1 0 1 0 1 1 0
Cipher	0 0 0 1 0 1 0 1 0 0 0 1 0 1 1 1 0 0 0 0 0 0 1 0

Hình 4.12. Mã hóa bằng phương pháp XOR

4.2.4. Phương pháp Vernam

Phương pháp Vernam sử dụng một tập ký tự để nối vào các ký tự của bản rõ để tạo bản mã. Tập ký tự này được gọi là *one-time pad* và mỗi ký tự trong tập chỉ dùng 1 lần trong một tiến trình mã hóa. Với bộ chữ tiếng Anh có 26 chữ cái, quá trình mã hóa bằng phương pháp Vernam được thực hiện như sau:

- Các ký tự của bản rõ và các ký tự của tập nối thêm (*one-time pad*) được chuyển thành số trong khoảng 1-26;
- Cộng giá trị của ký tự trong bản rõ với giá trị tương ứng trong tập nối thêm;
- Nếu giá trị cộng lớn hơn 26 thì đem trừ cho 26 (đây chính là phép modulo – chia lấy phần dư).
- Chuyển giá trị số thành ký tự mã.

Hình 4.13 minh họa mã hóa bản rõ “SACKGAULSPARENOONE” bằng phương pháp Vernam với tập nối thêm “FPQRNSBIEHTZLACDGJ”.

Plaintext:	S	A	C	K	G	A	U	L	S	P	A	R	E	N	O	O	N	E
Plaintext value:	19	01	03	11	07	01	21	12	19	16	01	18	05	14	15	15	14	05
One-time pad text:	F	P	Q	R	N	S	B	I	E	H	T	Z	L	A	C	D	G	J
One time pad value:	06	16	17	18	14	19	02	09	05	08	20	26	12	01	03	04	07	10
Sum of plaintext and pad:	25	17	20	29	21	20	23	21	24	24	21	44	17	15	18	19	21	15
After modulo Subtraction:					03							18						
Ciphertext:	Y	Q	T	C	U	T	W	U	X	X	U	R	Q	O	R	S	U	O

Hình 4.13. Mã hóa bằng phương pháp Vernam

4.2.5. Phương pháp sách hoặc khóa chạy

Phương pháp sách, hoặc khóa chạy thực hiện việc mã hóa và giải mã sử dụng các khóa mã chứa trong các cuốn sách. Hiện nay phương pháp này thường được dùng trong các bộ phim trinh thám do tính chất kỳ bí của nó. Ví dụ như, với bản mã “259,19,8; 22,3,8; 375,7,4; 394,17,2” và cuốn sách được dùng chứa khóa là “A Fire Up on the Deep”, ta có thể giải mã như sau:

- Trang 259, dòng 19, từ thứ 8 là *sack*
- Trang 22, dòng 3, từ thứ 8 là *island*
- Trang 375, dòng 7, từ thứ 4 là *sharp*
- Trang 394, dòng 17, từ thứ 2 là *path*

Bản rõ tương ứng của bản mã “259,19,8;22,3,8;375,7,4;394,17,2” là “sack island sharp path”.

4.2.6. Phương pháp hàm băm

Các hàm băm (Hash function) là các giải thuật để tạo các bản tóm tắt (digest) của thông điệp, thường được sử dụng để nhận dạng và đảm bảo tính toàn vẹn của thông điệp. Độ dài của thông điệp đầu vào là bất kỳ, nhưng đầu ra hàm băm thường có độ dài cố định. Chi tiết về các hàm băm được ở mục 4.4. Các hàm băm thông dụng gồm:

- Các hàm băm MD2, MD4, MD5 với độ dài chuỗi đầu ra là 128 bit;
- Hàm băm MD6 cho chuỗi đầu ra có độ dài trong khoảng 0 đến 512 bit;
- Các hàm băm SHA0, SHA1 với độ dài chuỗi đầu ra là 160 bit;
- Các hàm băm SHA2, gồm SHA256, SHA384, SHA512 cho phép một số lựa chọn chuỗi đầu ra tương ứng 256, 384 và 512 bit;
- Hàm băm SHA3 cho chuỗi đầu ra có độ dài trong khoảng 0 đến 512 bit;
- Hàm băm CRC32 với chuỗi đầu ra 32 bit sử dụng trong kiểm tra dư thừa mạch vòng.

4.3. CÁC GIẢI THUẬT MÃ HÓA

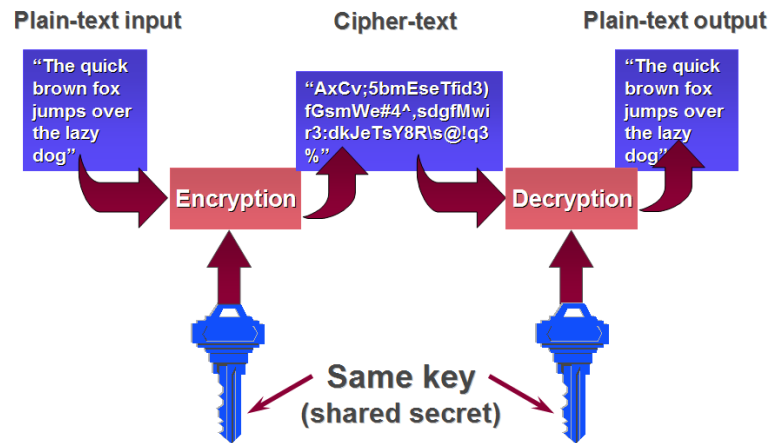
4.3.1. Các giải thuật mã hóa khóa đối xứng

4.3.1.1. Khái quát về mã hóa khóa đối xứng

Mã hóa khóa đối xứng (Symmetric key encryption) hay còn gọi là mã hóa khóa bí mật (Secret key encryption) sử dụng một khóa bí mật (Secret key) duy nhất cho cả quá trình mã hóa và giải mã. Khóa bí mật được sử dụng trong quá trình mã hóa và giải mã còn được gọi là *khóa chia sẻ* (Shared key) do bên gửi (Sender) và bên nhận (Receiver) cần chia sẻ khóa bí mật một cách an toàn trước khi có thể thực hiện việc mã hóa và giải mã. Hình 4.14 minh họa quá trình mã hóa và giải mã sử dụng chung một khóa bí mật chia sẻ.

Các hệ mã hóa khóa đối xứng thường sử dụng khóa với kích thước tương đối ngắn. Một số kích thước khóa được sử dụng phổ biến là 64, 128, 192 và 256 bit. Do sự phát triển nhanh về tốc độ tính toán của máy tính, nên các khóa có kích thước nhỏ hơn 128 bit được xem là không an toàn và hầu hết các hệ mã hóa khóa đối xứng đảm bảo an toàn hiện tại sử dụng khóa có kích thước từ 128 bit trở lên. Ưu điểm nổi bật của các hệ mã hóa khóa đối xứng là có độ an

toàn cao và tốc độ thực thi nhanh. Tuy nhiên, nhược điểm lớn nhất của các hệ mã hóa khóa đối xứng là việc quản lý và phân phối khóa rất khó khăn, đặc biệt là trong các môi trường mở như mạng Internet do các bên tham gia phiên truyền thông cần thực hiện việc trao đổi các khóa bí mật một cách an toàn trước khi có thể sử dụng chúng để mã hóa và giải mã các thông điệp trao đổi.



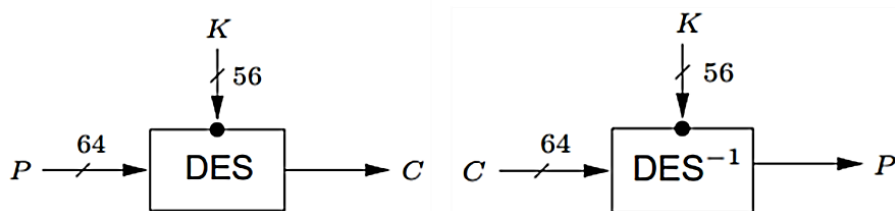
Hình 4.14. Quá trình mã hóa khóa đối xứng (Symmetric key encryption)

Một số hệ mã hóa khóa đối xứng tiêu biểu, gồm DES (Data Encryption Standard), 3-DES (Triple-DES), AES (Advanced Encryption Standard), IDEA (International Data Encryption Algorithm), Blowfish, Twofish, RC4 và RC5. Phần tiếp theo của mục này là mô tả các giải thuật mã hóa DES, 3-DES và AES do chúng là các giải thuật đã và đang được sử dụng rộng rãi nhất trên thực tế.

4.3.1.2. Giải thuật mã hóa DES

a. Giới thiệu

DES (Data Encryption Standard) được phát triển tại IBM với tên gọi Lucifer vào đầu những năm 1970 và được chấp nhận là chuẩn mã hóa ở Hoa Kỳ vào năm 1977. DES được sử dụng rộng rãi trong những năm 1970 và 1980. DES là dạng mã hóa khối với khối dữ liệu vào kích thước 64 bit và khóa 64 bit, trong đó thực sự sử dụng 56 bit của khóa (còn gọi là kích thước hiệu dụng của khóa) và 8 bit còn lại dùng cho kiểm tra chẵn lẻ. Một ưu điểm của DES là sử dụng chung một giải thuật cho cả khâu mã hóa và khâu giải mã, như minh họa trên Hình 4.15, trong đó P là khối bản rõ 64 bit, K là khóa với kích thước hiệu dụng 56 bit, C là khối bản mã 64 bit, DES biểu diễn khâu mã hóa và DES^{-1} biểu diễn khâu giải mã. Hiện nay DES được coi là không an toàn do nó có không gian khóa nhỏ, dễ bị vét cạn và tốc độ tính toán của các hệ thống máy tính ngày càng nhanh.

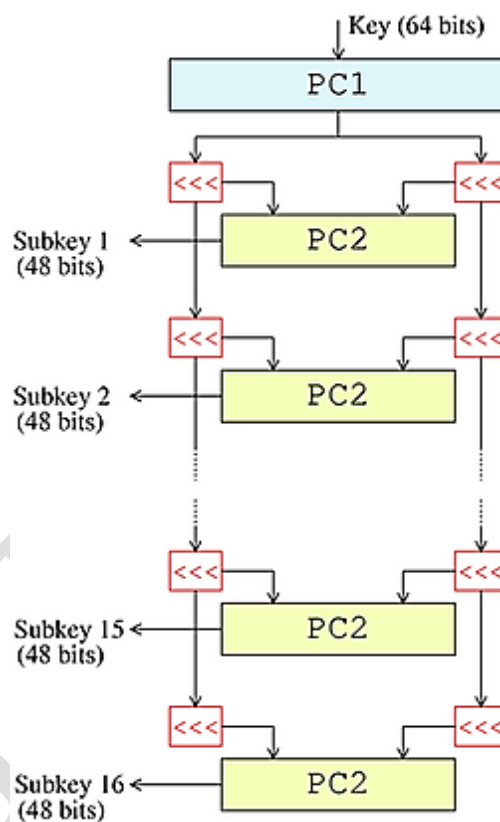


Hình 4.15. Mô hình các khâu mã hóa và giải mã của DES

b. Thủ tục sinh khoá phụ

DES sử dụng một thủ tục sinh 16 khoá phụ (Subkey) từ khoá chính để sử dụng trong 16 vòng lặp hàm Feistel – là hàm xử lý khối dữ liệu của DES. Hình 4.16 minh họa thủ tục sinh 16 khoá phụ từ khoá chính của DES. Các bước xử lý chính của thủ tục sinh khoá phụ như sau:

- 56 bit khoá được chọn từ khoá gốc 64 bit bởi PC1 (Permuted Choice 1). 8 bit còn lại được hủy hoặc dùng để kiểm tra chẵn lẻ;
- 56 bit được chia thành 2 phần 28 bit, mỗi phần được xử lý riêng;
- Mỗi phần được quay trái 1 hoặc 2 bit;
- Hai phần được ghép lại và 48 bit được chọn làm khoá phụ 1 (Subkey 1) bởi PC2;
- Lặp lại bước trên để tạo 15 khoá phụ còn lại.

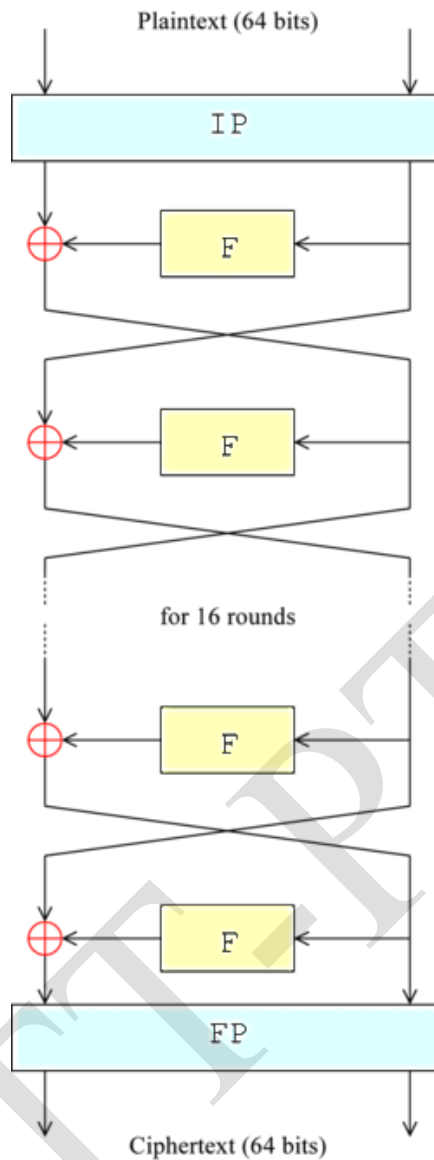


Hình 4.16. Thủ tục sinh các khoá phụ từ khoá chính của DES

c. Mã hoá khối dữ liệu

Với mỗi khối dữ liệu đầu vào 64 bit, DES thực hiện 3 bước xử lý như minh họa trên Hình 4.17 để chuyển nó thành khối mã 64 bit tương ứng. Các bước cụ thể gồm:

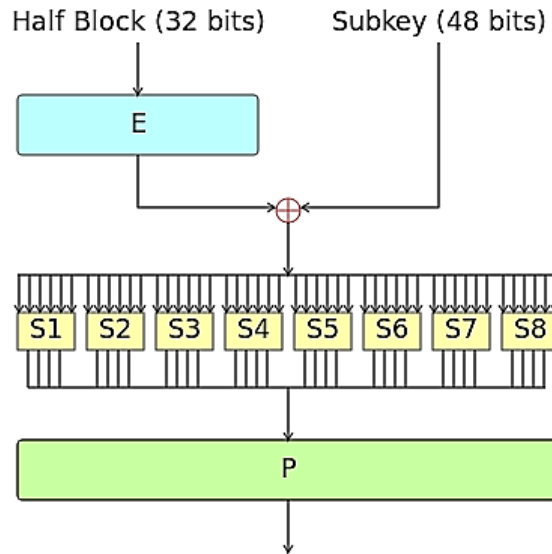
- Bước 1: Hoán vị khởi tạo (IP – Initial Permutation);
- Bước 2: 16 vòng lặp chính thực hiện xáo trộn dữ liệu sử dụng hàm Feistel (F). Trong mỗi vòng lặp, một khoá phụ được tạo từ khoá chính được sử dụng. Sau mỗi vòng lặp, các kết quả trung gian được kết hợp lại sử dụng phép $\oplus$ (XOR).
- Bước 3: Hoán vị kết thúc (FP – Final Permutation).



Hình 4.17. Các bước xử lý chuyển khối rõ 64 bit thành khối mã 64 bit của DES

Hàm Feistel (F) là hạt nhân trong các vòng lặp xử lý dữ liệu của DES. Trước hết, khối 64 bit được chia thành 2 khối 32 bit và được xử lý lần lượt. Hàm Feistel được thực hiện trên một khối dữ liệu 32 bit (Half Block 32 bits) gồm 4 bước xử lý như minh họa trên Hình 4.18. Cụ thể, các bước xử lý như sau:

- E (Expansion): thực hiện mở rộng 32 bit khối đầu vào thành 48 bit bằng cách nhân đôi một nửa số bit.
- $\oplus$: Trộn khối 48 bit kết quả ở bước E với khóa phụ 48 bit. Khóa phụ được sinh từ thủ tục sinh khóa phụ đã mô tả ở trên.
- Si (Substitution): Khối dữ liệu 48 bit được chia thành 8 khối 6 bit và được chuyển cho các bộ thay thế (S1-S8). Mỗi bộ thay thế Si sử dụng phép chuyển đổi phi tuyến tính để chuyển 6 bit đầu vào thành 4 bit đầu ra theo bảng tham chiếu. Các bộ thay thế là thành phần nhân an ninh (Security core) của DES.
- P (Permutation): khối 32 bit đầu ra từ các bộ thay thế được sắp xếp bằng phép hoán vị cố định (Fixed permutation) cho ra đầu ra 32 bit.



Hình 4.18. Các bước xử lý của hàm Feistel (F)

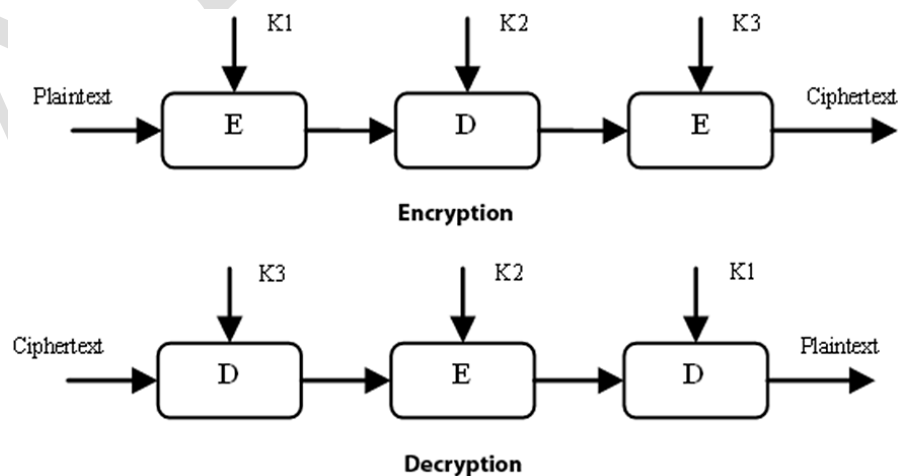
d. Giải mã khối dữ liệu

Như đã đề cập, giải thuật DES có thể sử dụng cho cả khâu mã hóa và giải mã. Trong khâu giải mã các bước xử lý tương tự khâu mã hóa. Tuy nhiên, các khóa phụ sử dụng cho các vòng lặp được sử dụng theo trật tự ngược lại: khóa phụ số 16, 15,..., 2, 1 được sử dụng cho các vòng lặp số 1, 2,..., 15, 16 tương ứng.

4.3.1.3. Giải thuật mã hóa 3-DES

3-DES hay Triple DES có tên đầy đủ là Triple Data Encryption Algorithm (TDEA) được phát triển từ giải thuật DES bằng cách áp dụng giải thuật DES 3 lần cho mỗi khối dữ liệu đầu vào 64 bit. 3-DES sử dụng một bộ gồm 3 khóa DES: K1, K2, K3, trong đó mỗi khóa kích thước hiệu dụng là 56 bit. 3-DES cho phép lựa chọn các bộ khóa:

- Lựa chọn 1: cả 3 khóa độc lập, với tổng kích thước bộ khóa là 168 bit;
- Lựa chọn 2: K1 và K2 độc lập, K3 = K1, với tổng kích thước bộ khóa là 112 bit;
- Lựa chọn 3: 3 khóa giống nhau, K1 = K2 = K3, với tổng kích thước bộ khóa là 56 bit.



Hình 4.19. Mã hóa và giải mã với giải thuật 3-DES

Hình 4.19 biểu diễn quá trình mã hóa và giải mã với giải thuật 3-DES, trong đó khâu mã hóa được ký hiệu là E và khâu giải mã được ký hiệu là D. Theo đó, ở bên gửi bản rõ (Plaintext) được mã hóa bằng khóa K1, giải mã bằng khóa K2 và mã hóa bằng khóa K3 để cho ra bản mã (Ciphertext). Ở bên nhận, quá trình giải mã bắt đầu bằng việc giải mã bằng khóa K3, sau đó mã hóa bằng khóa K2 và cuối cùng giải mã bằng khóa K1 để khôi phục bản rõ. Ưu điểm của 3-DES là nâng cao được độ an toàn nhờ tăng kích thước khóa. Tuy nhiên, nhược điểm chính của 3-DES là tốc độ thực thi chậm do phải thực hiện DES lặp 3 lần cho mỗi khâu mã hóa và giải mã.

4.3.1.4. Giải thuật mã hóa AES

a. Giới thiệu

AES (Advanced Encryption Standard) là một chuẩn mã hóa dữ liệu được Viện Tiêu chuẩn và Công nghệ Hoa Kỳ (NIST) công nhận năm 2001. AES được xây dựng dựa trên Rijndael cipher được phát triển và công bố năm 1998 bởi 2 nhà mật mã học người Bỉ là Joan Daemen và Vincent Rijmen. AES là dạng mã hóa khối, với khối dữ liệu đầu vào có kích thước 128 bit và khóa bí mật với kích thước có thể là 128, 192, hoặc 256 bit. AES được thiết kế dựa trên mạng hoán vị-thay thế (Substitution-permutation network) và nó có thể cho tốc độ thực thi cao khi cài đặt bằng cả phần mềm và phần cứng. Đặc biệt, giải thuật AES đã được tích hợp vào các bộ vi xử lý gần đây của hãng Intel dưới dạng tập lệnh AES-NI, giúp tăng đáng kể tốc độ thực thi các thao tác mã hóa và giải mã dựa trên AES.

AES vận hành dựa trên một ma trận vuông 4x4, được gọi là *state* (trạng thái). Ma trận này gồm 16 phần tử, mỗi phần tử là 1 byte dữ liệu. State được khởi trị là khối 128 bit bản rõ và qua quá trình biến đổi sẽ chứa khối 128 bit bản mã ở đầu ra. Như đã đề cập, AES hỗ trợ 3 kích thước khóa và kích thước của khóa quyết định số vòng lặp chuyển đổi cần thực hiện để chuyển bản rõ thành bản mã như sau:

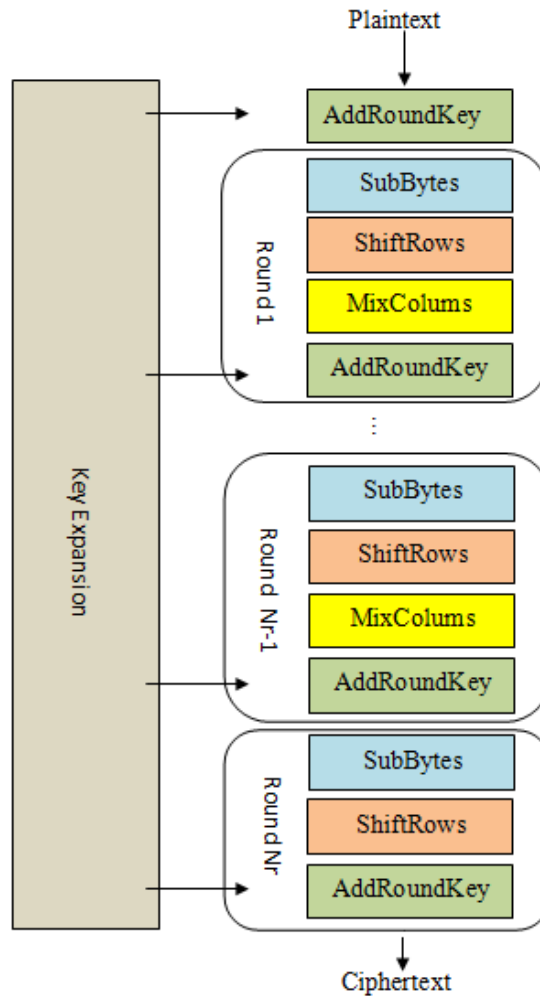
- 10 vòng lặp với khóa 128 bit;
- 12 vòng lặp với khóa 192 bit;
- 14 vòng lặp với khóa 256 bit.

b. Mô tả khái quát giải thuật

Giải thuật AES cho mã hóa dữ liệu, như minh họa trên Hình 4.20, gồm các bước xử lý chính như sau:

- Mở rộng khóa (Key expansion): các khóa vòng (Round key) dùng trong các vòng lặp được sinh ra từ khóa chính AES sử dụng thủ tục sinh khóa Rijndael.
- Vòng khởi tạo (Initial round): Thực hiện hàm AddRoundKey, trong đó mỗi byte trong *state* được kết hợp với khóa vòng sử dụng phép XOR.
- Các vòng lặp chính (Rounds): Có 4 hàm biến đổi dữ liệu được thực hiện trong mỗi vòng, gồm:
 - + SubBytes: hàm thay thế phi tuyến tính, trong đó mỗi byte trong *state* được thay thế bằng một byte khác sử dụng bảng tham chiếu S-box;
 - + ShiftRows: hàm đổi chỗ, trong đó mỗi dòng trong *state* được dịch một số bước theo chu kỳ;

- + MixColumns: trộn các cột trong *state*, kết hợp 4 bytes trong mỗi cột.
- + AddRoundKey.



Hình 4.20. Các bước xử lý mã hóa dữ liệu của AES

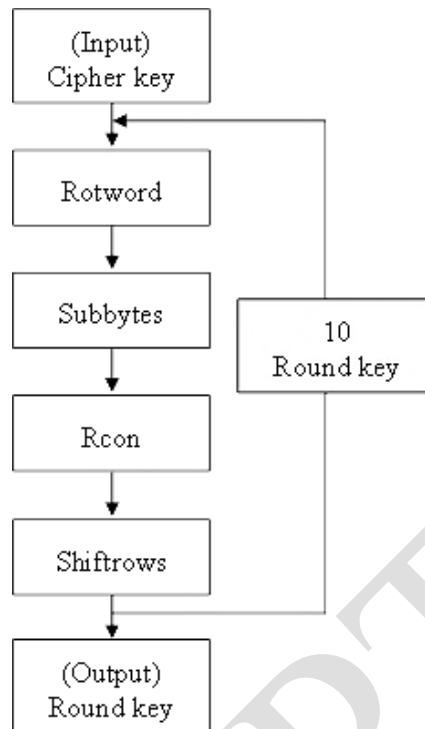
- Vòng cuối (Final Round): Tương tự các vòng lặp chính, nhưng chỉ thực hiện 3 hàm biến đổi dữ liệu, gồm:
 - + SubBytes;
 - + ShiftRows;
 - + AddRoundKey.

c. Mở rộng khóa

Khâu mở rộng khóa AES sử dụng thủ tục sinh khóa Rijndael để sinh các khóa vòng (Round key) cho các vòng lặp xử lý như biểu diễn trên Hình 4.21. Thủ tục Rijndael nhận đầu vào là khóa chính AES (cipher key) và xuất ra một khóa vòng sau mỗi vòng lặp. Một vòng lặp của thủ tục Rijndael gồm các khâu:

- Rotword: quay trái 8 bit từng từ 32 bit lấy từ khóa chính;
- SubBytes: thực hiện phép thay thế sử dụng bảng tham chiếu S-box.
- Rcon: tính toán giá trị $Rcon(i) = x^{(i-1)} \bmod (x^8 + x^4 + x^3 + x + 1)$

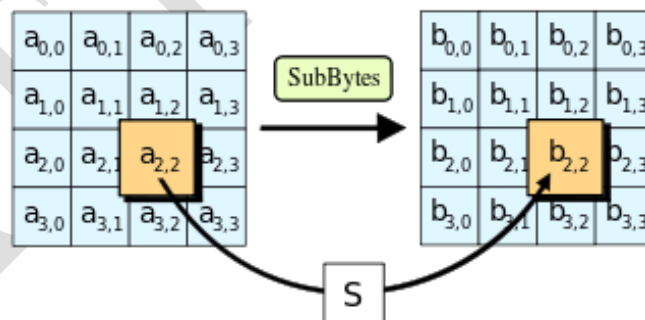
- ShiftRows: thực hiện đổi chỗ tương tự hàm ShiftRows của AES.



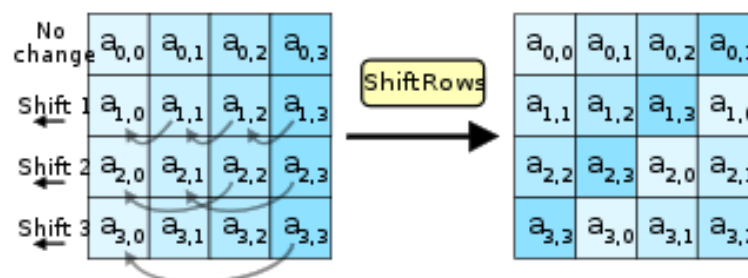
Hình 4.21. Thủ tục sinh khóa Rijndael

d. Các hàm xử lý chính

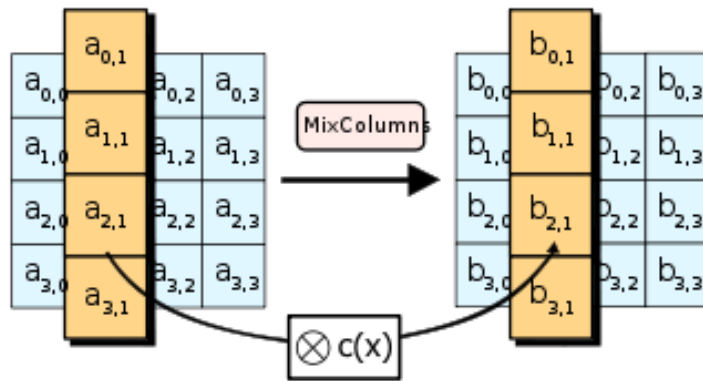
Hàm SubBytes: Mỗi byte trong ma trận *state* được thay thế bởi 1 byte trong Rijndael S-box, hay $b_{ij} = S(a_{ij})$ như minh họa trên Hình 4.22. S-box là một bảng tham chiếu phi tuyến tính, được tạo ra bằng phép nhân nghịch đảo một số cho trước trong trường $GF(2^8)$. Nếu như trong khâu mã hóa S-box được sử dụng thì bảng S-box đảo được sử dụng trong khâu giải mã.



Hình 4.22. Hàm SubBytes sử dụng Rijndael S-box



Hình 4.23. Hàm ShiftRows

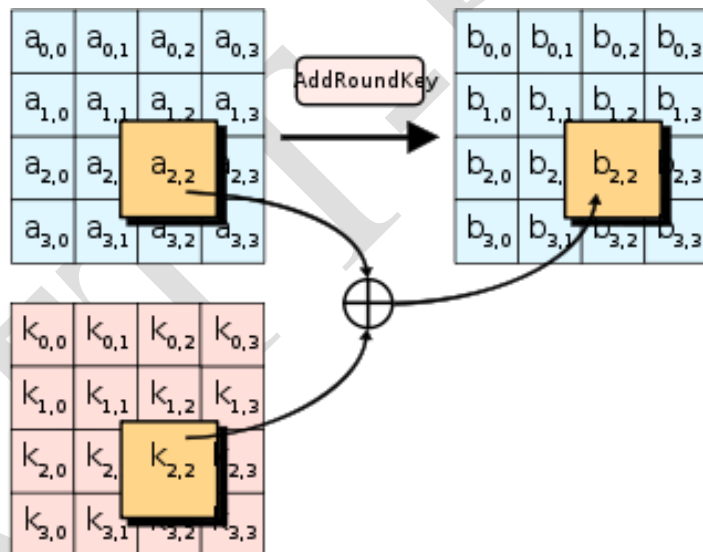


Hình 4.24. Hàm MixColumns

Hàm ShiftRows: Các dòng của ma trận *state* được dịch theo chu kỳ sang trái theo nguyên tắc: hàng số 0 giữ nguyên, hàng số 1 dịch 1 byte sang trái, hàng số 2 dịch 2 byte và hàng số 3 dịch 3 byte, như minh họa trên Hình 4.23.

Hàm MixColumns: Mỗi cột của ma trận *state* được nhân với một đa thức $c(x)$, như minh họa trên Hình 4.24. Đa thức $c(x) = 3x^3 + x^2 + x + 2$.

Hàm AddRoundKey: Mỗi byte của ma trận *state* được kết hợp với một byte tương ứng của khóa vòng sử dụng phép $\oplus$ (XOR), như minh họa trên Hình 4.25.

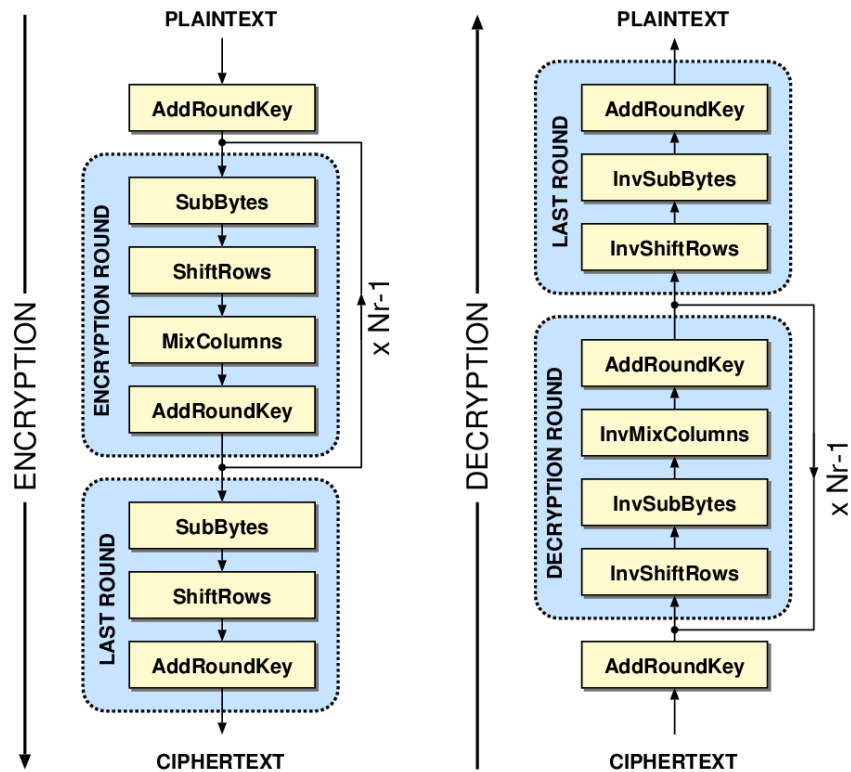


Hình 4.25. Hàm AddRoundKey

e. Giải mã

Khâu giải mã trong AES cũng gồm các bước xử lý tương tự như khâu mã hóa. Hình 4.26 biểu diễn quá trình mã hóa và giải mã trong AES. Theo đó, ngoài bước Mở rộng khóa, quá trình giải mã gồm Vòng khởi tạo (AddRoundKey), Các vòng lặp chính (Decryption round) và Vòng cuối (Last round) để chuyển khối mã thành khối rõ. Điểm khác biệt chính của khâu giải mã so với khâu mã hóa là các *hàm đảo* được sử dụng, gồm các InvSubBytes, InvShiftRows và InvMixColumns tương ứng thay cho các hàm SubBytes, ShiftRows và MixColumns. Hàm InvSubBytes thay thế các byte sử dụng bảng S-box *đảo*, InvShiftRows dịch các byte của dòng

sang phải theo cùng nguyên tắc với ShiftRows và hàm InvMixColumns nhân các cột của ma trận $state$ với đa thức $c(x)$ đảo.

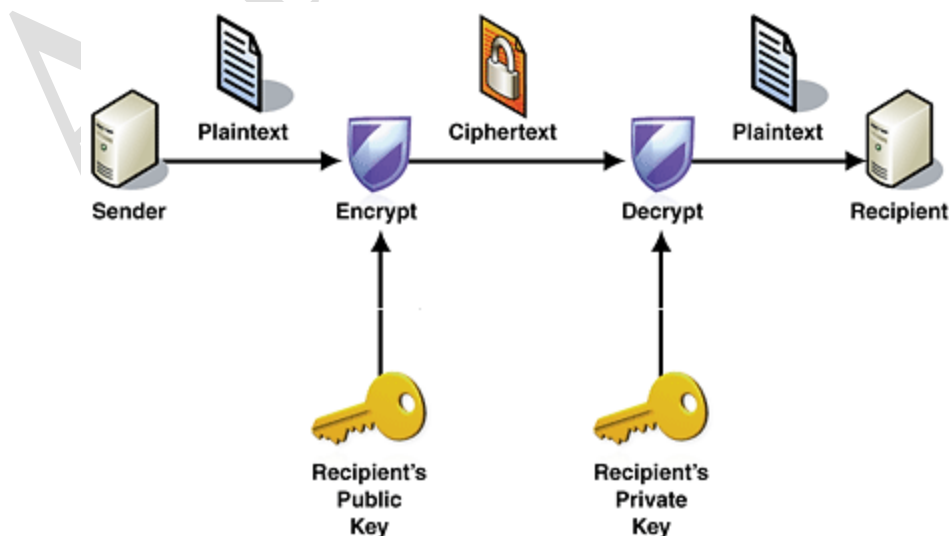


Hình 4.26. Quá trình mã hóa và giải mã trong AES

4.3.2. Các giải thuật mã hóa khóa bất đối xứng

4.3.2.1. Khái quát về mã hóa khóa bất đối xứng

Mã hóa khóa bất đối xứng, thường được gọi là mã hóa khóa công khai sử dụng một cặp khóa cho quá trình mã hóa và giải mã. Trong cặp khóa, khóa công khai được sử dụng cho mã hóa và khóa riêng được sử dụng cho giải mã. Chỉ khóa riêng cần giữ bí mật, còn khóa công khai có thể phổ biến rộng rãi, nhưng phải đảm bảo tính toàn vẹn và xác thực chủ thể của khóa.



Hình 4.27. Mã hóa và giải mã trong hệ mã hóa bất đối xứng

Hình 4.27 minh họa quá trình mã hóa (Encrypt) và giải mã (Decrypt) sử dụng mã hóa khóa bất đối xứng. Theo đó, người gửi (Sender) sử dụng khóa công khai (Public key) của người nhận (Recipient) để mã hóa bản rõ (Plaintext) thành bản mã (Ciphertext) và gửi nó cho người nhận. Người nhận nhận được bản mã sử dụng khóa riêng (Private key) của mình để giải mã khôi phục bản rõ.

Đặc điểm nổi bật của các hệ mã hóa khóa bất đối xứng là kích thước khóa lớn, có thể lên đến hàng ngàn bit. Do vậy, các hệ mã hóa dạng này thường có tốc độ thực thi chậm hơn nhiều lần so với các hệ mã hóa khóa đối xứng có độ an toàn tương đương. Mặc dù vậy, các hệ mã hóa khóa bất đối xứng có khả năng đạt độ an toàn cao và ưu điểm nổi bật nhất là việc quản lý và phân phối khóa đơn giản hơn do khóa công khai có thể phân phối rộng rãi.

Các giải thuật mã hóa khóa bất đối xứng điển hình bao gồm: RSA, Rabin, ElGamal, McEliece và Knapsack. Trong mục tiếp theo chúng ta tìm hiểu về giải thuật mã hóa RSA – một trong các giải thuật mã hóa khóa đối xứng được sử dụng rộng rãi nhất trên thực tế.

4.3.2.2. Giải thuật mã hóa RSA

a. Giới thiệu

Giải thuật mã hóa RSA được 3 nhà khoa học người Mỹ là Ronald Rivest, Adi Shamir và Leonard Adleman phát minh năm 1977, và tên giải thuật RSA lấy theo chữ cái đầu của tên 3 đồng tác giả. Độ an toàn của RSA dựa trên tính khó của việc phân tích số nguyên rất lớn, với độ lớn cỡ hàng trăm chữ số thập phân. Giải thuật RSA sử dụng một cặp khóa, trong đó khóa công khai dùng để mã hóa và khóa riêng dùng để giải mã. Chỉ khóa riêng RSA cần giữ bí mật. Khóa công khai có thể công bố rộng rãi. Hiện nay, các khóa RSA có kích thước nhỏ hơn 1024 bit được coi là không an toàn do tốc độ các hệ thống máy tính tăng nhanh. Để đảm bảo an toàn, khuyến nghị sử dụng khóa 2048 bit trong giai đoạn 2010-2020. Trong tương lai, cần sử dụng khóa RSA có kích thước lớn hơn, chẳng hạn 3072 bit.

b. Sinh khóa

RSA cung cấp một thủ tục sinh cặp khóa (khóa công khai và khóa riêng) tương đối đơn giản. Cụ thể, thủ tục sinh khóa gồm các bước như sau:

- Tạo 2 số nguyên tố p và q ;
- Tính modulo $n = p \times q$
- Tính $\Phi(n) = (p-1) \times (q-1)$
- Chọn số nguyên tố e sao cho $0 < e < \Phi(n)$ và $\gcd(e, \Phi(n)) = 1$, trong đó hàm $\gcd()$ tính ước số chung lớn nhất của 2 số nguyên. Nếu $\gcd(e, \Phi(n)) = 1$ thì e và $\Phi(n)$ là 2 số nguyên tố cùng nhau.
- Chọn số d sao cho $d \equiv e^{-1} \pmod{\Phi(n)}$,

$$\text{hoặc } (d \times e) \pmod{\Phi(n)} = 1$$
 hay d là modulo nghịch đảo của e .
- Ta có (n, e) là khóa công khai, (n, d) là khóa riêng và n còn được gọi là modulo.

c. Mã hóa và giải mã

- Mã hóa:
 - + Thông điệp bản rõ m đã được chuyển thành số, với $m < n$. Nếu thông điệp bản rõ m có kích thước lớn thì được chia thành các khối m_i , với $m_i < n$.
 - + Bản mã $c = m^e \bmod n$
- Giải mã:
 - + Bản mã c , với $c < n$
 - + Bản rõ $m = c^d \bmod n$

d. Ví dụ

- Sinh khóa:
 - + Chọn 2 số nguyên tố $p = 3$ và $q = 11$
 - + Tính $n = p \times q = 3 \times 11 = 33$
 - + Tính $\Phi(n) = (p-1) \times (q-1) = 2 \times 10 = 20$
 - + Chọn số e sao cho $0 < e < 20$, và e và $\Phi(n)$ là số nguyên tố cùng nhau ($\Phi(n)$ không chia hết cho e). Chọn $e = 7$
 - + Tính $(d \times e) \bmod \Phi(n) \rightarrow (d \times 7) \bmod 20 = 1$

$$d = (20 \times k + 1)/7 \rightarrow d = 3 \quad (k=1)$$
 - + Ta có: khóa công khai là $(33, 7)$ và khóa riêng là $(33, 3)$
- Mã hóa:
 - + Với bản rõ $m = 6$,
 - + $c = m^e \bmod n = 6^7 \bmod 33 = 279936 \bmod 33 = 30$
 - + Vậy bản mã $c = 30$
- Giải mã:
 - + Với bản mã $c = 30$
 - + $m = c^d \bmod n = 30^3 \bmod 33 = 27000 \bmod 33 = 6$
 - + Vậy bản rõ $m = 6$.

e. Một số yêu cầu với quá trình sinh khóa

Dưới đây liệt kê các yêu cầu đặt ra với các tham số sinh khóa và khóa để đảm bảo sự an toàn cho cặp khóa RSA. Các yêu cầu cụ thể gồm:

- Yêu cầu với các tham số sinh khóa p và q :
 - + Các số nguyên tố p và q phải được chọn sao cho việc phân tích n ($n = p \times q$) là không khả thi về mặt tính toán. p và q nên có cùng độ lớn (tính bằng bit) và phải là các số đủ lớn. Nếu n có kích thước 2048 bit thì p và q nên có kích thước khoảng 1024 bit.
 - + Hiệu số $p - q$ không nên quá nhỏ, do nếu $p - q$ quá nhỏ, tức $p \approx q$ và $p \approx \sqrt{n}$. Như vậy, có thể chọn các số nguyên tố ở gần $\sqrt{n}$ và thử. Khi có được p , có thể tính q và

tìm ra d là khóa bí mật từ khóa công khai e và $\Phi(n) = (p - 1)(q - 1)$. Nếu p và q được chọn ngẫu nhiên và $p - q$ đủ lớn, khả năng hai số này bị phân tích từ n giảm đi.

- Vấn đề sử dụng số mũ mã hóa (e) nhỏ: Khi sử dụng số mũ mã hóa (e) nhỏ, chẳng hạn $e = 3$ có thể tăng tốc độ mã hóa. Kẻ tấn công có thể nghe lén và lấy được bản mã, từ đó phân tích bản mã để khôi phục bản rõ. Do số mũ mã hóa nhỏ nên chi phí cho phân tích, hoặc vét cạn không quá lớn. Do vậy, nên sử dụng số mũ mã hóa e đủ lớn và thêm chuỗi ngẫu nhiên vào khối rõ trước khi mã hóa để giảm khả năng bị vét cạn hoặc phân tích bản mã.
- Vấn đề sử dụng số mũ giải mã (d) nhỏ: Khi sử dụng số mũ giải mã (d) nhỏ, có thể tăng tốc độ giải mã. Nếu d nhỏ và $\gcd(p-1, q-1)$ cũng nhỏ thì d có thể tính được tương đối dễ dàng từ khóa công khai (n, e) . Do vậy, để đảm bảo an toàn, nên sử dụng số mũ giải mã d đủ lớn.

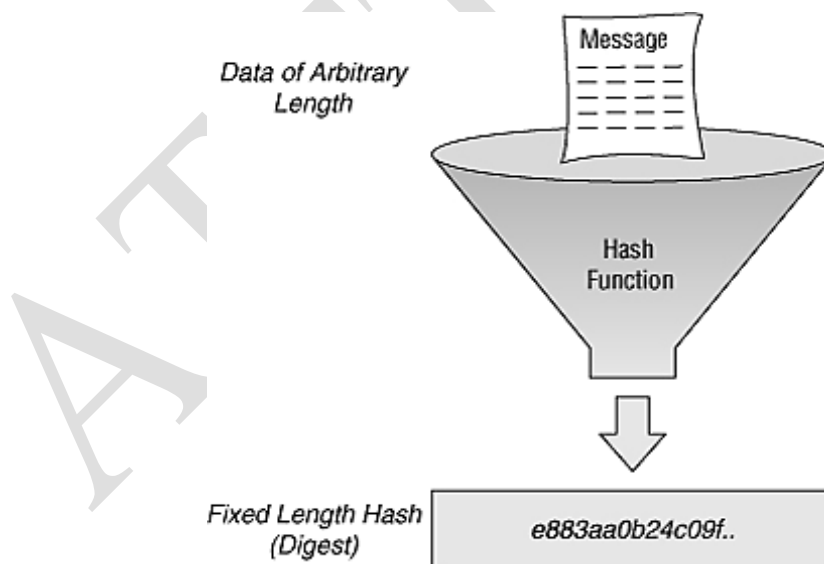
4.4. CÁC HÀM BẮM

4.4.1. Khái quát về hàm băm

4.4.1.1. Giới thiệu

Hàm băm (hash function) là một hàm toán học h có tối thiểu 2 thuộc tính:

- Nén (Compression): h là một ánh xạ từ chuỗi đầu vào x có chiều dài bất kỳ sang một chuỗi đầu ra $h(x)$ có chiều dài cố định n bit;
- Dễ tính toán (Ease of computation): cho trước hàm h và đầu vào x , việc tính toán $h(x)$ là dễ dàng.

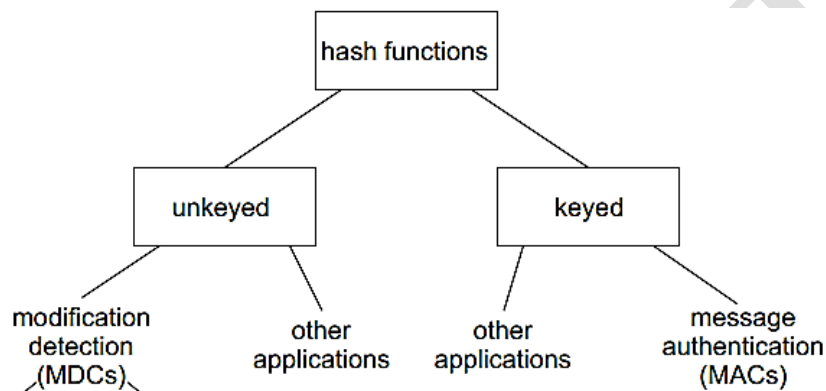


Hình 4.28. Mô hình nén thông tin của hàm băm

Hình 4.28 minh họa mô hình nén thông tin của hàm băm, theo đó thông điệp (Message) đầu vào với chiều dài tùy ý đi qua nhiều vòng xử lý của hàm băm để tạo chuỗi rút gọn, hay chuỗi đại diện (Digest) có kích thước cố định ở đầu ra.

4.4.1.2. Phân loại

Có thể phân loại các hàm băm theo khóa sử dụng hoặc theo chức năng. Theo khóa sử dụng, các hàm băm gồm 2 loại: hàm băm không khóa (unkeyed) và hàm băm có khóa (keyed), như biểu diễn trên Hình 4.29. Trong khi hàm băm không khóa nhận đầu vào chỉ là thông điệp (dạng $h(x)$, với hàm băm h và thông điệp x), hàm băm có khóa nhận đầu vào gồm thông điệp và khóa bí mật (theo dạng $h(x, K)$, với hàm băm h và thông điệp x và K là khóa bí mật). Trong các hàm băm không khóa, các mã phát hiện sửa đổi (MDC – Modification Detection Code) được sử dụng rộng rãi nhất, bên cạnh một số hàm băm không khóa khác. Tương tự, trong các hàm băm có khóa, các mã xác thực thông điệp (MAC - Message Authentication Code) được sử dụng rộng rãi nhất, bên cạnh một số hàm băm có khóa khác.



Hình 4.29. Phân loại các hàm băm theo khóa sử dụng

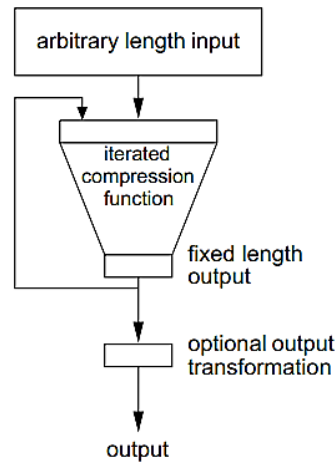
Theo chức năng, có thể chia các hàm băm thành 2 loại chính:

- Mã phát hiện sửa đổi (MDC - Modification Detection Code): MDC thường được sử dụng để tạo chuỗi đại diện cho thông điệp và dùng kết hợp với các kỹ thuật khác (như chữ ký số) để đảm bảo tính toàn vẹn của thông điệp. MDC thuộc loại hàm băm không khóa. MDC lại gồm 2 loại:
 - + Hàm băm một chiều (OWHF - One-way hash function): Với hàm băm một chiều, việc tính giá trị băm là dễ dàng, nhưng việc khôi phục thông điệp từ giá trị băm là rất khó khăn;
 - + Hàm băm chống đụng độ (CRHF - Collision resistant hash function): Với hàm băm chống đụng độ, sẽ là rất khó để tìm được 2 thông điệp khác nhau nhưng có cùng giá trị băm đầu ra.
- Mã xác thực thông điệp (MAC - Message Authentication Code): MAC cũng được dùng để đảm bảo tính toàn vẹn của thông điệp mà không cần một kỹ thuật bổ sung nào khác. MAC là loại hàm băm có khóa như đã đề cập ở trên, với đầu vào là thông điệp và một khóa bí mật.

4.4.1.3. Mô hình xử lý dữ liệu

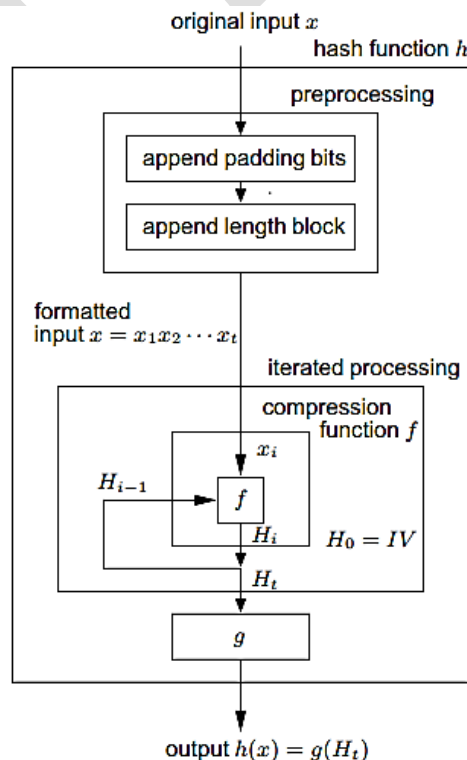
Hình 4.30 biểu diễn mô hình tổng quát xử lý dữ liệu của các hàm băm. Theo đó, thông điệp đầu vào với độ dài tùy ý (arbitrary length input) đi qua hàm nén lặp nhiều vòng (iterated compression function) để tạo chuỗi đầu ra có kích thước cố định (fixed length output). Chuỗi

này đi qua một khâu chuyển đổi định dạng tùy chọn (optional output transformation) để tạo ra chuỗi băm kết quả (output).



Hình 4.30. Mô hình tổng quát xử lý dữ liệu của hàm băm

Hình 4.31 mô tả chi tiết quá trình xử lý dữ liệu của các hàm băm. Theo đó, quá trình xử lý gồm 3 bước chính: (1) tiền xử lý (preprocessing), (2) xử lý lặp (iterated processing) và (3) chuyển đổi định dạng. Trong bước tiền xử lý, thông điệp đầu vào x trước hết được nối đuôi thêm một số bit và kích thước khối, sau đó chia thành các khối có kích thước xác định. Kết quả của bước này là t khối dữ liệu có cùng kích thước có dạng $x = x_1x_2 \dots x_t$ làm đầu vào cho bước 2. Trong bước 2, từng khối dữ liệu x_i được xử lý thông qua hàm nén f để tạo đầu ra là H_i . Kết quả của bước 2 là chuỗi đầu ra H_t và H_t được chuyển đổi định dạng bởi hàm g để tạo chuỗi giá trị băm kết quả $h(x)$.



Hình 4.31. Mô hình chi tiết xử lý dữ liệu của hàm băm

4.4.2. Một số hàm băm thông dụng

Các hàm băm thông dụng giới thiệu trong mục này đều là các hàm băm không khóa, gồm các họ hàm băm chính như sau:

- Họ hàm băm MD (Message Digest) gồm các hàm băm MD2, MD4, MD5 và MD6.
- Họ hàm băm SHA (Secure Hash Algorithm) gồm các hàm băm SHA0, SHA1, SHA2 và SHA3.
- Một số hàm băm khác, gồm CRC (Cyclic redundancy check), Checksum,...

Các mục con tiếp theo của mục này giới thiệu 2 hàm băm đã và đang được sử dụng rộng rãi nhất là hàm băm MD5 và SHA1.

4.4.2.1. Hàm băm MD5

a. Giới thiệu

MD5 (Message Digest) là hàm băm không khóa được Ronald Rivest thiết kế năm 1991 để thay thế MD4. Chuỗi giá trị băm đầu ra của MD5 là 128 bit (tương đương 16 byte) và thường được biểu diễn thành 32 số hexa. MD5 được sử dụng khá rộng rãi trong nhiều ứng dụng, như tạo chuỗi đảm bảo tính toàn vẹn thông điệp, tạo chuỗi kiểm tra lỗi, hoặc kiểm tra tính toàn vẹn dữ liệu (Checksum) và mã hóa mật khẩu trong các hệ điều hành và các ứng dụng. MD5 hiện nay được khuyến nghị không nên sử dụng do nó không còn đủ an toàn. Nhiều điểm yếu của MD5 đã bị khai thác, như điển hình MD5 bị khai thác bởi mã độc Flame vào năm 2012.

b. Quá trình xử lý thông điệp

Quá trình xử lý thông điệp của MD5 gồm 2 khâu là *tiền xử lý* và *các vòng lặp xử lý*. Cụ thể, chi tiết về các khâu này như sau:

- Tiền xử lý: Thông điệp được chia thành các khối 512 bit (16 từ, mỗi từ 32 bit). Nếu kích thước thông điệp không là bội số của 512 thì nối thêm số bit còn thiếu.
- Các vòng lặp xử lý: Phần xử lý chính của MD5 làm việc trên *state* 128 bit, chia thành 4 từ, mỗi từ 32 bit (A, B, C, D):
 - + Các từ A, B, C, D được khởi trị bằng một hằng cố định;
 - + Từng phần 32 bit của khối đầu vào 512 bit được đưa dần vào để thay đổi *state*;
 - + Quá trình xử lý gồm 4 vòng, mỗi vòng gồm 16 thao tác tương tự nhau.
 - + Mỗi thao tác gồm: Xử lý bởi hàm F (4 dạng hàm khác nhau cho mỗi vòng), phép Cộng modulo và phép Quay trái. Hình 4.32 biểu diễn lưu đồ xử lý của một thao tác của MD5, trong đó A, B, C, D là các từ 32 bit của *state*, Mi: khối 32 bit thông điệp đầu vào, Ki là 32 bit hằng khác nhau cho mỗi thao tác, <<<s là thao tác dịch trái s bit, $\boxplus$ biểu diễn phép cộng modulo 32 bit và F là hàm phi tuyến tính.

Hàm F gồm 4 dạng được dùng cho 4 vòng lặp. Cụ thể, F có các dạng như sau:

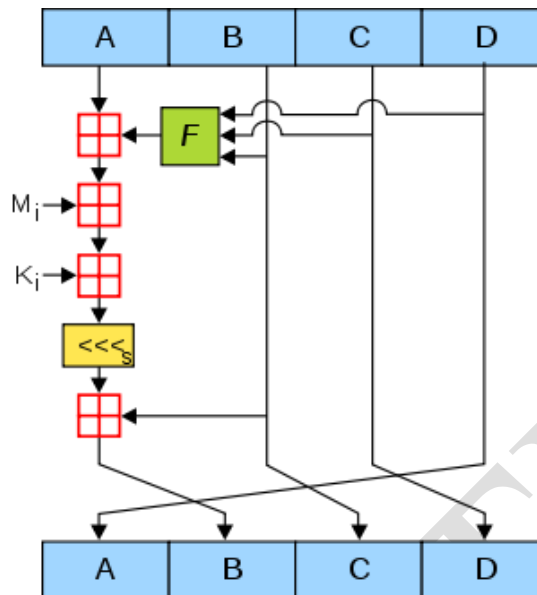
$$F(B, C, D) = (B \wedge C) \vee (\neg B \wedge D)$$

$$G(B, C, D) = (B \wedge D) \vee (C \wedge \neg D)$$

$$H(B, C, D) = B \oplus C \oplus D$$

$$I(B, C, D) = C \oplus (B \vee \neg D)$$

trong đó, các ký hiệu $\oplus$, $\wedge$, $\vee$, $\neg$ biểu diễn các phép toán lô gíc XOR, AND, OR và NOT tương ứng.



Hình 4.32. Lưu đồ xử lý một thao tác của MD5

4.4.2.2. Hàm băm SHA1

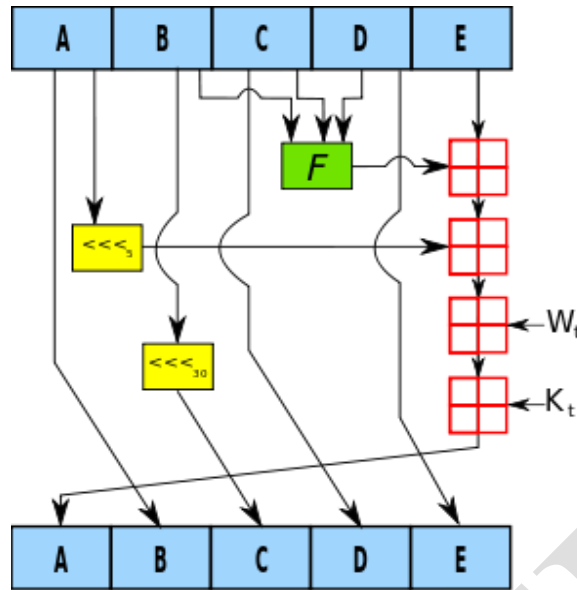
a. Giới thiệu

SHA1 (Secure Hash Function) được Cơ quan mật vụ Hoa Kỳ thiết kế năm 1995 để thay thế cho hàm băm SHA0. Chuỗi giá trị băm đầu ra của SHA1 có kích thước 160 bit và thường được biểu diễn thành 40 số hexa. Tương tự MD5, SHA1 được sử dụng rộng rãi để đảm bảo tính xác thực và toàn vẹn thông điệp.

b. Quá trình xử lý thông điệp

SHA1 sử dụng thủ tục xử lý thông điệp tương tự MD5, cũng gồm 2 khâu là *tiền xử lý* và *các vòng lặp xử lý*. Cụ thể, chi tiết về các khâu này như sau:

- Tiền xử lý: Thông điệp được chia thành các khối 512 bit (16 từ, mỗi từ 32 bit). Nếu kích thước thông điệp không là bội số của 512 thì nối thêm số bit còn thiếu.
- Các vòng lặp xử lý: Phần xử lý chính của SHA1 làm việc trên *state* 160 bit, chia thành 5 từ, mỗi từ 32 bit (A, B, C, D, E):
 - + Các từ A, B, C, D, E được khởi trị bằng một hằng cố định;
 - + Từng phần 32 bit của khối đầu vào 512 bit được đưa dần vào để thay đổi *state*;
 - + Quá trình xử lý gồm 80 vòng, mỗi vòng gồm các thao tác: add, and, or, xor, rotate, mod.
 - + Mỗi vòng xử lý gồm: Xử lý bởi hàm phi tuyến tính F (có nhiều dạng hàm khác nhau), phép Cộng modulo và phép Quay trái. Hình 4.33 biểu diễn lưu đồ một vòng xử lý của SHA1, trong đó A, B, C, D, E là các từ 32 bit của *state*, W_t : khối 32 bit thông điệp đầu vào, K_t là 32 bit hằng khác nhau cho mỗi vòng, $\lll n$ là thao tác dịch trái n bit, $\boxplus$ biểu diễn phép cộng modulo 32 bit và F là hàm phi tuyến tính.



Hình 4.33. Lưu đồ một vòng xử lý của SHA1

4.5. CÂU HỎI ÔN TẬP

- 1) Mã hóa thông tin là gì? Nêu vai trò của mã hóa.
- 2) Mô tả các thành phần của một hệ mã hóa.
- 3) Mô tả các phương pháp mã hóa dòng và mã hóa khối.
- 4) Nêu các ứng dụng của mã hóa.
- 5) Mô tả phương pháp mã hóa thay thế (substitution).
- 6) Mô tả phương pháp mã hóa hoán vị (permutation).
- 7) Mô tả phương pháp mã hóa XOR.
- 8) Vẽ sơ đồ hoạt động và nêu các đặc điểm hệ mã hóa khóa đối xứng.
- 9) Nêu các đặc điểm và mô tả các bước xử lý khối dữ liệu của giải thuật mã hóa DES.
- 10) Mô tả nguyên tắc hoạt động của giải thuật mã hóa 3-DES. Nêu các ưu nhược điểm của giải thuật mã hóa 3-DES.
- 11) Nêu các đặc điểm và mô tả các bước xử lý khối dữ liệu của giải thuật mã hóa AES.
- 12) Vẽ sơ đồ hoạt động và nêu các đặc điểm hệ mã hóa khóa bất đối xứng.
- 13) Nêu các đặc điểm, thủ tục sinh khóa, mã hóa và giải mã của giải thuật mã hóa RSA.
- 14) Nêu các yêu cầu đảm bảo an toàn của quá trình sinh khóa RSA.
- 15) Nêu 2 thuộc tính tối thiểu của hàm băm. Mô tả phương pháp phân loại các hàm băm.
- 16) Mô tả mô hình xử lý dữ liệu tổng quát và chi tiết của các hàm băm.
- 17) Nêu các đặc điểm và mô tả các bước xử lý dữ liệu của giải thuật băm MD5.
- 18) Nêu các đặc điểm và mô tả các bước xử lý dữ liệu của giải thuật băm SHA1.

CHƯƠNG 5. CÁC KỸ THUẬT VÀ CÔNG NGHỆ ĐẢM BẢO AN TOÀN THÔNG TIN

Chương 5 giới thiệu khái quát về điều khiển truy nhập, các cơ chế điều khiển truy nhập và một số công nghệ điều khiển truy nhập được sử dụng trên thực tế. Phần tiếp theo của chương giới thiệu về tường lửa – một trong các kỹ thuật được sử dụng rất phổ biến trong đảm bảo an toàn cho hệ thống máy tính và mạng. Phần cuối của chương giới thiệu về các hệ thống phát hiện và ngăn chặn xâm nhập.

5.1. ĐIỀU KHIỂN TRUY NHẬP

5.1.1. Khái niệm điều khiển truy nhập

Điều khiển truy nhập (Access control) là quá trình mà trong đó người dùng được *nhận dạng* và *trao quyền* truy nhập đến các thông tin, các hệ thống và tài nguyên. Một hệ thống điều khiển truy nhập có thể được cấu thành từ 3 dịch vụ: Xác thực (Authentication), Trao quyền, hoặc cấp quyền (Authorization) và Quản trị (Administration).

Xác thực là quá trình xác minh tính chân thực của các thông tin nhận dạng mà người dùng cung cấp. Đây là khâu đầu tiên cần thực hiện trong một hệ thống điều khiển truy nhập. Cần nhớ rằng, xác thực chỉ có khả năng khẳng định các thông tin nhận dạng mà người dùng cung cấp tồn tại trong hệ thống mà thường không thể xác minh chủ thể thực sự của thông tin đó. Sau khi người dùng đã được xác thực, *trao quyền* xác định các tài nguyên mà người dùng được phép truy nhập dựa trên chính sách quản trị tài nguyên của cơ quan, tổ chức và vai trò của người dùng trong hệ thống.

Trong khi Xác thực và Trao quyền là các dịch vụ chính của một hệ thống điều khiển truy nhập, Quản trị là dịch vụ cung cấp khả năng thêm, bớt và sửa đổi các thông tin tài khoản người dùng, cũng như quyền truy nhập của người dùng trong hệ thống. Mặc dù quản trị không trực tiếp tham gia vào quá trình xác thực và trao quyền cho người dùng, nó là dịch vụ không thể thiếu trong một hệ thống điều khiển truy nhập.

Mục đích chính của điều khiển truy nhập là để đảm bảo tính bí mật, toàn vẹn và sẵn dùng hoặc khả dụng của thông tin, hệ thống và các tài nguyên. Đây cũng là các yêu cầu đảm bảo an toàn thông tin và hệ thống thông tin đã đề cập trong Mục 1.2, CHƯƠNG 1.

5.1.2. Các biện pháp điều khiển truy nhập

Các biện pháp hay cơ chế (mechanism) điều khiển truy nhập là các phương pháp thực hiện điều khiển truy nhập, gồm 4 loại chính:

- Điều khiển truy nhập tùy chọn – Discretionary Access Control (DAC)
- Điều khiển truy nhập bắt buộc – Mandatory Access Control (MAC)
- Điều khiển truy nhập dựa trên vai trò – Role-Based Access Control (RBAC); và
- Điều khiển truy nhập dựa trên luật – Rule-Based Access Control.

Phần tiếp theo của mục này đề cập chi tiết từng biện pháp điều khiển truy nhập kể trên.

5.1.2.1. Điều khiển truy nhập tùy chọn

Điều khiển truy nhập tùy chọn (còn gọi là tùy quyền) được định nghĩa là cơ chế hạn chế truy nhập đến các đối tượng dựa trên thông tin nhận dạng của các chủ thể, hoặc nhóm của các chủ thể. Các thông tin nhận dạng chủ thể (còn gọi là các *nhân tố - factor*) có thể gồm:

- Bạn là ai? (CMND, bằng lái xe, vân tay,...)
- Những cái bạn biết (tên truy nhập, mật khẩu, số PIN...)
- Bạn có gì? (Thẻ ATM, thẻ tín dụng, ...)

Đặc điểm nổi bật của điều khiển truy nhập tùy chọn là cơ chế này cho phép người dùng có thể cấp hoặc huỷ quyền truy nhập cho các người dùng khác đến các đối tượng thuộc quyền điều khiển của họ. Điều này cũng có nghĩa là chủ sở hữu của các đối tượng (owner of objects) là người có toàn quyền điều khiển các đối tượng này. Chẳng hạn, trong một hệ thống nhiều người dùng, mỗi người dùng được cấp 1 thư mục riêng (home directory) và là chủ sở hữu của thư mục này. Người dùng có quyền tạo, sửa đổi và xóa các file trong thư mục của riêng mình. Người dùng cũng có khả năng cấp hoặc huỷ quyền truy nhập vào các file của mình cho các người dùng khác.

Có nhiều kỹ thuật thực hiện cơ chế điều khiển truy nhập tùy chọn trên thực tế, trong đó 2 kỹ thuật được sử dụng rộng rãi nhất là *Ma trận điều khiển truy nhập* (Access Control Matrix - ACM) và *Danh sách điều khiển truy nhập* (Access Control List - ACL). Ma trận điều khiển truy nhập là một phương pháp thực hiện điều khiển truy nhập thông qua 1 ma trận 2 chiều gồm chủ thể (subject), đối tượng (object) và các quyền truy nhập, như biểu diễn trên Hình 5.1. Các đối tượng, hay khách thể (Object) là các thực thể cần bảo vệ, được ký hiệu là $O_1, O_2, O_3, \dots$. Các đối tượng có thể là các file, các thư mục hay các tiến trình (process). Các chủ thể (Subject) là người dùng (user), hoặc các tiến trình tác động lên các đối tượng, được ký hiệu là $S_1, S_2, S_3, \dots$. Quyền truy nhập là hành động mà chủ thể thực hiện trên đối tượng. Các quyền bao gồm r (read – đọc), w (write - ghi), x (execute – thực hiện) và o (own – chủ sở hữu).

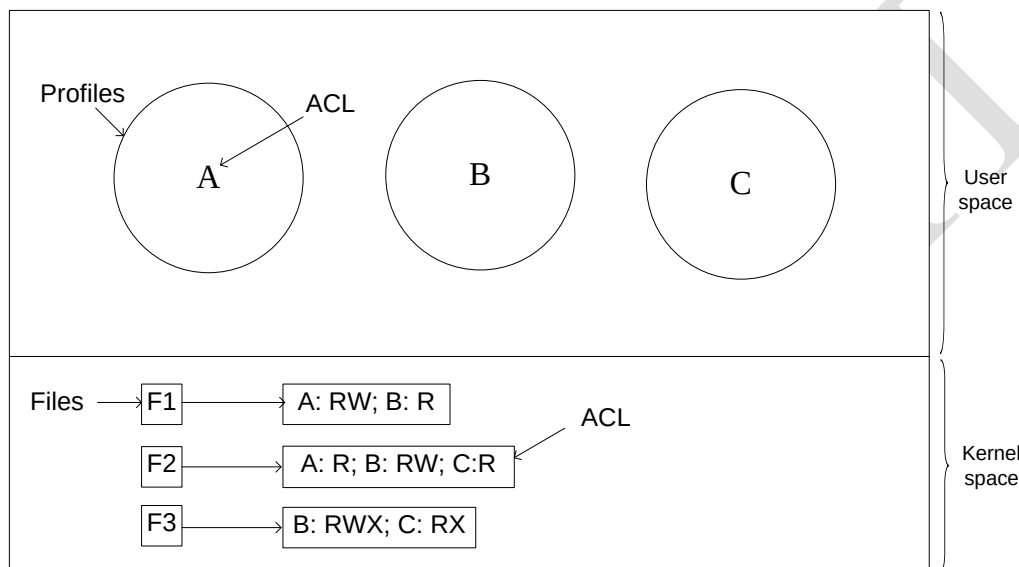
Objects Subjects	O1	O2	O3	O4
S1	rw	rwxo	r	rwxo
S2	rw	rx	rw	rwX
S3	r	rw	rwo	rw

Hình 5.1. Mô hình ma trận điều khiển truy nhập

Ưu điểm của ma trận điều khiển truy nhập là đơn giản, trực quan, dễ sử dụng. Tuy nhiên, khi số lượng các đối tượng và số lượng các chủ thể lớn, kích thước của ma trận sẽ rất lớn. Hơn nữa, quyền truy nhập của các chủ thể vào các đối tượng là khác nhau, trong đó một số chủ thể không có quyền truy nhập vào một số đối tượng, và như vậy ô nhớ chứa quyền truy nhập của chủ thể vào đối tượng là *rỗng*. Trong ma trận điều khiển truy nhập có thể tồn tại rất

nhiều ô rỗng và điều này làm giảm hiệu quả sử dụng bộ nhớ của phương pháp này. Do vậy, ma trận điều khiển truy nhập ít được sử dụng hiện nay trên thực tế.

Danh sách điều khiển truy nhập là một danh sách các quyền truy nhập của một chủ thể đối với một đối tượng. Một danh sách điều khiển truy nhập chỉ ra các người dùng hoặc tiến trình được truy nhập vào đối tượng nào và các thao tác cụ thể (hay quyền) được thực hiện trên đối tượng đó. Một bản ghi điển hình của ACL có dạng (subject, operation). Ví dụ bản ghi (Alice, write) của 1 file có nghĩa là Alice có quyền ghi vào file đó. Khi chủ thể yêu cầu truy nhập, hệ điều hành sẽ kiểm tra ACL xem yêu cầu đó có được phép hay không. ACL có thể được áp dụng cho một hoặc 1 nhóm đối tượng.



Hình 5.2. Mô hình danh sách điều khiển truy nhập

Hình 5.2 biểu diễn mô hình danh sách điều khiển truy nhập trong không gian người dùng (user space) và không gian nhân (kernel space) tổ chức bởi hệ điều hành. Mỗi file (F1, F2, F3,...) có một danh sách điều khiển truy nhập (ACL) của riêng mình lưu trong hồ sơ (profile) của file. Quyền truy nhập vào file được tổ chức thành một chuỗi gồm nhiều cặp (subject, operation), với A, B, C là ký hiệu biểu diễn chủ thể (subject) và các thao tác (operation) hay quyền gồm R (Read - đọc), W (Write - ghi), và X (eXecute - thực hiện). Chẳng hạn, trong danh sách điều khiển truy nhập F1(A: RW; B: R) thì chủ thể A được quyền đọc (R) và ghi (W) đối với F1, còn chủ thể B chỉ có quyền đọc (R).

5.1.2.2. Điều khiển truy nhập bắt buộc

Điều khiển truy bắt buộc (MAC) được định nghĩa là các cơ chế hạn chế truy nhập đến các đối tượng dựa trên hai yếu tố chính:

- Tính nhạy cảm (sensitivity) của thông tin chứa trong các đối tượng, và
- Sự trao quyền chính thức (formal authorization) cho các chủ thể truy nhập các thông tin nhạy cảm này.

Các thông tin nhạy cảm thường được gán nhãn với các *mức nhạy cảm* (Sensitivity level). Có nhiều phương pháp phân chia các mức nhạy cảm của các thông tin tùy thuộc vào chính

sách an toàn thông tin của các cơ quan, tổ chức. Các mức nhạy cảm thường được sử dụng gồm:

- Tối mật (Top Secret - T): Được áp dụng với thông tin mà nếu bị lộ có thể dẫn đến những thiệt hại trầm trọng đối với an ninh quốc gia.
- Tuyệt mật (Secret - S): Được áp dụng với thông tin mà nếu bị lộ có thể dẫn đến một loạt thiệt hại đối với an ninh quốc gia.
- Mật (Confidential - C): Được áp dụng với thông tin mà nếu bị lộ có thể dẫn đến thiệt hại đối với an ninh quốc gia.
- Không phân loại (Unclassified - U): Những thông tin không gây thiệt hại đối với an ninh quốc gia nếu bị tiết lộ.

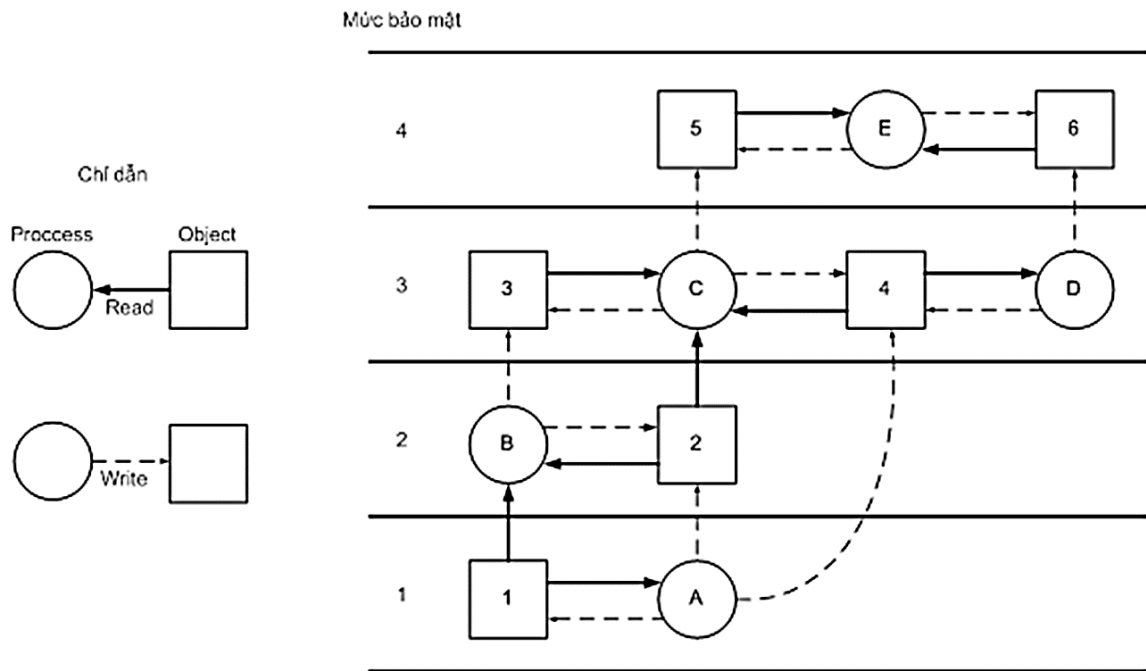
Đặc điểm nổi bật của cơ chế điều khiển truy nhập bắt buộc là nó không cho phép người tạo ra các đối tượng (thông tin, hoặc tài nguyên) có toàn quyền truy nhập các đối tượng này. Quyền truy nhập đến các đối tượng do người quản trị hệ thống định ra trước trên cơ sở chính sách an toàn thông tin của tổ chức đó. Đây cũng là điểm khác biệt hoàn toàn với cơ chế điều khiển truy nhập tùy chọn, trong đó người tạo ra các đối tượng là chủ sở hữu và có toàn quyền đối với các đối tượng họ tạo ra. Ví dụ như, một tài liệu được tạo ra và được đóng dấu “Mật” thì chỉ những người có trách nhiệm trong cơ quan, tổ chức mới được quyền xem và phổ biến cho người khác, còn bản thân tác giả của tài liệu không được quyền phổ biến đến người khác. Cơ chế điều khiển truy nhập bắt buộc thường được sử dụng phổ biến trong các cơ quan an ninh, quân đội và ngân hàng.

Có nhiều kỹ thuật thực hiện cơ chế điều khiển truy nhập bắt buộc, trong đó mô hình điều khiển truy nhập Bell-LaPadula là một trong các kỹ thuật được sử dụng rộng rãi nhất. Mô hình Bell-LaPadula là mô hình bảo mật đa cấp thường được sử dụng trong quân sự, nhưng nó cũng có thể áp dụng cho các lĩnh vực khác. Theo mô hình này trong quân sự, các tài liệu được gán một mức độ bảo mật, chẳng hạn như không phân loại, mật, bí mật và tối mật. Người dùng cũng được ấn định các cấp độ bảo mật, tùy thuộc vào những tài liệu mà họ được phép xem. Chẳng hạn, một vị tướng quân đội có thể được phép xem tất cả các tài liệu, trong khi một trung úy có thể bị hạn chế chỉ được xem các tài liệu mật và thấp hơn. Đồng thời, một tiến trình chạy nhân danh một người sử dụng có được mức độ bảo mật của người dùng đó.

Mô hình Bell-LaPadula sử dụng nguyên tắc “đọc xuống” (read down) và nguyên tắc “ghi lên” (write up) để đảm bảo an toàn trong việc cấp quyền truy nhập cho người dùng đến các đối tượng. Với nguyên tắc “đọc xuống”, một người dùng ở mức độ bảo mật k chỉ có thể đọc các đối tượng ở cùng mức bảo mật hoặc thấp hơn. Ví dụ, một vị tướng có thể đọc các tài liệu của một trung úy, nhưng một trung úy không thể đọc các tài liệu của vị tướng đó. Ngược lại, nguyên tắc “ghi lên” quy định, một người dùng ở mức độ bảo mật k chỉ có thể ghi các đối tượng ở cùng mức bảo mật hoặc cao hơn. Ví dụ, một trung úy có thể nối thêm một tin nhắn vào hộp thư của chung của đơn vị về tất cả mọi thứ ông biết, nhưng một vị tướng không thể ghi thêm một tin nhắn vào hộp thư của trung úy với tất cả mọi thứ ông ấy biết vì vị tướng có thể đã nhìn thấy các tài liệu có mức bảo mật cao mà không thể được tiết lộ cho một trung úy.

Hình 5.3 minh họa việc thực hiện các nguyên tắc “đọc xuống” và nguyên tắc “ghi lên” trong mô hình Bell-LaPadula. Trong đó, các tiến trình chạy bởi người dùng (Process) được ký

hiệu A, B, C, D, E được biểu diễn bởi các hình tròn và các đối tượng (Object) được đánh số 1, 2, 3, 4, 5, 6. Mũi tên liền nét biểu diễn quyền đọc (Read), mũi tên đứt nét biểu diễn quyền ghi (Write) và các mức bảo mật cho cả tiến trình và đối tượng được đánh số 1, 2, 3, 4. Theo mô hình này, tiến trình B có mức bảo mật là 2 chỉ được phép đọc các đối tượng số 1 và 2 – là các đối tượng có cùng mức bảo mật và thấp hơn 2. B không được phép đọc đối tượng số 3 do đối tượng này có mức bảo mật cao hơn. Ngược lại, B có quyền ghi các đối tượng số 2 và 3 – là các đối tượng có cùng mức bảo mật và cao hơn 2. Tuy nhiên, B không được phép ghi đối tượng số 1 do đối tượng này có mức bảo mật thấp hơn.



Hình 5.3. Mô hình điều khiển truy nhập Bell-LaPadula

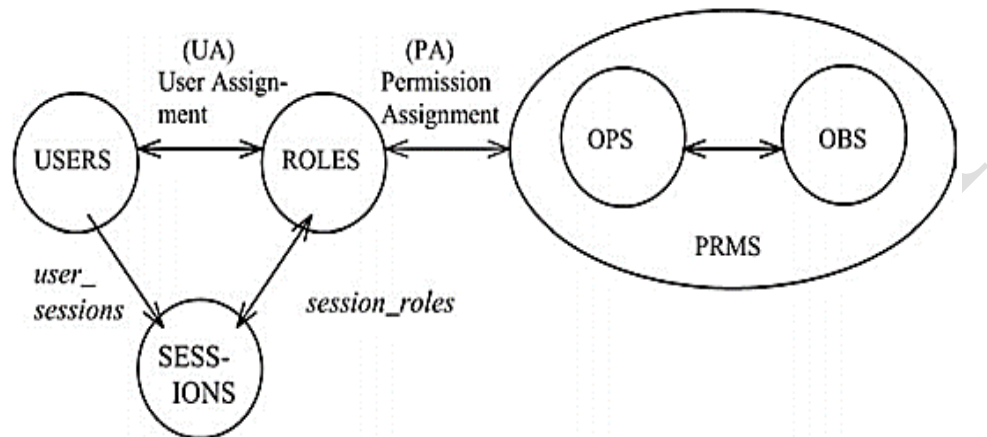
5.1.2.3. Điều khiển truy nhập dựa trên vai trò

Điều khiển truy nhập dựa trên vai trò (RBAC) cho phép người dùng truy nhập vào hệ thống và thông tin dựa trên vai trò (role) của họ trong cơ quan, tổ chức đó. Điều khiển truy nhập dựa trên vai trò có thể được áp dụng cho một nhóm người dùng hoặc từng người dùng riêng lẻ. Quyền truy nhập vào các đối tượng trong hệ thống được tập hợp thành các nhóm “vai trò” với các mức quyền truy nhập khác nhau. Các vai trò được tổ chức thành một cây theo mô hình phân cấp tự nhiên của các cơ quan, tổ chức. Ví dụ như, hệ thống thông tin trong một trường học chia người dùng thành các nhóm gán sẵn quyền truy nhập vào các phần trong hệ thống như sau:

- Nhóm Quản lý được quyền truy nhập vào tất cả các thông tin trong hệ thống;
- Nhóm Giáo viên được truy nhập vào cơ sở dữ liệu các môn học, bài báo khoa học, cập nhật điểm các lớp do mỗi giáo viên phụ trách;
- Nhóm Sinh viên chỉ được quyền xem nội dung các môn học, tài liệu học tập và xem điểm của mình.

Việc liên kết giữa người dùng và nhóm vai trò có thể được tạo lập và hủy bỏ dễ dàng và được thực hiện theo nguyên tắc: Người dùng được cấp “thẻ thành viên” của các nhóm “vai

trò” trên cơ sở năng lực và vai trò, cũng như trách nhiệm của họ trong một tổ chức. Trong nhóm “vai trò”, người dùng được cấp vừa đủ quyền để thực hiện các thao tác cần thiết cho công việc được giao. Hình 5.4 minh họa một mô hình RBAC đơn giản, trong đó quyền truy nhập vào các đối tượng (PRMS) được tập hợp thành các nhóm vai trò (Role) và việc cấp quyền truy nhập các đối tượng cho người dùng (User) được thực hiện thông qua thao tác gán quyền (UA – User Assignment). Việc cấp quyền truy nhập các đối tượng cho người dùng có thể có hiệu lực trong dài hạn, hoặc cũng có thể có hiệu lực trong ngắn hạn, như theo phiên làm việc (Session).



Hình 5.4. Một mô hình RBAC đơn giản

5.1.2.4. Điều khiển truy nhập dựa trên luật

Điều khiển truy nhập dựa trên luật (Rule-based Access Control) là cơ chế cho phép người dùng truy nhập vào hệ thống và thông tin dựa trên các luật (rule) đã được định nghĩa trước. Các luật có thể được thiết lập để hệ thống cho phép truy nhập đến các tài nguyên của mình cho người dùng thuộc một tên miền, một mạng hay một dải địa chỉ IP. Các tường lửa (firewall), hoặc proxy là ví dụ điển hình về việc thực hiện cơ chế điều khiển truy nhập dựa trên luật. Các luật trong tường lửa thực hiện kiểm soát truy nhập sử dụng các thông tin trích xuất từ các gói tin, thông tin về nội dung truy nhập, có thể bao gồm:

- Địa chỉ IP nguồn và đích của các gói tin;
- Cổng dịch vụ của các máy chủ;
- Địa chỉ IP hoặc các tên miền để lọc, hoặc chặn các website bị cấm;
- Phân mở rộng các file để lọc các mã độc hại;
- Tập các từ khóa để lọc các nội dung bị cấm.

5.1.3. Một số công nghệ điều khiển truy nhập

Mục này trình bày một số công nghệ điều khiển truy nhập được ứng dụng rộng rãi trên thực tế, trong đó nhấn mạnh đến các thông tin (hoặc các phương tiện mang thông tin) xác thực người dùng được sử dụng. Các công nghệ điều khiển truy nhập được đề cập gồm:

- Điều khiển truy nhập dựa trên mật khẩu (password)
- Điều khiển truy nhập dựa trên các khoá mã (encrypted key)
- Điều khiển truy nhập dựa trên thẻ thông minh (smartcard)

- Điều khiển truy nhập dựa trên thẻ bài (token)
- Điều khiển truy nhập dựa trên các đặc điểm sinh trắc (biometric).

5.1.3.1. Điều khiển truy nhập dựa trên mật khẩu

Điều khiển truy nhập dựa trên mật khẩu là công nghệ điều khiển truy nhập được sử dụng từ lâu và vẫn đang được sử dụng rộng rãi do tính dễ dùng và rẻ tiền. Thông thường, mỗi người dùng được cấp 1 tài khoản (account) để truy nhập vào hệ thống. Mỗi tài khoản người dùng thường gồm 2 thành tố: tên người dùng (username) và mật khẩu (password), trong đó mật khẩu cần được giữ bí mật. Trong một số hệ thống, tên người dùng có thể được thay thế bằng địa chỉ email, số điện thoại,... Mật khẩu có thể lưu trong hệ thống ở dạng rõ (plaintext) hoặc dạng mã hóa (encrypted text - thường dưới dạng giá trị băm).

Độ an toàn của điều khiển truy nhập sử dụng mật khẩu dựa trên 2 yếu tố: (1) độ khó đoán của mật khẩu và (2) tuổi thọ của mật khẩu. Độ khó đoán của mật khẩu lại phụ thuộc vào số bộ ký tự sử dụng trong mật khẩu và độ dài của mật khẩu. Nhìn chung, mật khẩu càng an toàn nếu càng nhiều bộ ký tự được sử dụng và có kích thước đủ lớn. Với các tài khoản của ứng dụng thông thường, khuyến nghị nên sử dụng cả ký tự in thường, ký tự in hoa, chữ số và ký tự đặc biệt trong mật khẩu với độ dài từ 8 ký tự trở lên. Theo tuổi thọ, mật khẩu gồm 3 loại: không hết hạn, có thời hạn sử dụng và mật khẩu sử dụng 1 lần. Để đảm bảo an toàn, khuyến nghị định kỳ đổi mật khẩu. Khoảng thời gian sử dụng của mật khẩu có thể được thiết lập từ 3 tháng đến 6 tháng phụ thuộc chính sách an toàn thông tin của cơ quan, tổ chức.

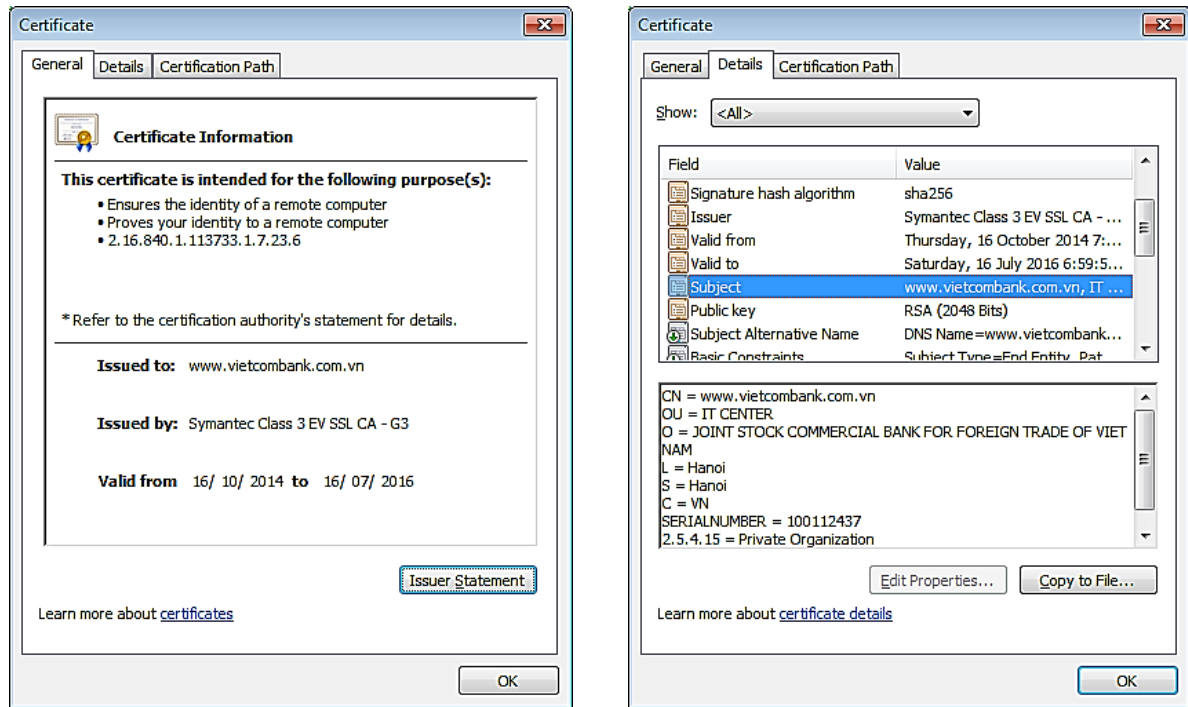
Nhìn chung, điều khiển truy nhập dựa trên mật khẩu có độ an toàn thấp do người dùng có xu hướng chọn các từ đơn giản, dễ nhớ làm mật khẩu. Ngoài ra, mật khẩu có thể bị nghe lén khi được truyền trên môi trường mạng mở như Internet. Hơn nữa, việc nhiều ứng dụng cung cấp tính năng “nhớ tài khoản/mật khẩu” và tự động đăng nhập để tăng sự tiện lợi cho người dùng cũng tạo ra các nguy cơ tài khoản/mật khẩu rò rỉ hoặc bị đánh cắp. Do vậy, để đảm bảo an toàn, cần có chính sách quản lý tài khoản và sử dụng mật khẩu phù hợp với từng hệ thống cụ thể.

5.1.3.2. Điều khiển truy nhập dựa trên các khoá mã

Điều khiển truy nhập dựa trên các khoá mã (Encrypted key) cho phép đảm bảo tính bí mật của thông tin và đồng thời cho phép kiểm tra thông tin nhận dạng của các bên tham gia giao dịch. Một trong các ứng dụng rộng rãi nhất của khóa mã là chứng chỉ số khóa công khai (Public Key Digital Certificate). Một chứng chỉ số khóa công khai thường gồm 3 thông tin quan trọng nhất:

- Thông tin nhận dạng của chủ thể (Subject);
- Khóa công khai của chủ thể (Public key);
- Chữ ký số của nhà cung cấp chứng chỉ số (Certificate Authority – CA).

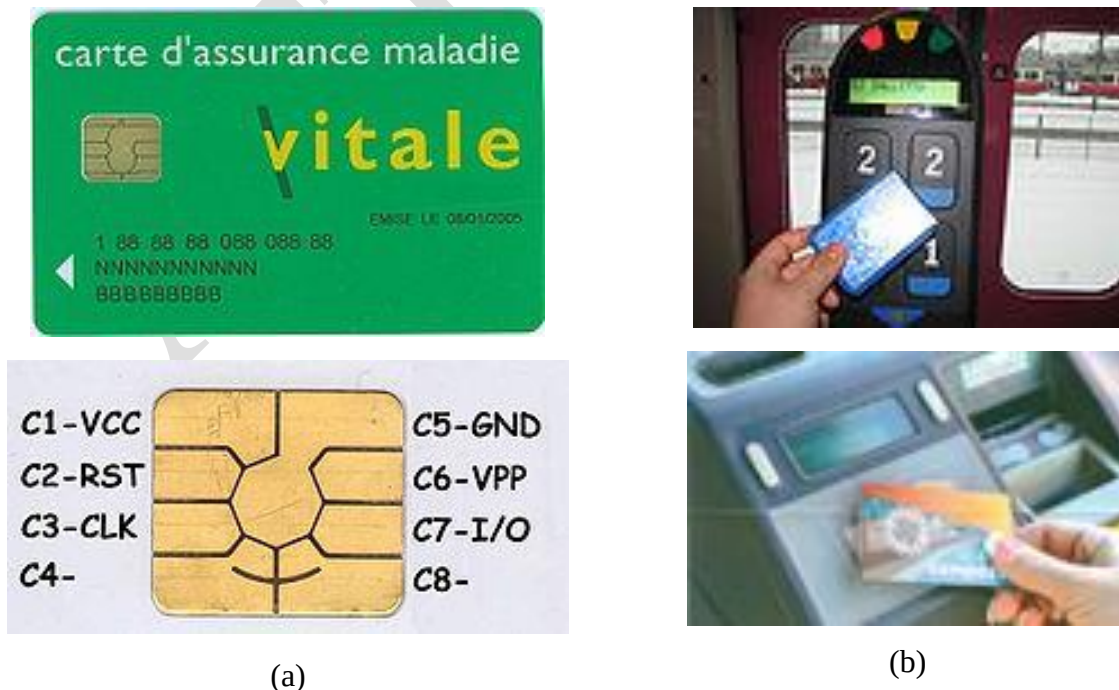
Hình 5.5 là giao diện của một chứng chỉ số khóa công khai cấp cho tên miền www.vietcombank.com.vn. Chứng chỉ số khóa công khai có thể được sử dụng để xác thực các thực thể tham gia phiên truyền thông, đồng thời hỗ trợ trao đổi khóa cho các khâu mã hóa – giải mã thông điệp, nhằm đảm bảo tính bí mật thông tin truyền.



Hình 5.5. Giao diện kiểm tra thông tin của một chứng chỉ số khóa công khai

5.1.3.3. Điều khiển truy nhập dựa trên thẻ thông minh

Thẻ thông minh (Smartcard) là các thẻ nhựa gắn các chip điện tử có khả năng tính toán và các thông tin lưu trong thẻ được mã hoá. Điều khiển truy nhập dựa trên thẻ thông minh là phương pháp có độ an toàn cao do thẻ thông minh sử dụng hai nhân tố (two-factor) để xác thực và nhận dạng chủ thẻ: (1) cái bạn có (what you have) là thẻ thông minh và (2) cái bạn biết (what you know) là số PIN, hay mã xác thực thẻ. Hình 5.6 là hình ảnh thẻ thông minh tiếp xúc (a) và thẻ thông minh không tiếp xúc (b).



Hình 5.6. Thẻ thông minh tiếp xúc (a) và thẻ không tiếp xúc (b)

5.1.3.4. Điều khiển truy nhập dựa trên thẻ bài

Các thẻ bài (Token) thường là các thiết bị cầm tay được thiết kế nhỏ gọn để có thể dễ dàng mang theo. Khác với thẻ thông minh, thẻ bài được tích hợp pin cung cấp nguồn nuôi. Thẻ bài có thể được sử dụng để lưu mật khẩu, các thông tin cá nhân và các thông tin quan trọng khác. Tương tự thẻ thông minh, thẻ bài thường được trang bị cơ chế xác thực 2 nhân tố, gồm thẻ bài và mật khẩu, hoặc PIN (thường dùng 1 lần). Ưu điểm của thẻ bài là có cơ chế xác thực mạnh hơn thẻ thông minh do thẻ bài có CPU với năng lực xử lý cao hơn và bộ nhớ lưu trữ lớn hơn. Hình 5.7, Hình 5.8 và Hình 5.9 minh họa một số thẻ bài của hãng RSA Security, ví điện tử của cổng thanh toán trực tuyến Paypal và hệ thống ApplePay tích hợp vào điện thoại di động.



Hình 5.7. Một số thẻ bài (Token) của hãng RSA Security



Hình 5.8. Ví điện tử (một dạng thẻ bài) của cổng thanh toán trực tuyến Paypal



Hình 5.9. Hệ thống ApplePay tích hợp vào điện thoại di động

5.1.3.5. Điều khiển truy nhập dựa trên các đặc điểm sinh trắc

Các đặc điểm sinh trắc (biometric) là các đặc điểm riêng có để nhận dạng người dùng, bao gồm dấu vân tay, tròng mắt, khuôn mặt, tiếng nói, chữ ký tay,... Điều khiển truy nhập sử dụng các đặc điểm sinh trắc để nhận dạng chủ thể là phương pháp có khả năng cung cấp độ an toàn cao nhất và cho phép xác thực chủ thể do các đặc điểm sinh trắc luôn đi cùng chủ thể và khó bị đánh cắp hoặc làm giả. Hình 5.10 minh họa (a) Khóa vân tay, (b) Khe xác thực vân tay trên laptop và (c) Xác thực vân tay trên điện thoại thông minh Samsung. Hình 5.11 minh họa việc quét võng mạc để nhận dạng tròng mắt.



(c)



Hình 5.10. (a) Khóa vân tay, (b) Khe xác thực vân tay trên laptop và (c) Xác thực vân tay trên điện thoại thông minh Samsung



Hình 5.11. Quét võng mạc nhận dạng tròng mắt

Nhược điểm chính của điều khiển truy nhập sử dụng các đặc điểm sinh trắc là phương pháp này yêu cầu chi phí đầu tư lớn cho các thiết bị quét, đọc và xử lý các đặc điểm sinh trắc. Ngoài ra, phương pháp này tương đối chậm do thường liên quan đến xử lý ảnh – công việc đòi hỏi khối lượng tính toán lớn. Một vấn đề khác cần quan tâm là tỷ lệ nhận dạng sai cao do có nhiều yếu tố nhiều ảnh hưởng.

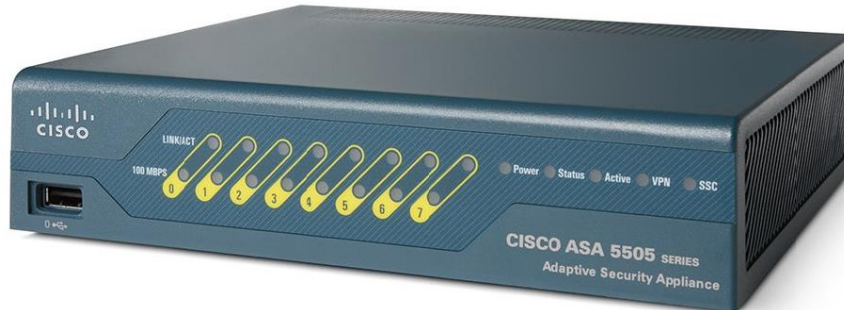
5.2. TƯỜNG LỬA

5.2.1. Giới thiệu

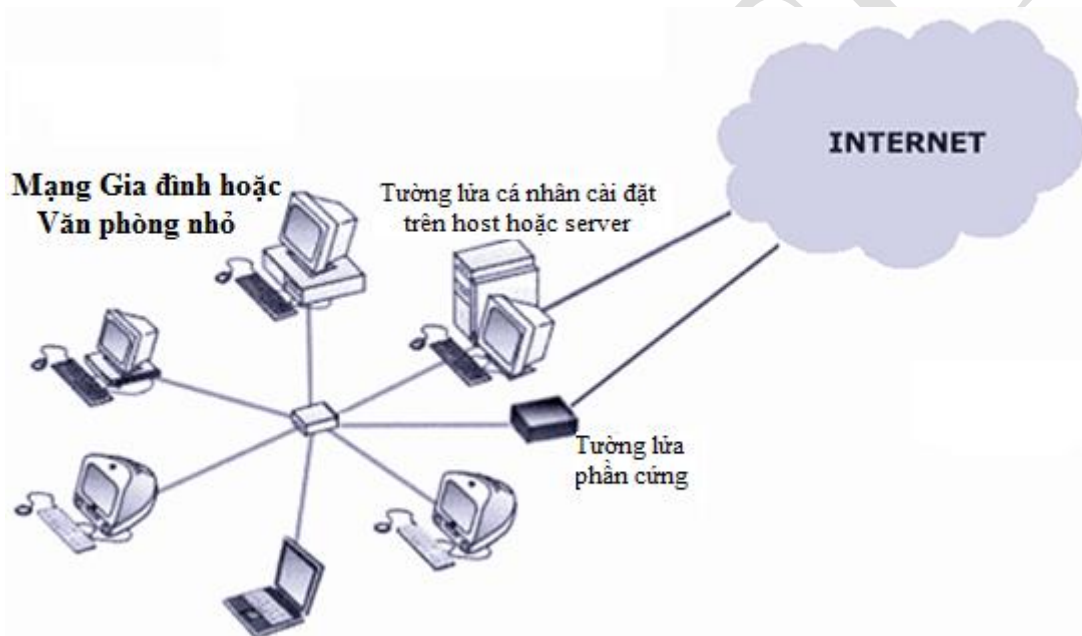
Tường lửa (Firewall) là một trong các kỹ thuật được sử dụng phổ biến nhất để bảo vệ hệ thống và mạng cục bộ tránh các đe dọa từ bên ngoài. Tường lửa có thể là một thiết bị phần cứng chuyên dụng, hoặc mô đun phần mềm chạy trên máy tính. Hình 5.12 là hình ảnh một tường lửa phần cứng chuyên dụng của hãng Cisco.

Để đảm bảo hiệu quả bảo vệ, tường lửa phải miễn dịch với các loại tấn công, xâm nhập và thường được đặt ở vị trí cổng vào của mạng nội bộ cơ quan hoặc tổ chức, như minh họa trên Hình 5.13. Nhờ vị trí đặt ở cổng mạng, tất cả các gói tin từ trong ra và từ ngoài vào đều phải

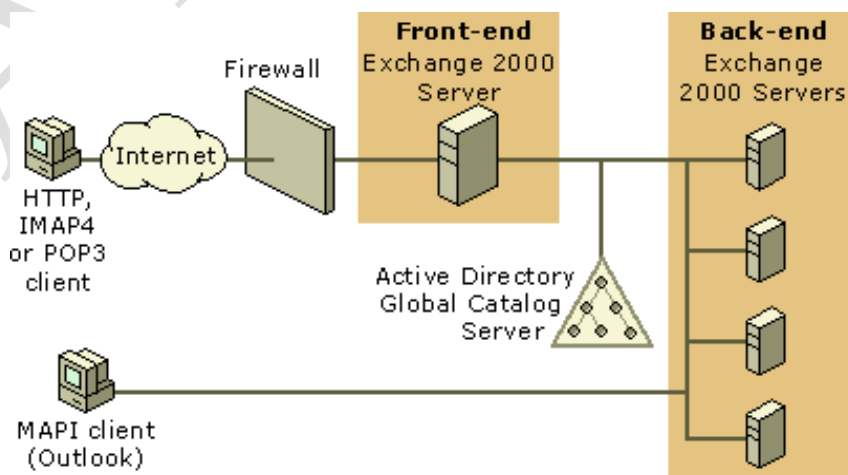
đi qua tường lửa và chỉ các gói tin hợp pháp được phép đi qua tường lửa. Việc xác định một gói tin là hợp pháp hay không được thực hiện bởi thao tác lọc (filtering) dựa trên các luật (rule). Tập các luật sử dụng cho việc lọc các gói tin được tạo ra dựa trên chính sách an ninh của cơ quan, tổ chức.



Hình 5.12. Một tường lửa phần cứng chuyên dụng của hãng Cisco

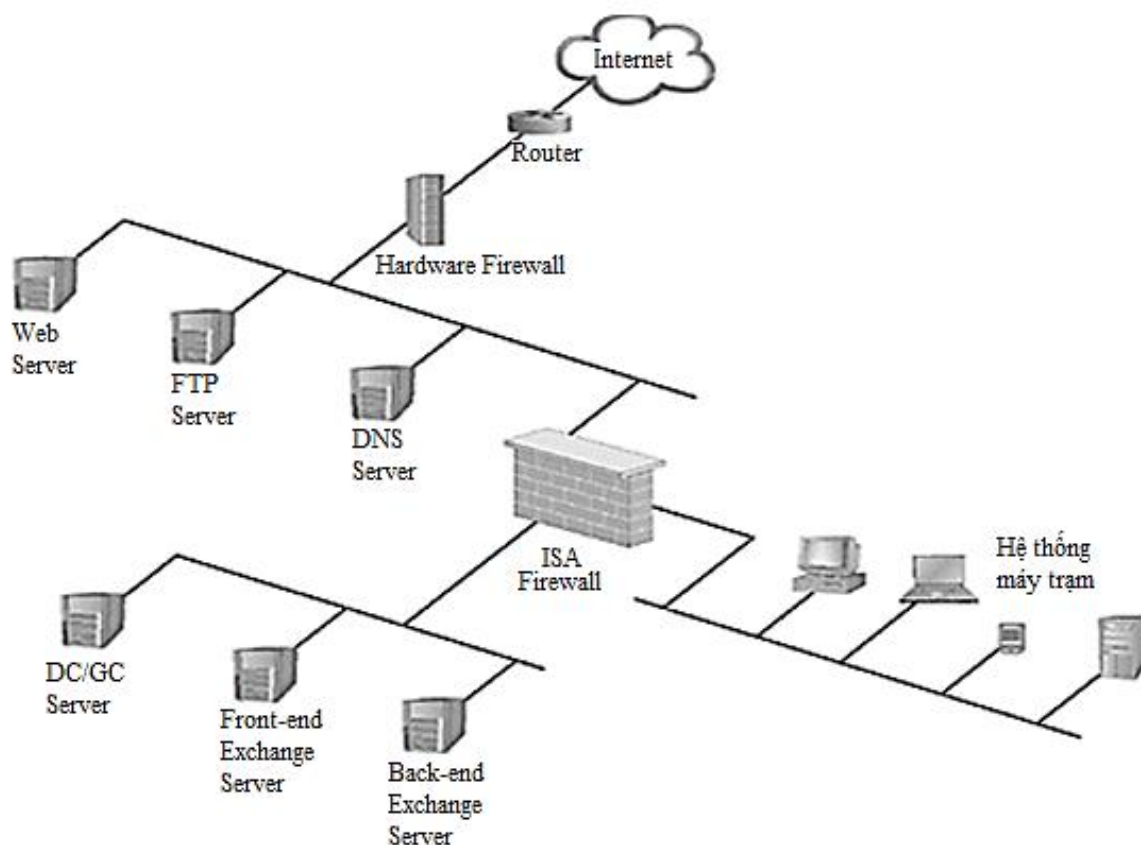


Hình 5.13. Tường lửa bảo vệ mạng gia đình hoặc văn phòng nhỏ



Hình 5.14. Tường lửa bảo vệ các máy chủ dịch vụ

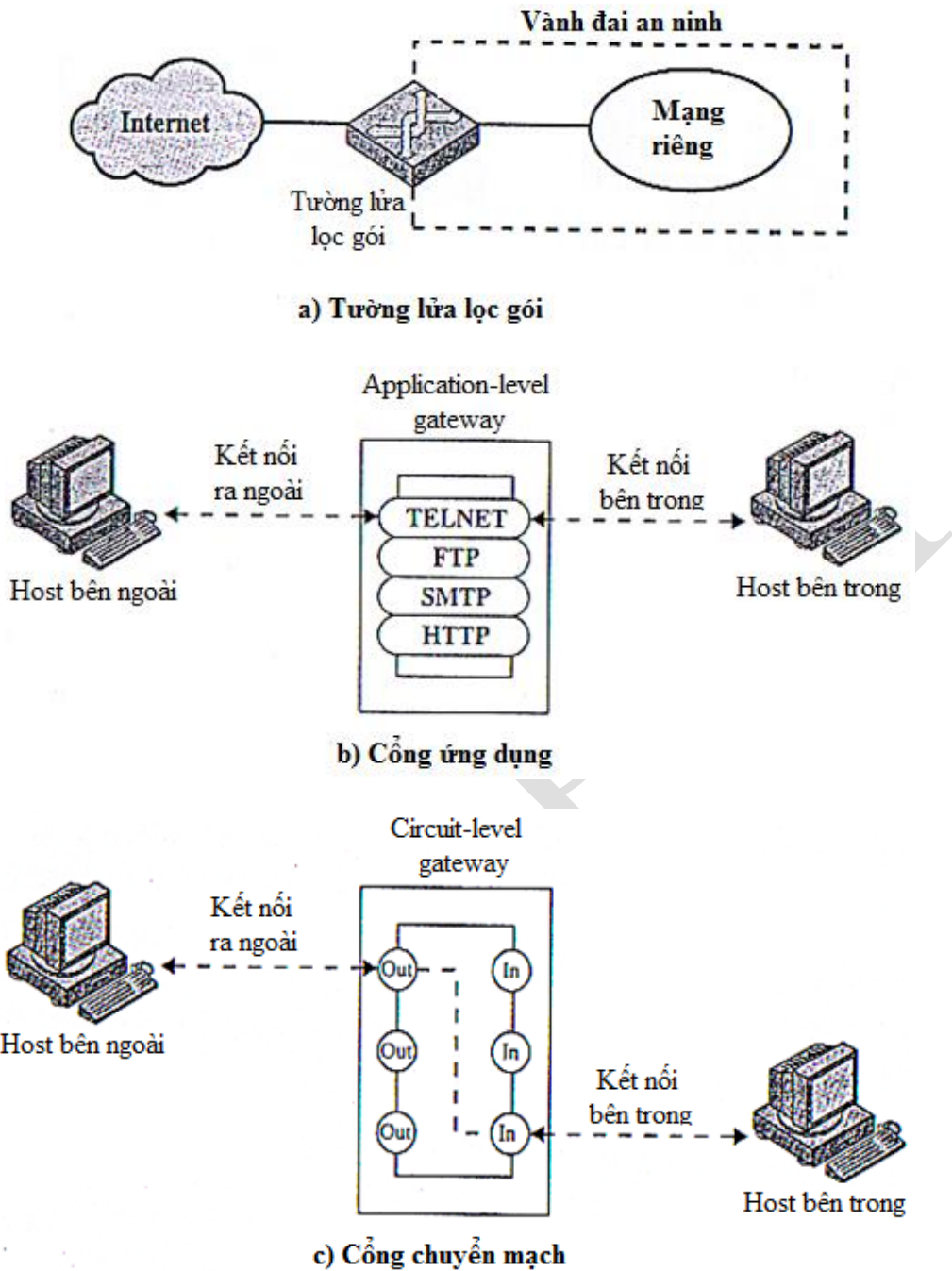
Hình 5.14 biểu diễn sơ đồ mạng trong đó tường lửa được sử dụng để bảo vệ các máy chủ dịch vụ email Microsoft Exchange. Tất cả các kết nối đến hệ thống máy chủ email đều phải đi qua tường lửa. Hình 5.15 sơ đồ mạng sử dụng 2 tường lửa để bảo vệ, trong đó một tường lửa phần cứng (Hardware Firewall) được sử dụng tại cổng kết nối Internet để bảo vệ các máy chủ dịch vụ công cộng (dịch vụ web, dịch vụ FTP và dịch vụ DNS) và một tường lửa phần mềm (ISA Firewall) được sử dụng để bảo vệ các máy chủ nội bộ và các máy trạm trong mạng LAN của cơ quan, tổ chức. Hai tường lửa có chính sách kiểm soát truy nhập và tập luật khác nhau phù hợp với các đối tượng được bảo vệ khác nhau.



Hình 5.15. Hệ thống tường lửa bảo vệ các máy chủ dịch vụ và máy trạm

5.2.2. Các loại tường lửa

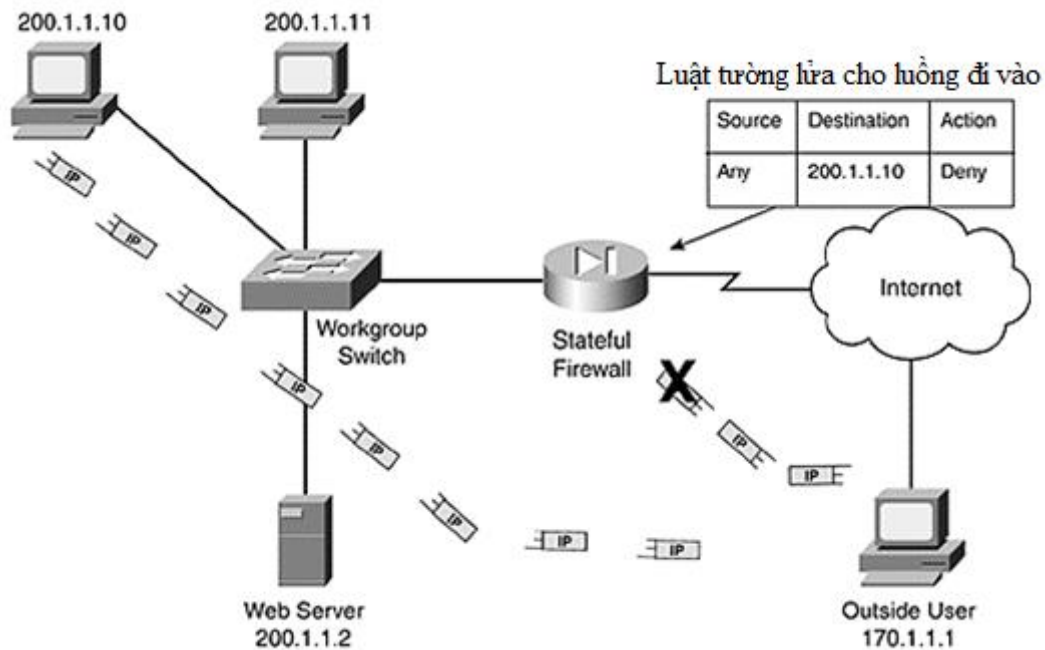
Có nhiều phương pháp phân loại các tường lửa, chẳng hạn như dựa trên vị trí các lớp giao thức mạng và khả năng lưu trạng thái của các kết nối mạng. Dựa trên vị trí các lớp giao thức mạng, có thể chia tường lửa thành 3 loại: tường lửa lọc gói (Packet-filtering firewall), cổng ứng dụng (Application-level gateway) và cổng chuyển mạch (Circuit-level gateway). Tường lửa lọc gói thường thực hiện việc lọc các gói tin IP, theo đó một tập, hoặc một nhóm các luật được áp dụng cho mỗi gói tin gửi đi, hoặc chuyển đến để quyết định chuyển tiếp các gói tin hợp pháp, hay loại bỏ gói tin bất hợp pháp. Cổng ứng dụng, còn gọi là máy chủ proxy thường được sử dụng để phát lại lưu lượng mạng ở mức ứng dụng. Cổng ứng dụng thực hiện việc lọc các yêu cầu, hoặc hồi đáp (request/response) ở các giao thức ứng dụng phổ biến như HTTP, SMTP, FTP,... Cổng chuyển mạch hoạt động ở mức thấp nhất, với cơ chế tương tự như các bộ chuyển mạch (switch). Hình 5.16 minh họa mô hình tường lửa lọc gói (a), cổng ứng dụng (b) và cổng chuyển mạch (c).



Hình 5.16. Mô hình tường lửa lọc gói (a), Cổng ứng dụng (b) và Cổng chuyển mạch (c)

Dựa trên khả năng lưu trạng thái của các kết nối mạng, tường lửa được chia thành 2 loại: tường lửa có trạng thái (Stateful firewall) và tường lửa không trạng thái (Stateless firewall). Tường lửa có trạng thái có khả năng lưu trạng thái của các kết nối mạng đi qua và được lập trình để phân biệt các gói tin thuộc về các kết nối mạng khác nhau. Theo đó, chỉ những gói tin thuộc một kết nối mạng đang hoạt động mới được đi qua tường lửa, còn các gói tin khác không thuộc kết nối đang hoạt động sẽ bị chặn lại. Hình 5.17 minh hoạt một tường lửa có trạng thái chặn các gói tin IP gửi từ người dùng ngoài (Outside User) đến địa chỉ IP 200.1.1.10 do chúng không thuộc kết nối đang hoạt động. Ngược lại, tường lửa không trạng thái thực hiện việc lọc các gói tin riêng rẽ mà không quan tâm mỗi gói tin thuộc về kết nối

mạng nào. Tường lửa dạng này dễ bị tấn công bởi kỹ thuật giả mạo địa chỉ, giả mạo nội dung gói tin do tường lửa không có khả năng nhớ các gói tin đi trước thuộc cùng một kết nối mạng.



Hình 5.17. Tường lửa có trạng thái chặn gói tin không thuộc kết nối đang hoạt động

5.2.3. Các kỹ thuật kiểm soát truy nhập

Hầu hết các tường lửa hỗ trợ nhiều kỹ thuật kiểm soát truy nhập, gồm kiểm soát dịch vụ, kiểm soát hướng, kiểm soát người dùng và kiểm soát hành vi. Cụ thể:

- Kiểm soát dịch vụ xác định dịch vụ nào có thể được truy nhập và thường được thực hiện thông qua việc mở hoặc đóng một cổng dịch vụ nào đó. Chẳng hạn, để cung cấp dịch vụ web và cấm tất cả các dịch vụ khác, tường lửa mở cổng HTTP 80 và HTTPS 443, còn đóng tất cả các cổng dịch vụ khác.
- Kiểm soát hướng điều khiển hướng được phép đi của các gói tin của mỗi dịch vụ. Hướng có thể gồm luồng từ mạng nội bộ đi ra (outgoing) và luồng từ ngoài đi vào mạng nội bộ (incoming).
- Kiểm soát người dùng xác định người dùng nào được quyền truy nhập và thường áp dụng cho người dùng mạng nội bộ.
- Kiểm soát hành vi thực hiện kiểm soát việc sử dụng các dịch vụ cụ thể. Ví dụ như, tường lửa có thể được cấu hình để lọc loại bỏ các thư rác, hoặc hạn chế truy nhập đến một bộ phận thông tin của máy chủ web.

5.2.4. Các hạn chế của tường lửa

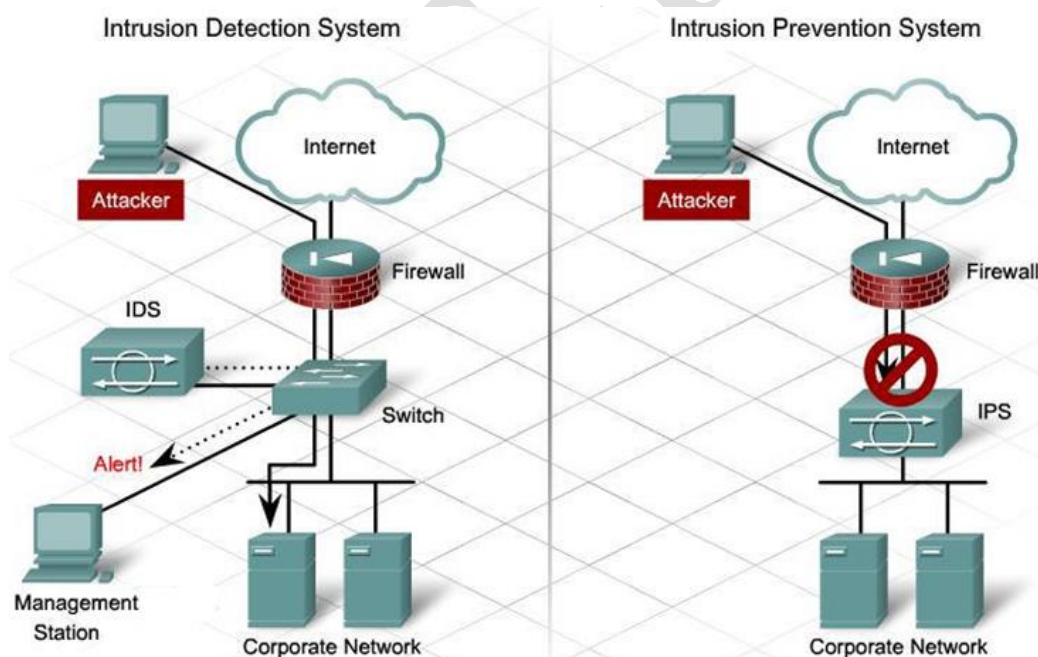
Mặc dù tường lửa được sử dụng rộng rãi để bảo vệ mạng nội bộ khỏi các cuộc tấn công, xâm nhập, nhưng cũng như hầu hết các kỹ thuật và công cụ đảm bảo an toàn khác, tường lửa cũng có những hạn chế. Các hạn chế của tường lửa gồm:

- Không thể chống lại các tấn công không đi qua tường lửa. Đó có thể là các dạng tấn công khai thác yếu tố con người, hoặc kẻ tấn công có thể xâm nhập trực tiếp vào hệ thống mạng nội bộ mà không đi qua tường lửa.
- Không thể chống lại các tấn công hướng dữ liệu, hoặc tấn công vào các lỗ hổng bảo mật của các phần mềm.
- Không thể chống lại các hiểm họa từ bên trong, như từ người dùng trong mạng nội bộ.
- Không thể ngăn chặn việc vận chuyển các chương trình hoặc các file bị nhiễm vi rút hoặc các phần mềm độc hại (thường ở dạng nén hoặc mã hóa).

5.3. CÁC HỆ THỐNG PHÁT HIỆN VÀ NGĂN CHẶN XÂM NHẬP

5.3.1. Giới thiệu

Các hệ thống phát hiện, ngăn chặn tấn công, xâm nhập (IDS/IPS) là một lớp phòng vệ quan trọng trong các lớp giải pháp đảm bảo an toàn cho hệ thống thông tin và mạng theo mô hình phòng thủ có chiều sâu (defence in depth). IDS (Intrusion Detection System) là hệ thống phát hiện tấn công, xâm nhập và IPS (Intrusion Prevention System) là hệ thống ngăn chặn tấn công, xâm nhập. Các hệ thống IDS/IPS có thể được đặt trước hoặc sau tường lửa trong mô hình mạng tùy theo mục đích sử dụng. Hình 5.18 cung cấp vị trí các hệ thống IDS và IPS trong sơ đồ mạng, trong đó IDS thường được kết nối vào bộ chuyển mạch (switch) phía sau tường lửa, còn IPS được ghép vào giữa đường truyền từ cổng mạng, phía sau tường lửa.



Hình 5.18. Vị trí các hệ thống IDS và IPS trong sơ đồ mạng

Nhiệm vụ chính của các hệ thống IDS/IPS bao gồm:

- Giám sát lưu lượng mạng hoặc các hành vi trên một hệ thống để nhận dạng các dấu hiệu của tấn công, xâm nhập;
- Khi phát hiện các hành vi tấn công, xâm nhập, thì ghi logs các hành vi này cho phân tích bổ sung sau này;

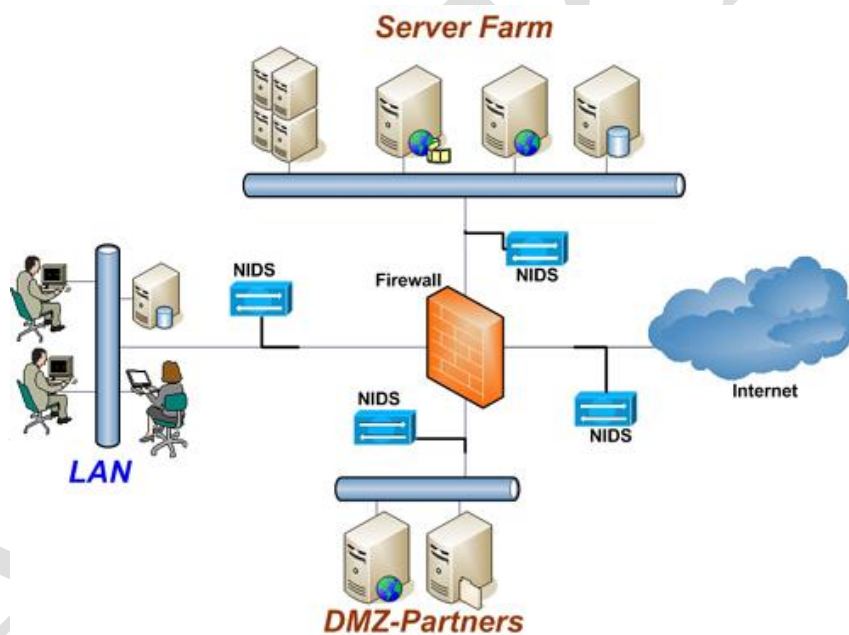
- Ngăn chặn hoặc dừng các hành vi tấn công, xâm nhập;
- Gửi thông báo cho người quản trị về các hành vi tấn công, xâm nhập đã phát hiện được.

Về cơ bản IPS và IDS giống nhau về chức năng giám sát lưu lượng mạng hoặc các sự kiện trong hệ thống. Tuy nhiên, IPS thường được đặt giữa đường truyền thông và có thể chủ động ngăn chặn các tấn công, xâm nhập bị phát hiện. Trong khi đó, IDS thường được kết nối vào các bộ định tuyến, switch, card mạng và chủ yếu làm nhiệm vụ giám sát và cảnh báo, không có khả năng chủ động ngăn chặn tấn công, xâm nhập.

5.3.2. Phân loại

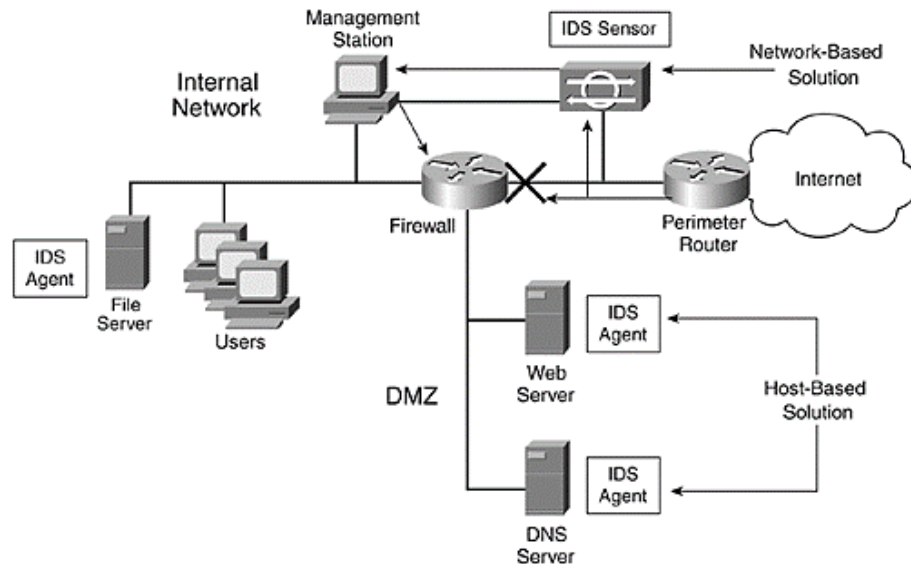
Có 2 phương pháp phân loại chính các hệ thống IDS và IPS, gồm (1) phân loại theo nguồn dữ liệu và (2) phân loại theo phương pháp phân tích dữ liệu. Theo nguồn dữ liệu, có 2 loại hệ thống phát hiện xâm nhập:

- Hệ thống phát hiện xâm nhập mạng (NIDS – Network-based IDS): NIDS phân tích lưu lượng mạng để phát hiện tấn công, xâm nhập cho cả mạng hoặc một phần mạng. Hình 5.19 biểu diễn một sơ đồ mạng, trong đó các NIDS được bố trí để giám sát phát hiện xâm nhập tại cổng vào và cho từng phân đoạn mạng.



Hình 5.19. Các NIDS được bố trí để giám sát phát hiện xâm nhập tại cổng vào và cho từng phân đoạn mạng

- Hệ thống phát hiện xâm nhập cho host (HIDS – Host-based IDS): HIDS phân tích các sự kiện xảy ra trong hệ thống/dịch vụ để phát hiện tấn công, xâm nhập cho hệ thống đó. Hình 5.20 minh họa một sơ đồ mạng, trong đó sử dụng NIDS để giám sát lưu lượng tại cổng mạng và HIDS để giám sát các host thông qua các IDS agent. Một trạm quản lý (Management station) được thiết lập để thu nhập các thông tin từ các NIDS và HIDS để xử lý và đưa ra quyết định cuối cùng.



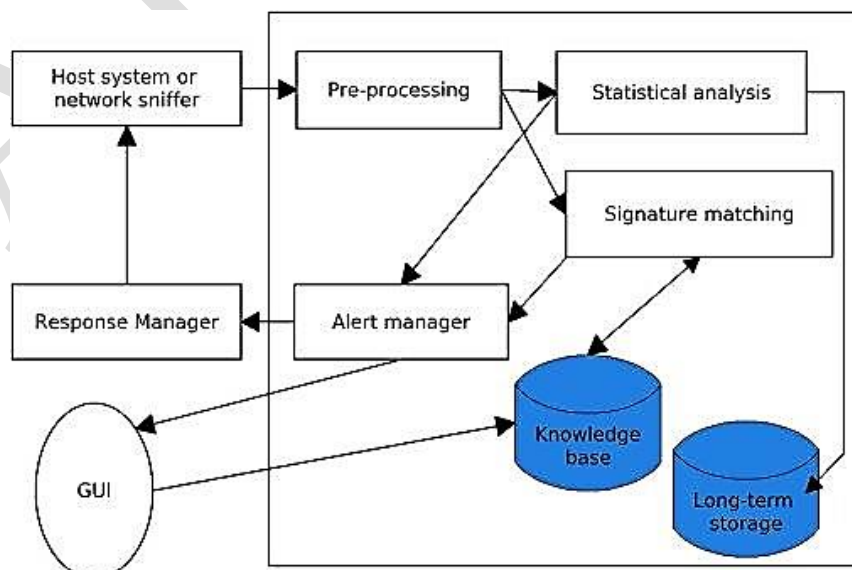
Hình 5.20. Sử dụng kết hợp NIDS và HIDS để giám sát lưu lượng mạng và các host

Theo phương pháp phân tích dữ liệu, có 2 kỹ thuật phân tích chính, gồm (1) phát hiện xâm nhập dựa trên chữ ký, hoặc phát hiện sự lạm dụng (Signature-based / misuse intrusion detection) và (2) phát hiện xâm nhập dựa trên các bất thường (Anomaly intrusion detection). Mục tiếp theo trình bày chi tiết hơn về hai kỹ thuật phát hiện này.

5.3.3. Các kỹ thuật phát hiện xâm nhập

5.3.3.1. Phát hiện xâm nhập dựa trên chữ ký

Phát hiện xâm nhập dựa trên chữ ký trước hết cần xây dựng cơ sở dữ liệu các chữ ký, hoặc các dấu hiệu của các loại tấn công, xâm nhập đã biết. Hầu hết các chữ ký, dấu hiệu được nhận dạng và mã hóa thủ công và dạng biểu diễn thường gặp là các luật phát hiện (Detection rule). Bước tiếp theo là sử dụng cơ sở dữ liệu các chữ ký để giám sát các hành vi của hệ thống, hoặc mạng, và cảnh báo nếu phát hiện chữ ký của tấn công, xâm nhập. Hình 5.21 biểu diễn lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký điển hình, trong đó Knowledge base là cơ sở dữ liệu lưu các chữ ký tấn công, xâm nhập.

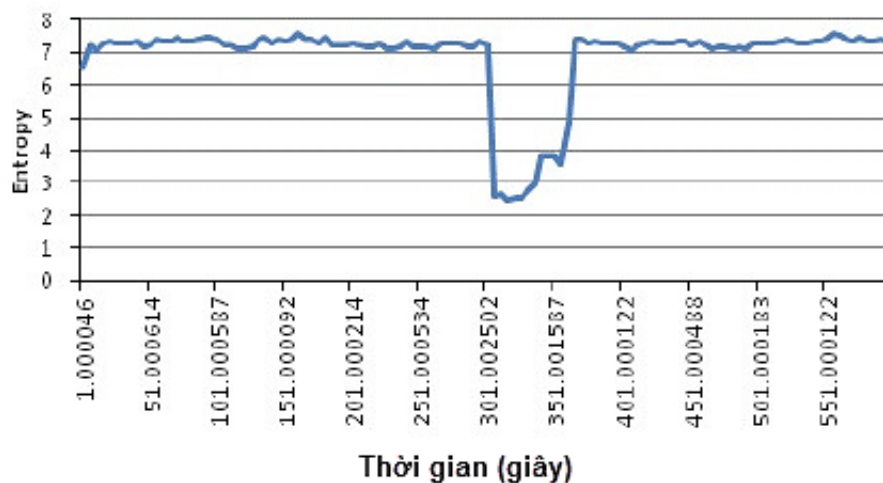


Hình 5.21. Lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký

Ưu điểm lớn nhất của phát hiện xâm nhập dựa trên chữ ký là có khả năng phát hiện các tấn công, xâm nhập đã biết một cách hiệu quả. Ngoài ra, phương pháp này cho tốc độ xử lý cao, đồng thời yêu cầu tài nguyên tính toán tương đối thấp. Nhờ vậy, các hệ thống phát hiện xâm nhập dựa trên chữ ký được ứng dụng rộng rãi trong thực tế. Tuy nhiên, nhược điểm chính của phương pháp này là không có khả năng phát hiện các tấn công, xâm nhập mới, do chữ ký của chúng chưa tồn tại trong cơ sở dữ liệu các chữ ký. Hơn nữa, phương pháp này cũng đòi hỏi nhiều công sức xây dựng và cập nhật cơ sở dữ liệu chữ ký, dấu hiệu của các tấn công, xâm nhập.

5.3.3.2. Phát hiện xâm nhập dựa trên bất thường

Phát hiện xâm nhập dựa trên bất thường dựa trên giả thiết: *các hành vi tấn công, xâm nhập thường có quan hệ chặt chẽ với các hành vi bất thường*. Quá trình xây dựng và triển khai một hệ thống phát hiện xâm nhập dựa trên bất thường thường gồm 2 giai đoạn: (1) huấn luyện và (2) phát hiện. Trong giai đoạn huấn luyện, hồ sơ (profile) của đối tượng trong chế độ làm việc bình thường được xây dựng. Để thực hiện giai đoạn huấn luyện, cần giám sát đối tượng trong một khoảng thời gian đủ dài để thu thập được đầy đủ dữ liệu mô tả các hành vi của đối tượng trong điều kiện bình thường làm dữ liệu huấn luyện. Tiếp theo, thực hiện huấn luyện dữ liệu để xây dựng mô hình phát hiện, hay hồ sơ của đối tượng. Trong giai đoạn phát hiện, thực hiện giám sát hành vi hiện tại của hệ thống và cảnh báo nếu có khác biệt rõ nét giữa hành vi hiện tại và các hành vi lưu trong hồ sơ của đối tượng.



Hình 5.22. Giá trị entropy của IP nguồn của các gói tin từ lưu lượng hợp pháp (phần giá trị cao, đều) và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS (phần giá trị thấp)

Hình 5.22 biểu diễn giá trị entropy của IP nguồn của các gói tin theo cửa sổ trượt từ lưu lượng bình thường và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS. Có thể thấy sự khác biệt rõ nét giữa giá trị entropy của lưu lượng bình thường và lưu lượng tấn công và như vậy nếu một ngưỡng entropy được chọn phù hợp ta hoàn toàn có thể phát hiện sự xuất hiện của cuộc tấn công DDoS dựa trên sự thay đổi đột biến của giá trị entropy.

Ưu điểm của phát hiện xâm nhập dựa trên bất thường là có tiềm năng phát hiện các loại tấn công, xâm nhập mới mà không yêu cầu biết trước thông tin về chúng. Tuy nhiên, phương

pháp này thường có tỷ lệ cảnh báo sai tương đối cao so với phương pháp phát hiện dựa trên chữ ký. Điều này làm giảm khả năng ứng dụng thực tế của phát hiện xâm nhập dựa trên bất thường. Ngoài ra, phương pháp này cũng tiêu tốn nhiều tài nguyên hệ thống cho việc xây dựng hồ sơ đối tượng và phân tích hành vi hiện tại.

5.4. CÂU HỎI ÔN TẬP

- 1) Nêu khái niệm, các thành phần và mục đích của điều khiển truy nhập.
- 2) Nêu cơ chế hoạt động của mô hình (biện pháp) điều khiển truy nhập tùy chọn (DAC).
- 3) Nêu cơ chế hoạt động của mô hình (biện pháp) điều khiển truy nhập bắt buộc (MAC).
- 4) Nêu cơ chế hoạt động của mô hình (biện pháp) điều khiển truy nhập dựa trên vai trò (RBAC).
- 5) Nêu cơ chế hoạt động của mô hình (biện pháp) điều khiển truy nhập dựa trên luật (Rule-based access control).
- 6) So sánh 2 kỹ thuật thực hiện mô hình điều khiển truy nhập tùy chọn (DAC): ma trận điều khiển truy nhập và danh sách điều khiển truy nhập.
- 7) Mô tả cơ chế hoạt động của mô hình bảo mật đa cấp Bell-LaPadula.
- 8) Mô tả công nghệ điều khiển truy nhập dựa trên mật khẩu.
- 9) Trong các công nghệ điều khiển truy nhập: dựa trên mật khẩu, khóa mã, thẻ thông minh, thẻ bài và các đặc điểm sinh trắc, công nghệ nào có khả năng cho độ bảo mật cao nhất? Tại sao?
- 10) Tường lửa là gì? Nêu vai trò của tường lửa. Nêu các phương pháp phân loại tường lửa.
- 11) Nêu các kỹ thuật kiểm soát truy nhập và các hạn chế của tường lửa.
- 12) Các hệ thống IDS/IPS là gì? Nêu các nhiệm vụ chính của IDS/IPS. IDS và IPS giống và khác nhau ở những điểm nào?
- 13) Nêu các phương pháp phân loại IDS/IPS. Có thể sử dụng kết hợp NIDS và HIDS trong cùng một hệ thống mạng được không?
- 14) Mô tả phương pháp phát hiện xâm nhập dựa trên chữ ký. Nêu ưu nhược điểm của phương pháp này. Tại sao phát hiện xâm nhập dựa trên chữ ký không có khả năng phát hiện các tấn công xâm nhập mới?
- 15) Mô tả phương pháp phát hiện xâm nhập dựa trên bất thường. Nêu ưu nhược điểm của phương pháp này.
- 16) Tại sao phát hiện xâm nhập dựa trên bất thường có khả năng phát hiện các tấn công xâm nhập mới? Tại sao phát hiện xâm nhập dựa trên bất thường thường có tỷ lệ cảnh báo sai cao hơn phát hiện xâm nhập dựa trên chữ ký?

CHƯƠNG 6. QUẢN LÝ, CHÍNH SÁCH VÀ PHÁP LUẬT AN TOÀN THÔNG TIN

Chương 6 giới thiệu một số khái niệm cơ bản trong quản lý an toàn thông tin, vấn đề đánh giá rủi ro an toàn thông tin và thực thi quản lý an toàn thông tin. Nội dung tiếp theo của chương đề cập đến các chuẩn quản lý an toàn thông tin, trong đó giới thiệu một số chuẩn của bộ chuẩn ISO/IEC 27000. Phần cuối của chương giới thiệu khái quát về các vấn đề chính sách, pháp luật và đạo đức an toàn thông tin.

6.1 QUẢN LÝ AN TOÀN THÔNG TIN

6.1.1. Khái quát về quản lý an toàn thông tin

Chúng ta bắt đầu mục này với khái niệm *Tài sản* (Asset) trong lĩnh vực an toàn thông tin, gọi tắt là *Tài sản an toàn thông tin*. Tài sản an toàn thông tin là thông tin, thiết bị, hoặc các thành phần khác hỗ trợ các hoạt động có liên quan đến thông tin. Tài sản an toàn thông tin có thể gồm:

- Phần cứng (máy chủ, các thiết bị mạng,...);
- Phần mềm (hệ điều hành, các phần mềm máy chủ dịch vụ,...); và
- Thông tin (thông tin khách hàng, nhà cung cấp, hoạt động kinh doanh,...).

Khái niệm tiếp theo là *Quản lý an toàn thông tin* (Information security management). Quản lý an toàn thông tin là một tiến trình (process) nhằm đảm bảo các tài sản an toàn thông tin quan trọng của cơ quan, tổ chức, doanh nghiệp được *bảo vệ đầy đủ với chi phí phù hợp*.

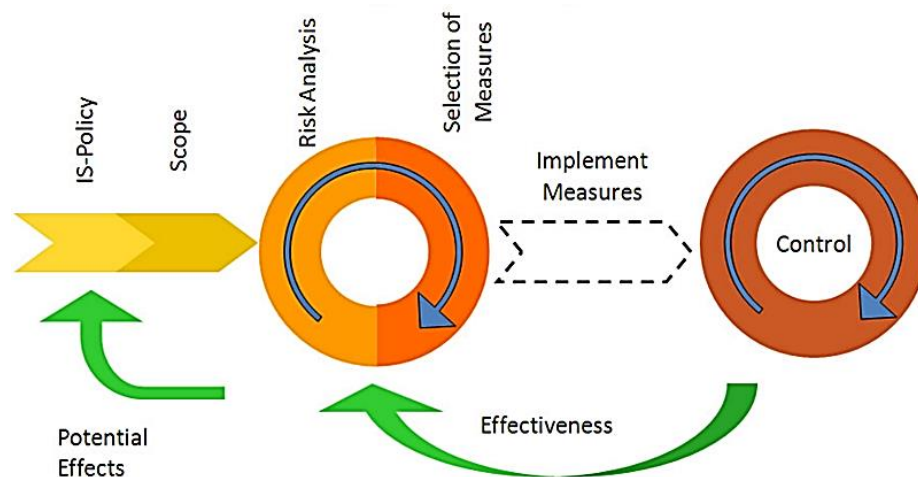
Quản lý an toàn thông tin là một thành phần rất quan trọng trong an toàn thông tin và nó phải trả lời được 3 câu hỏi:

1. Những tài sản nào cần được bảo vệ?
2. Những đe dọa nào có thể có đối với các tài sản này?
3. Những biện pháp có thể thực hiện để ứng phó với các đe dọa đó?

Quản lý an toàn thông tin có thể được thực hiện 3 khâu chính sau:

- Khâu 1: Xác định rõ mục đích đảm bảo an toàn thông tin và xây dựng hồ sơ tổng hợp về các rủi ro;
- Khâu 2: Đánh giá rủi ro với từng tài sản an toàn thông tin cần bảo vệ; và
- Khâu 3: Xác định và triển khai các biện pháp quản lý, kỹ thuật kiểm soát, giảm rủi ro về mức chấp nhận được.

Một điểm quan trọng cần lưu ý là, quá trình quản lý an toàn thông tin cần được thực hiện liên tục theo chu trình do sự thay đổi nhanh chóng của công nghệ và môi trường xuất hiện rủi ro. Hình 6.1 mô tả mô hình hệ thống quản lý an toàn thông tin theo chuẩn ISO 27001. Theo đó, phần việc Risk Analysis (Phân tích rủi ro) được thực hiện trong các Khâu 1 và Khâu 2, và các phần việc Selection of Measures (Lựa chọn các kiểm soát) và Implement Measures (Thực thi các kiểm soát) được thực hiện trong Khâu 3. Khi các kiểm soát được triển khai sẽ có khả năng thay đổi mức rủi ro đối với các tài sản an toàn thông tin.



Hình 6.1. Mô hình hệ thống quản lý an toàn thông tin theo chuẩn ISO 27001

6.1.2. Đánh giá rủi ro an toàn thông tin

6.1.2.1. Giới thiệu

Đánh giá rủi ro an toàn thông tin (Security risk assessment) là một bộ phận quan trọng của vấn đề quản lý rủi ro an toàn thông tin. Theo đó, mỗi tài sản của tổ chức cần được xem xét, nhận dạng các rủi ro có thể có và đánh giá mức rủi ro. Đánh giá rủi ro là một trong các cơ sở để xác định mức rủi ro chấp nhận được với từng loại tài sản. Trên cơ sở xác định mức rủi ro, có thể đề ra các biện pháp xử lý, kiểm soát rủi ro trong mức chấp nhận được, với mức chi phí phù hợp.



Hình 6.2. Mô hình đánh giá rủi ro an toàn thông tin

Hình 6.2 minh họa mô hình đánh giá rủi ro an toàn thông tin, trong đó 3 nhân tố chính liên quan trực tiếp cần được xem xét gồm: (1) Tài sản an toàn thông tin (Asset) cần được bảo vệ, (2) Các mối đe dọa (Threat) đối với các tài sản an toàn thông tin và (3) Các lỗ hổng bảo mật (Vulnerability) tồn tại trong các tài sản an toàn thông tin. Như vậy, việc đánh giá rủi ro an toàn thông tin cần phải xem xét toàn diện cả các vấn đề bên trong của các tài sản an toàn thông tin (các lỗ hổng bảo mật) và các vấn đề bên ngoài (các mối đe dọa).

Có 4 phương pháp tiếp cận đánh giá rủi ro: Phương pháp đường cơ sở (Baseline approach), Phương pháp không chính thức (Informal approach), Phương pháp phân tích chi tiết rủi ro (Detailed risk analysis) và Phương pháp kết hợp (Combined approach). Tùy theo quy mô của hệ thống thông tin của đơn vị và tài sản an toàn thông tin cần được bảo vệ, đơn vị

có thể xem xét lựa chọn phương pháp đánh giá rủi ro cho phù hợp. Mục tiếp theo mô tả chi tiết về các phương pháp đánh giá rủi ro kể trên.

6.1.2.2. Các phương pháp đánh giá rủi ro

Phương pháp đánh giá rủi ro đường cơ sở là phương pháp đơn giản nhất. Mục đích của phương pháp này là thực thi các kiểm soát an ninh ở mức cơ bản dựa trên các tài liệu cơ bản, các quy tắc thực hành và các thực tế tốt nhất của ngành đã được áp dụng. Phương pháp đường cơ sở có ưu điểm là không đòi hỏi các chi phí cho các tài nguyên bổ sung sử dụng trong đánh giá rủi ro chính thức và cùng nhóm các biện pháp có thể triển khai trên nhiều hệ thống. Tuy nhiên, nhược điểm của nó là không xem xét kỹ đến các điều kiện nảy sinh các rủi ro ở các hệ thống của các tổ chức khác nhau. Một vấn đề khác của phương pháp này là mức đường cơ sở được xác định chung nên có thể không phù hợp với từng tổ chức cụ thể. Nếu chọn mức quá cao có thể gây tốn kém, nhưng nếu chọn mức quá thấp có thể gây mất an toàn. Nhìn chung, phương pháp đường cơ sở phù hợp với các tổ chức với hệ thống công nghệ thông tin có quy mô nhỏ, có nguồn lực hạn chế.

Phương pháp không chính thức là phương pháp tiếp cận đánh giá rủi ro tiếp theo. Phương pháp không chính thức liên quan đến việc thực hiện các nội dung sau:

- Thực hiện một số dạng phân tích rủi ro hệ thống công nghệ thông tin của tổ chức một cách không chính thức,
- Sử dụng kiến thức chuyên gia của các nhân viên bên trong tổ chức, hoặc các nhà tư vấn từ bên ngoài, và
- Không thực hiện đánh giá toàn diện các rủi ro đối với tất cả các tài sản công nghệ thông tin của tổ chức.

Phương pháp này có ưu điểm là không đòi hỏi các nhân viên phân tích rủi ro có các kỹ năng bổ sung, nên có thể thực hiện nhanh với chi phí thấp, và việc có phân tích hệ thống công nghệ thông tin của tổ chức giúp cho việc đánh giá rủi ro, lỗ hổng chính xác hơn và các biện pháp kiểm soát đưa ra cũng phù hợp hơn phương pháp đường cơ sở. Phương pháp không chính thức có các nhược điểm:

- Do đánh giá rủi ro không được thực hiện toàn diện nên có thể một rủi ro không được xem xét kỹ, nên có thể để lại nguy cơ cao cho tổ chức, và
- Kết quả đánh giá dễ phụ thuộc vào quan điểm của các cá nhân.

Trên thực tế phương pháp không chính thức phù hợp với các tổ chức với hệ thống công nghệ thông tin có quy mô nhỏ và vừa, có nguồn lực tương đối hạn chế.

Phương pháp phân tích chi tiết rủi ro là phương pháp đánh giá toàn diện, được thực hiện một cách chính thức và được chia thành nhiều giai đoạn, bao gồm:

- Nhận dạng các tài sản,
- Nhận dạng các mối đe dọa và lỗ hổng đối với các tài sản này,
- Xác định xác suất xuất hiện các rủi ro và các hậu quả có thể có nếu rủi ro xảy ra với cơ quan, tổ chức, và

- Lựa chọn các biện pháp xử lý rủi ro dựa trên kết quả đánh giá rủi ro của các giai đoạn nêu trên.

Ưu điểm của phương pháp này là cho phép xem xét chi tiết các rủi ro đối với hệ thống công nghệ thông tin của tổ chức, và lý giải rõ ràng các chi phí cho các biện pháp kiểm soát rủi ro đề xuất. Đồng thời, nó cung cấp thông tin tốt nhất cho việc tiếp tục quản lý vấn đề an ninh của các hệ thống công nghệ thông tin khi chúng được nâng cấp, sửa đổi. Tuy nhiên, phương pháp này có 2 nhược điểm:

- Chi phí lớn về thời gian, các nguồn lực và yêu cầu kiến thức chuyên gia có trình độ cao, và
- Có thể dẫn đến chậm trễ trong việc đưa ra các biện pháp xử lý, kiểm soát rủi ro phù hợp.

Phương pháp phân tích chi tiết rủi ro phù hợp với các tổ chức chính phủ cung cấp các dịch vụ thiết yếu cho người dân và doanh nghiệp, hoặc các tổ chức có hệ thống công nghệ thông tin quy mô lớn, hoặc các tổ chức cung cấp nền tảng hạ tầng truyền thông cho quốc gia.

Phương pháp kết hợp là phương pháp tiếp cận đánh giá rủi ro cuối cùng. Phương pháp này kết hợp các thành phần của 3 phương pháp đường cơ sở, không chính thức và phân tích chi tiết, với các mục tiêu là cung cấp mức bảo vệ hợp lý càng nhanh càng tốt và sau đó kiểm tra và điều chỉnh các biện pháp bảo vệ trên các hệ thống chính theo thời gian. Phương pháp kết hợp được thực hiện theo 3 bước:

- Thực hiện phương pháp đường cơ sở với tất cả các thành phần của hệ thống công nghệ thông tin của tổ chức;
- Tiếp theo, các thành phần có mức rủi ro cao, hoặc trọng yếu được xem xét đánh giá theo phương pháp không chính thức;
- Cuối cùng hệ thống được xem xét đánh giá toàn diện rủi ro ở mức chi tiết.

Các ưu điểm của phương pháp kết hợp là việc bắt đầu bằng việc đánh giá rủi ro ở mức cao dễ nhận được sự ủng hộ của cấp quản lý, thuận lợi cho việc lập kế hoạch quản lý an toàn thông tin, đồng thời có thể giúp sớm triển khai các biện pháp xử lý và kiểm soát rủi ro ngay từ giai đoạn đầu, cũng như có thể giúp giảm chi phí với đa số các tổ chức. Tuy nhiên, phương pháp kết hợp có nhược điểm là nếu đánh giá ở mức cao trong giai đoạn đầu không chính xác có thể dẫn đến áp dụng các biện pháp kiểm soát không phù hợp, hệ thống có thể gặp rủi ro trong thời gian chờ đánh giá chi tiết. Nói chung, phương pháp kết hợp phù hợp các cơ quan, tổ chức với hệ thống công nghệ thông tin quy mô vừa và lớn.

6.1.3. Phân tích chi tiết rủi ro an toàn thông tin

6.1.3.1. Giới thiệu

Phân tích chi tiết rủi ro an toàn thông tin là phương pháp xem xét, phân tích toàn diện các rủi ro của từng thành phần trong hệ thống công nghệ thông tin của cơ quan, tổ chức. Phân tích chi tiết rủi ro an toàn thông tin gồm nhiều hoạt động được chia thành 9 bước:

1. Mô tả đặc điểm hệ thống
2. Nhận dạng các mối đe dọa

3. Nhận dạng các lỗ hổng bảo mật
4. Phân tích các kiểm soát
5. Xác định xác suất rủi ro
6. Phân tích các ảnh hưởng
7. Xác định các rủi ro
8. Đề xuất các kiểm soát
9. Viết tài liệu kết quả phân tích.

Nội dung cụ thể từng bước của phân tích chi tiết rủi ro an toàn thông tin được trình bày trong mục sau.

6.1.3.2. Các bước phân tích chi tiết rủi ro

Bước 1: Mô tả đặc điểm hệ thống

- Đầu vào: Các thành phần của hệ thống:
 - + Phần cứng, phần mềm, giao diện
 - + Dữ liệu và thông tin
 - + Con người
 - + Sức mệnh của hệ thống.
- Đầu ra:
 - + Ranh giới và chức năng hệ thống;
 - + Tính trọng yếu của dữ liệu và hệ thống;
 - + Tính nhạy cảm

Bước 2: Nhận dạng các mối đe dọa

- Đầu vào:
 - + Lịch sử tấn công vào hệ thống
 - + Dữ liệu từ các tổ chức chuyên về an toàn thông tin
 - + Dữ liệu từ các phương tiện thông tin đại chúng.
- Đầu ra:
 - + Báo cáo về các mối đe dọa đối với hệ thống

Bước 3: Nhận dạng các lỗ hổng bảo mật

- Đầu vào:
 - + Các báo cáo đánh giá rủi ro đã có
 - + Các nhận xét kiểm toán hệ thống
 - + Các yêu cầu an ninh, an toàn
 - + Các kết quả kiểm tra an ninh, an toàn
- Đầu ra:
 - + Danh sách các lỗ hổng bảo mật tiềm tàng.

Bước 4: Phân tích các kiểm soát (control)

- Đầu vào:
 - + Các kiểm soát hiện có
 - + Các kiểm soát được lập kế hoạch
- Đầu ra:
 - + Danh sách các kiểm soát hiện có và được lập kế hoạch.

Bước 5: Xác định xác suất rủi ro

- Đầu vào:
 - + Động cơ của các nguồn đe dọa
 - + Khả năng của đe dọa
 - + Bản chất của lỗ hổng bảo mật
 - + Các kiểm soát hiện có
- Đầu ra:
 - + Đánh giá xác suất rủi ro.

Bước 6: Phân tích các ảnh hưởng (liên quan sự vi phạm tính toàn vẹn, sẵn dùng và bí mật của các tài sản hệ thống)

- Đầu vào:
 - + Phân tích ảnh hưởng sứ mệnh
 - + Đánh giá tầm quan trọng của tài sản
 - + Tầm quan trọng của dữ liệu
 - + Tính nhạy cảm của dữ liệu
- Đầu ra:
 - + Đánh giá các ảnh hưởng.

Bước 7: Xác định các rủi ro

- Đầu vào:
 - + Khả năng bị mối đe dọa khai thác
 - + Tầm quan trọng của ảnh hưởng
 - + Sự phù hợp của các kiểm soát theo kế hoạch, hoặc hiện có
- Đầu ra:
 - + Các rủi ro và các mức rủi ro có liên quan.

Bước 8: Đề xuất các kiểm soát

- Đầu vào: Không
- Đầu ra: Đề xuất các biện pháp xử lý, kiểm soát rủi ro

Bước 9: Viết tài liệu kết quả phân tích

- Đầu vào: Không
- Đầu ra: Báo cáo đánh giá rủi ro.

6.1.4. Thực thi quản lý an toàn thông tin

6.1.4.1. Giới thiệu

Thực thi quản lý an toàn thông tin là bước tiếp theo của khâu đánh giá rủi ro, nhằm triển khai, thực thi các kiểm soát (control) nhằm đảm bảo an toàn cho hệ thống công nghệ thông tin của tổ chức. Các nội dung chính của thực thi quản lý an toàn thông tin gồm:

- Thực thi (Implementation): Thực thi các kiểm soát, và đào tạo nâng cao ý thức người dùng và đào tạo chuyên môn an toàn thông tin.
- Thực thi tiếp tục (Implementation follow-up): Bảo trì, kiểm tra hợp chuẩn, quản lý thay đổi và xử lý sự cố.

Kiểm soát (control), đảm bảo an toàn (safeguard), hoặc biện pháp đối phó (countermeasure) là các thuật ngữ có thể được sử dụng tương đương, hoặc tráo đổi cho nhau trong quản lý an toàn thông tin. Kiểm soát là phương tiện để quản lý rủi ro, bao gồm các chính sách, thủ tục, các hướng dẫn, các thực tế, hoặc cấu trúc tổ chức. Kiểm soát có thể là vấn đề quản lý hành chính hoặc kỹ thuật, hoặc có bản chất luật pháp.

Các kiểm soát được thực thi trong quản lý an toàn thông tin có thể gồm 6 loại:

- Kiểm soát quản lý (Management control)
- Kiểm soát vận hành (Operational control)
- Kiểm soát kỹ thuật (Technical control)
- Kiểm soát hỗ trợ (Supportive control)
- Kiểm soát ngăn ngừa (Preventive control)
- Kiểm soát phát hiện và phục hồi (Detection and recovery control).

6.1.4.2. Các loại kiểm soát

Kiểm soát quản lý bao gồm các nội dung:

- Tập trung vào các chính sách, lập kế hoạch, hướng dẫn và chuẩn an toàn thông tin;
- Các kiểm soát có ảnh hưởng đến việc lựa chọn các kiểm soát vận hành và kiểm soát kỹ thuật nhằm giảm tổn thất do rủi ro và bảo vệ sứ mệnh của tổ chức;
- Các kiểm soát tham chiếu đến các vấn đề được giải quyết thông qua lĩnh vực quản lý.

Kiểm soát vận hành bao gồm các nội dung:

- Giải quyết vấn đề thực thi chính xác và sử dụng các chính sách và chuẩn an toàn thông tin, đảm bảo tính nhất quán trong vận hành an toàn thông tin và khắc phục các khiếm khuyết vận hành đã được nhận dạng;
- Các kiểm soát này liên quan đến các cơ chế và thủ tục được thực thi chủ yếu bởi con người, hơn là bởi hệ thống;
- Được sử dụng để tăng cường an ninh cho một hệ thống hoặc một nhóm các hệ thống.

Kiểm soát kỹ thuật bao gồm các nội dung:

- Các kiểm soát kỹ thuật thường liên quan đến việc sử dụng đúng đắn các biện pháp đảm bảo an ninh bằng phần cứng và phần mềm trong hệ thống;

- Bao gồm các biện pháp từ đơn giản đến phức tạp để đảm bảo an toàn cho các thông tin nhạy cảm và các chức năng trọng yếu của các hệ thống;
- Một số kiểm soát kỹ thuật: xác thực, trao quyền và thực thi kiểm soát truy nhập,...

Kiểm soát hỗ trợ là các kiểm soát chung ở lớp dưới, có quan hệ và được sử dụng bởi nhiều kiểm soát khác.

Kiểm soát ngăn ngừa là kiểm soát tập trung vào việc ngăn ngừa việc xảy ra các vi phạm an ninh, bằng cách khắc chế các nỗ lực vi phạm chính sách an ninh, hoặc khai thác các lỗ hổng bảo mật.

Kiểm soát phát hiện và phục hồi là kiểm soát tập trung vào việc đáp trả vi phạm an ninh bằng cách đưa ra cảnh báo vi phạm, hoặc các nỗ lực vi phạm chính sách an ninh, hoặc khai thác các lỗ hổng bảo mật, đồng thời cung cấp các biện pháp phục hồi các tài nguyên tính toán bị ảnh hưởng do vi phạm an ninh.

6.1.4.3. Xây dựng kế hoạch đảm bảo an toàn

Kế hoạch đảm bảo an toàn (Security plan) là một tài liệu chỉ rõ các phần việc sẽ được thực hiện, các tài nguyên cần sử dụng và những người, hoặc nhân viên chịu trách nhiệm thực hiện. Mục đích của kế hoạch đảm bảo an toàn là cung cấp chi tiết về các hành động cần thiết để cải thiện các vấn đề đã được nhận dạng trong hồ sơ đánh giá rủi ro một cách nhanh chóng. Kế hoạch đảm bảo an toàn nên gồm các thông tin chi tiết sau (theo chuẩn hướng dẫn quản lý rủi ro năm 2002 của NIST):

- Các rủi ro (sự kết hợp của tài sản/mối đe dọa/lỗ hổng)
- Các kiểm soát được khuyến nghị (từ đánh giá rủi ro)
- Các hành động ưu tiên cho mỗi rủi ro
- Các kiểm soát được chọn (dựa trên phân tích lợi ích – chi phí)
- Các tài nguyên cần có cho thực thi các kiểm soát đã chọn
- Nhân sự chịu trách nhiệm
- Ngày bắt đầu và kết thúc việc thực thi
- Các yêu cầu bảo trì và các nhận xét khác.

6.1.4.4. Nội dung thực thi quản lý an toàn thông tin

Như đã đề cập trong mục 6.1.4.1, việc thực thi quản lý an toàn thông tin gồm 2 khâu là (1) *thực thi* (Implementation) và (2) *thực thi tiếp tục* (Implementation follow-up). Khâu *thực thi* gồm 2 phần việc là thực thi các kiểm soát, và đào tạo nâng cao ý thức người dùng và đào tạo chuyên sâu về an toàn thông tin. Thực thi các kiểm soát là phần việc tiếp theo cần thực hiện trong kế hoạch đảm bảo an toàn của tiến trình quản lý an toàn thông tin. Thực thi các kiểm soát có liên hệ mật thiết với việc đào tạo nâng cao ý thức an toàn thông tin cho nhân viên nói chung và đào tạo chuyên sâu về an toàn thông tin cho nhân viên an toàn thông tin, công nghệ thông tin trong tổ chức.

Khâu *thực thi tiếp tục* là việc cần lặp lại trong chu trình quản lý an toàn thông tin để đáp ứng sự thay đổi trong môi trường công nghệ thông tin và môi trường rủi ro. Trong đó, các kiểm soát đã được thực thi cần được giám sát để đảm bảo tính hiệu quả, và bất kỳ một sự thay

đổi trên hệ thống cần được xem xét vấn đề an ninh và hồ sơ rủi ro của hệ thống bị ảnh hưởng. Giai đoạn thực thi tiếp tục bao gồm các khía cạnh: bảo trì các kiểm soát an ninh, kiểm tra hợp chuẩn an ninh, quản lý thay đổi và cấu hình và xử lý các sự cố.

Bảo trì các kiểm soát an ninh gồm các phần việc phải đảm bảo các yêu cầu sau:

- Các kiểm soát được xem xét định kỳ để đảm bảo chúng hoạt động như mong muốn;
- Các kiểm soát cần được nâng cấp khi các yêu cầu mới được phát hiện;
- Các thay đổi với hệ thống không được có các ảnh hưởng tiêu cực đến các kiểm soát;
- Các mối đe dọa mới hoặc các lỗ hổng đã không trở thành được biết đến.

Kiểm tra hợp chuẩn an ninh là quá trình kiểm toán việc quản lý an toàn thông tin của tổ chức nhằm đảm bảo tính phù hợp với kế hoạch đảm bảo an ninh. Việc kiểm toán có thể được thực hiện bởi nhân sự bên trong hoặc bên ngoài tổ chức. Cần sử dụng danh sách kiểm tra (checklist) các vấn đề: các chính sách và kế hoạch an ninh được tạo ra, các kiểm soát phù hợp được lựa chọn và các kiểm soát được sử dụng và bảo trì phù hợp.

Quản lý thay đổi và cấu hình là tiến trình được sử dụng để xem xét các thay đổi được đề xuất cho hệ thống trong quá trình sử dụng. Các thay đổi với các hệ thống hiện có là cần thiết do nhiều lý do, như hệ thống có trục trặc, hoặc sự xuất hiện của các mối đe dọa hoặc lỗ hổng mới, sự xuất hiện của yêu cầu mới, nhiệm vụ mới,... Các thay đổi cần được xem xét kỹ lưỡng cả vấn đề vận hành, tính năng và vấn đề an toàn,... Quản lý cấu hình liên quan đến việc lưu vết các cấu hình của mỗi hệ thống khi chúng được nâng cấp, thay đổi. Việc này bao gồm danh sách các phiên bản của phần cứng, phần mềm cài đặt trong mỗi hệ thống, và thông tin quản lý cấu hình hữu ích để khôi phục hệ thống khi việc thay đổi hoặc nâng cấp thất bại.

Xử lý các sự cố bao gồm các thủ tục được sử dụng để phản ứng lại các sự cố an ninh. Xử lý sự cố có liên quan đến vấn đề đào tạo nâng cao ý thức an toàn thông tin cho người dùng và đào tạo chuyên sâu cho chuyên viên an toàn thông tin.

6.2. CÁC CHUẨN QUẢN LÝ AN TOÀN THÔNG TIN

6.2.1. Giới thiệu

Trong các chuẩn quản lý an toàn thông tin, bộ chuẩn NIST SP 800 của Viện tiêu chuẩn và công nghệ Hoa Kỳ và bộ chuẩn quốc tế ISO/IEC 27000 được tham chiếu và sử dụng rộng rãi nhất. Nhiều quốc gia, trong đó có Việt Nam đã dịch và chấp thuận nguyên vẹn một số chuẩn trong bộ chuẩn quốc tế ISO/IEC 27000 làm chuẩn quản lý an toàn thông tin quốc gia. Trong phạm vi của môn học, mục này giới thiệu khái quát về bộ chuẩn quản lý an toàn thông tin ISO/IEC 27000. Chi tiết về bộ chuẩn ISO/IEC 27000 và các bộ chuẩn quản lý an toàn thông tin khác được đề cập trong môn học Quản lý an toàn thông tin.

Chuẩn ISO/IEC 27000: 2009 giới thiệu khái quát về bộ chuẩn ISO/IEC 27000 và định nghĩa các thuật ngữ và từ vựng sử dụng cho toàn bộ các chuẩn con trong bộ chuẩn ISO/IEC 27000.

Chuẩn ISO/IEC 17799 được soạn thảo năm 2000 bởi các tổ chức ISO (International Organization for Standardization) và IEC (International Electrotechnical Commission) là tiền thân của bộ chuẩn ISO 27000. Năm 2005, ISO 17799 được chỉnh sửa và trở thành ISO

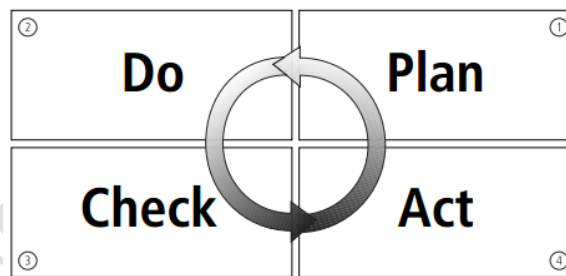
17799:2005. Năm 2007, ISO 17799:2005 được đổi tên thành ISO 27002, song hành với ISO 27001.

Chuẩn ISO/IEC 27001:2005 chuyên về hệ thống quản lý an toàn thông tin (Information Security Management System - ISMS). Chuẩn này cung cấp các thông tin để thực thi các yêu cầu của ISO/IEC 27002 và vấn đề cài đặt một hệ thống quản lý an toàn thông tin. Trong việc xây dựng hệ thống ISMS, chuẩn này cung cấp các chi tiết cho thực hiện chu kỳ Plan-Do-Check-Act (Lập kế hoạch – Thực hiện – Giám sát – Hành động). Một điểm cần lưu ý là ISO/IEC 27001 chỉ tập trung vào các phần việc phải thực hiện mà không chỉ dẫn cách thức thực hiện.

Chuẩn ISO/IEC 27002 gồm 127 điều, cung cấp cái nhìn tổng quan về nhiều lĩnh vực trong an toàn thông tin. Nó đề ra các khuyến nghị về quản lý an toàn thông tin cho những người thực hiện việc khởi tạo, thực hiện và duy trì an ninh an toàn trong tổ chức của họ. Chuẩn này được thiết kế để cung cấp nền tảng cơ sở giúp đề ra các chuẩn an toàn thông tin cho tổ chức và các thực thể quản lý an toàn thông tin một cách hiệu quả.

Chuẩn ISO/IEC 27005: 2009 chuyên về quản lý rủi ro cho hệ thống quản lý an toàn thông tin. Chuẩn này hỗ trợ ISO/IEC 27001, nhưng nó không đề cập đến phương pháp kiểm soát rủi ro cụ thể.

6.2.2. Chu trình Plan-Do-Check-Act



Hình 6.3. Chu trình Plan-Do-Check-Act của ISO/IEC 27001:2005

Chuẩn ISO/IEC 27001:2005 chuyên về hệ thống quản lý an toàn thông tin cung cấp các chi tiết cho thực hiện chu kỳ Plan-Do-Check-Act gồm 4 pha: Plan - Lập kế hoạch, Do – Thực hiện kế hoạch, Check – Giám sát việc thực hiện và Act – Thực hiện các cải tiến, hiệu chỉnh. Phần tiếp theo trình bày nội dung chi tiết của các pha này.

Pha **Plan** gồm các nội dung:

- Đề ra phạm vi của ISMS;
- Đề ra chính sách của ISMS;
- Đề ra hướng tiếp cận đánh giá rủi ro;
- Nhận dạng các rủi ro;
- Đánh giá rủi ro;
- Nhận dạng và đánh giá các lựa chọn phương pháp xử lý rủi ro;
- Lựa chọn các mục tiêu kiểm soát và biện pháp kiểm soát;
- Chuẩn bị tuyển bố, báo cáo áp dụng.

Pha **Do** gồm các nội dung:

- Xây dựng kế hoạch xử lý rủi ro;
- Thực thi kế hoạch xử lý rủi ro;
- Thực thi các kiểm soát;
- Thực thi các chương trình đào tạo chuyên môn và giáo dục ý thức;
- Quản lý các hoạt động;
- Quản lý các tài nguyên;
- Thực thi các thủ tục phát hiện và phản ứng lại các sự cố an ninh.

Pha **Check** gồm các nội dung:

- Thực thi các thủ tục giám sát;
- Thực thi việc đánh giá thường xuyên tính hiệu quả của ISMS;
- Thực hiện việc kiểm toán (audits) nội bộ với ISMS;
- Thực thi việc đánh giá thường xuyên với ISMS bởi bộ phận quản lý;
- Ghi lại các hành động và sự kiện ảnh hưởng đến ISMS.

Pha **Act** gồm các nội dung:

- Thực hiện các cải tiến đã được nhận dạng;
- Thực hiện các hành động sửa chữa và ngăn chặn;
- Áp dụng các bài đã được học;
- Thảo luận kết quả với các bên quan tâm;
- Đảm bảo các cải tiến đạt được các mục tiêu.

6.3. PHÁP LUẬT VÀ CHÍNH SÁCH AN TOÀN THÔNG TIN

6.3.1. Giới thiệu về pháp luật và chính sách an toàn thông tin

Các chính sách và pháp luật an toàn thông tin có vai trò rất quan trọng trong việc đảm bảo an toàn cho thông tin, hệ thống và mạng. Trong đó, vai trò của nhân viên đảm bảo an toàn thông tin là rất quan trọng trong việc giảm thiểu rủi ro, đảm bảo an toàn cho thông tin, hệ thống và mạng và giảm thiệt hại nếu xảy ra sự cố. Các nhân viên đảm bảo an toàn thông tin phải hiểu rõ những khía cạnh pháp lý và đạo đức an toàn thông tin. Theo đó, họ phải luôn nắm vững môi trường pháp lý hiện tại (gồm các luật và các quy định luật pháp trong lĩnh vực an toàn thông tin và công nghệ thông tin) và luôn thực hiện công việc nằm trong khuôn khổ cho phép của luật pháp. Ngoài ra, cần thực hiện việc giáo dục ý thức về luật pháp và đạo đức an toàn thông tin cho cán bộ quản lý và nhân viên trong tổ chức, đảm bảo sử dụng đúng mục đích các công nghệ đảm bảo an toàn thông tin.

Chính sách (Policy - còn gọi là quy định, nội quy) là các quy định về các hành vi chấp nhận được của các nhân viên trong tổ chức tại nơi làm việc. Chính sách là các "luật" của tổ chức có giá trị thực thi trong nội bộ, gồm một tập các quy định và các chế tài xử phạt bắt buộc phải thực hiện. Các chính sách, hoặc nội quy cần được nghiên cứu, soạn thảo kỹ lưỡng. Đồng thời, chính sách cần đầy đủ, đúng đắn và áp dụng công bằng với mọi nhân viên. Điểm khác

biệt giữa luật và chính sách là Luật luôn bắt buộc, còn với Chính sách, việc thiếu hiểu biết chính sách là 1 cách bào chữa chấp nhận được.



Hình 6.4. Vấn đề tuân thủ (Compliance) pháp luật, chính sách và các nội quy, quy định

Cần có phân biệt rõ ràng giữa *luật* (Law) và *đạo đức* (Ethic). Luật gồm những điều khoản bắt buộc hoặc cấm những hành vi cụ thể. Các điều luật thường được xây dựng từ các vấn đề đạo đức. Trong khi đó, đạo đức định nghĩa những hành vi xã hội chấp nhận được. Đạo đức thường dựa trên các đặc điểm văn hóa. Do đó, hành vi đạo đức giữa các dân tộc, các nhóm người khác nhau có thể khác nhau. Một số hành vi vi phạm đạo đức được luật hóa trên toàn thế giới, như trộm, cướp, cưỡng dâm, bạo hành trẻ em,... Khác biệt giữa luật và đạo đức thể hiện ở chỗ luật được thực thi bởi các cơ quan chính quyền, còn đạo đức không được thực thi bởi các cơ quan chính quyền.

Để các chính sách có thể được áp dụng hiệu quả, chúng phải đạt được các yêu cầu sau:

- Có khả năng phổ biến rộng rãi, bằng tài liệu giấy hoặc điện tử;
- Nhân viên có thể xem, hiểu được – cần thực hiện trên nhiều ngôn ngữ, ví dụ bằng tiếng Anh và tiếng địa phương;
- Chính sách cần rõ ràng dễ hiểu – tổ chức cần có các điều tra/khảo sát về mức độ hiểu biết/nắm bắt các chính sách của nhân viên;
- Cần có biện pháp để nhân viên cam kết thực hiện – thông qua ký văn bản cam kết hoặc tick vào ô xác nhận tuân thủ;
- Chính sách cần được thực hiện đồng đều, bình đẳng, nhất quán, không có ưu tiên với bất kỳ nhân viên nào, kể cả người quản lý.

6.3.2. Luật quốc tế về an toàn thông tin

Mục này đề cập đến một số luật và văn bản có liên quan đến an toàn thông tin của Hoa Kỳ và Châu Âu – là những nước và khu vực đã phát triển và có hệ thống luật pháp về an toàn thông tin tương đối hoàn thiện.

Có thể nói hệ thống luật pháp về an toàn thông tin của Hoa Kỳ khá đầy đủ và được chia thành các nhóm: các luật tội phạm máy tính, các luật về sự riêng tư, luật xuất khẩu và chống gián điệp, luật bản quyền và luật tự do thông tin. Các luật về tội phạm máy tính gồm:

- Computer Fraud and Abuse Act of 1986 (CFA Act): quy định về các tội phạm lừa đảo và lạm dụng máy tính;
- Computer Security Act, 1987: đề ra các nguyên tắc đảm bảo an toàn cho hệ thống máy tính;
- National Information Infrastructure Protection Act of 1996: là bản sửa đổi của CFA Act, tăng khung hình phạt một số tội phạm máy tính đến 20 năm tù;
- USA PATRIOT Act, 2001: cho phép các cơ quan nhà nước một số quyền theo dõi, giám sát các hoạt động trên mạng nhằm phòng chống khủng bố hiệu quả hơn;
- USA PATRIOT Improvement and Reauthorization Act: Mở rộng của USA PATRIOT Act, 2001, cấp cho các cơ quan nhà nước nhiều quyền hạn hơn cho nhiệm vụ phòng chống khủng bố.

Các luật về sự riêng tư nhằm bảo vệ quyền riêng tư của người dùng, bảo vệ các thông tin cá nhân của người dùng, gồm:

- Federal Privacy Act, 1974: luật Liên bang Hoa Kỳ bảo vệ quyền riêng tư của người dùng;
- Electronic Communications Privacy Act, 1986: luật bảo vệ quyền riêng tư trong các giao tiếp điện tử;
- Health Insurance Portability and Accountability Act, 1996 (HIPAA): luật bảo vệ tính bí mật và an toàn của các dữ liệu y tế của người bệnh. Tổ chức, hoặc cá nhân vi phạm có thể bị phạt đến 250.000 USD hoặc 10 năm tù;
- Financial Services Modernization Act or Gramm-Leach-Bliley Act, 1999: luật điều chỉnh các hoạt động liên quan đến nhà nước của các ngân hàng, bảo hiểm và các hãng an ninh.

Luật xuất khẩu và chống gián điệp hạn chế việc xuất khẩu các công nghệ và hệ thống xử lý thông tin và phòng chống gián điệp kinh tế, gồm:

- Economic Espionage Act, 1996: phòng chống việc thực hiện giao dịch có liên quan đến bí mật kinh tế và công nghệ;
- Security and Freedom through Encryption Act, 1999: quy định về các vấn đề có liên quan đến sử dụng mã hóa trong đảm bảo an toàn và tự do thông tin.

U.S. Copyright Law là Luật bản quyền của Hoa Kỳ, điều chỉnh các vấn đề có liên quan đến xuất bản, quyền tác giả của các tài liệu, phần mềm, bao gồm cả các tài liệu số. Freedom of Information Act, 1966 (FOIA) là Luật tự do thông tin nêu rõ các cá nhân được truy nhập các thông tin không gây tổn hại đến an ninh quốc gia.

Các tổ chức và luật quốc tế có liên quan đến an toàn thông tin, gồm:

- Hội đồng Châu Âu về chống tội phạm mạng (Council of Europe Convention on Cybercrime);

- Hiệp ước về chống tội phạm mạng được Hội đồng châu Âu phê chuẩn vào năm 2001;
- Hiệp ước bảo vệ quyền sở hữu trí tuệ (Agreement on Trade-Related Aspects of Intellectual Property Rights (TRIPS)): là hiệp ước do Tổ chức Thương mại thế giới WTO chủ trì đàm phán trong giai đoạn 1986–1994;
- Digital Millennium Copyright Act (DMCA): Luật bản quyền số Thiên niên kỷ.

6.3.3. Luật Việt Nam về an toàn thông tin

Luật An toàn thông tin mạng được Quốc hội thông qua vào tháng 11 năm 2015 và chính thức có hiệu lực từ ngày 01/7/2016 và Luật an ninh mạng được Quốc hội thông qua vào tháng 6 năm 2018 và chính thức có hiệu lực từ ngày 01/01/2019. Đây là các cơ sở pháp lý quan trọng cho việc quản lý các hoạt động liên quan đến an toàn, an ninh thông tin ở Việt Nam. Ngoài Luật an toàn thông tin mạng và Luật an ninh mạng, đã có nhiều văn bản có liên quan đến công nghệ thông tin và an toàn thông tin được Quốc hội, Chính phủ và các cơ quan nhà nước ban hành như:

- Luật công nghệ thông tin số 67/2006/QH11 của Quốc hội, ngày 12/07/2006.
- Nghị định số 90/2008/NĐ-CP của Chính phủ "Về chống thư rác", ngày 13/08/2008.
- Quyết định số 59/2008/QĐ-BTTTT của Bộ Thông tin và Truyền thông "Ban hành Danh mục tiêu chuẩn bắt buộc áp dụng về chữ ký số và dịch vụ chứng thực chữ ký số", ngày 31/12/2008.
- Quyết định 63/QĐ-TTg của Thủ tướng Chính phủ "Phê duyệt Quy hoạch phát triển an toàn thông tin số quốc gia đến năm 2020", ngày 13/01/2010.
- Chỉ thị số 897/CT-TTg của Thủ tướng Chính phủ "V/v tăng cường triển khai các hoạt động đảm bảo an toàn thông tin số", 10/06/2011.
- Thông tư số 23/2011/TT-BTTTT của Bộ TT&TT "Quy định về việc quản lý, vận hành, sử dụng và bảo đảm an toàn thông tin trên Mạng truyền số liệu chuyên dùng của các cơ quan Đảng, Nhà nước", ngày 11/08/2011.
- Nghị định số 77/2012/NĐ-CP của Chính phủ "Sửa đổi, bổ sung một số điều của Nghị định số 90/2008/NĐ-CP ngày 13 tháng 8 năm 2008 của Chính phủ về chống thư rác", ngày 05/10/2012.
- Nghị định 72/2013/NĐ-CP của Chính phủ về Quản lý, cung cấp, sử dụng dịch vụ internet và thông tin trên mạng; quy định về việc chia sẻ thông tin trên các trang mạng xã hội.
- Luật An toàn thông tin mạng số 86/2015/QH13 được Quốc hội khoá 13 thông qua ngày 19 tháng 11 năm 2015 và có hiệu lực từ ngày 01 tháng 7 năm 2016.
- Luật An ninh mạng số 24/2018/QH14 được Quốc hội khoá 14 thông qua ngày 12 tháng 6 năm 2018 và có hiệu lực từ ngày 01 tháng 01 năm 2019.

6.4. VẤN ĐỀ ĐẠO ĐỨC AN TOÀN THÔNG TIN

6.4.1. Sự cần thiết của đạo đức an toàn thông tin

Vấn đề đạo đức nghề nghiệp (Professional ethic) hay quy tắc ứng xử (Code of conduct) được đề cập trong ngành công nghệ thông tin nói chung và an toàn thông tin nói riêng do các

công việc trong lĩnh vực an toàn thông tin có thể liên quan đến các thông tin nhạy cảm, như thông tin, hệ thống bí mật quốc gia, thông tin bí mật của các cơ quan, tổ chức, hoặc bí mật công nghệ, bí mật kinh doanh của các công ty. Nếu các thông tin nhạy cảm bị rò rỉ, hoặc bị đánh cắp và lạm dụng, có thể ảnh hưởng nghiêm trọng đến an ninh quốc gia, hoặc ảnh hưởng xấu đến các cơ quan, tổ chức và người dùng. Do vậy, người làm trong lĩnh vực an toàn thông tin cần có hiểu biết về chính sách, pháp luật và có thái độ và hành động đúng đắn trong khi thực thi nhiệm vụ.

6.4.2. Một số bộ quy tắc ứng xử trong CNTT và ATTT

Nhiều tổ chức xã hội nghề nghiệp đã ban hành các quy tắc ứng xử bắt buộc tại nơi làm việc, như với luật sư, bác sỹ và vận động viên thể thao. Nếu vi phạm nghiêm trọng các quy tắc ứng xử tại nơi làm việc có thể bị cấm hành nghề có thời hạn, hoặc vĩnh viễn. Trong lĩnh vực công nghệ thông tin và an toàn thông tin, hiện không có bộ quy tắc ứng xử bắt buộc. Một số tổ chức xã hội nghề nghiệp như ACM (Association for Computing Machinery) và ISSA (Information Systems Security Association) hợp tác để đề ra các quy tắc ứng xử trong an toàn thông tin. Tuy nhiên, các quy tắc ứng xử trong an toàn thông tin chỉ có tính khuyến nghị do các tổ chức trên không có thẩm quyền bắt buộc phải thực hiện.

Hiệp hội an toàn thông tin Việt Nam đã công bố Bộ Quy tắc ứng xử an toàn thông tin vào đầu năm 2015, trong đó đưa ra một số quy tắc và khuyến nghị về những việc không được làm cho các thành viên và nhân viên của các tổ chức hoạt động trong lĩnh vực an toàn thông tin.

Viện đạo đức máy tính (Hoa Kỳ) đưa ra Bộ Quy tắc ứng xử 10 điểm (Ten Commandments of Computer Ethics) như sau:

1. Không được sử dụng máy tính để gây hại cho người khác;
2. Không được can thiệp vào công việc của người khác trên máy tính;
3. Không trộm cắp các file trên máy tính của người khác;
4. Không được sử dụng máy tính để trộm cắp;
5. Không được sử dụng máy tính để tạo bằng chứng giả;
6. Không sao chép hoặc sử dụng phần mềm không có bản quyền;
7. Không sử dụng các tài nguyên máy tính của người khác khi không được phép hoặc không có bồi thường thỏa đáng;
8. Không chiếm đoạn tài sản trí tuệ của người khác;
9. Nên suy nghĩ về các hậu quả xã hội của chương trình mình đang xây dựng hoặc hệ thống đang thiết kế;
10. Nên sử dụng máy tính một cách có trách nhiệm, đảm bảo sự quan tâm và tôn trọng đến đồng bào của mình.

6.4.3. Một số vấn đề khác

Liên quan đến vấn đề đạo đức trong an toàn thông tin, có một số vấn đề khác cần lưu ý gồm: (1) sự khác biệt về vấn đề đạo đức giữa các nền văn hóa, (2) vấn đề vi phạm bản quyền phần mềm và (3) vấn đề lạm dụng các tài nguyên của cơ quan, tổ chức.

Trên thực tế, có sự khác biệt khá lớn về vấn đề đạo đức giữa các nền văn hóa. Trong đó, nhận thức về vấn đề đạo đức trong sử dụng các tài nguyên của cơ quan, tổ chức là rất khác biệt giữa các quốc gia có nền văn hóa khác nhau. Trong nhiều trường hợp, một hành vi được phép của một số cá nhân trong một quốc gia lại vi phạm quy tắc đạo đức của quốc gia khác. Chẳng hạn, hành vi tiết lộ thông tin cá nhân và đặc biệt là mức thu nhập của người khác được coi là bình thường ở Việt Nam, nhưng đây là hành vi vi phạm quyền riêng tư ở các nước phát triển như Hoa Kỳ và Châu Âu.

Vấn đề vi phạm bản quyền phần mềm là rất nghiêm trọng, đặc biệt là ở các nước đang phát triển ở châu Á và châu Phi. Đa số người dùng có hiểu biết về vấn đề bản quyền phần mềm, nhưng coi việc sử dụng phần mềm bất hợp pháp là bình thường vì nhiều nước chưa có quy định, hoặc không xử lý nghiêm vi phạm. Tỷ lệ vi phạm bản quyền phần mềm ở Việt Nam hiện rất cao, đến khoảng 90% do các chế tài xử lý vi phạm chưa đầy đủ, hoặc chế tài xử lý chưa được thực hiện nghiêm minh và chưa đủ sức răn đe.

Vấn đề lạm dụng các tài nguyên của công ty, tổ chức xảy ra tương đối phổ biến và cần có các quy định và chế tài để kiểm soát. Một số cơ quan, tổ chức chưa có các quy định cấm nhân viên sử dụng các tài nguyên của cơ quan, tổ chức vào việc riêng. Một số đơn vị khác có quy định nhưng chưa được thực thi chặt chẽ và chưa có chế tài xử phạt nghiêm minh. Các hành vi lạm dụng thường gặp gồm:

- In ấn tài liệu riêng;
- Sử dụng email cá nhân cho việc riêng;
- Tải các tài liệu, file không được phép;
- Cài đặt và chạy các chương trình, phần mềm không được phép;
- Sử dụng máy tính công ty làm việc riêng;
- Sử dụng các phương tiện làm việc khác như điện thoại công ty quá mức vào việc riêng.

6.5. CÂU HỎI ÔN TẬP

- 1) Nêu khái niệm tài sản an toàn thông tin, khái niệm quản lý an toàn thông tin. Nêu vai trò và các khâu cần thực hiện của quản lý an toàn thông tin.
- 2) Đánh giá rủi ro an toàn thông tin là gì? Mô tả các phương pháp tiếp cận đánh giá rủi ro an toàn thông tin.
- 3) Rủi ro an toàn thông tin có liên quan đến những những yếu tố nào? Giải thích.
- 4) Mô tả các bước của phân tích chi tiết rủi ro an toàn thông tin.
- 5) Mô tả các loại kiểm soát trong thực thi quản lý an toàn thông tin.
- 6) Mô tả nội dung thực thi quản lý an toàn thông tin.
- 7) Mô tả vắn tắt các chuẩn ISO/IEC 27000, ISO/IEC 27001, ISO/IEC 27002 và ISO/IEC 27005.
- 8) Mô tả chu trình Plan-Do-Check-Act của chuẩn ISO/IEC 27001.
- 9) Phân biệt pháp luật và chính sách. Nêu các yêu cầu của chính sách để có thể được áp dụng hiệu quả.

- 10) Mô tả vắn tắt các văn bản luật có liên quan đến an toàn thông tin của Việt Nam.
- 11) Tìm hiểu và nêu các nội dung cơ bản của Luật an toàn thông tin mạng số 86/2015/QH13.
- 12) Tìm hiểu và nêu các nội dung cơ bản của Luật an ninh mạng số 24/2018/QH14.
- 13) Nêu sự cần thiết của vấn đề đạo đức an toàn thông tin. Nêu bộ qui tắc ứng xử của Viện đạo đức máy tính Hoa Kỳ.

ATTT-PTIT

TÀI LIỆU THAM KHẢO

- [1] Michael E. Whitman, Herbert J. Mattord, *Principles of information security*, 4th edition, Course Technology, Cengage Learning, 2012.
- [2] David Kim, Michael G. Solomon, *Fundamentals of Information Systems Security*, Jones & Bartlett Learning, 2012.
- [3] Forbes.com, *Internet Of Things On Pace To Replace Mobile Phones As Most Connected Device In 2018*, <http://www.forbes.com/sites/louiscolumbus/2016/07/09/internet-of-things-on-pace-to-replace-mobile-phones-as-most-connected-device-in-2018/>, accessed Sep 2018.
- [4] US Government Accountability Office, *Cyber Threats and Data Breaches Illustrate Need for Stronger Controls across Federal Agencies*, Available online at <http://www.gao.gov/assets/680/671253.pdf>, accessed Sep 2018.
- [5] Tập đoàn Bkav, *Tổng kết an ninh mạng 2017 và dự báo xu hướng 2018*, https://www.bkav.com.vn/trong-ngoi-nha-bkav/-/chi_tiet/511114/tong-ket-an-ninh-mang-nam-2017-va-du-bao-xu-huong-2018, truy cập tháng 8.2018.
- [6] US National Vulnerability Database, <https://nvd.nist.gov>, accessed Sep 2018.
- [7] Boni, W. C., & Kovacich, G. L. (1999). *I-way robbery: crime on the Internet*, Boston MA: Butterworth.
- [8] Butler, J. G. (1998). *Contingency planning and disaster recovery: protecting your organisation's resources*. New York: Computer Tech Research.
- [9] Denning D. E. (1999). *Information warfare and security*, New York. Addison-Wesley.
- [10] Erbschloe, M. & Vacca, J. R. (2001). *Information warfare*. New York: McGraw-Hill.
- [11] Ghosh, A. (1998). *E-Commerce security – weak links, best defenses*. New York: Wiley Computer Publishing.
- [12] Hutchinson, W. & Warren, M. (2001). *Information warfare: corporate attack and defence in the digital age*. Oxford: Butterworth-Heinemann.
- [13] Alfred J. Menezes, Paul C. van Oorschot and Scott A. Vanstone, *Handbook of Applied Cryptography*, CRC Press, Fifth Printing, August 2001.
- [14] Bruce Schneier, *Applied Cryptography*, 2nd edition, John Wiley & Sons, 1996.
- [15] Schneier, B. (2000). *Secrets and lies: digital security in a networked world*. New York: John Wiley and Sons.